



HIPAA Security Rule

Companion Guide for VMware Cloud Foundation 9.1

June 2026

Table of Contents

Disclaimer.....	5
Version.....	6
Introduction.....	6
Third Party Identifiers and Mappings	6
Coverage Levels	6
Controls.....	7
Control 164.306(a)(1)	7
Control 164.306(a)(2)	8
Control 164.306(a)(3)	9
Control 164.306(b)(1)	15
Control 164.306(b)(2)(i)	20
Control 164.306(b)(2)(ii)	21
Control 164.306(b)(2)(iii)	22
Control 164.306(b)(2)(iv)	23
Control 164.306(c)	24
Control 164.306(d)(1)	25
Control 164.306(d)(2)	26
Control 164.306(d)(3)(i)	27
Control 164.306(d)(3)(ii)(A)	28
Control 164.306(d)(3)(ii)(B)(1)	29
Control 164.306(d)(3)(ii)(B)(2)	30
Control 164.306(e)	31
Control 164.308(a)(1)(i)	36
Control 164.308(a)(1)(ii)(A)	40
Control 164.308(a)(1)(ii)(B)	41
Control 164.308(a)(1)(ii)(C)	42
Control 164.308(a)(1)(ii)(D)	43
Control 164.308(a)(2)	49
Control 164.308(a)(3)(i)	50
Control 164.308(a)(3)(ii)(A)	55
Control 164.308(a)(3)(ii)(B)	59
Control 164.308(a)(3)(ii)(C)	63
Control 164.308(a)(4)(i)	67

Control 164.308(a)(4)(ii)(A)	71
Control 164.308(a)(4)(ii)(B)	72
Control 164.308(a)(4)(ii)(C)	77
Control 164.308(a)(5)(i)	83
Control 164.308(a)(5)(ii)(A)	84
Control 164.308(a)(5)(ii)(B)	85
Control 164.308(a)(5)(ii)(C)	86
Control 164.308(a)(5)(ii)(D)	87
Control 164.308(a)(6)(i)	88
Control 164.308(a)(6)(ii)	91
Control 164.308(a)(7)(i)	95
Control 164.308(a)(7)(ii)(A)	99
Control 164.308(a)(7)(ii)(B)	105
Control 164.308(a)(7)(ii)(C)	110
Control 164.308(a)(7)(ii)(D)	114
Control 164.308(a)(7)(ii)(E)	116
Control 164.308(a)(8)	119
Control 164.308(b)(1)	123
Control 164.308(b)(2)	124
Control 164.308(b)(3)	125
Control 164.310(a)(1)	126
Control 164.310(a)(2)(i)	127
Control 164.310(a)(2)(ii)	128
Control 164.310(a)(2)(iii)	129
Control 164.310(a)(2)(iv)	134
Control 164.310(b)	135
Control 164.310(c)	136
Control 164.310(d)(1)	137
Control 164.310(d)(2)(i)	141
Control 164.310(d)(2)(ii)	142
Control 164.310(d)(2)(iii)	144
Control 164.310(d)(2)(iv)	149
Control 164.312(a)(1)	155
Control 164.312(a)(2)(i)	160

Control 164.312(a)(2)(ii)	165
Control 164.312(a)(2)(iii)	170
Control 164.312(a)(2)(iv)	176
Control 164.312(b)	183
Control 164.312(c)(1)	189
Control 164.312(c)(2)	195
Control 164.312(d)	199
Control 164.312(e)(1)	200
Control 164.312(e)(2)(i)	206
Control 164.312(e)(2)(ii)	212
Control 164.314(a)(1)	218
Control 164.314(a)(2)(i)(B)	219
Control 164.314(a)(2)(i)(C)	220
Control 164.314(a)(2)(ii)	221
Control 164.314(a)(2)(iii)	222
Control 164.314(b)(1)	223
Control 164.314(b)(2)(i)	224
Control 164.314(b)(2)(ii)	225
Control 164.314(b)(2)(iii)	226
Control 164.314(b)(2)(iv)	227
Control 164.316(a)	228
Control 164.316(b)(1)(i)	229
Control 164.316(b)(1)(ii)	230
Control 164.316(b)(2)(i)	231
Control 164.316(b)(2)(ii)	235
Control 164.316(b)(2)(iii)	236

Disclaimer

This document is intended to provide general guidance for organizations that are considering Broadcom solutions. The information contained in this document is for educational and informational purposes only. This document is not intended to provide advice and is provided “AS IS.” Broadcom makes no claims, promises, or guarantees about the accuracy, completeness, or adequacy of the information contained herein. Organizations should engage appropriate legal, business, technical, and audit expertise within their specific organization for review of requirements and effectiveness of implementations.

Version

910-20260612-01

Introduction

This document describes how VMware Cloud Foundation (VCF) 9.1 and the separately licensed advanced services assessed alongside it, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, and VMware Avi Load Balancer, can support organizations working toward compliance with the HIPAA Security Rule, using the implementation guidance in NIST SP 800-66 Revision 2. The HIPAA Security Rule establishes standards for protecting electronic protected health information (ePHI) through administrative, physical, and technical safeguards. Each assessed product is reported separately for every control, with VCF covering the full platform, including its consumption services and Private AI Services capabilities. The responsibility for performing risk analysis and safeguarding ePHI remains with the covered entity or business associate.

<https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C>

This guidance evolves. Please check the current revision at: <https://bcm.tech/vcf-compliance>

Third Party Identifiers and Mappings

This document includes regulatory compliance and security control identifiers from external sources as a convenience to end users. This does not constitute endorsement, in either direction.

There is not a one-to-one mapping of product capabilities to third-party controls. A product capability, or set of capabilities, may be applicable to multiple controls. Conversely, a control may be satisfied with the use of multiple capabilities.

Control identifier numbers have been included from the Secure Controls Framework, version 2026.1, under the terms of the Creative Commons Attribution-NoDerivatives 4.0 International Public License. No modifications have been made to the control identifier numbers under the terms of the license.

<https://securecontrolsframework.com/>

Coverage Levels

Each control entry below carries the framework control text, the SCF control or controls it maps to, and an Aggregate Coverage line showing the strongest position any one of the assessed products holds for that control. Products that meet or contribute to the control follow as subsections, each with its own coverage level and response. Products the control does not apply to are listed together at the end of the entry, with a brief explanation. The coverage levels are:

- **Meets** -- the product directly provides the capability described in the control. No additional organizational process, external product, or human activity is needed beyond configuring the product itself.
- **Contributes** -- the product provides technical capabilities that help satisfy the control, but the control also requires something outside the product to be fully met, such as an organizational process, human activity, or an additional tool.
- **Not Applicable** -- the control does not apply to the product. Physical facility controls, staffing decisions, organizational governance processes, and domains the product does not operate in fall here.
- **Not Supported** -- the control is relevant to the product's domain (infrastructure, networking, security), but the product lacks the specific capability the control requires.
- **Not Assessed** -- the control has not yet been evaluated against the product.

Controls

Control 164.306(a)(1)

> General requirements. Covered entities and business associates must do the following: Ensure the confidentiality, integrity, and availability of all electronic protected health information the covered entity or business associate creates, receives, maintains, or transmits

SCF Controls: GOV-01, GOV-15, GOV-15.1, GOV-15.2, GOV-15.3, GOV-15.4, GOV-15.5

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.306(a)(2)

> General requirements. Covered entities and business associates must do the following: Protect against any reasonably anticipated threats or hazards to the security or integrity of such information.

SCF Controls: GOV-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.306(a)(3)

> General requirements. Covered entities and business associates must do the following: Protect against any reasonably anticipated uses or disclosures of such information that are not permitted or required under subpart E of this part.

SCF Controls: DCH-01, GOV-01, RSK-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides multiple layers of data protection controls spanning encryption, storage resilience, backup and recovery, disaster recovery, centralized monitoring, and access management.

For data at rest, vSAN encryption protects data on storage devices so that if a device is physically removed from the cluster, the data remains unreadable. At the virtual machine level, VM encryption protects NVRAM, swap (VSWP), and snapshot (VMSN) files, providing per-VM granularity independent of the underlying storage encryption. For data in transit, vSAN data-in-transit encryption protects data as it moves between hosts and file service inter-host connections within a vSAN cluster, with forward secrecy enforced. TLS protects data in transit between other VCF components. Both vSAN and VM encryption integrate with external Key Management Server (KMS) infrastructure for key lifecycle management, requiring a trust relationship established through certificate and key file exchange. VCF components use FIPS-validated cryptographic modules: NSX cryptographic modules are validated to FIPS 140-3 standards, vSphere uses FIPS-validated cryptographic modules matching the FIPS 140-2 standard, and VCF Automation runs in FIPS-compliant mode by default using FIPS 140-3 validated modules.

vSAN implements erasure coding through RAID-5 storage policies, which split data into blocks with parity information to protect against component failures. vSAN includes failure indication and data rebuild mechanisms that detect storage failures and automatically reconstruct unavailable data. Virtual machines on vSAN datastores can be assigned storage policies that define specific data protection and performance characteristics, giving administrators granular control over how data is protected at the workload level.

VCF supports backup methods for its management components at multiple levels. VMware vCenter file-based daily backups are configured through the vCenter Management Interface for each vCenter instance. vCenter file-based backup supports optional password-based encryption of backup files, and backup files are stored off-appliance on servers accessible via FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB. When vSphere Native Key Provider is configured, vCenter backups contain the Key Derivation Key and must be stored in a secure, access-controlled location. VCF Operations backups support both file-based and image-based methods. NSX Manager backup is configured automatically during the bring-up process. For vSphere Supervisor environments, control plane backup and restore can be performed from the Workload Management UI, and Supervisor control plane backup can also be included as an option in vCenter file-based backup schedules. vSAN Data Protection uses native snapshots stored locally on vSAN Express Storage Architecture (ESA) clusters to help recover virtual machines from operational failure or ransomware attacks.

For Kubernetes workloads, VMware Kubernetes Service (VKS) provides dedicated data protection capabilities built into the VCF platform. VKS cluster node VMs are backed up through Supervisor state backup using the vCenter backup feature available in the vCenter Management Interface, so Supervisor state is covered by the same vCenter backup workflow used for the management plane. When data protection is activated for a VKS cluster, VKS cluster management installs the data protection extension, selected plugins, and Velero on the cluster; activation requires an Organization Administrator or Project Administrator role. Backup and restore operations are managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management > Clusters > Data Protection. Two backup methods are available: vSphere Plugin Snapshot performs block-level backup writing directly to object storage and is faster for workloads with large numbers of small files, while File System Backup operates at the file system level and supports incremental backups. The vSphere Plugin Snapshot method performs full backups on each run since it does not support changed block tracking, so organizations that require incremental backups should use the File System Backup method. Both methods support stateless and stateful workloads. Backup scope is configurable to the entire cluster, selected namespaces, or specific resources identified by label, and VKS cluster backups include file system backups in the restore by default. Velero 1.17 supports scheduled backups,

allowing organizations to configure automated backup cadences. Backup repositories support deduplication, compression, and encryption of backup data. The Velero Plugin for vSphere backs up and restores both stateless and stateful applications running on vSphere Pods in the Supervisor. VKS Backup and Restore Hooks enable execution of pre- and post-operation scripts for granular control over the data protection lifecycle, supporting application consistency and custom automation during recovery. Cross-cluster restore is available through the Restore from another cluster option in the Data Protection tab of the VCF Automation Tenant Portal. Data protection account credentials are scoped to users with Organization Administrator or Project Administrator roles, restricting who can configure backup target locations; VCF Automation enables platform teams to create target locations pointing to self-provisioned storage environments, supporting both cloud-hosted accounts and on-premises endpoints. VCF Automation also supports snapshotting VM groups, where each member VM receives a distinct snapshot, and restoring a VM group snapshot restores each member of the group.

Kubernetes cluster state is stored in etcd, and two backup methods are available for the etcd datastore: the built-in snapshot method and volume snapshot. The `etcdctl snapshot save` command creates a backup by specifying the endpoint, CA certificate, client certificate, and client key, providing authenticated access to the backup operation. Snapshots can be restored from a snapshot file or from a remaining data directory. During `kubeadm` upgrades, backup folders for etcd state and cluster manifests are written automatically to `/etc/kubernetes/tmp` with timestamped names, providing a recovery point in case of upgrade failure. Storage policy-based data management is available through Kubernetes StorageClass objects that reference vSphere storage policies via Storage Policy Based Management (SPBM); those policies may include encryption settings, allowing organizations to apply consistent encryption-at-rest requirements to persistent volumes through standard Kubernetes StorageClass configuration. CSI-based data protection for VKS requires a validated configuration between VKS and the underlying storage infrastructure.

VKS clusters on the Supervisor also support the Kubernetes VolumeSnapshot API, which provides `VolumeSnapshotContent` and `VolumeSnapshot` resources as a native point-in-time snapshot mechanism for persistent volumes. Volume snapshots can be provisioned dynamically from a `PersistentVolumeClaim` using a `VolumeSnapshotClass` that specifies storage provider parameters and the deletion policy for snapshot content. Restoring from a snapshot is performed by creating a new `PersistentVolumeClaim` with the target `VolumeSnapshot` as its `dataSource`, referenced via the `snapshot.storage.k8s.io` API group. Kubernetes `PersistentVolumes` have a configurable reclaim policy; setting the policy to `Retain` preserves volume data in a `Released` state after the associated `PersistentVolumeClaim` is deleted, allowing administrators to recover or migrate the data before the underlying storage is reclaimed.

Kubernetes Secrets provide a mechanism for storing sensitive configuration data separately from application code, reducing the risk of accidental exposure in container workloads. Applications consuming Secrets from environment variables or mounted volumes should avoid logging secret values in the clear or transmitting them to untrusted parties. Using short-lived Secrets helps limit the impact of accidental or intentional exposure. Kubernetes and applications can take additional precautions with Secrets, such as avoiding writing sensitive data to non-volatile storage.

vSphere APIs for Data Protection provide an integration point for third-party backup software to perform nondisruptive full, differential, and incremental image backups using VMFS snapshot capabilities, without requiring virtual machines to be powered off or placing backup processing overhead on VMware ESX hosts. For virtual machines running supported Microsoft Windows operating systems, these APIs integrate with Microsoft Volume Shadow Copy Services (VSS) to maintain application consistency during backup operations.

VMware Live Site Recovery extends data protection with orchestrated disaster recovery across sites. Replication can be configured with recovery point objectives as low as 60 seconds, with options for network compression, multiple point-in-time recovery, and automatic replication of new disks. vSphere Replication provides configurable RPO settings for VM-level replication to local or remote datastores. Application-level high availability and disaster recovery mechanisms combine real-time availability with sitewide disaster recovery, with data replication to secondary sites providing recovery options in case of catastrophic failure.

VCF Operations Data and Site Resiliency Monitoring provides centralized visibility into data protection metrics across private clouds, enabling administrators to track the status of data protection controls from a single view. This monitoring layer helps organizations verify that their data protection configurations remain in place and functioning as expected.

For Kubernetes workloads on VKS clusters, volume health status is reported through `volumehealth.storage.kubernetes.io/messages` annotations on `PersistentVolumeClaims`, giving administrators granular visibility into whether individual persistent volumes are accessible.

Management of data protection settings is restricted through role-based access controls. VCF Operations uses privilege-based access controls that restrict visibility based on user roles, limiting which accounts can view sensitive operational data. For VKS clusters, managing data protection requires assignment of an Organization Administrator or Project Administrator role. VCF documentation includes storage security best practices covering securing access to storage devices, implementing storage encryption, and protecting virtual machine data as part of an overall data protection posture.

Selecting which of these data protection mechanisms apply to specific datasets, defining protection policies and recovery objectives, and configuring the relevant features to match those decisions remain organizational responsibilities. VCF supplies the technical mechanisms; organizations define what to protect, to what recovery point, and with which retention and access controls.

VMware Private AI Services (PAIS) contributes to data protection by applying access controls, authenticated connectivity, and credential management to AI workloads, model repositories, knowledge bases, and associated data assets that the platform handles.

The Model Gallery uses Harbor project access capabilities to restrict access to the sensitive data used to train and tune models. PAIS integrates with Harbor registries as a model storage backend, requiring authentication and certificate-based trust for model retrieval. PAIS is also compatible with OCI-compliant registries from other vendors, so organizations using an alternate backend can apply equivalent registry-level access controls.

Access to PAIS itself is gated by OIDC group-based authorization. Only user accounts that are members of the groups specified in the `authorizedGroups` configuration can access the service, and the OIDC group claim name is configurable to match the identity provider in use. PAIS uses a CA trust bundle for secure communication with external services and databases, and supports CA trust bundle management for secure connections with external registries and content management systems by uploading or referencing certificate files. VCF Automation Provider Management requires trusted certificate import for vCenter validation before integration with PAIS, restricting integration paths to validated endpoints.

For retrieval-augmented generation, PAIS Knowledge Bases link to external data sources through stored credentials, scoping indexed-data retrieval to defined service identities, and Data Indexing and Retrieval handles automatic collection and indexing of updates from those linked sources over time. Personal access tokens generated from user account settings provide programmatic access to Knowledge Bases and data sources. SharePoint data sources for PAIS Knowledge Bases require user name and password authentication, with support limited to SharePoint On-Premises deployments.

PAIS observability also flows through authenticated paths: the Grafana integration uses OIDC provider authentication for metrics visualization, and LLM traces can be sent to an OpenTelemetry Collector for monitoring.

PAIS DSM database resource allocation is controlled through an infrastructure policy that defines the quality and quantity of resources the database can consume from vSphere clusters, with associated storage policies and VM classes. A default storage policy can be selected to define storage placement for the database in PAIS, and storage policy and VM class selections should be chosen to suit RAG workloads when the database supports RAG use cases.

Organizations connecting external data sources or registries to PAIS should examine the capabilities and parameters of those integrations and approve only those suitable for use, since unreviewed connectors can affect what data models access or expose.

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to data protection controls by providing network-level security mechanisms that protect data in transit and restrict unauthorized network access to systems where data is stored or processed.

The vDefend distributed firewall (DFW) enforces microsegmentation policies at the vNIC level, restricting which workloads can communicate with data stores, databases, and application tiers. By segmenting the data center network into isolated security

zones, vDefend limits the blast radius of a compromise and restricts lateral movement toward systems that hold sensitive data. Administrators define granular firewall rules based on workload identity, security tags, and application-level attributes, limiting access to data repositories to authorized services. Identity Firewall extends policy enforcement to user identity, allowing administrators to define access controls based on which authenticated user initiated the connection rather than solely the source workload, strengthening data access controls in environments with user-based authorization requirements. Security policies are defined, propagated, and enforced across Bare Metal servers through the Security Services Platform (SSP), extending microsegmentation protections beyond virtualized workloads to physical infrastructure connected to the environment.

The SSP includes Security Intelligence, which identifies risky application protocols that transport data in clear text, including HTTP, Telnet, FTP, TFTP, LDAP, POP3, and IMAP. This visibility allows administrators to detect and remediate unencrypted data flows that could expose sensitive information in transit. Security Intelligence administrators can monitor traffic leakage between environments, establish exceptions, and implement lockdown protection rules to control inter-environment flows. Security Intelligence also enables administrators to generate policy recommendations and deploy them in monitor-before-enforcement mode, allowing observation of traffic patterns before applying restrictive rules. The SSP summary panel displays the number of services that are fully protected, partially protected, or not protected, giving administrators a dashboard view of segmentation coverage gaps across the environment.

IDS/IPS profiles attach to Distributed Firewall and Gateway Firewall rules to inspect east-west and north-south network traffic for signatures and behaviors associated with data theft, command-and-control communication, and exploitation of vulnerabilities in data-handling services. In vDefend, IDS/IPS signature rules support storing TLS/SSL certificates on disk for forensic analysis and threat investigation, providing durable artifacts for post-incident review of potential data exfiltration events.

Malware Prevention profiles attach to DFW and Gateway Firewall rules and can be configured to send files to the cloud for detailed analysis or to process files locally without cloud connectivity, accommodating environments with data-residency or air-gap requirements. Malware Prevention collects file analysis data including file hash submissions and assigns an Analyst UUID to each submission to track its analysis lifecycle. The Malware Prevention dashboard displays trends of malicious, suspicious, and suppressed file events across the data center, and file verdict filtering allows operators to focus on specific verdict categories such as malicious-only views.

Network Detection and Response (NDR) anonymizes sensitive customer information when sharing telemetry data to cloud services, providing a built-in data privacy mechanism for environments that enable cloud-assisted threat detection.

These network security controls complement the data-at-rest encryption, backup, replication, and access management capabilities provided by other VCF components. vDefend does not perform data encryption, classification, backup, or recovery itself, but it protects the network paths and access patterns through which data is stored, replicated, and retrieved.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides replication-based data protection for virtual machine workloads across sites. Protection groups allow administrators to organize virtual machines and datastores under consistent snapshot and replication policies at scale, covering both local recovery via vSAN snapshots and cross-site recovery via vSphere Replication or array-based replication. Protection group membership can be modified after creation, and virtual machines can be automatically enrolled for protection using storage tag selection on designated datastores, reducing manual overhead in maintaining protection coverage across a growing environment.

PNR introduces an immutability mode for protection groups that, when enabled, prevents the data protection group from being modified or deleted. This mechanism allows administrators to safeguard protection configurations against inadvertent or unauthorized changes. PNR Health monitoring provides consolidated visibility into data protection service health, operation issues for local and replication snapshots, storage utilization, and protection group membership changes, giving administrators a current view of protection posture across the environment.

Site Recovery Manager (SRM) integrates with vSphere Replication to provide orchestrated failover with configurable recovery point objectives, giving organizations control over acceptable data loss thresholds for protected workloads. PNR supports

additional site topologies, including shared recovery site configurations where protected site resources are mapped to isolated datacenters, networks, folders, and datastores on the recovery site. Inventory mappings allow administrators to define resource configurations once and apply them consistently across protection groups.

vSAN Snapshots and Replication is a native, integrated snapshot-based backup capability for virtual machines running on vSAN datastores, managed through the vSphere Client. It provides VM restore and clone operations from existing snapshots, supporting both rapid recovery from operational failures and ransomware recovery scenarios. Test failover operations allow administrators to validate that recovery configurations are functional before an actual recovery event occurs.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support data protection for managed database instances, covering PostgreSQL, MySQL, and SQL Server databases.

The most direct contribution is DSM's automated backup framework, which administrators can enable on a per-database basis or through data service policies. When configured, DSM performs scheduled full and incremental backups of database content and stores them in S3-compatible object storage at a configurable backup location. Backup retention is configurable (backup-retention-period), and DSM retains backups of deleted databases until the configured retention period expires, supporting recovery from accidental deletion. For point-in-time recovery, DSM restores a backup to a newly created database VM with a user-specified name and datastore location, and can target the most recent timestamp or a specific point in time. DSM archives binary logs in backup storage as part of its backup protection mechanism. Administrators can also initiate manual on-demand backups of primary PostgreSQL databases to safeguard data before high-impact operations or as immediate protection after major changes. For PostgreSQL multi-site deployments, DSM performs a full backup automatically during a promotion event before resuming the regular schedule.

Data service policies give administrators control over backup behavior across all databases governed by a policy. Policies can require that databases have automated backups enabled, allow users to opt in, or disallow automated backups entirely. The allowed-backup-locations setting in the data service policy restricts users to selecting from approved backup locations, reducing the risk of backup misconfiguration. Policies can be enforced across multiple tenants and across different namespaces and namespace labels, supporting consistent data protection posture in multi-tenant deployments. A Compliance tab on data service policies displays compliance reports and allows administrators to expand each policy violation to view the noncompliant database, data service, and namespace, giving administrators visibility into where data protection requirements are not being met. In 9.1, data service policies extend to SQL Server databases in addition to MySQL and PostgreSQL.

DSM implements role-based access control that separates administrative and user-level database access. DSM Admins can create, monitor, and manage all data services in the environment; DSM Users can only manage and monitor the data services they own. This access model limits who can modify backup configurations and policy settings. Infrastructure policies govern which storage resources are available for database VMs, including CPU, memory, storage policies, IP pool, and VM classes, giving administrators control over the storage environment in which data resides.

Control plane recovery requires that a Provider Backup Repo has been configured at installation time. If the Provider VM fails, the restore-provider command restores it to the latest timestamp. In the VCF Automation context, tenants can perform point-in-time restores directly through the VCF Automation UI, broadening restore access to self-service scenarios.

One limitation applies: if an incremental backup in the backup chain is deleted, DSM cannot restore the full data; a successful restore from an incremental chain requires the last full backup and all following incremental backups. Organizations must protect the integrity of the backup chain through access controls on the backup storage.

DSM provides configurable backup, recovery, and policy enforcement mechanisms for managed database instances. The broader data protection program requires organizational decisions about backup schedules, retention periods, backup storage security, and off-site management that DSM does not prescribe on its own.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several application-layer mechanisms that support the implementation of data protection controls within a VCF deployment.

At the transport layer, Avi performs TLS termination with configurable SSL/TLS profiles for connections between clients and virtual services. The SSL/TLS protocol at the Avi proxy secures data in transit by reducing the risk of unauthorized parties reading or modifying information transferred between end users and application workloads. SSL/TLS profiles are configurable through the Avi Controller UI under Templates > Security > SSL/TLS Profile. Management interface access is further restricted through configuration of allowed ciphers and HMACs for management sessions.

Avi integrates with Hardware Security Modules (HSMs), including the Thales Luna (formerly SafeNet Luna) HSM, for cryptographic key storage and management. This allows organizations to store the private keys used in TLS termination and other cryptographic operations within a dedicated hardware key store rather than in software. The Avi Controller also stores sensitive configuration data encrypted in a local database, and backup files can be protected with a passphrase that encrypts the keys included in the backup. Backup and restore operations verify that the FIPS mode of the backup configuration matches the target controller environment.

Avi's Web Application Firewall (WAF) applies both positive and negative security models to inspect and filter HTTP/HTTPS application traffic. WAF policies support ModSecurity rules for application protection and a Positive Security model that learns application behavior to define allowed request patterns. The Application Rules service, available through the Avi Cloud Console, provides WAF rules specifically designed to address known application vulnerabilities including CVE-tracked issues, with automatic updates to keep rules current. WAF configuration is accessible through the Controller UI under Templates > Security > WAF Policy.

Avi DataScript provides a programmable layer for enforcing additional data protection behaviors at the proxy boundary. DataScripts are Lua-based scripted rules that allow inspection and manipulation of client HTTP requests and server HTTP responses, supporting content switching, redirection, header manipulation, and logging. DataScript can be used to enforce cipher suite policies by denying clients connecting with unsupported ciphers. DataScript also supports blocklist-based access control by checking client IP addresses against named IP groups and terminating connections from blocked sources while logging the violation. XML-based DataScript use cases can extract client identifiers from request payloads and compare them against configured string groups to restrict access to authorized clients.

Access to Avi configuration objects is restricted through granular role-based access control (RBAC). Avi supports extended granular RBAC using label-based markers to restrict user permissions to specific resources based on key-value pair matching. The RBAC model differentiates Read and Write access across objects such as SSL/TLS Profiles, PKI Profiles, Authentication Profiles, IP Address Groups, and Health Monitors, allowing organizations to scope access to data protection-relevant configuration to authorized roles only. Roles can also be scoped to tenants through label group associations.

These mechanisms address data protection at the application delivery layer. Broader organizational data protection controls, including data classification policies, data handling procedures, and data-at-rest protection beyond the Avi proxy boundary, require organizational governance and platform-level capabilities that Avi does not provide as an application delivery controller.

Control 164.306(b)(1)

> Covered entities and business associates may use any security measures that allow the covered entity or business associate to reasonably and appropriately implement the standards and implementation specifications as specified in this subpart.

SCF Controls: GOV-09, GOV-15, SEA-01, SEA-02, SEA-03

Aggregate Coverage: Meets

VCF (Meets)

VCF implements security as a layered architecture where each layer operates independently and does not depend on the correctness of layers above it. These layers span hardware-rooted trust at the physical host, network isolation, hypervisor-level encryption and access controls, identity and certificate management, encrypted communications, distributed security enforcement, workload-level policy propagation, and compliance assessment.

At the physical and network layer, VCF supports traffic separation through distributed switch models that isolate management, vMotion, vSAN, and workload traffic onto separate physical or logical networks. These models can be selected based on design qualities including availability, performance, and security. Dedicated distributed switches for vSAN traffic, for example, separate storage traffic from all other traffic types, while the Single Distributed Switch Model does not provide network traffic separation to another physical network fabric, making the choice of switch model a meaningful security design decision. This physical separation provides a foundational security boundary that operates independently of any software-defined overlay. NSX extends this with software-defined routing, switching, and segmentation using overlay-backed segments that do not require segment-specific physical infrastructure configuration. Network profiles support further isolation through subnets, security groups, and VLAN transport zones.

At the hypervisor layer, VMware ESX hosts support hardware-rooted security capabilities. TPM-based measured boot produces event logs that can be retrieved and validated by an attestation service, verifying the integrity of the boot process. UEFI Secure Boot verifies firmware and hypervisor integrity before the operating system loads. The Security Configuration Guide provides recommendations for enabling Secure Boot and TPM on ESX hosts as part of host hardening. ESX enforces local access controls, firewall rules (with per-service rulesets and allowed-host specifications), and resource isolation. The ESX host client enables management of the host even when VMware vCenter is not available, so these host-level protections continue to function independently of centralized management.

At the storage and encryption layer, vSAN provides data-at-rest encryption using a key management server, encrypting all data written to the vSAN datastore. VM encryption operates at the hypervisor level, protecting virtual machine disk files, NVRAM, swap files, snapshot files, and core dump files regardless of the guest operating system. These encryption controls function at the infrastructure layer without depending on application-level security. vSphere also supports Virtualization Based Security (VBS), which uses hardware virtualization capabilities to isolate key guest OS security services so they are protected against manipulation from within the guest environment. For workloads with data-in-use protection requirements, vSphere supports Intel Trust Domain Extension (TDX), a hardware-based mechanism that allows virtual machines to perform computations within a hardware-isolated trusted execution environment.

At the network security layer, VMware vDefend (a separate product that extends NSX and requires additional licensing) provides distributed security functions including Distributed Firewall (DFW) policies with Layer 2 through Layer 7 firewalling, Distributed IDS/IPS, Identity Firewall, Layer 7 Application Identification, Fully Qualified Domain Name filtering, and Guest Introspection. These security functions are enforced in the hypervisor kernel at the virtual NIC level, operating below the guest operating system and outside the reach of workloads running within virtual machines. NSX Projects enable isolation of networking and security configurations across departments within a single deployment, allowing delegation of configuration management to specific sets of users while restricting visibility to only project-scoped objects.

At the identity and access layer, VCF SSO provides centralized authentication as a single point of user verification for vCenter clients. Role-based access control (RBAC) restricts access across all VCF components. NSX provides granular RBAC with distinct roles including Enterprise Admin, Network Admin, Security Admin, Cloud Admin, and Cloud Project Admin, among others, separating administrative privileges so that network administrators, security administrators, and workload operators

have distinct permission sets. VCF implements security roles and management of security functions aligned with global compliance frameworks. The VMware Certificate Authority (VMCA), a purpose-built internal certificate authority integral to vSphere, issues certificates for service-to-service authentication between platform components. A dedicated No Cryptography Administrator role supports all Administrator privileges except for Cryptographic Operations, enabling separation of duties between infrastructure management and encryption key management.

At the communications layer, all management interfaces and API endpoints use TLS encryption. NSX Manager supports configurable TLS protocol versions and cipher suites, with older TLS versions deactivated by default.

At the Kubernetes and consumption layer, VMware Kubernetes Service (VKS), the native Kubernetes platform within VCF, implements multiple independent security enforcement points at distinct positions in the Kubernetes stack. All access to the Kubernetes API server requires TLS-encrypted transport, followed by authentication via OIDC, X.509 client certificates, or service account tokens, and then authorization via Kubernetes RBAC. Admission controllers, including validating and mutating webhooks, operate as a third independent check before any object is persisted, so a principal that passes authentication can still be rejected by RBAC or by an admission webhook. The Kubernetes cluster infrastructure is designed to provide the security supports that higher application layers expect, consistent with the principle that lower layers do not depend on higher-layer correctness.

VKS Cluster Management Security Policies can be applied at the cluster, project, or organization level and propagate downward through the resource hierarchy so that all clusters within a project inherit the project's security policy. These policies are implemented using the Gatekeeper project from Open Policy Agent (OPA), maintaining a consistent security posture across workload layers without requiring each layer to independently define its own controls. A Baseline pod security template is available that mitigates common privilege escalation risks while maintaining compatibility with standard containerized workloads; custom security policy templates allow fine-tuning of individual security context parameters to support organizational requirements. Individual pods can be further constrained through security contexts that configure fields such as `runAsUser`, `allowPrivilegeEscalation`, Linux capabilities, `readOnlyRootFilesystem`, and `seccomp` or AppArmor profiles. Seccomp profiles reduce the Linux kernel syscall attack surface available within containers using BPF-based allow or deny lists, and Linux kernel security features including AppArmor and SELinux can be applied to pods and containers through SecurityContext configuration, providing a security boundary below the container runtime that operates regardless of the container's contents. The Supervisor secret injection agent itself drops all Linux capabilities and enforces a RuntimeDefault seccomp profile to restrict the system calls available to it, minimizing its own attack surface.

At the namespace and network layer within VKS, Kubernetes network policies restrict ingress and egress traffic per namespace. VKS supports Antrea and NSX-based network policy enforcement as well as Cilium, which enforces policies at OSI layers 3 through 7 using an identity-based model decoupled from IP addressing. Service meshes available on VKS clusters provide OSI Layer 7 policies based on workload identity and mutual TLS encryption, protecting data in transit even in the presence of a compromised node. These controls operate independently of what applications within the namespace do.

At the secrets and credential layer within VKS, the Secret Store Supervisor Service enforces RBAC for administrators, DevOps engineers, and application tenants separately from the application workloads that consume secrets, so that access to a running application does not by itself yield access to stored credentials.

At the supply chain and pipeline layer, Harbor Registry secures container images with artifact security policies and RBAC before images reach the runtime environment. Harness CI/CD, available on VKS, incorporates integrated security scanning and secrets management, including pre-deployment vulnerability scanning and post-deployment performance verification, applied before artifacts are promoted. Argo CD deployments use network segmentation to secure inter-component communication. Security Technical Implementation Guides (STIGs) for system components, including Supervisor and VKR components, are available through Tanzu STIG Hardening to guide layer-by-layer hardening of the Kubernetes environment.

At the compliance and assessment layer, the VCF Security Baseline provides a consolidated, out-of-the-box benchmark that evaluates both default and non-default configurations. This baseline is designed and validated to tailor security settings without impacting VCF's ability to meet its design objectives. VCF Operations surfaces a security dashboard that complements the compliance capability, and each component has its own Security Configuration Guide with hardening recommendations

aligned with DISA STIG guidance. These assessment and monitoring functions operate as an independent verification layer above the controls they measure.

VMware vDefend (Contributes)

VMware vDefend (vDefend) implements multiple independent security layers within its own architecture, contributing to a defense-in-depth strategy at the network security tier of VCF. The vDefend security model is structured as a Security Journey, a staged approach that allows organizations to progressively adopt a Zero Trust posture, moving from initial assessment through increasing levels of microsegmentation and policy enforcement. Each stage can be deployed and validated independently, with lower-level enforcement mechanisms remaining operational regardless of higher-level policy states.

At the network enforcement layer, the vDefend distributed firewall provides Layer 2 through Layer 7 traffic inspection and policy enforcement at the hypervisor level. The Applied-To field defines precisely where security rules are enforced, enabling scoped enforcement boundaries within the environment. Security profiles are organized per Project, and Security Strategies are collections of policies and rules applied at the project level, allowing discrete enforcement boundaries to be maintained across the environment. Bare Metal Security extends this enforcement model to physical servers, applying Layer 3/4 Distributed Firewall policies outside the virtualization stack through a workflow that onboards physical servers to the Bare Metal Orchestrator for policy propagation and enforcement.

At the threat detection layer, vDefend IDS/IPS provides signature-based intrusion detection and prevention. Gateway Firewall TLS Inspection allows encrypted traffic flows to be analyzed before reaching their destination. Advanced Threat Prevention (ATP) adds malware analysis as a distinct layer operating on file content extracted from network flows.

At the segmentation planning layer, Security Intelligence and the Security Services Platform (SSP) provide traffic flow analysis, security posture assessment, and policy lifecycle management. The Security Segmentation hierarchy is structured as Region, Zone, Environment, Application, and Tier, enabling granular segmentation planning across the environment. Security Intelligence provides targeted policy recommendations organized within Distributed Firewall categories, supporting administrators in planning and verifying segmentation coverage.

The Security Segmentation Score assessment calculates security posture by evaluating Distributed Firewall configuration and traffic rules, and generates a Blast Radius Report that provides a qualitative view of segmentation posture. The Security Segmentation Report identifies vulnerable workloads that could be exploited for lateral movement and presents recommendations for strengthening defenses. The score breakdown details total environments and pairs, protection rule actions, and highlights environment pairs lacking inter-environment policies, giving operators visibility into coverage gaps between enforcement layers.

Administrative access to the Security Services Platform itself is governed by role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. This role structure means that policy authorship, audit review, and operational support functions are distinct within the platform's control plane, adding an administrative separation layer on top of the enforcement architecture.

Taken together, these layers, including packet filtering, threat detection, malware analysis, encrypted traffic inspection, and segmentation assessment, are designed so that each layer makes enforcement decisions based on its own analysis without relying on the correctness of adjacent layers. A misconfiguration or gap in one layer does not disable enforcement in others.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) implements its security controls as distinct, layered mechanisms that map to different tiers of the database-as-a-service architecture. This layered structure means that a failure or bypass at one level does not automatically compromise the controls operating at other levels.

At the network layer, DSM requires VDS and N-VDS port groups to be available for host component isolation. Infrastructure policies define the compute, storage, and networking resources for each database deployment, including IP pool configuration with subnet-scoped addressing. This creates a defined, bounded network environment for database workloads that is configured by administrators independently of the database consumers who use those workloads. DSM also detects

and blocks network overlap between infrastructure policy IP ranges and system configuration networks, a check that stops subnet conflicts before they affect database network isolation.

At the authentication and identity layer, DSM requires Lightweight Directory Access Protocol over TLS (LDAPS) for all directory service communication. There is no option to connect a directory service without transport encryption. MySQL deployments support Active Directory Secure/SSL Global Catalog on port 3269 for multi-domain controller environments. For local accounts, DSM supports automatic authentication secret generation with rootCA certificate configuration in the Supervisor Service, providing a credential layer for endpoint-to-endpoint communication that is generated rather than administrator-managed.

At the access control layer, DSM applies role-based access control at two scopes. DSM Admin roles govern platform-wide configuration. DSM User role assignments can be scoped to one or more specific namespaces, so that a given user can access only the databases and resources within their assigned namespace and no others. Namespaces themselves enforce this access boundary, and role assignments are visible and manageable through the DSM administrator UI.

At the database engine layer, DSM isolates management operations from user-accessible database operations through engine-specific mechanisms. For SQL Server, the `dsm_mgmt` internal management login confines administrative operations to a secure, isolated context; users cannot access or modify system-level objects through this channel. User-defined DDL triggers that execute during DSM management operations run within a restricted database-level security context, which blocks those triggers from accessing the server-level permissions held by the internal management account. PostgreSQL deployments support the `pgcrypto` extension, which provides cryptographic functions as an additional data security layer within the database engine.

At the resource governance layer, infrastructure policies act as guardrails that restrict the type and quantity of compute, memory, storage, and networking resources that DSM users can request when provisioning databases. These policies are configured by administrators and presented to users as a curated set of options. Storage policies within an infrastructure policy are filtered to show only those compatible with the specified compute resources, reducing the chance that a user provisions a database in a configuration that violates organizational standards. Data service policies can be applied uniformly across tenants, maintaining a consistent security posture at scale.

Network perimeter controls, workload traffic inspection, host-level security, and the organizational design decisions that govern how layers interact across the broader platform are addressed by other components of VCF or by organizational policy. DSM operates as one layer within a broader security architecture rather than defining or enforcing that architecture on its own.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer contributes to a Defense-in-Depth (DiD) architecture by acting as the application delivery and inspection layer within VCF. Avi's security enforcement mechanisms are organized as distinct, ordered tiers within the application delivery path, each operating independently without relying on the correctness of the network layers beneath them.

The Virtual Service Policy framework is the primary structural mechanism for applying layered controls. Policies are applied in ordered stages covering network-layer security, HTTP security, HTTP request handling, and HTTP response handling, allowing administrators to apply different security controls at the appropriate point in the traffic-processing pipeline. Network Security Policies provide L4 access control across UDP, TCP, and Layer 7 virtual services, with IP Group references enabling IP-based filtering rules that scale across multiple virtual services without per-rule manual maintenance. NSX security groups can be defined once in NSX and reused across Avi Virtual Service security policies, eliminating the need to maintain duplicate IP address lists. These network-layer policies function independently of the HTTP-layer controls, preserving the separation between tiers. The System-Secure-HTTP application profile provides a pre-configured baseline that enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior. Front-end security for each Virtual IP can be enforced using network security policies on the virtual service. Virtual Service Policies are configured under the Virtual Service settings in the Avi Controller UI or via the Avi API.

At the application layer, Avi's Web Application Firewall (WAF) provides two independent security models that can be combined. The negative security model uses Application Rules to detect known attack patterns through signature matching. The Positive Security model, configured under Virtual Service > Positive Security Policy, works differently: it uses a decoupled Learning function to gather application behavior data and then promotes verified patterns to rules that restrict traffic to known-good requests. WAF Policies attach a Positive Security group to apply learned data for security and to define hit and miss actions. Together, these models represent distinct enforcement mechanisms within the application inspection tier, each addressing a different class of attack pattern without depending on the other. In VMware Kubernetes Service (VKS) environments, the Avi Kubernetes Operator (AKO) provides WAF integration for application-layer security in VKS clusters. The AKO also supports a SecurityPolicy custom resource definition that enables virtual services to reference a security policy for Distributed Denial of Service (DDoS) attack mitigation, bringing Kubernetes-native policy control to application delivery security.

TLS termination is handled by configurable SSL/TLS profiles applied at the Virtual Service level. Profiles control cipher suite selection, protocol version, and certificate assignment, with trade-offs between security, compatibility, and computational cost. The Avi Controller integrates with external Hardware Security Modules, specifically Thales Luna HSMs, to separate key management and cryptographic operations from application processing. This separation provides an additional boundary within the cryptographic control plane that is independent of the application and network policy tiers.

The Avi Service Engine's data-plane architecture isolates attacks on the data plane to the data plane alone, avoiding impact to management interfaces. The Avi control plane provides visibility into data-plane attacks through management interfaces and can help secure the data plane from certain attack types. This control-plane and data-plane separation is itself a layering boundary that preserves the integrity of management operations even under active attack conditions. The Service Engine detects and mitigates a wide range of Layer 4 through Layer 7 network attacks.

Avi's denial-of-service protection spans both Layer 4 and Layer 7 as distinct monitoring and enforcement tiers. The DDoS Policy, accessible via the Network Security policy on the virtual service, detects and mitigates a wide range of Layer 4 through Layer 7 network attacks. The Avi Service Engine tracks and breaks down attack data separately for Layer 4 and Layer 7 through DDoS Insights, displayed on the default security page in the Avi Controller. The application profile includes a DDoS tab for configuring custom Layer 7 attack limits.

Auditors should verify that Virtual Service Policies are configured with appropriate Network Security Policies for each service, that WAF policies include both Application Rules and Positive Security policies calibrated to the application's known-good traffic profile, that SSL/TLS profiles enforce the organization's required protocol and cipher standards, and that DDoS thresholds are set according to the organization's risk profile. The DiD architecture as a whole requires design and integration across VCF, which provides infrastructure-level security controls, and VMware vDefend, which provides network-level enforcement through its distributed firewall and inspection capabilities.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 164.306(b)(2)(i)

> In deciding which security measures to use, a covered entity or business associate must take into account the following factors: The size, complexity, and capabilities of the covered entity or business associate.

SCF Controls: GOV-08, PRM-06

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.306(b)(2)(ii)

> The covered entity's or the business associate's technical infrastructure, hardware, and software security capabilities.

SCF Controls: PRM-05, SEA-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.306(b)(2)(iii)

> The costs of security measures.

SCF Controls: PRM-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.306(b)(2)(iv)

> The probability and criticality of potential risks to electronic protected health information.

SCF Controls: RSK-01, RSK-01.1, RSK-02, RSK-03, RSK-03.1, RSK-04, THR-09, THR-10

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.306(c)

> Standards. A covered entity or business associate must comply with the applicable standards as provided in this section and in 164.308, 164.310, 164.312, 164.314 and 164.316 with respect to all electronic protected health information.

SCF Controls: CPL-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.306(d)(1)

> Implementation specifications are required or addressable. If an implementation specification is required, the word "Required" appears in parentheses after the title of the implementation specification. If an implementation specification is addressable, the word "Addressable" appears in parentheses after the title of the implementation specification.

SCF Controls: CPL-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.306(d)(2)

> When a standard adopted in 164.308, 164.310, 164.312, 164.314, or 164.316 includes required implementation specifications, a covered entity or business associate must implement the implementation specifications.

SCF Controls: CPL-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.306(d)(3)(i)

> When a standard adopted in § 164.308, § 164.310, § 164.312, § 164.314, or § 164.316 includes addressable implementation specifications, a covered entity or business associate must- Assess whether each implementation specification is a reasonable and appropriate safeguard in its environment, when analyzed with reference to the likely contribution to protecting electronic protected health information; and

SCF Controls: CPL-02, CPL-03, CPL-03.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.306(d)(3)(ii)(A)

> When a standard adopted in § 164.308, § 164.310, § 164.312, § 164.314, or § 164.316 includes addressable implementation specifications, a covered entity or business associate must- As applicable to the covered entity or business associate- Implement the implementation specification if reasonable and appropriate; or

SCF Controls: GOV-15.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.306(d)(3)(ii)(B)(1)

> When a standard adopted in § 164.308, § 164.310, § 164.312, § 164.314, or § 164.316 includes addressable implementation specifications, a covered entity or business associate must- As applicable to the covered entity or business associate- If implementing the implementation specification is not reasonable and appropriate: Document why it would not be reasonable and appropriate to implement the implementation specification;

SCF Controls: GOV-02.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.306(d)(3)(ii)(B)(2)

> When a standard adopted in § 164.308, § 164.310, § 164.312, § 164.314, or § 164.316 includes addressable implementation specifications, a covered entity or business associate must- As applicable to the covered entity or business associate- If implementing the implementation specification is not reasonable and appropriate- Implement an equivalent alternative measure if reasonable and appropriate.

SCF Controls: RSK-06.2

Aggregate Coverage: Contributes

VMware vDefend (Contributes)

VMware vDefend provides a layered set of technical mechanisms that organizations can deploy as compensating countermeasures to reduce risk exposure and limit the impact of threats at the network security layer. In addition to core preventive controls such as Distributed Firewall microsegmentation, Distributed IDS/IPS, TLS Inspection, URL filtering, and malware prevention, vDefend includes identification and response capabilities that support the compensating countermeasure lifecycle.

The vDefend distributed firewall (DFW) supports targeted policy enforcement using the Applied To field to scope policies to specific workload groups, zones, tenants, or applications without affecting other policies. Stage 2 of the vDefend Zero Trust journey (Infrastructure Services Protection) prioritizes securing critical infrastructure services such as DNS with specific deny rules scoped to infrastructure groups, providing a risk reduction approach that does not require a full Zero Trust policy deployment. DFW policies applied globally allow sources or destinations to be any object without span restrictions, supporting broad or targeted countermeasure scope as needed.

vDefend Distributed IDS/IPS provides intrusion detection and prevention capabilities and supports custom signature creation, allowing administrators to address threats from custom applications and zero-day vulnerabilities beyond standard signature coverage. The Oversubscription setting for Distributed IDS/IPS lets administrators configure whether excess traffic is dropped or bypassed when the IDS/IPS engine is overloaded, providing operational control over inspection behavior under high load.

The Security Services Platform supports investigation of individual threat events and correlated campaigns, enabling security teams to assess impact, identify root causes, and take mitigation actions. Campaign impact scoring within the Security Services Platform helps administrators prioritize which threats to address first. Comparing the ratio of detected versus prevented events in Security Intelligence informs administrators about how well current controls are protecting infrastructure, supporting identification of areas where additional countermeasures may be warranted.

vDefend Advanced Threat Prevention includes Network Detection and Response (NDR) as an activatable feature, providing supplemental threat detection coverage that complements preventive controls.

Formal compensating control documentation and organizational approval processes remain outside vDefend's scope; this control requires those organizational governance processes in addition to the technical mechanisms vDefend supplies.

Not applicable for this control: VCF, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.306(e)

> When a standard adopted in § 164.308, § 164.310, § 164.312, § 164.314, or § 164.316 includes addressable implementation specifications, a covered entity or business associate must- Maintenance. A covered entity or business associate must review and modify the security measures implemented under this subpart as needed to continue provision of reasonable and appropriate protection of electronic protected health information, and update documentation of such security measures in accordance with § 164.316(b)(2)(iii).

SCF Controls: CPL-03.2

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides configuration-state review and continuous compliance monitoring capabilities that contribute to regular functional reviews of cybersecurity and data protection controls across the infrastructure stack, though the organizational review process, schedule, and corrective action procedures must be established and maintained outside the platform.

VCF Operations includes a compliance management capability that continuously monitors infrastructure against industry-standard security benchmarks and custom policies. Rather than relying solely on periodic manual reviews, VCF Operations flags configuration drift and policy deviations as they occur, giving auditors and administrators ongoing visibility into the compliance posture of technology assets and services running on the platform. When VCF Operations detects non-compliance with a policy, it can generate alerts or notifications, and depending on the severity, administrators can configure automated remediation actions to bring the object back into compliance. Compliance management detects violations, highlights risk areas, and provides actionable remediation recommendations.

VCF Operations calculates a compliance score for each managed object based on the ratio of compliant objects to total objects assessed by a given benchmark, expressed as a percentage. The most critical violated standard determines the overall compliance score for a given object, making it straightforward to identify which assets need attention first. Compliance score cards display the number of non-compliant objects and the total number of objects affected by each hardening guide. Administrators manage all compliance-related tasks from the Security > Compliance page, where they can discover non-compliant objects, review associated violations, and take remedial action.

To support structured reviews against recognized standards, VCF provides pre-built compliance packs available as native packs from the compliance repository. These include packs aligned with ISO security standards and the DISA Security Technical Implementation Guide (STIG), among others. Organizations can apply these packs to evaluate their VCF deployment against established security baselines, identify gaps, and track remediation progress. The vSphere Security Configuration Guide and the vSAN Security Configuration Guide provide additional hardening guidance and address compliance considerations, and are references for what settings and configurations to verify during a functional review. The NSX Security Configuration Guide provides recommendations for securing NSX components such as NSX nodes, NSX Controllers, and NSX Edge nodes.

Beyond the built-in benchmarks, organizations can create custom compliance benchmarks that codify their own cybersecurity and data protection policies. Custom benchmarks are configured through a multi-step process that includes naming, selecting compliance alerts to monitor, and activating policies. VCF Operations supports up to five custom compliance score cards. Custom benchmarks can be exported from one VCF Operations instance and imported to another, providing consistent policy enforcement across multiple deployments.

At the host layer, VCF Operations Configuration Drifts provides a proactive method to monitor configuration changes across vCenter instances and vSphere clusters. vSphere Configuration Profiles must be enabled on clusters to view drift status, and the feature applies to deployments running VCF or later. The Configuration Drift dashboard allows administrators to view and monitor drift statuses, detecting when hosts fall out of their desired-state configurations. vSphere Lifecycle Manager can check the compliance of a cluster or host against the desired state and determine whether additional remediation steps are required.

NSX provides its own compliance status reporting. NSX Manager offers a Compliance Status Report accessible from the Monitoring Dashboards that displays the number of affected resources and compliance status. The report identifies non-compliant configurations by non-compliance code, description, compliance standard violated, affected resource name or ID, and resource type. Organizations can use the NSX compliance report to configure their NSX environment to adhere to IT policies and industry standards.

The VMware Kubernetes Service (VKS) layer of VCF extends compliance review capabilities to containerized workloads and the Kubernetes control plane. Pod Security Admission (PSA) is the built-in Kubernetes admission controller that evaluates pod specifications against defined security standards at the point of deployment. PSA operates in three modes: enforce blocks non-compliant pods from running, audit records security violations as audit events without blocking deployment, and warn returns warnings to the caller without blocking. Organizations can configure PSA to enforce a baseline standard cluster-wide while operating the restricted standard in audit and warn modes, producing an ongoing stream of compliance findings about workloads that do not meet the stricter profile without disrupting existing workloads. PSA can be configured per namespace using the podSecurityStandard API, allowing different review stringency to be applied to different teams or workload types. Pods' security contexts should be separately reviewed to identify any privileges or capabilities that exceed what the predefined security standards permit for a given use case.

VKS Cluster Management provides out-of-the-box security policy templates that mirror the Kubernetes Pod Security Standards profiles, including baseline and restricted. The baseline template mitigates common privilege escalation risks while maintaining compatibility with standard containerized workloads. Custom security policy templates extend these defaults, allowing organizations to fine-tune individual security context parameters in support of governance requirements specific to their environment.

For Kubernetes RBAC review, the Kubernetes documentation distributed with VKS notes that the default RBAC rights provided in clusters should be reviewed to identify opportunities for security hardening. Auditors reviewing a VKS deployment should examine ClusterRole and ClusterRoleBinding objects for overly broad permissions as well as namespace-scoped Role and RoleBinding objects for each team or namespace. IAM role trust policies should be scoped to specific service accounts and namespaces to support least-privilege enforcement.

STIGs for VKS system components, including Supervisor and VMware Kubernetes Release (VKr) components, are available through Tanzu STIG Hardening and provide a recognized baseline against which deployed VKS environments can be compared during periodic compliance reviews.

Harbor Registry, available as a standard package on VKS clusters, provides vulnerability scanning, content trust, and policy-based replication to help evaluate the security of the container image supply chain. Harbor's role-based access controls and artifact policies can themselves be audited to confirm that only approved images are accessible to workloads. Within CI/CD pipelines integrated through Harness, the Harness Security Testing Orchestration (STO) capability enforces policy based on CVE data and severity thresholds, and Wiz integrates with the pipeline to authenticate to the artifact registry, pull container images, and perform vulnerability scanning before workloads are promoted to production. Wiz can also be deployed as a service on VKS clusters to continuously monitor the cloud environment and deployed workloads for security risks and compliance deviations.

Third-party policy engines such as Kyverno and OPA Gatekeeper can be deployed on VKS clusters to implement policy-as-code compliance review. These tools evaluate cluster resources against defined policies and can generate compliance reports identifying violations across the cluster, extending the platform's built-in review instrumentation.

For auditors evaluating a VCF environment against this control, the key areas to examine are: whether VCF Operations compliance monitoring is enabled and configured with benchmarks that map to the organization's policies; whether compliance packs appropriate to the organization's regulatory environment have been applied; whether the Configuration Drifts feature is active for vSphere clusters; whether PSA is configured in audit and warn modes on VKS namespaces to produce ongoing compliance findings; whether RBAC bindings across VKS clusters have been reviewed against least-privilege expectations; and whether the compliance dashboard and NSX compliance reports are being reviewed on a regular cadence with findings triaged and remediated.

These capabilities verify that infrastructure configurations match desired baselines and that compliance benchmarks are met, but they do not functionally test whether security controls are actively operating as intended. Organizations should supplement VCF's configuration-state reviews with periodic functional validation such as security assessments or controlled test scenarios. The review schedule, escalation procedures, and corrective action processes are organizational responsibilities that VCF does not enforce on its own.

VMware vDefend (Contributes)

VMware vDefend contributes to the functional review of cybersecurity controls by providing network security-specific compliance assessment, policy analysis, and segmentation scoring capabilities. While the broader review of all technology assets against organizational policies is handled by VCF Operations and its compliance management features, vDefend provides the network security dimension of that review.

Security Services Platform includes a Security Segmentation score and report generation capability that helps compliance officers meet security audit requirements and demonstrate adherence to network security best practices. This scoring mechanism evaluates the current state of microsegmentation policy enforcement across the environment, providing auditors a quantitative measure of alignment between network security controls and policy objectives. The Security Segmentation Score Breakdown report details total environments and pairs, protection rule actions, and highlights environment pairs that lack inter-environment policies, providing specific visibility into coverage gaps in the microsegmentation posture. The Security Policies window within Security Services Platform displays all firewall rules applied for environment pairs, and administrators can change the action of published environment pair protection rules directly from this view.

The metrics service within Security Services Platform collects key performance indicators and operational data points across vDefend components including Distributed Firewall, Gateway Firewall, IDS/IPS, and TLS Inspection, providing the data foundation for ongoing compliance reviews. Viewing the TLS Inspection dashboard requires Security Services Platform to be deployed with the Metrics feature enabled. Security Services Platform Inventory monitoring allows administrators to view the infrastructure hierarchy including regions, zones, and VMs to verify correct definition, supporting periodic reviews of Technology Assets.

Security Services Platform's Security Intelligence capability provides policy recommendation analysis that compares recommended rules, groups, and services against the current environment to identify gaps between desired and actual security policy. Administrators use the Monitor & Plan interface to review, filter, and manage policy recommendations, identifying where current firewall rules diverge from what traffic analysis suggests is appropriate. Recommendations can be filtered by Status and Ready to Publish state, and scoped to selected groups and VMs. Policy Recommendations can be exported in JSON format with resource_type, id, and children elements for infrastructure and domain configuration, allowing compliance teams to analyze recommended rule sets outside the platform.

The Security Overview dashboard in Security Services Platform provides summary-level statistics of file inspections, and the platform provides monitoring of current deployment status and platform-related alarms that highlight errors requiring attention. Security Services Platform support bundles collect diagnostic information from all controller and worker nodes in the deployment for troubleshooting and compliance documentation. Security Services Platform also supports assessment of control effectiveness by enabling comparison of the ratio of detected versus prevented events, providing reviewers a quantifiable measure of security control activity relative to observed threats.

Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. The dedicated Auditor role is designed for personnel performing compliance and security reviews, allowing compliance teams to access review and assessment capabilities without requiring administrative privileges.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides built-in mechanisms that support regular review of database infrastructure assets for adherence to security, compliance, and resilience policies.

The most direct compliance review mechanism in DSM is the Compliance tab, available on each data service policy detail page. This tab displays compliance reports for data service policies and allows administrators to expand policy violations to identify noncompliant databases, data services, namespaces, and resource configurations. Administrators can use this view to assess which database instances are operating outside defined policy parameters and take corrective action.

Infrastructure policies in DSM create a framework of standards against which deployed database resources are evaluated. Administrators define data service policies that govern resource consumption limits, storage placement, VM class selection, and IP range assignments. These policies apply to PostgreSQL, MySQL, and SQL Server databases and can be enforced across different tenants to maintain a consistent security and compliance posture. The Infrastructure Policies view in the DSM administrator UI lists all policies in the environment and shows which databases are associated with each policy, providing a consolidated view for compliance assessment.

DSM generates infrastructure policy compliance alerts, including `INFRASTRUCTURE_POLICY_CLUSTER_COMPLIANT` and `INVALID_SUPERVISOR_INFRASTRUCTURE_POLICY_STATUS`, to flag when cluster configurations drift from policy requirements. The monitoring framework also raises metrics-based and status-condition-based alerts to identify critical failure conditions across database engines, including engine degradation, non-operational status, and backup failures for PostgreSQL, MySQL, and SQL Server databases. These alerts provide ongoing visibility into the compliance and resilience state of database resources without requiring manual inspection.

For resilience review specifically, DSM requires that High Availability be activated on VMware vCenter clusters as a prerequisite for infrastructure policy compliance. The resiliency of the DSM Provider Appliance itself is provided through vSphere HA. These requirements are surfaced through the policy compliance alerting mechanism, making infrastructure resilience status an integrated part of policy compliance reporting.

Organizations should supplement DSM's built-in compliance reporting with documented review schedules, assigned review responsibilities, and a process for tracking and remediating identified violations. DSM provides technical visibility into policy adherence for database infrastructure, but the organizational governance processes that constitute a complete functional review program remain the responsibility of the operating organization.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) supports organizational reviews of application-layer security, compliance, and resilience through its built-in reporting capabilities.

The Application Security Report generates audit-ready records of WAF findings, statistics, and overall security posture accessible to both technical teams and executive stakeholders. The report is available as a downloadable PDF, making it suitable for sharing findings with auditors and compliance reviewers. Security teams can use this report to assess whether Avi-managed applications are aligned with organizational security policies and to track posture over time.

The WAF Evaluation Report provides structured recommendations for strengthening an application's security posture, giving reviewers a concrete basis for identifying and remediating configuration gaps across virtual services.

In 9.1, Positive Security configuration has been consolidated under Virtual Service > Positive Security Policy, a change from its prior location within the WAF Policy. This mechanism determines which learned application behaviors are promoted to enforced security rules. Periodic review of the Positive Security Policy is part of maintaining the application security posture across Avi-protected services.

User-Defined Metrics extend Avi's reporting capabilities by allowing administrators to define and extract customized telemetry data required for specific enterprise compliance or reporting needs through API calls. This capability supports integration of Avi-specific application metrics into broader compliance dashboards and review workflows.

Avi's contribution to this control is bounded by its role as an application delivery controller. The review program this control requires, encompassing all technology assets and services across the organization, is an organizational governance responsibility that extends beyond the application-layer reporting and validation capabilities Avi provides.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 164.308(a)(1)(i)

> A covered entity or business associate must, in accordance with § 164.306: Standard: Security management process. Implement policies and procedures to prevent, detect, contain, and correct security violations.

SCF Controls: CFG-01, CHG-01, GOV-02, IRO-01, MON-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support an organization's change management program, though the program itself must be established and governed through organizational policy and process.

VCF Operations is the central lifecycle management engine for the platform. It coordinates updates across the full stack and requires a precheck before applying any update to verify that the environment is ready. Lifecycle management tools within VCF Operations support planning updates so that administrators can schedule maintenance windows and make changes with minimal disruption to services. When updates are available, VCF Operations Fleet Management displays them through its Lifecycle view, where administrators can select a VCF instance and review pending VCF Operations updates.

vSphere Lifecycle Manager (vLCM) provides centralized lifecycle management for ESX hosts, drivers, firmware, and add-on software. vLCM uses desired-state configuration with a single image per cluster to maintain consistency across infrastructure components. Upon remediation, the image is installed on all hosts in the cluster, replacing the older baseline and baseline group approach from Update Manager. vLCM synchronizes to its download sources, including VCF Operations, on a regular and automatic basis. The Update Manager module provides PowerCLI cmdlets for downloading patches, creating and modifying baselines, and scanning and remediating hosts and virtual machines. Together, these components provide a structured, repeatable process for applying changes to the infrastructure.

VCF Operations extends change management support through configuration drift detection and source control integration. The Configuration Drifts feature tracks changes in product configurations over time and compares them against assigned desired values, providing scheduled drift detection for VMware vCenter and cluster objects to proactively detect configuration deviations from the desired state. Configuration Drifts Templates can be integrated with a source control repository (GitHub or GitLab), which enables versioning, auditing, and management of configuration templates. This integration supports change control with reviews and can be incorporated into continuous integration and continuous deployment pipelines for automated testing and validation of configuration changes. VCF Operations orchestrator also supports pushing local change sets to a Git repository, where each change set can consist of one or more modified orchestrator objects, providing a traceable record of automation changes. VCF Operations audit logging tracks each configuration change to the authenticated user who initiated the change or scheduled the job that performed it, allowing data center administrators to determine who changed what and when.

VCF Automation includes workflow capabilities with approval policies that require project administrators to review changes to deployed catalog instances before they take effect. This allows organizations to integrate change approval into their operational workflows. For organizations that use ServiceNow for IT service management, the ServiceNow ITSM Plug-in for VCF Automation integrates deployment lifecycle actions (such as power operations, lease changes, ownership transfers, and deployment edits) with ServiceNow change workflows. This allows VCF operational changes to be routed through an organization's existing ITSM change approval processes. Policy management capabilities within VCF Automation allow Organization Administrators to create, update, and manage policy definitions, providing a governance layer for controlling what changes are permitted within the platform.

NSX Global Manager provides change validation by checking proposed configuration changes against both Global Manager and Local Manager configurations before they are applied, reducing the risk of conflicting or disruptive network changes in federated environments.

Role-based access control across VCF components restricts who can make configuration changes. Audit logging across the platform captures change activity for review, including vDefend firewall audit logs that capture both old and new values for

modified security policies and VCF Operations audit events that record interactions such as configuration modifications, logins, and capability checks.

VMware vDefend (Contributes)

VMware vDefend (vDefend) supports network security monitoring through multiple integrated capabilities that contribute to enterprise-wide monitoring frameworks.

Security Intelligence, hosted on the Security Services Platform (SSP), provides continuous visibility into network traffic flows across protected workloads. It monitors flows between application pairs, updates the Policy Protection Status for each application to indicate that flows are being monitored, and continuously detects new flows between environment pairs, alerting administrators to unauthorized or unexpected traffic. The Monitor & Plan Overview page presents a consolidated view of pending actions, data collection activity status, network security posture, flow trends, and a summary of suspicious traffic. The Security Intelligence Recommendations monitoring capability checks for changes in the scope of monitored entities every hour when the Monitoring toggle is enabled, allowing administrators to keep policy recommendations current as environments evolve. Segmentation Monitoring provides dedicated views of application and infrastructure flows with configurable time ranges spanning from the last hour to the last month, and displays flows related to detected infrastructure servers in a specified time interval.

The Network Detection and Response (NDR) Sensor checks the status of activated detection features every 15 minutes and updates its configuration accordingly, supporting sustained threat detection coverage. NDR Sensor health status monitoring tracks whether key components, including network traffic capture, file analysis, and data transmission, are operating properly. The NDR Sensor also sends alerts notifying administrators of conditions such as services being down, high CPU, memory, or disk usage, packet drops, or missed heartbeats. NDR provides role-based access control covering triage operations such as viewing detections and campaigns, as well as SIEM configuration management.

The Security Services Platform monitors its own health, with Yellow or Red health status indicators displayed when issues occur in subcomponents. SSP monitoring tracks the status of the flow clustering job that runs every hour and reports suspicious traffic detector execution status after each run, with values such as SUCCESS, NOT_ENOUGH_BASELINE, and FAILURE.

The Security dashboard provides a consolidated view for monitoring and configuring security features across network workloads. In federated deployments, the Global Manager provides centralized event management and monitoring for malicious IP blocking activity across all Local Managers.

vDefend generates Unified Security Logs that VCF Log Management can collect and analyze. These logs cover Distributed Firewall, Gateway Firewall, Identity Firewall, FQDN Analysis, TLS Inspection, Intrusion Detection/Prevention System (IDPS), and URL Filtering activity. Broader log aggregation and SIEM correlation for enterprise-wide monitoring remain the responsibility of the SIEM and logging infrastructure deployed alongside vDefend.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides role-based access controls, audit logging, and operational safeguards that contribute to change management programs for disaster recovery configurations.

PNR separates change authority through role-based access that restricts who can modify DR infrastructure. The Protection and Recovery Appliance Management Interface requires admin credentials to access reconfiguration and service management functions, controlling administrative-level changes to the appliance itself, including hostname changes, certificate changes, and patch application. In VCF Automation deployments, namespace network mappings can only be edited by an Organization Administrator in the VCF Automation Organization UI. Provider Administrators with the system administrator predefined role install PNR in regions, pair regions, and manage organizational access to PNR capabilities through the VCF Automation Provider Management UI. These access controls restrict modification of DR infrastructure to authorized personnel.

PNR logs configuration change events to support traceability. Array Manager reconfiguration events are recorded when a user edits Array Manager properties, capturing changes to storage replication infrastructure. The Appliance Management Interface

provides an authenticated path for appliance-level configuration changes, requiring admin credentials for all reconfiguration and service management operations.

Recovery plans in PNR support structured and auditable change to DR workflows. Plans can be edited to modify the recovery site, protection groups, and test network selection, and can be organized into folders and edited from either the protected site or the recovery site. Recovery plan steps run in a specific order that cannot be changed, but custom steps that display messages and run commands can be added to extend the workflow. Array managers can be edited to modify settings such as IP address, user name, and password without rebuilding dependent protection groups.

A configurable setting, `replication.updateVmProtectionOnPlacementChange`, controls whether VM protection is updated automatically when VM placement changes. Setting this to false prevents infrastructure placement operations from triggering protection reconfigurations outside of an intentional change workflow.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to enterprise-wide monitoring controls through a layered set of observability capabilities covering database health, infrastructure compliance, and event-driven alerting.

DSM provides a built-in monitoring framework that tracks database instance health across multiple dimensions. From the Monitoring tab in the DSM UI or the vSphere Client, administrators and authorized users can view real-time and historical metrics for database VMs, including CPU Health, Data Disk Health, System Disk Health, Max Connections, Active Connections, Write Throughput, Read Throughput, Thread Resource Utilization, Slow Queries per Second, InnoDB Buffer Usage, and InnoDB Reads and Writes. The Monitoring page defaults to the last three hours of aggregated metric data, with the time range adjustable through the Time Range Last dropdown. This visibility supports detection of resource contention, performance degradation, and connectivity anomalies at the database layer.

DSM's alert framework provides configurable thresholds for warning and critical conditions on key health indicators. Administrators and users can set separate warning and critical thresholds for CPU Health, Data Disk Health, System Disk Health, and Max Connections parameters. When thresholds are exceeded, DSM generates typed alerts such as Database Engine Health, Custom Config Health, and Backup Storage Health alerts. DSM monitors database replication status and raises an alert when a secondary database is not replicating data from the primary. DSM also raises an alert when metrics are no longer being received from a cluster, supporting detection of monitoring gaps. Alerts can be activated or deactivated per data service through the "Enable Alerts for DB Alert" setting, providing granular control over which databases are subject to active alerting. For each alert, DSM provides mitigation suggestions to help administrators resolve issues without disrupting database services.

In addition to database-level alerts, DSM generates global infrastructure alerts that surface vCenter integration and infrastructure policy issues. These include `INFRASTRUCTURE_POLICY_VC_ALARMS`, raised when vCenter resource alarms are active; `INFRASTRUCTURE_POLICY_CLUSTER_COMPLIANT` and `INVALID_SUPERVISOR_INFRASTRUCTURE_POLICY_STATUS`, which reflect cluster compliance state; `VCENTER_CONNECTIVITY`, raised when vCenter connectivity fails and triggering troubleshooting steps that include verifying connectivity and checking authentication logs; and `LicensingNotUpdated` and `vCenterBinding` API status alerts that surface license and API integration conditions. A Global Alerts page in the DSM UI provides a centralized view of these alerts during and after installation and ongoing operation.

In 9.1, DSM integrates with VCF Operations to extend observability beyond the DSM UI. When configured, VCF Operations automatically discovers and monitors PostgreSQL and MySQL clusters in the Ready state and displays a Data Services View dashboard showing active alerts and inventory items. VCF Operations presents performance data across three levels: cluster-level for overall health, node-level for infrastructure resource use, and database-level for KPIs including Active Connections, Commits, Rollbacks, and Deadlocks. This integration requires configuring the connection between DSM and VCF Operations before use.

DSM also adds SQL Server as a supported database type, with dedicated monitoring through an integrated InfluxDB instance and Telegraf agents deployed across the provider appliance and SQL Server workload clusters. The monitoring framework

supports metrics-based and status-condition-based alerts for SQL Server, covering database engine degradation, non-operational status, and automated or transaction log backup failure conditions.

DSM supports event notification to external systems through a webhook integration. Webhooks transmit alert notifications containing the triggered date, triggered time, triggered user email, task status, previous status, and task type. This allows DSM alerts to feed into centralized monitoring or incident management platforms maintained by the organization. DSM generates plug-in registration logs that administrators can review for vCenter connectivity errors, and DSM's troubleshooting guidance directs administrators to review active vCenter infrastructure alarms and resolve underlying issues identified through the alert system.

Enterprise-wide monitoring requires organizational decisions about monitoring architecture, log aggregation platforms, alerting policies, and operational response procedures that lie outside DSM's scope. DSM provides the data and integration points; the organization must determine how those signals are collected, correlated, and acted upon across the broader environment.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer includes several mechanisms that support change management practices for application delivery configurations.

The Avi Controller generates configuration event codes for all changes: CONFIG_CREATE, CONFIG_UPDATE, and CONFIG_DELETE. CONFIG_UPDATE events capture the resource name, status, and prior resource data, giving administrators and auditors a traceable record of changes to virtual services, pools, WAF policies, Service Engine Groups, and other Avi-managed objects. These events are accessible via Operations > Events > Config Audit Trail. Administrators can also use the Config Events overlay in Service Engine analytics to correlate traffic behavior changes with specific configuration modifications, identifying whether a shift in traffic was caused by a change to virtual service security settings, pool membership, or other configuration parameters.

Configuration changes made through the web interface, CLI, or REST API are automatically propagated to all Controller cluster members, so all nodes maintain a consistent and current configuration state.

Avi supports infrastructure-as-code tooling for controlled deployment workflows. Terraform integration includes a plan phase that shows administrators what changes will be made to Avi Controller deployment before they are applied, allowing review and approval prior to execution. Ansible can be integrated with CI/CD pipelines to trigger automated, repeatable Avi Controller deployments, supporting consistent and auditable change procedures. In VCF environments, new Avi installations must be performed through VCF Lifecycle Management, adding a structured change governance layer to the deployment lifecycle itself.

The Avi CLI provides a `configure upgrade profile` command for setting parameters that govern Controller and Service Engine upgrade sequencing, and a rollback capability allows reverting to a prior state if a change introduces problems.

Avi Contributes rather than Meets because the control asks whether the organization facilitates a change management program. A program of this kind includes formal approval workflows, change advisory processes, scheduling policies, and governance documentation that Avi does not provide independently. The configuration audit trail and automation integrations support the technical aspects of change traceability, but the governance program itself must be established and operated by the organization.

Control 164.308(a)(1)(ii)(A)

> A covered entity or business associate must, in accordance with § 164.306: Implementation specifications: Risk analysis (Required). Conduct an accurate and thorough assessment of the potential risks and vulnerabilities to the confidentiality, integrity, and availability of electronic protected health information held by the covered entity or business associate.

SCF Controls: RSK-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.308(a)(1)(ii)(B)

> A covered entity or business associate must, in accordance with § 164.306: Implementation specifications: Risk management (Required). Implement security measures sufficient to reduce risks and vulnerabilities to a reasonable and appropriate level to comply with § 164.306(a).

SCF Controls: GOV-09, GOV-15.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.308(a)(1)(ii)(C)

> A covered entity or business associate must, in accordance with § 164.306: Implementation specifications: Sanction policy (Required). Apply appropriate sanctions against workforce members who fail to comply with the security policies and procedures of the covered entity or business associate.

SCF Controls: HRS-07

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.308(a)(1)(ii)(D)

> A covered entity or business associate must, in accordance with § 164.306: Implementation specifications: Information system activity review (Required). Implement procedures to regularly review records of information system activity, such as audit logs, access reports, and security incident tracking reports.

SCF Controls: IRO-09, MON-01, MON-01.8

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides enterprise-wide monitoring through integrated tools that span infrastructure health, performance metrics, compliance assessment, log analysis, and alerting.

VCF Operations continuously monitors the operational state of all VCF components to detect conditions that may affect availability or compliance. It collects metrics across compute, storage, and networking resources, and correlates them over time to identify trends that may lead to potential failures. VCF Health, a component of VCF Operations, continuously monitors the operational state of VCF components to verify they are functioning as expected, giving platform operators a single view of operational status. Platform operators can configure alerts, perform log analysis, run infrastructure diagnostics, and review VCF health from a unified interface.

VCF Operations provides continuous compliance management by monitoring infrastructure against industry-standard benchmarks and custom policies. Administrators can create custom compliance benchmarks that monitor selected alert definitions and policies, tailoring the monitoring posture to organizational requirements. The platform assesses objects based on selected compliance policies and activates alert definitions associated with the current scorecard, providing ongoing visibility into compliance status. Compliance-related alerts are triggered on objects and displayed through a dedicated compliance alert subtype.

The alerting subsystem in VCF Operations supports the full lifecycle of alert management. Administrators can configure and manage alert definitions to monitor infrastructure events and conditions, including performance metrics, log events, and custom conditions configured through the Management Pack Builder. The Platform Health Alerts page provides a centralized view of all alerts related to overall system health, including alerts from data sources and infrastructure nodes. Health alerts are generated for conditions that affect the health of the environment and require immediate attention. Administrators can create policies to govern how alert definitions are evaluated, including which objects to monitor and what thresholds to apply, and can apply consistent practices to optimize alert behavior across monitored objects.

VCF Operations supports flexible grouping and scheduling to align monitoring with operational realities. Custom groups can be configured with automatic membership criteria to support monitoring strategies and achieve a high level of automation. Maintenance schedules can be assigned to objects undergoing planned downtime to keep monitoring data accurate and avoid false alerts when an object is offline for scheduled maintenance.

VCF Log Management provides centralized log collection and analysis. It ingests logs from VMware vCenter, VMware ESX hosts, NSX, vSAN, VCF Automation, VCF Operations, VCF Identity Broker, VCF Operations for Networks, and VCF Operations HCX. VCF Operations and VCF Log Management must be integrated to implement the centralized log collection architecture. The platform provides dashboards and analytics for troubleshooting and security investigation. Log-based alert definitions allow administrators to trigger notifications when specific log patterns appear across monitored systems. Log forwarding to external SIEM or syslog targets is configurable, with support for TLS encryption to protect log data in transit. The vCenter syslog forwarding API supports TCP, UDP, TLS, and RELP protocols. NSX Manager syslog supports TLS and requires port 6514 for encrypted log transmission.

At the vSphere layer, the alarm infrastructure integrates with events and performance counters to provide real-time alerting. The MetricAlarmExpression data object allows administrators to set alarms on specific performance metrics with configurable monitoring intervals and aggregation functions for processing data points. The vSphere Client provides direct visibility into tasks and events for change tracking and troubleshooting. VCF ships with preconfigured vSphere alarms that are active by default and monitor specific components including the Identity Management Service, Message Bus Configuration Service, ESX

Agent Manager, VMware Service Control Agent, vSphere HA host status, and host connection and power state. The vCenter Management Interface provides appliance-level health visibility through an Overall Health badge that reflects one of five states (Good, Warning, Alert, Critical, or Unknown) across all vCenter components, and notifies administrators of available security patches through Critical or Alert badge indicators when automatic patch checks are enabled.

When VCF Automation is integrated with VCF Operations, the Insights dashboard and Alerts tab provide real-time capacity awareness and alert information for VCF Automation objects, giving IT teams visibility into resource usage across both provisioned workloads and the underlying infrastructure. The VCF Automation Monitor tab surfaces deployment health information sourced from VCF Operations, and deployment cards display Last Request Status information that tracks the most recent operation on each deployment (Create, Update, or Delete) and its outcome (Successful, In Progress, or Failed). The Management Pack Builder allows administrators to set up event definitions for integrated systems, monitoring specific conditions or thresholds and configuring alerts for proactive management. Management Packs extend monitoring to network devices, including sensor monitoring for devices such as switches and routers. Adapters can be installed on VCF Operations nodes to extend monitoring to additional systems and data sources beyond the core VCF components.

The VMware Kubernetes Service (VKS) layer of VCF extends enterprise monitoring to container workloads and Kubernetes infrastructure. VKS clusters support MachineHealthCheck objects for both control plane nodes and worker node deployments; administrators manage these through the VCF CLI `vcf cluster machinehealthcheck` command, which supports configuration of unhealthy-condition definitions, maximum unhealthy thresholds (expressed as an absolute number or a percentage), and label selectors to target specific machines. The VCF CLI `vcf cluster machinehealthcheck node get` and `vcf cluster machinehealthcheck control-plane get` commands retrieve node and control plane health status on demand. VKS cluster health conditions, including the Ready and ControlPlaneReady status indicators, reflect the operational state of each cluster and are accessible via `kubectl` and the VCF CLI. The VCF Automation Provider Management UI includes a Services overview interface that exposes VKS cluster management functions and the health status of all cluster elements, giving platform operators a centralized view of the VKS tier. The Kubernetes API server within VKS clusters exposes diagnostic and health check endpoints (`/healthz`, `/livez`, `/readyz`, `/statusz`, and `/metrics`) that external monitoring systems can scrape to track API server availability and readiness; the `kube-apiserver` also emits the `kubernetes_healthchecks_total` counter and `kubernetes_healthcheck` gauge metric, which report structured health check status for components including `etcd` and `autoregister-completion`. Access to these monitoring endpoints is governed by the built-in Kubernetes `system:monitoring` RBAC group, which grants read access to liveness, readiness, and metrics endpoints while restricting broader cluster access. The Kubernetes Watch API allows monitoring tools to track changes to any API object as a live stream, supporting event-driven monitoring without continuous polling. The Node Problem Detector monitors node health and surfaces node-level problems as Kubernetes events and node conditions that external monitoring systems can consume via the event stream.

For workload-level monitoring within VKS clusters, Prometheus Operator is available as a standard package and defines custom resource definitions to deploy and manage Prometheus and Alertmanager StatefulSets, enabling high-availability alerting configurations. The Prometheus Alertmanager custom resource definition configures alert grouping, inhibition, and routing to external notification systems. The Istio service mesh, also available as a standard package on VKS clusters, provides service-level monitoring alongside its traffic management capabilities. The Dynatrace Operator can be deployed on VKS clusters to automate the deployment, scaling, and maintenance of the Dynatrace monitoring stack. Historical analysis, dashboarding, and alerting on cluster-level metrics require a dedicated monitoring solution configured to scrape the VKS metrics endpoints and subscribe to the Kubernetes event stream. The `vcf cluster support-bundler create` command gathers diagnostic information from Supervisor and VKS clusters when troubleshooting is needed.

At the network layer, NSX provides monitored indicators including node uptime status, deployment status, management and controller connections, tunnel status, PNIC status, and uptime duration. NSX time series APIs allow viewing data such as VPN statistics, including metadata about the number of tunnels configured and how many are up or down at a given time.

VCF Operations also supports self-monitoring through the VCF Operations adapter, which collects internal metrics such as activity success counts. This allows administrators to verify that the monitoring platform itself is functioning correctly. The VCF Operations policy engine monitors conditions and generates events to react to changing states in the orchestrator server or connected technologies. The Adapter Instance monitoring interval is configurable, with intervals as granular as five minutes.

VMware Private AI Services (PAIS) includes a built-in observability stack that supplies monitoring data for AI infrastructure and AI workloads. PAIS Controller metrics are exposed at a Prometheus metrics endpoint on the pais-controller-manager service, allowing collection by monitoring systems and visualization in observability platforms such as Grafana. Observability is activated by updating the PAISConfiguration custom resource with optional sections for Prometheus metrics collection and LLM trace forwarding. The Prometheus runtime can be configured with a specified storage class policy and a configurable metrics retention period, giving administrators control over how long monitoring data is stored. A Prometheus server pod must be in a ready and running state for observability to function.

LLM trace data from PAIS can be forwarded to an OpenTelemetry Collector endpoint over http/protobuf or gRPC, providing distributed tracing for AI model inference activity. The observability.IlmTraces configuration governs trace forwarding and works alongside the Prometheus metrics pipeline to produce two signals: metrics for health and performance, and traces for inference-level behavior. PAIS Controller metrics include the Model Endpoint Controller and PAIS Configuration Controller, giving monitoring platforms component-level visibility into PAIS operations.

In 9.1, PAIS adds direct integration with VCF Operations. The controller-pod-metrics-streaming setting activates streaming of PAIS controller pod metrics from the Supervisor cluster to VCF Operations, allowing administrators to view PAIS metrics alongside other VCF infrastructure metrics. A Telegraf deployment in the vmware-system-monitoring namespace uses a telegraf-user-config ConfigMap to manage user-configured monitoring endpoints for PAIS. The VCF Consumption CLI connects to the Supervisor endpoint and enables VI administrators to stream metrics from the PAIS controller pod. DevOps engineers can visualize health and performance metrics for PAIS components running in a VCF Automation namespace using Grafana, and MLOps engineers and application developers can monitor the health, quality, and behavior of AI applications and the models used in agents through the same observability platforms.

PAIS supplies the technical monitoring mechanisms this control requires. Enterprise-wide orchestration of monitoring controls, including alert threshold definition, escalation procedures, and integration with a centralized monitoring or log management platform, remain organizational responsibilities.

VMware vDefend (Contributes)

VMware vDefend (vDefend) supports network security monitoring through multiple integrated capabilities that contribute to enterprise-wide monitoring frameworks.

Security Intelligence, hosted on the Security Services Platform (SSP), provides continuous visibility into network traffic flows across protected workloads. It monitors flows between application pairs, updates the Policy Protection Status for each application to indicate that flows are being monitored, and continuously detects new flows between environment pairs, alerting administrators to unauthorized or unexpected traffic. The Monitor & Plan Overview page presents a consolidated view of pending actions, data collection activity status, network security posture, flow trends, and a summary of suspicious traffic. The Security Intelligence Recommendations monitoring capability checks for changes in the scope of monitored entities every hour when the Monitoring toggle is enabled, allowing administrators to keep policy recommendations current as environments evolve. Segmentation Monitoring provides dedicated views of application and infrastructure flows with configurable time ranges spanning from the last hour to the last month, and displays flows related to detected infrastructure servers in a specified time interval.

The Network Detection and Response (NDR) Sensor checks the status of activated detection features every 15 minutes and updates its configuration accordingly, supporting sustained threat detection coverage. NDR Sensor health status monitoring tracks whether key components, including network traffic capture, file analysis, and data transmission, are operating properly. The NDR Sensor also sends alerts notifying administrators of conditions such as services being down, high CPU, memory, or disk usage, packet drops, or missed heartbeats. NDR provides role-based access control covering triage operations such as viewing detections and campaigns, as well as SIEM configuration management.

The Security Services Platform monitors its own health, with Yellow or Red health status indicators displayed when issues occur in subcomponents. SSP monitoring tracks the status of the flow clustering job that runs every hour and reports suspicious traffic detector execution status after each run, with values such as SUCCESS, NOT_ENOUGH_BASELINE, and FAILURE.

The Security dashboard provides a consolidated view for monitoring and configuring security features across network workloads. In federated deployments, the Global Manager provides centralized event management and monitoring for malicious IP blocking activity across all Local Managers.

vDefend generates Unified Security Logs that VCF Log Management can collect and analyze. These logs cover Distributed Firewall, Gateway Firewall, Identity Firewall, FQDN Analysis, TLS Inspection, Intrusion Detection/Prevention System (IDPS), and URL Filtering activity. Broader log aggregation and SIEM correlation for enterprise-wide monitoring remain the responsibility of the SIEM and logging infrastructure deployed alongside vDefend.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides monitoring capabilities specific to the disaster recovery domain and integrates with the broader VCF monitoring ecosystem through dedicated Protection and Recovery dashboards in VCF Operations. VCF Operations collects configuration, component health, and usage information from protection and recovery servers and site pairs, presenting this through an overview dashboard that displays all site pairs, configurations, health scores, and protection and recoverability status for sites and virtual machines. PNR provides default health alerts for protection groups, recovery plans, cloud file systems, recovery SDDCs, and protected sites through VCF Operations, and the dashboards surface alerts informing administrators about configurations and deployments that require attention. Separate dashboard views cover vSAN Snapshots and Replication monitoring, and an Inventory view provides health status, metrics, alerts, and network topology for all monitored objects.

Within its own domain, PNR provides event logging and configurable alarms for replication and recovery operations. Administrators can create alarms that trigger on specified event conditions, with support for email notifications, SNMP traps, or script execution in response. PNR monitors connections between sites by sending periodic ping requests, logs connection check events, and generates alarms when broken connections are detected. The alarm system generates warning-level alerts for expired snapshot schedules, replication errors such as missing VMs, and connectivity issues with protected and target sites. PNR also monitors resource consumption on the Protection and Recovery Server host and raises alarms when configurable resource thresholds are reached.

PNR includes a health monitoring service that checks each health finding every five minutes and records a timestamp at each check. Health findings are tracked with status history that can be reviewed over configurable time periods, defaulting to a 24-hour window. The Protection and Recovery Appliance supports syslog forwarding to a remote syslog server for log analysis and centralized monitoring, allowing appliance-level events to flow into existing log management infrastructure.

The Clean Room Orchestrator, part of PNR's Cyber Recovery capabilities, supports monitoring of clean room events, tasks, and alarms for recovery operations. Clean Room Orchestrator can forward events to VCF Operations, Microsoft Sentinel, or Splunk Cloud for centralized monitoring, supporting organizations that require DR event data to flow into enterprise SIEM and log management platforms as part of a broader monitoring strategy. The Clean Room Orchestrator integrates with endpoint detection and response tools, including CrowdStrike and Carbon Black sensor appliances, for threat detection within isolated recovery environments.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to enterprise-wide monitoring controls through a layered set of observability capabilities covering database health, infrastructure compliance, and event-driven alerting.

DSM provides a built-in monitoring framework that tracks database instance health across multiple dimensions. From the Monitoring tab in the DSM UI or the vSphere Client, administrators and authorized users can view real-time and historical metrics for database VMs, including CPU Health, Data Disk Health, System Disk Health, Max Connections, Active Connections, Write Throughput, Read Throughput, Thread Resource Utilization, Slow Queries per Second, InnoDB Buffer Usage, and InnoDB Reads and Writes. The Monitoring page defaults to the last three hours of aggregated metric data, with the time range adjustable through the Time Range Last dropdown. This visibility supports detection of resource contention, performance degradation, and connectivity anomalies at the database layer.

DSM's alert framework provides configurable thresholds for warning and critical conditions on key health indicators. Administrators and users can set separate warning and critical thresholds for CPU Health, Data Disk Health, System Disk Health, and Max Connections parameters. When thresholds are exceeded, DSM generates typed alerts such as Database Engine Health, Custom Config Health, and Backup Storage Health alerts. DSM monitors database replication status and raises an alert when a secondary database is not replicating data from the primary. DSM also raises an alert when metrics are no longer being received from a cluster, supporting detection of monitoring gaps. Alerts can be activated or deactivated per data service through the "Enable Alerts for DB Alert" setting, providing granular control over which databases are subject to active alerting. For each alert, DSM provides mitigation suggestions to help administrators resolve issues without disrupting database services.

In addition to database-level alerts, DSM generates global infrastructure alerts that surface vCenter integration and infrastructure policy issues. These include `INFRASTRUCTURE_POLICY_VC_ALARMS`, raised when vCenter resource alarms are active; `INFRASTRUCTURE_POLICY_CLUSTER_COMPLIANT` and `INVALID_SUPERVISOR_INFRASTRUCTURE_POLICY_STATUS`, which reflect cluster compliance state; `VCENTER_CONNECTIVITY`, raised when vCenter connectivity fails and triggering troubleshooting steps that include verifying connectivity and checking authentication logs; and `LicensingNotUpdated` and `vCenterBinding` API status alerts that surface license and API integration conditions. A Global Alerts page in the DSM UI provides a centralized view of these alerts during and after installation and ongoing operation.

In 9.1, DSM integrates with VCF Operations to extend observability beyond the DSM UI. When configured, VCF Operations automatically discovers and monitors PostgreSQL and MySQL clusters in the Ready state and displays a Data Services View dashboard showing active alerts and inventory items. VCF Operations presents performance data across three levels: cluster-level for overall health, node-level for infrastructure resource use, and database-level for KPIs including Active Connections, Commits, Rollbacks, and Deadlocks. This integration requires configuring the connection between DSM and VCF Operations before use.

DSM also adds SQL Server as a supported database type, with dedicated monitoring through an integrated InfluxDB instance and Telegraf agents deployed across the provider appliance and SQL Server workload clusters. The monitoring framework supports metrics-based and status-condition-based alerts for SQL Server, covering database engine degradation, non-operational status, and automated or transaction log backup failure conditions.

DSM supports event notification to external systems through a webhook integration. Webhooks transmit alert notifications containing the triggered date, triggered time, triggered user email, task status, previous status, and task type. This allows DSM alerts to feed into centralized monitoring or incident management platforms maintained by the organization. DSM generates plug-in registration logs that administrators can review for vCenter connectivity errors, and DSM's troubleshooting guidance directs administrators to review active vCenter infrastructure alarms and resolve underlying issues identified through the alert system.

Enterprise-wide monitoring requires organizational decisions about monitoring architecture, log aggregation platforms, alerting policies, and operational response procedures that lie outside DSM's scope. DSM provides the data and integration points; the organization must determine how those signals are collected, correlated, and acted upon across the broader environment.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) contributes to enterprise-wide monitoring through application-delivery-layer mechanisms built into the Avi Controller and Service Engines.

The Avi Controller monitors Service Engine metrics and sends alarms and notifications to administrators when resource utilization data exceeds defined thresholds. Administrators configure custom thresholds on Service Engine groups through the Resource Events tab in the Avi UI. The Alert feature processes system events and metrics against user-defined rules and generates alerts that trigger configured actions, including sending an email, a syslog message, or an SNMP trap. Alert notifications can be forwarded to remote syslog servers for integration with centralized log management and monitoring platforms.

ControlScripts extend this event-response capability: a ControlScript can alter Avi configuration or communicate to external systems, including through webhook integrations with external monitoring tools, in response to defined system events. This supports dynamic responses including resource scaling or automated notifications based on health scores from monitoring data.

The Avi Controller and Service Engines track health score changes and SSL certificate expiration events. Avi integrates with external monitoring tools such as Prometheus for metrics collection and analysis. User-Defined Metrics allow administrators to define and extract customized telemetry data for specific compliance or reporting needs through the API. Real-time metrics are available via API but deactivate by default after 30 minutes to conserve resources and must be reactivated when sustained real-time visibility is required.

At the data plane, Avi health monitors track the status of backend servers and Service Engines continuously. Service Engine health monitoring records detailed server operational status, including health monitor name, type, last transition timestamps, rise count, fall count, total checks, and total failed checks. Each health monitor can be assigned its own threshold and timeout period for server health validation. Monitors support HTTP, HTTPS, TCP, and UDP health-check protocols with configurable success and failure thresholds, send intervals, and receive timeouts.

In Kubernetes environments managed by the Avi Kubernetes Operator (AKO), the HealthMonitor custom resource definition (CRD) allows users to define custom health monitoring configurations for backend services with fine-grained control over health check parameters. The Avi Multi-Cluster Kubernetes Operator (AMKO) GlobalDeploymentPolicy supports health monitor references for consistent monitoring across multi-cluster deployments. Within VCF Automation, a HealthMonitor custom resource can create monitors for tracking backend pool member status using TCP, PING, and HTTP check types.

Control 164.308(a)(2)

> Standard: Assigned security responsibility. Identify the security official who is responsible for the development and implementation of the policies and procedures required by this subpart for the covered entity or business associate.

SCF Controls: GOV-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.308(a)(3)(i)

> Standard: Workforce security. Implement policies and procedures to ensure that all members of its workforce have appropriate access to electronic protected health information, as provided under paragraph (a)(4) of this section, and to prevent those workforce members who do not have access under paragraph (a)(4) of this section from obtaining access to electronic protected health information.

SCF Controls: CFG-08, GOV-02, IAC-01, IAC-08, IAC-21

Aggregate Coverage: Meets

VCF (Meets)

VCF provides a layered identity and access management architecture spanning centralized identity services, role-based access control, group-based access policies, identity provider federation, and programmatic access management through APIs.

VCF SSO is the centralized authentication service. VCF SSO issues security tokens that grant authenticated users access to VMware vCenter, NSX Manager, VCF Operations, and other platform components without requiring separate credentials for each service. VCF Operations supports importing users and groups from VCF SSO for consistent identity management across the stack. VMware Identity Manager provides a platform for managing users and groups, managing resources and user authentication, and configuring access policies and resource entitlements. vCenter also supports built-in identity source authentication using local domain credentials. The built-in identity provider can also be configured to use Active Directory as an identity source through LDAP/S, OpenLDAP/S, or Integrated Windows Authentication (IWA), depending on the directory environment.

VCF supports federation with enterprise identity providers. vCenter can be federated to providers such as Microsoft Entra ID, ADFS, and Okta, which enables multifactor authentication and automatic user synchronization with the organization's directory. PingFederate is also supported as a federated identity provider; for these integrations, vCenter uses System for Cross-domain Identity Management (SCIM) to automate the exchange of user and group identity information between the external identity domain and vCenter. VMware Identity Broker allows principals to authenticate to vCenter through an external identity provider. NSX Manager can be configured to authenticate users from identity management providers and can be integrated with Workspace ONE Access for identity management services. The Supervisor component supports registration of OIDC-compliant external identity providers for authentication to VMware Kubernetes Service (VKS) clusters; supported providers include Okta, Workspace ONE Access, and Dex, configured by supplying the Supervisor callback URL to the identity provider.

Role-based access control is enforced across all VCF components. In vCenter, permissions associate a user or group with a role on a specific inventory object, and predefined roles cover common administrative functions. Custom roles can be created with only the minimum required privileges for a given workflow. Managing identity provider configuration in vCenter requires the VcIdentityProviders Manage privilege. VCF Operations supports group-based access control, allowing administrators to configure groups and assign roles that control access to dashboards, reports, policies, alerts, and administration functions, as well as granular role-based controls for platform operations including approvals, audits, certificates, and content libraries.

VCF Automation extends access management through organization-level and project-level controls. The VCF Automation Access Control service supports identity operations for managing groups and users, including editing user names, passwords, and role assignments. The organization portal enforces role-based access control, requiring either Organization Administrator or Organization Auditor roles to manage policy templates. Organization administrators can distribute infrastructure and configure group-level access through the organization management functionality. Project access is governed by predefined roles. Users and groups can be disabled at the organization level to revoke access without deleting accounts. The System Administrator role has the right to manage and view Access Control Lists, and the accessControls API allows administrators to view and manage ACL entries for defined entities.

For Kubernetes workloads within the VCF consumption layer, VKS supports two authentication methods: VCF SSO and OIDC-compliant external identity providers. The OIDC path is implemented through Pinniped and supports providers including Okta,

Workspace ONE Access, Dex, GitLab, and Google OAuth. Configuring an external provider requires setting up an OpenID Connect ID Token with a Groups claim type filter to enable group-based access control tied to the organization's directory. Custom ClusterClass configurations allow clusters to authenticate developers using existing corporate identity systems. VKS supports namespace permission roles: Owner (full control including deletion), Can Edit (provisioning and operating workloads), and Can View (read-only access). These roles map to Kubernetes ClusterRoles through RoleBindings, and RoleBinding objects can reference VCF SSO users and groups directly to integrate SSO identities with Kubernetes role-based access control. A user with the Namespaces.Edit privilege on a user-created Namespace folder can perform CRUD operations on Kubernetes API resources in the Supervisor. Namespace Self-Service permissions control which users can self-provision namespaces through kubectrl.

Kubernetes RBAC is the primary authorization mechanism within VKS, using Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings to bind permissions to users, groups, or service accounts. Kubernetes Attribute-Based Access Control (ABAC) is also available, defining access rights through policies that combine user, namespace, resource, and access mode attributes. Authorization webhooks can interpret field and label selectors to enforce fine-grained access control based on resource attributes such as node names and labels.

Service accounts provide namespaced workload identity within VKS clusters. For Windows containers, the Group Managed Service Account (gMSA) Webhook allows containers to run as Active Directory identities. VKS service accounts can be annotated with IAM role ARNs to enable pod identity and role assumption for cloud resource access through OIDC federation, replacing long-lived static credentials with short-lived, least-privileged credentials on demand. IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege.

Several supplementary services within the VKS layer extend the IAM surface. Harbor Registry, available as a standard package on VKS clusters, enforces role-based access control to manage access to container image artifacts. The Secret Store Supervisor Service enforces RBAC for administrators, DevOps engineers, and application tenants managing sensitive data. Argo CD supports both OIDC configuration for external identity providers and local account configuration with global RBAC policies that define role-based access through policy rules and group mappings. The Istio service mesh package includes a pluggable policy layer supporting access controls, rate limits, and quotas at the service-to-service level.

Programmatic access management is available through several APIs. The Identity API authenticates and manages the authorization provider. The Identity Service and Infrastructure as a Service APIs are used to acquire access tokens for REST API authentication. Principal Identity users authenticate using client certificates for service-to-service communications between VCF components.

NSX integrates with LDAP and external identity management services for administrative access to networking configuration. NSX Manager enforces role-based access control with roles such as auditor and network administrator assignable to LDAP users. vDefend, a separate product that extends NSX with security capabilities, offers an Identity Firewall that integrates with Active Directory for identity-based firewall rules.

VMware Private AI Services (PAIS) provides OIDC-based authentication and group-based authorization for AI workloads, the primary IAM mechanisms controlling access to model endpoints, the model runtime, Agent Builder, and Data Indexing and Retrieval capabilities. PAIS authentication is configured with an issuer URL, a client ID (pais-authentication-id), and the openid, groups, and offline_access scopes. The OIDC provider must support the .well-known/openid-configuration discovery endpoint. Authorization restricts access to user accounts that are members of named groups listed in the authorizedGroups setting (such as group-for-pais-access-01 or group-for-pais-access-02). A groups claim is included in the Access Token and a corresponding groups scope is created in the OIDC configuration, while the oidc-groups-claim setting selects which claim name carries group membership when the OIDC provider uses a non-default name. The oidc-extra-audiences setting accepts additional OAuth 2.0 client identifiers that PAIS will accept when validating Access Tokens, supporting integration with downstream clients that present their own audience. Activating PAIS in an organization namespace requires coordination with the OIDC provider administrator and an organization administrator account in VCF Automation.

Identity provider integration for PAIS deployments is configured at the Supervisor level under Workload Management > Supervisors > Configure > Identity Providers. When a PAIS region is created for a Supervisor, an identity provider entry is

automatically created in VMware vCenter for that Supervisor, linking the Supervisor namespace to the configured OIDC source.

The Model Gallery, the curated repository for ML models in PAIS, restricts access to model artifacts and the training data used to tune them through Harbor project access controls. These controls scope which users and service accounts can read, push, or manage sensitive model data, adding an IAM enforcement layer to the model supply chain. A Harbor registry is recommended for PAIS deployments, and OCI-compliant registries from other vendors are also supported.

PAIS Knowledge Bases extend IAM to ingested data sources. Confluence data sources authenticate with a user name and password or a personal access token, while Microsoft SharePoint On-Premises data sources authenticate with a user name and password. Personal access tokens for Knowledge Bases are generated from user account settings and used for programmatic access to linked data sources.

PAIS integrates with Grafana for metrics visualization using the same OIDC provider, extending the IAM model to the observability layer so that operators authenticate through the configured identity provider before accessing PAIS dashboards.

VMware vDefend (Contributes)

VMware vDefend contributes to identity and access management by providing identity-aware network enforcement through Identity Firewall, which integrates with Active Directory to apply firewall policy based on authenticated user identity rather than IP address alone. Identity Firewall supports assigning Active Directory users and groups as source criteria in both distributed firewall rules and gateway firewall rules, applying to tier-0 and tier-1 gateways. This allows organizations to enforce network access policy by user or group membership rather than relying solely on IP-based controls.

Within its management plane, the Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. These roles govern access to security policy management, analytics, incident response, and diagnostic functions across the platform. Network Detection and Response enforces the same five-role RBAC model for triage operations such as viewing detections and campaigns, and for configuration operations including SIEM integration management. For authentication, the Security Services Platform supports Active Directory and OpenLDAP as external identity sources, with one identity source configurable at a time. The License Hub integrates with external identity providers to store and manage user and group information for access delegation.

Centralized IAM for organizational users, including VCF SSO, MFA, and directory lifecycle management, is handled by VCF and falls outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) supports least privilege through role-based access control with a defined set of predefined roles and the ability to clone and customize roles for narrower operational scope. The 9.1 release consolidates Site Recovery Manager and vSphere Replication management under a single permissions model where PNR augments vCenter roles and permissions with additional permissions that allow detailed control over PNR-specific tasks and operations. PNR also verifies permissions on the remote vCenter instance as part of its access control validation, so privilege assignments are evaluated at both sites.

By default, PNR restricts login access to vCenter administrators; other users must be explicitly granted access by an administrator through the PNR interface. Users or user groups assigned a PNR role who are not vCenter administrators do not obtain vSphere Replication privileges, because PNR roles do not include the privileges of vSphere Replication roles. A user who is not a vCenter administrator but requires privileges to perform both PNR and vSphere Replication operations should be added to two user groups, one for each role type, to avoid granting vCenter administrator privileges.

vSphere Replication uses role-based access control with predefined roles that can be cloned and customized by adding or removing privileges based on organizational needs. PNR supports role propagation to child objects in the inventory hierarchy, allowing administrators to extend privileges from parent objects such as folders to all virtual machines within them, or to assign permissions at specific inventory levels without propagation when narrower scope is required. When permissions are assigned without propagation, users must have at least Read-only permission on all parent objects in the vCenter inventory.

PNR for VCF Automation access is controlled through role-based permissions assigned to Provider Administrators, Organization Administrators, Project Administrators, and Project Advanced Users, aligning RBAC with VCF Automation tenancy boundaries. Namespace unpair operations require Organization Administrator role authorization. In shared recovery site configurations, PNR restricts users from changing roles or assigning permissions for objects not dedicated to their own use, which helps prevent unauthorized privilege escalation across tenants, and the vCenter administrator manages PNR permissions so that each user has sufficient privileges to configure and use PNR but no user has access to resources belonging to other tenants.

PNR requires separate privilege assignment for testing a recovery plan and running a recovery plan, which helps prevent unintended changes at both sites that would require significant time and effort to reverse. PNR roles that allow users to run commands on PNR Server should be assigned to trusted administrator-level users only, and PNR server access should be limited to administrators to reduce the number of accounts available to an attacker. PNR administrators can assign `SrmAdministrator` or `SrmProtectionGroupsAdministrator` roles to the automatic protection user or user groups for managing automatic protection permissions.

For the 9.1 Clean Room Orchestrator, at least one user must be assigned the Organization Owner role to enable administrative access to all resources in the Organization, with additional roles available for narrower delegation. VCF Operations orchestrator workflows for PNR require administrator credentials to access and execute, which restricts non-administrative users from performing sensitive recovery operations through the orchestration interface.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) incorporates multiple identification and access management mechanisms that support organization-wide IAM controls within the data services layer.

DSM implements role-based access control with two defined roles: the DSM Admin role, which can create, monitor, and manage all data services in the environment, and the DSM User role, which is restricted to managing and monitoring data services within the namespaces to which the user has been granted access. These roles are assigned at user creation time and govern what each user can see and do within the DSM interface. The Permissions view in the DSM dashboard provides administrators with a centralized location for creating, monitoring, and managing all configured users.

DSM supports two identity sources, which can be used independently or together. Local users are created directly within DSM, with credentials validated by matching email address and password. LDAPS users are sourced from a configured LDAP identity provider, allowing organizations to extend their existing directory service into DSM. When LDAPS is configured, administrators can import users from the directory provider and assign them DSM Admin or DSM User roles. DSM also supports group-based access control: Directory Service Groups from the LDAP provider can be assigned roles directly, so group membership in the external directory determines access level in DSM without requiring per-user assignments.

At the database level, DSM extends authentication controls beyond the platform management layer. MySQL database instances support LDAPS authentication using Active Directory. PostgreSQL and other database instances support host-based authentication (HBA) rule configuration, which determines which clients are permitted to authenticate to a given database instance. SQL Server instances support Windows Authentication through Active Directory integration, enabling Kerberos-based authentication so that clients such as SQL Server Management Studio running on domain-joined machines can authenticate via single sign-on. SQL Server also uses contained database users, where identity information resides within the database itself rather than at the server level. Administrators can configure SQL Server instances with either a SQL User or Windows Principal as the primary administrator identity, with Windows Principal available for Active Directory-integrated clusters. An internal `dsm_mgmt` management login restricts users from accessing or modifying system-level objects, keeping administrative operations within an isolated context.

Namespace isolation adds a further access boundary. DSM namespaces enforce role-based access control that allows multiple users to work jointly on data services within a namespace while remaining isolated from data services in other namespaces. This supports least-privilege access within multi-tenant deployments.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer (Avi) provides a dedicated administrative identity and access management plane through the Avi Controller, supporting multiple authentication methods and fine-grained authorization controls that allow organizations to implement IAM policies across both the management plane and the application delivery layer.

For administrative access, the Avi Controller supports local user accounts, LDAP and LDAPS directory integration, SAML-based federated authentication (including integration with Workspace ONE Access for catalog-based application access), basic authentication, and OAuth/OIDC for API access. Auth Mapping Profiles allow organizations to map external directory groups to specific roles and tenants, so that group membership in an external identity provider directly controls what a user can access within Avi.

Authorization is handled through role-based access control (RBAC) with object-level granularity. Avi's extended granular RBAC uses markers, which are labels assigned to objects, to enable fine-grained authorization based on object ownership and classification. Permission categories cover Operations (including alerts, actions, and traffic capture) and Administration (including controller, tenant, user, role, and system configuration management). This allows restrictions so that a user's permissions apply only to the specific resources matching the markers assigned to their role. RBAC covers object categories including Virtual Services, Application Profiles, SSL/TLS Certificates, Certificate Management Profiles, Cloud definitions, TCP/UDP Profiles, Persistence Profiles, Health Monitors, Analytics Profiles, IP Address Groups, String Groups, SSL/TLS Profiles, PKI Profiles, and Authentication Profiles, with distinct read and write access levels configured per object type.

For multi-tenant deployments, Auth Mapping Profiles support tenant isolation with configurable user group to role mappings, allowing organizations to enforce separation between teams or business units operating within the same Avi Controller.

The Avi License Hub supports role-based access control through an external identity provider, with three predefined roles: Enterprise Admin (full access for all operations, including upgrades and authentication configuration), Auditor (view-only access for tracking activity without making changes), and Support Bundle Collector (restricted to collecting system logs and diagnostics). Management interface access is further controlled through restrictions on allowed ciphers and HMACs for management sessions.

For deployments involving the Avi Kubernetes Operator (AKO), Kubernetes RBAC policies can be applied to AKO Custom Resource Definitions (CRDs) to enforce stricter access control over routing configuration for specific user groups. The Avi Controller also implements RBAC at the Kubernetes and OpenShift cluster level by assigning tenants and roles to user accounts.

At the application layer, Avi can enforce client authentication using OAuth, SAML, JWT token validation, and mutual TLS with client certificates, extending access control to the traffic flowing through virtual services rather than only to the management interface.

Organizations are responsible for defining roles, mapping directory groups to permissions, establishing naming conventions for markers, and maintaining user lifecycle processes. Avi provides the technical mechanisms; the governance and operational processes for identity management must be organized by the teams managing the deployment.

Control 164.308(a)(3)(ii)(A)

> Implementation specifications: Authorization and/or supervision (Addressable). Implement procedures for the authorization and/or supervision of workforce members who work with electronic protected health information or in locations where it might be accessed.

SCF Controls: HRS-01, IAC-07.1, IAC-08, IAC-28.1

Aggregate Coverage: Meets

VCF (Meets)

VCF provides granular role-based access control (RBAC) mechanisms across VMware vCenter, VCF Automation, and VCF Operations that allow administrators to modify, revoke, and remove user access rights when personnel roles and duties change. Each component offers role management functions that support access adjustment in response to organizational changes.

In vCenter, roles are predefined sets of privileges that can be assigned to users or groups and associated with inventory objects. Only System Administrators can modify the rights in a predefined role. The AuthorizationManager includes a RemoveAuthorizationRole method that allows administrators to programmatically remove roles from the system, supporting automation of access revocation workflows when integrated with identity governance processes. Role assignments on vCenter objects can be modified or removed through both the UI and the API. The vCenter REST API also includes a dedicated Roles API with methods to list, create, update, and delete roles and to manage both global and local permissions.

The VMware Host Client provides role management at the VMware ESX host level, where editing a role's privileges automatically applies the changes to all users and groups assigned that role. Shell access for individual ESX users can also be deactivated, which prevents those users from granting shell access to other users or changing the passwords of users with existing shell access.

VCF Automation provides a layered role management model. System Administrators can create, edit, and delete global roles and publish or unpublish them across organizations. When a role is unpublished from an organization, it is removed from that organization and can no longer be assigned to users there. Organization users can use only those rights from their roles that are published to their organizations, so unpublishing a role or its associated rights immediately restricts what affected users can do. When the rights of a role are modified, the new set of rights is applied to all users assigned that role, allowing bulk access changes when duties shift across a team or department. Organization administrators can also create and edit organization-specific roles that are local to their organizations, providing fine-grained control at the organizational level. Roles assigned to users imported into VCF Automation can be edited at any time to adjust access control as needed.

VCF Automation supports disabling individual user accounts without removing the user from the organization. A deactivated user cannot log in, but the account remains available for reactivation if the person moves to a new role that requires access. Provider users can also be deactivated through the Access Control interface, after which the user cannot log in to VCF Automation. System administrators can revoke access tokens of users through the Administration access control settings, manage service account attributes, revoke previously granted access, and delete service accounts when access is no longer needed. The accessControls API enables programmatic modification and removal of specific ACLs.

For more granular control, VCF Automation supports defined entity access control with View (read-only), Edit (create, view, modify), and Full Control (create, view, modify, delete) permission levels that can be assigned to specific user roles. These defined entity rights work only in combination with an ACL entry, providing layered access restriction.

VCF Operations supports role management operations including editing, deleting, cloning, and exporting user roles. Administrators can create custom roles in addition to predefined roles, and each role's permissions can be modified through the Role Information page using a role tree with selectable permissions. Imported user groups can be edited to reassign Roles and Scopes, which supports adjusting access for groups of users when organizational changes occur. User accounts in VCF Operations can be disabled by selecting a check box to deactivate the user. The administrators role should be assigned only to specific users who must access objects and perform actions across the entire environment.

When VCF is federated with an enterprise identity provider or directory service, changes to group memberships in the directory are reflected in VCF access. LDAP-based directory services such as Active Directory are supported for identity management. VCF Automation supports importing provider groups from LDAP, SAML, or OIDC identity providers. Removing a user from a directory group that maps to a VCF role effectively revokes that access without requiring manual intervention in VCF itself.

The VCF Consumption layer, which covers VMware Kubernetes Service (VKS) clusters and vSphere namespaces, extends these access control mechanisms into the Kubernetes workload plane. Each vSphere Namespace has role-based access control configured to govern user and service account permissions. VKS clusters use the Kubernetes RBAC model, where Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings define what actions identities can perform against Kubernetes API resources. Access follows a defined role hierarchy: DevOps and Platform Operator roles are assigned as non-admin or custom roles scoped to ServiceProviderUsers and authenticated through VCF SSO or Active Directory, while developer roles are scoped to read-only or no access. When personnel duties change, an administrator removes or modifies the relevant RoleBinding; changes take effect immediately upon the next API request. The Kubernetes RBAC API enforces an immutable roleRef field on RoleBindings and ClusterRoleBindings after creation, so changing the role that a binding references requires deleting and recreating the binding object, making the full set of subjects and their intended permissions explicit during each change. Users should not be added to the system:masters group, because members bypass all RBAC checks and gain unrestricted superuser access that cannot be revoked by removing RoleBindings. IAM role trust policies for service accounts should be scoped to specific service accounts and namespaces to enforce least privilege. Among Supervisor Services, Harbor Registry enforces role-based access control over access to container artifacts, the Secret Store Service uses RBAC to separate administrator, DevOps engineer, and application tenant permissions, and Argo CD implements RBAC through policy rules and group mappings with Casbin syntax that allow role assignments to be updated when job duties change within a GitOps workflow.

VCF contributes the technical mechanisms for adjusting and revoking access rights across all of its components, including the Consumption layer. The organizational process of detecting when role and duty changes occur, determining which access rights are no longer necessary, and initiating the appropriate access modifications remains outside VCF's scope. Organizations should integrate VCF's role management capabilities with their identity governance and human resources processes to trigger timely access reviews and revocations when personnel transitions occur.

VMware vDefend (Contributes)

VMware vDefend contributes narrowly to this control by supporting role-based access control within its own management plane, where administrators can update or remove role assignments for Security Services Platform users when personnel roles change. The Security Services Platform (SSP) implements five defined roles with differentiated permissions: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Security Intelligence, a component within SSP, applies the same five-role model. Accessing User Management to modify or revoke role assignments requires Enterprise Admin privileges.

SSP role assignments can be applied to individual remote users or to remote user groups through mapping to groups in external identity providers, including Active Directory and LDAP-based directories. When organizational group membership is updated to reflect a personnel role change, the change propagates to vDefend access controls through the group mapping. The Enterprise Admin role holds full access to configure authentication and authorization, making it the role responsible for executing access revocation within the vDefend management plane.

Broader organizational access revocation following role changes across VCF, VMware vCenter, and other systems is handled through VCF SSO and enterprise identity lifecycle processes, which are outside vDefend's scope.

VCF Protection and Recovery (Contributes)

Protection and Recovery (PNR) implements role-based access control through purpose-built roles registered in VMware vCenter and through a multi-tenant administrative model for Protection and Recovery for VCF Automation. The SRM Administrator role allows users or user groups to perform all PNR configuration and administration operations. The Protection and Recovery Administrator role can be assigned to user groups to manage permissions. Default roles provide the privileges

users require to manage protection groups and perform recoveries, while restricting access to resources belonging to other users.

For automatic protection of virtual machines within a protection group, administrators assign either the SrmAdministrator or SrmProtectionGroupsAdministrator role to the automatic protection user or user group. This scopes the protection actions performed on the user's behalf to the privileges of the assigned role.

Each role is a collection of privileges that defines the actions a user can perform on the protection and recovery site. A user can have at most one role on an object, but roles combine when the user belongs to multiple groups that all have roles on the object. PNR supports propagating roles to child objects in the inventory hierarchy, so administrators can extend privileges from parent objects such as folders to all virtual machines within them.

Protection and Recovery for VCF Automation introduces a multi-tenant role model with Provider Administrator, Organization Administrator, Project Administrator, and Project Advanced User. Each role has specific authorization levels for disaster recovery operations. Provider Administrators select which replication classes each Organization can use, restricting organizational access to specific recovery configurations. Organization Administrators manage the pairing of namespaces and assignment of replication classes within their tenancy.

Underlying directory services, authentication, and enterprise identity governance are provided by VCF SSO and the broader VCF platform. PNR consumes those identities and layers its protection and recovery roles on top of them.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) supports revocation of user access through its user management interface, enabling administrators to remove or modify access rights when personnel roles change. The platform's RBAC model defines two role types: the DSM Administrator, a super-user with full access to all data services in the environment, and the DSM User, whose scope is limited to viewing and managing only the data service deployments they own.

For local user accounts, DSM administrators can edit role assignments and namespace access for existing users, or delete users entirely through the user management interface. Deleting a user from DSM revokes their access to the system. The deletion workflow requires the administrator to first reset the departing user's password to block continued access, and then transfer ownership of their databases to another user before the account is removed. As an alternative to deletion, administrators can reset the user password and delegate management of the databases to a different user, which blocks access while keeping the databases running. This sequence addresses the continuity of managed database resources when a user's role changes or they leave the team.

For directory service (LDAP) integrations, DSM supports group-based access control by mapping LDAP groups to DSM roles. Administrators can change the role assignment for an LDAP group or delete the group mapping, which affects all users in that group. When a user's organizational role changes in the directory, adjusting or removing the corresponding DSM group mapping controls their access to DSM resources.

The DSM UI enforces role scope at the interface level: views and available actions differ based on the assigned role, so a user whose role is modified sees a reduced set of capabilities and resources immediately. Administrator-managed tasks include changing database ownership, which is relevant when a user moves to a different team and their provisioned databases need to transfer to a new owner.

At the database-engine level, DSM also revokes create and update privileges on objects in the MySQL system schema for database users, including the default database user. This constrains what database-level actions a user can perform independent of their DSM platform role assignment.

Because DSM supports two fixed roles and does not provide workflow automation for access review tied to HR systems, organizations must establish their own processes to detect and act on personnel role changes in a timely manner. The actual decision to revoke or modify a user's DSM access depends on organizational HR and access review procedures that are outside the platform's scope.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer provides mechanisms to manage user access rights through its built-in role-based access control (RBAC) system. When a user's organizational role changes, administrators can reassign or remove role assignments directly through the Controller's Administration console (Administration > Accounts > Roles), through the CLI using the `configure role` command, or through the REST API. Avi supports both predefined system roles and custom roles, each scoping permissions to specific resources with write, read, or no access. Role changes take effect immediately, restricting the user's access to what the newly assigned role permits.

For environments that integrate Avi with an external identity provider, Auth Mapping Profiles map directory group memberships to specific Avi roles and tenants. When a user is moved to a different group in the upstream LDAP, SAML, or OAuth directory, the matching rules in the Auth Mapping Profile determine the corresponding access level on the user's next authentication. Auth Mapping rules can also be updated to deny privileges to specific users entirely, preventing them from obtaining any roles or tenants upon login. This makes it practical to align access changes in Avi with identity governance processes managed in the directory.

For fine-grained delegation, the Extended Granular RBAC feature allows administrators to scope access at the per-object level using labels and the `allow_unlabelled_access` parameter in the role definition. The CLI `configure role` command supports setting specific sub-resource permissions, enabling least-privilege assignments when reassigning users to narrower roles after a position change. Some permissions classified under Operations and Administration are not supported for per-application label-based RBAC, which is a documented limitation to consider when designing role structures.

Avi GSLB deployments support creation of non-admin users with assigned roles, extending granular access control to global server load balancing administration. In Avi for VCF deployments using organization-managed mode, a provider administrator can manage service engine group assignments and adjust organization resource limits.

The organizational process that determines when a personnel change requires an access update in Avi or in the upstream directory remains outside the product. Administrators must periodically review role assignments and respond to HR-driven change notifications, or configure the upstream directory to reflect role changes so that Auth Mapping Profile rules propagate them to Avi access levels automatically.

Control 164.308(a)(3)(ii)(B)

> Implementation specifications: Workforce clearance procedure (Addressable). Implement procedures to determine that the access of a workforce member to electronic protected health information is appropriate.

SCF Controls: HRS-02, HRS-03, IAC-17

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support periodic review of account privileges, though the organizational process of scheduling and conducting those reviews remains a customer responsibility.

VCF's role-based access control model structures privileges as fine-grained access controls that can be grouped into roles and mapped to users or groups. This model applies across VCF components including VMware vCenter, NSX, VCF Automation, and Avi Load Balancer. Administrators can define custom roles containing only the minimum set of required privileges, and VCF documentation recommends that user accounts be given the minimal number of privileges on the system that they require to do their jobs. This least-privilege foundation makes periodic reviews more tractable by providing well-defined privilege boundaries to evaluate against. For VMware ESX hosts specifically, vSphere documentation recommends creating individual accounts for administrative access rather than shared accounts, which provides the per-account audit traceability needed to conduct meaningful privilege reviews at the host level.

VCF Operations generates User Permissions Audit reports that provide traceability of user accounts, their roles, access groups, and access privileges. These reports give reviewers a consolidated view of who has access to what across the environment, directly supporting the periodic review process. VCF Operations Access Control also maintains audit records of the last person to update a user account and the last time the user account was updated, which helps reviewers identify stale accounts or recently changed privilege assignments that warrant closer inspection. System administrators can change account attributes, revoke previously granted access, and delete accounts when reviews determine that privileges are no longer needed.

For deeper analysis of privilege usage, vCenter includes a Privilege Checks Recorder feature that monitors and records the privileges checked during vCenter operations. Administrators can retrieve recorded privilege checks through the vCenter Management API, filtering results by managed object IDs, request operation IDs, privilege names, sessions, and user or group identities. This data allows reviewers to compare assigned privileges against actually exercised privileges, identifying cases where accounts hold more access than they use. The PrivilegeChecks service interface provides operations for retrieving the latest privilege checks along with corresponding sessions, users, managed objects, and operation IDs. The recorded privilege check data can also be used to create scripts that automatically build roles with the minimum privileges required for specific workflows, helping enforce least-privilege assignments as an outcome of periodic reviews. Note that the Privilege Checks Recorder is available only through the API and supports scripted workflows; it does not provide a graphical interface, so organizations should plan for scripted or automated retrieval of privilege check data when incorporating this capability into review processes.

For service accounts specifically, VCF Automation allows system administrators to manage service account attributes, revoke previously granted access, and delete service accounts entirely. Service account creation requires specific administrative privileges (View Service Accounts and Manage Service Accounts), restricting who can provision these accounts. Service accounts are granted access using the Request Service Account Authorization process, which restricts token access so that only the authorized application can use it. During platform upgrades, VCF automatically deletes old service account privileges and replaces them with predefined privileges, providing a form of automated privilege realignment.

The Consumption layer of VCF, which encompasses VMware Kubernetes Service (VKS), vSphere Supervisor, and VCF Services, extends the privilege review surface to Kubernetes workloads. Kubernetes RBAC structures permissions through Roles and ClusterRoles that define discrete permission sets, and RoleBindings and ClusterRoleBindings that attach those permissions to users, groups, and ServiceAccounts. This declarative model allows cluster administrators to enumerate all privilege assignments at any point in time using standard Kubernetes API tools such as `kubectl auth can-i`, `kubectl get`

rolebindings, and `kubectl get clusterrolebindings`. Kubernetes documentation specifically recommends periodically reviewing RBAC settings for redundant entries and possible privilege escalation paths, and recommends that cluster administrators avoid using cluster-admin accounts except where specifically required, instead using low-privileged accounts for routine operations and reserving broader access for break-glass emergency scenarios. VKS cluster security guidance calls for scoping IAM role trust policies to specific service accounts and namespaces to enforce least privilege at the workload level.

For Kubernetes service accounts, Kubernetes separates `ServiceAccount` objects from human user identities, and VCF Consumption documentation notes that auditing considerations for humans and service accounts may differ; this separation makes it easier to apply differentiated audit strategies and to review workload permissions independently of human access reviews. Each in-cluster service should be configured with a dedicated `ServiceAccount` with only the permissions required for its function, and granting cluster-wide roles to all service accounts should be avoided in favor of per-namespace `RoleBindings`. The `LegacyServiceAccountTokenCleanup` feature gate enables automatic cleanup of Secret-based service account tokens that are not used within a configurable period (with a default retention of one year), reducing the risk of stale service account credentials persisting beyond their useful lifetime. Kubernetes audit logging records API server interactions including RBAC-related operations, and organizations can configure the Kubernetes audit policy to capture reads and modifications of `Role`, `ClusterRole`, `RoleBinding`, and `ClusterRoleBinding` resources, supporting an audit trail for privilege changes between review cycles.

The vSphere Supervisor adds platform-level privilege gates that are subject to periodic review. The `Manage Supervisor Services` privilege is required to delete or deactivate a Supervisor Service, and the `SupervisorServices.Install` privilege is required to install, upgrade, or uninstall service instances on the Supervisor; these privileges are managed through VCF SSO and vCenter RBAC, which integrates with Supervisor namespace permissions. VCF Services consumed through the Tenant Portal and Content Hub can surface RBAC controls through Argo CD, where RBAC policy rules control account permissions including the ability to grant admin roles to specific local accounts and assign accounts to role groups through group mappings, supporting review of GitOps-layer access assignments.

VCF Automation also supports an access request approval workflow where access requests require approval before granting OAuth token access. This provides a checkpoint for new privilege grants that complements periodic reviews of existing privileges.

NSX Manager audits any user account change, providing an audit trail that reviewers can use to track privilege modifications over time and verify that changes follow approved processes.

VCF does not include automated recertification workflows or scheduled access review campaigns. Organizations should use external identity governance tools for the scheduling and tracking aspects of periodic privilege reviews, using the audit and reporting data that VCF and its Consumption layer provide as input to those reviews.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) supports periodic review of user privileges within its own management plane by providing an admin interface where role assignments for both local and directory-managed accounts can be reviewed and updated. In 9.1, SSP implements role-based access control with three defined roles: Enterprise Admin, Auditor, and Support Bundle Collector. The Enterprise Admin role grants full access to all platform operations, including User Management, while the Auditor role is scoped to read-only access, allowing holders to view information and track activity without the ability to make changes. The predefined local Auditor account provides API and service access for auditing purposes rather than administrative control. Access to User Management and modification of role assignments requires Admin privileges; administrators can review and adjust which accounts hold each role through the SSP interface. When removing an identity source from SSP, all associated user role assignments must first be deleted, which provides a built-in enforcement point for confirming that access has been cleaned up before the identity source is removed. vDefend's contribution is limited to privilege review within its own management interfaces; periodic review of privileges across the broader organizational environment, including service accounts and other systems, requires organizational governance processes outside vDefend's scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to periodic privilege review through its role-based access model, defined database-level privilege baselines, and audit logging capabilities, though the periodic review process itself is an organizational responsibility.

DSM organizes administrative access through two distinct roles: the DSM Admin role and the DSM User role. The Admin role carries broader capabilities across the environment, while the DSM User role is scoped to the user's own objects within their namespace. This role separation allows administrators to identify which users hold elevated access by reviewing the DSM user list and confirming that role assignments remain appropriate. Deleting a user in DSM revokes their access to the system. When access must be suspended while keeping databases running, administrators can reset the user password and delegate database management to a different account instead.

DSM maintains service account rotation logs that can be checked to verify service account management activities, including those for vCenter authentication. Service account expiry triggers an alert, supporting investigations into whether continued access remains needed.

For database-level privilege management, DSM defines and enforces a documented privilege baseline across its supported database engines. The default MySQL database user is not a superuser; DSM grants specific data and schema operation privileges while explicitly revoking create and update privileges on the mysql.system schema. MySQL users authenticated through LDAPS can be granted specific privileges using the GRANT command to restrict access to designated databases. For PostgreSQL, host-based authentication requires database administrators to grant specific privileges to LDAPS users. For SQL Server clusters, DSM restricts the cluster administrator login to read-only privileges and specific ALTER permissions for server management and auditing rather than full administrative access. DSM also deactivates the default sa account and uses a reserved internal management account for its own operations, reducing the number of high-privilege accounts requiring review.

DSM adds configurable audit logging for SQL Server clusters. Administrators can select the level of audit logging for system logins and set the log retention period. Preset server audit configurations support login tracking, providing a record of login activity that can inform periodic access reviews.

To satisfy the full requirements of this control, organizations must establish a periodic review process that formally schedules reviews, documents approvals, and records privilege changes. DSM does not automate the review cycle or generate access certification reports, so an access governance program or external identity management tool is needed to drive the review cadence and produce the evidence that auditors typically require.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides a role-based access control (RBAC) framework within the Avi Controller that gives administrators the mechanisms to view, assign, modify, and revoke account privileges for all users and service accounts across all tenants. Access to account management functions is governed by the Accounts section write privilege: any administrator holding that privilege can reactivate or deactivate other user accounts, modify role assignments, and adjust tenant scoping.

Avi enforces RBAC through Tenant and Role assignment, restricting each user account to specific areas of the system at account creation. Accounts can be scoped to specific tenants and granted different roles within each tenant, supporting the granular privilege model needed for periodic access reviews. The system ships with predefined roles. A Super User privilege level grants the same privileges as the admin account and is selectable via a checkbox during user account creation. Administrators can also create custom user account profiles with configurable security thresholds covering password history, login failure behavior, session limits, and credential timeout policies. Write privilege at the Controller level grants full access to create, read, modify, and delete resources, while more narrowly scoped roles can be assigned per tenant.

For CLI access, the admin account is the standard administrative account and is maintained as a locally authenticated account even in systems configured for remote authentication. Non-admin users access the Avi Load Balancer Linux CLI through an SSH client under distinct privilege boundaries, providing separation between elevated shell access and read-only log inspection.

For service account and API access patterns, the Avi Controller supports temporary token authentication. A system administrator can issue a token with a defined expiration time (the token-expiration setting), after which the token automatically expires without requiring explicit revocation. This bounds the duration of any granted service account access and reduces exposure from stale credentials. In VCF-integrated deployments, Avi manages two user accounts for password updates, admin and vcfops-admin, and the Controller provides a REST API endpoint for service account password rotation via POST to the reverse-proxy/password-update endpoint, requiring the username, old password, and new password. For Avi SaaS Controller deployments, authorization tokens can be generated to enable service account authentication.

The admin user is authorized and responsible for the highest-level configuration operations, including user creation and authorization. Administrators can suspend and reactivate accounts as needed. The periodic cadence of privilege reviews, the criteria for determining whether a privilege remains necessary, and the organizational decision to reassign or remove access are processes that Avi's account management tooling supports but does not schedule or automate.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 164.308(a)(3)(ii)(C)

> Implementation specifications: Termination procedures (Addressable). Implement procedures for terminating access to electronic protected health information when the employment of, or other arrangement with, a workforce member ends or as required by determinations made as specified in paragraph (a)(3)(ii)(B) of this section.

SCF Controls: HRS-08, HRS-09, IAC-07, IAC-07.2

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support formal user registration and de-registration processes, though the organizational policies, approval workflows, and periodic entitlement reviews that govern these processes must be established separately.

VCF SSO is the centralized authentication and identity service, supporting multiple user provisioning methods. Organizations can choose between Just-In-Time (JIT) provisioning, where user accounts are dynamically created upon first login from a configured identity provider, and Groups Pre-provisioning, where users and groups are synchronized from a directory source in advance. JIT provisioning requires no additional configuration beyond the identity provider setup, and can also handle group membership with options for either pre-provisioned groups or just-in-time group creation. For directory-based provisioning, VCF supports syncing users directly from groups, including nested group synchronization that imports all users from a selected group and its child groups. Active Directory or LDAP integration provisions users and groups from the enterprise directory. VMware vCenter Identity Provider Federation also supports external OIDC providers, including Okta and PingFederate. When configured with PingFederate, the integration requires a SCIM 2 application and supports User Create, User Update, and User Disable/Delete operations by default, providing a direct mapping to the provisioning and de-provisioning lifecycle this control describes. After initial identity provider configuration, administrators log in to each component with the local admin account and assign the necessary service roles to provisioned users and groups. This two-step process, where accounts are first provisioned through VCF SSO and then granted specific roles, enforces a structured approach to access rights assignment.

VCF Operations provides centralized management of identity provider configuration and user and group provisioning across VCF instances. It supports importing user accounts from external authorization sources such as LDAP databases or SSO servers through the Access Control interface. Imported users and groups receive role-based access control permissions that govern what objects and interface areas they can access. Access groups define granular rights including the ability to add, edit, or delete dashboards, or to view, configure, or manage objects. User groups can be created manually, imported from a single sign-on server, or imported from an LDAP database. VCF Operations user accounts can also be disabled through the Access Control interface to deactivate a user.

VCF Automation includes an Access Control service that supports identity operations for managing groups and users. System Administrators can create other system administrator and user accounts in the provider organization. Organization Administrators can view role rights or create roles local to their organization. VCF Automation supports cloning of rights bundles and global roles, with the ability to modify selected rights for the cloned role. This allows administrators to build custom access configurations tailored to specific provisioning requirements. User accounts in VCF Automation can have their name, password, and role assignments edited through the Access Control interface. Provider administrators can create projects, assign users and groups, and allocate quotas to restrict available configurations. When OIDC is configured as the identity provider, imported users authenticate with the credentials established in the external identity provider.

For de-provisioning, VCF provides several mechanisms across its components. VCF Automation supports explicit user account deactivation: disabling a user does not remove them from the organization, allowing reactivation if needed later. Before a user can be deleted in VCF Automation, their access must be disabled first, enforcing a controlled removal process. VCF Operations user accounts can similarly be disabled through the Access Control interface. When the identity provider configuration is reset or deregistered in VCF SSO, the provisioned users and groups are removed, and service roles must be reassigned after reconfiguration. Deregistering VCF SSO from VCF Operations or VCF Automation deactivates the previous authentication source and deletes the provisioned users and groups.

In NSX, user accounts must be created and activated before any role assignments can be made. VCF Operations for Networks supports local user management with role-based access control, where users are assigned roles during account creation.

At the Consumption layer, VMware Kubernetes Service (VKS) clusters within vSphere Supervisor enforce a Kubernetes-native access control model that ties permission assignment to explicitly defined RBAC objects and an authoritative identity source. DevOps users and groups to whom Kubernetes permissions are assigned must exist in the configured identity source integrated with VCF SSO, so that removing a user from the identity source revokes their ability to authenticate to VKS clusters. VKS cluster provisioning requires that cluster users and roles be defined as part of the cluster lifecycle, establishing a registration step before access rights can be granted. Access rights are assigned by creating RoleBindings or ClusterRoleBindings that associate a Role or ClusterRole with a specific user or group identity. These bindings name specific identity source principals and can be audited against the identity source to detect orphaned bindings where the referenced identity has been removed but the binding remains. Kubernetes documentation requires that user account creation prevent reuse of deleted user names, so that a newly provisioned account with the same name does not silently inherit the RoleBindings of its predecessor. VKS separates ServiceAccounts used by workloads from human user accounts, allowing different provisioning and de-provisioning procedures to be applied to each class of identity. IAM role trust policies for service accounts should be scoped to specific service accounts and namespaces to enforce least privilege at the workload level. For administrators, the Kubernetes documentation recommends creating a least-privilege kubeconfig for routine work and reserving elevated permissions for break-glass access only.

The Argo CD Supervisor Service, when deployed, enforces its own RBAC layer through policy rules and group mappings. Local accounts can be defined in the localAccounts configuration and granted roles through RBAC policy rules and group assignments. Argo CD also supports OIDC authentication with global RBAC policies for federated identity scenarios. Cluster registration for Argo CD creates ClusterRole and ClusterRoleBinding objects that explicitly associate service account identities with their permitted cluster-wide scope. The Secret Store Supervisor Service similarly enforces RBAC for administrators, DevOps engineers, and application tenants, maintaining role-based separation within the Supervisor Services layer.

Across all components, VCF enforces a privilege model where fine-grained access controls are grouped into roles, which are then mapped to users or groups. Each VCF component, including VMware vCenter, VCF Operations, and VCF Automation, enforces permissions based on assigned roles, so provisioning a user account is distinct from granting specific access rights. Administrative operations in VCF Operations require a user with the ADMIN role, maintaining role-based separation.

VCF contributes the technical enforcement layer for user provisioning and de-provisioning. The formal registration process, approval workflows, and periodic entitlement reviews that this control requires are organizational responsibilities outside VCF's scope.

VMware Private AI Services (PAIS) integrates with an external OIDC provider for user authentication, configured through the PAIS activation process on an organization namespace with the issuer URL, client ID, and OIDC scopes. Identity and access management for PAIS is set up in coordination with the OIDC provider administrator, making the external OIDC directory the authoritative source of user identities for PAIS. The oidc-authorized-groups, oidc-groups-claim, and oidc-extra-audiences settings on the organization namespace configure which OIDC groups are accepted, which claim carries group membership, and which additional OAuth 2.0 audiences PAIS will accept when validating the Access Token.

Access to PAIS is gated on OIDC group membership through the authorizedGroups configuration. Only user accounts that belong to one or more of the specified authorized groups (such as group-for-pais-access-01 or group-for-pais-access-02) can access the service. The OIDC configuration includes a groups scope that surfaces group membership in the Access Token, so PAIS enforces the authorization decision at service access time based on current group membership in the external directory. Removing a user from an authorized OIDC group at the provider revokes that user's access to PAIS at the next token issuance.

Within the PAIS platform, organization administrators control which users can perform privileged operations. An organization administrator account is required to activate PAIS in an organization namespace in VCF Automation. A user must be added to a project and namespace in the VCF Automation All Apps organization before that user can provision GPU-accelerated VMware Kubernetes Service (VKS) clusters or request Deep Learning VM and AI catalog items. Catalog item visibility in VCF

Automation is scoped to project membership, restricting which users can request AI workloads from the Private AI Services Quickstart blueprints.

For the model gallery and image registry, a Harbor robot account is created for the project allocated to the model gallery, providing a non-interactive credential that is separate from end-user identities and can be rotated or removed independently. Personal access tokens generated from a user's account settings provide programmatic access to PAIS Knowledge Bases and linked data sources, allowing tokens to be issued, scoped, and revoked separately from the user's interactive sessions.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) 9.1 provides structured user provisioning and de-provisioning capabilities that support a formal access rights lifecycle for both local accounts and directory-integrated users.

User accounts in DSM are managed through two identity sources: local users created and managed within the DSM platform itself, and LDAP/LDAPS users authenticated through an enterprise directory service such as Active Directory. DSM can be configured to use one or both identity sources independently. The first local user account is the DSM administrator, created during deployment of the DSM Provider Appliance. That account is mandatory and cannot be deleted. All subsequent local user creation requires administrator credentials, meaning only authorized personnel can add new accounts to the system.

When provisioning a local user, an administrator must specify the user's role, email address, and password through the DSM user creation workflow, accessible in the vSphere Client or the DSM UI. DSM's two built-in roles define the access scope: the Administrator role manages the platform, namespaces, and other users, while the User role creates and maintains individual databases. Namespace access is assigned at user creation. Administrators can modify both role assignments and namespace access for existing local users through the user management interface. Administrators can delete local user accounts when removal is the appropriate de-provisioning action. Alternatively, to prohibit a user's access to DSM while keeping databases running, an administrator can reset the user's password and delegate database management to a different user.

For directory-integrated environments, DSM supports LDAPS authentication and allows assignment of roles to Directory Service Groups, enabling group-based access control for LDAP users. When a user's directory group membership changes, their effective access within DSM reflects the group role assignment.

For SQL Server databases provisioned within VCF Automation, DSM data service policies define the allowed user types for databases created under the policy. Administrators can configure policies to permit Windows Principal authentication using Active Directory credentials, SQL User authentication using standard SQL Server login credentials, or both. For automated Active Directory integration, DSM requires a privileged Active Directory account with permissions to write service principal names (SPNs) and perform dynamic DNS updates. SQL Server databases map the dbo user, the database object owner, to administrator-controlled identities.

The Permissions view in the DSM dashboard provides a consolidated interface for creating, monitoring, and managing all configured user accounts and directory service groups. Because user login precedence between local and LDAPS accounts must be managed deliberately to avoid authentication conflicts, organizations should establish clear provisioning procedures that address the ordering and priority rules DSM applies.

DSM's mechanisms support the technical registration and de-registration workflow but do not themselves constitute a formal process. The control's requirement for governance-level procedures governing access rights assignment extends to organizational approval workflows, access review cycles, and documented registration practices that operate outside the platform. Organizations must establish these processes independently, using DSM's user management capabilities as the technical enforcement layer.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) includes a native user management system accessible through Administration > Accounts > Users on the Avi Controller. Administrators can create local user accounts, assign each account a specific role and tenant scope, and remove accounts when access is no longer required. Each user account stores role and tenant assignments directly, supporting granular scoping of permissions per deployment.

Avi's RBAC model supports both local user accounts validated against an internal database and remote authentication through LDAP or SAML. Auth Mapping Profiles extend the RBAC model by binding external directory group membership to specific Avi roles and tenants at login time. When a user's group membership changes in the directory, the Auth Mapping Profile applies the updated role and tenant assignments on the next login, without requiring manual changes inside Avi. Multiple Auth Mapping Profile rules can be configured so that a single user's LDAP or SAML group memberships determine distinct roles across multiple tenants simultaneously. SAML integration with Microsoft Active Directory Federation Services (ADFS) is also supported, with configurable issuance authorization rules that control which users may access the relying party.

Avi Controller allows creation of custom roles according to specific access requirements when predefined roles do not fit an account's needs. The Tenant-Admin role can be scoped so that tenant administrators can create, update, and delete cloud infrastructure within their tenant boundary without affecting other tenants. Avi GSLB extends user provisioning to global load balancing by supporting the creation of non-admin users with assigned roles for granular access control across GSLB deployments. The Avi License Hub also supports role-based access control by assigning roles to individual users or groups defined in an external identity provider.

User accounts are attached by default to the Default-User-Account-Profile, and administrators can create new user account profiles with different concurrent session thresholds to meet organizational security requirements.

Organizations should establish and document formal procedures for user registration, access approval, and de-registration to govern how and when accounts are created or removed in Avi. The technical mechanisms Avi provides, including account creation and deletion, role assignment, and directory integration via Auth Mapping Profiles, support a formal lifecycle process but do not replace the organizational procedures the control requires.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.308(a)(4)(i)

> Standard: Information access management. Implement policies and procedures for authorizing access to electronic protected health information that are consistent with the applicable requirements of subpart E of this part.

SCF Controls: GOV-02, IAC-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a layered identity and access management architecture spanning centralized identity services, role-based access control, group-based access policies, identity provider federation, and programmatic access management through APIs.

VCF SSO is the centralized authentication service. VCF SSO issues security tokens that grant authenticated users access to VMware vCenter, NSX Manager, VCF Operations, and other platform components without requiring separate credentials for each service. VCF Operations supports importing users and groups from VCF SSO for consistent identity management across the stack. VMware Identity Manager provides a platform for managing users and groups, managing resources and user authentication, and configuring access policies and resource entitlements. vCenter also supports built-in identity source authentication using local domain credentials. The built-in identity provider can also be configured to use Active Directory as an identity source through LDAP/S, OpenLDAP/S, or Integrated Windows Authentication (IWA), depending on the directory environment.

VCF supports federation with enterprise identity providers. vCenter can be federated to providers such as Microsoft Entra ID, ADFS, and Okta, which enables multifactor authentication and automatic user synchronization with the organization's directory. PingFederate is also supported as a federated identity provider; for these integrations, vCenter uses System for Cross-domain Identity Management (SCIM) to automate the exchange of user and group identity information between the external identity domain and vCenter. VMware Identity Broker allows principals to authenticate to vCenter through an external identity provider. NSX Manager can be configured to authenticate users from identity management providers and can be integrated with Workspace ONE Access for identity management services. The Supervisor component supports registration of OIDC-compliant external identity providers for authentication to VMware Kubernetes Service (VKS) clusters; supported providers include Okta, Workspace ONE Access, and Dex, configured by supplying the Supervisor callback URL to the identity provider.

Role-based access control is enforced across all VCF components. In vCenter, permissions associate a user or group with a role on a specific inventory object, and predefined roles cover common administrative functions. Custom roles can be created with only the minimum required privileges for a given workflow. Managing identity provider configuration in vCenter requires the VcIdentityProviders Manage privilege. VCF Operations supports group-based access control, allowing administrators to configure groups and assign roles that control access to dashboards, reports, policies, alerts, and administration functions, as well as granular role-based controls for platform operations including approvals, audits, certificates, and content libraries.

VCF Automation extends access management through organization-level and project-level controls. The VCF Automation Access Control service supports identity operations for managing groups and users, including editing user names, passwords, and role assignments. The organization portal enforces role-based access control, requiring either Organization Administrator or Organization Auditor roles to manage policy templates. Organization administrators can distribute infrastructure and configure group-level access through the organization management functionality. Project access is governed by predefined roles. Users and groups can be disabled at the organization level to revoke access without deleting accounts. The System Administrator role has the right to manage and view Access Control Lists, and the accessControls API allows administrators to view and manage ACL entries for defined entities.

For Kubernetes workloads within the VCF consumption layer, VKS supports two authentication methods: VCF SSO and OIDC-compliant external identity providers. The OIDC path is implemented through Pinniped and supports providers including Okta, Workspace ONE Access, Dex, GitLab, and Google OAuth. Configuring an external provider requires setting up an OpenID Connect ID Token with a Groups claim type filter to enable group-based access control tied to the organization's directory.

Custom ClusterClass configurations allow clusters to authenticate developers using existing corporate identity systems. VKS supports namespace permission roles: Owner (full control including deletion), Can Edit (provisioning and operating workloads), and Can View (read-only access). These roles map to Kubernetes ClusterRoles through RoleBindings, and RoleBinding objects can reference VCF SSO users and groups directly to integrate SSO identities with Kubernetes role-based access control. A user with the Namespaces.Edit privilege on a user-created Namespace folder can perform CRUD operations on Kubernetes API resources in the Supervisor. Namespace Self-Service permissions control which users can self-provision namespaces through kubectl.

Kubernetes RBAC is the primary authorization mechanism within VKS, using Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings to bind permissions to users, groups, or service accounts. Kubernetes Attribute-Based Access Control (ABAC) is also available, defining access rights through policies that combine user, namespace, resource, and access mode attributes. Authorization webhooks can interpret field and label selectors to enforce fine-grained access control based on resource attributes such as node names and labels.

Service accounts provide namespaced workload identity within VKS clusters. For Windows containers, the Group Managed Service Account (gMSA) Webhook allows containers to run as Active Directory identities. VKS service accounts can be annotated with IAM role ARNs to enable pod identity and role assumption for cloud resource access through OIDC federation, replacing long-lived static credentials with short-lived, least-privileged credentials on demand. IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege.

Several supplementary services within the VKS layer extend the IAM surface. Harbor Registry, available as a standard package on VKS clusters, enforces role-based access control to manage access to container image artifacts. The Secret Store Supervisor Service enforces RBAC for administrators, DevOps engineers, and application tenants managing sensitive data. Argo CD supports both OIDC configuration for external identity providers and local account configuration with global RBAC policies that define role-based access through policy rules and group mappings. The Istio service mesh package includes a pluggable policy layer supporting access controls, rate limits, and quotas at the service-to-service level.

Programmatic access management is available through several APIs. The Identity API authenticates and manages the authorization provider. The Identity Service and Infrastructure as a Service APIs are used to acquire access tokens for REST API authentication. Principal Identity users authenticate using client certificates for service-to-service communications between VCF components.

NSX integrates with LDAP and external identity management services for administrative access to networking configuration. NSX Manager enforces role-based access control with roles such as auditor and network administrator assignable to LDAP users. vDefend, a separate product that extends NSX with security capabilities, offers an Identity Firewall that integrates with Active Directory for identity-based firewall rules.

VMware Private AI Services (PAIS) provides OIDC-based authentication and group-based authorization for AI workloads, the primary IAM mechanisms controlling access to model endpoints, the model runtime, Agent Builder, and Data Indexing and Retrieval capabilities. PAIS authentication is configured with an issuer URL, a client ID (pais-authentication-id), and the openid, groups, and offline_access scopes. The OIDC provider must support the .well-known/openid-configuration discovery endpoint. Authorization restricts access to user accounts that are members of named groups listed in the authorizedGroups setting (such as group-for-pais-access-01 or group-for-pais-access-02). A groups claim is included in the Access Token and a corresponding groups scope is created in the OIDC configuration, while the oidc-groups-claim setting selects which claim name carries group membership when the OIDC provider uses a non-default name. The oidc-extra-audiences setting accepts additional OAuth 2.0 client identifiers that PAIS will accept when validating Access Tokens, supporting integration with downstream clients that present their own audience. Activating PAIS in an organization namespace requires coordination with the OIDC provider administrator and an organization administrator account in VCF Automation.

Identity provider integration for PAIS deployments is configured at the Supervisor level under Workload Management > Supervisors > Configure > Identity Providers. When a PAIS region is created for a Supervisor, an identity provider entry is automatically created in VMware vCenter for that Supervisor, linking the Supervisor namespace to the configured OIDC source.

The Model Gallery, the curated repository for ML models in PAIS, restricts access to model artifacts and the training data used to tune them through Harbor project access controls. These controls scope which users and service accounts can read, push, or manage sensitive model data, adding an IAM enforcement layer to the model supply chain. A Harbor registry is recommended for PAIS deployments, and OCI-compliant registries from other vendors are also supported.

PAIS Knowledge Bases extend IAM to ingested data sources. Confluence data sources authenticate with a user name and password or a personal access token, while Microsoft SharePoint On-Premises data sources authenticate with a user name and password. Personal access tokens for Knowledge Bases are generated from user account settings and used for programmatic access to linked data sources.

PAIS integrates with Grafana for metrics visualization using the same OIDC provider, extending the IAM model to the observability layer so that operators authenticate through the configured identity provider before accessing PAIS dashboards.

VMware vDefend (Contributes)

VMware vDefend contributes to identity and access management by providing identity-aware network enforcement through Identity Firewall, which integrates with Active Directory to apply firewall policy based on authenticated user identity rather than IP address alone. Identity Firewall supports assigning Active Directory users and groups as source criteria in both distributed firewall rules and gateway firewall rules, applying to tier-0 and tier-1 gateways. This allows organizations to enforce network access policy by user or group membership rather than relying solely on IP-based controls.

Within its management plane, the Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. These roles govern access to security policy management, analytics, incident response, and diagnostic functions across the platform. Network Detection and Response enforces the same five-role RBAC model for triage operations such as viewing detections and campaigns, and for configuration operations including SIEM integration management. For authentication, the Security Services Platform supports Active Directory and OpenLDAP as external identity sources, with one identity source configurable at a time. The License Hub integrates with external identity providers to store and manage user and group information for access delegation.

Centralized IAM for organizational users, including VCF SSO, MFA, and directory lifecycle management, is handled by VCF and falls outside vDefend's scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) incorporates multiple identification and access management mechanisms that support organization-wide IAM controls within the data services layer.

DSM implements role-based access control with two defined roles: the DSM Admin role, which can create, monitor, and manage all data services in the environment, and the DSM User role, which is restricted to managing and monitoring data services within the namespaces to which the user has been granted access. These roles are assigned at user creation time and govern what each user can see and do within the DSM interface. The Permissions view in the DSM dashboard provides administrators with a centralized location for creating, monitoring, and managing all configured users.

DSM supports two identity sources, which can be used independently or together. Local users are created directly within DSM, with credentials validated by matching email address and password. LDAPS users are sourced from a configured LDAP identity provider, allowing organizations to extend their existing directory service into DSM. When LDAPS is configured, administrators can import users from the directory provider and assign them DSM Admin or DSM User roles. DSM also supports group-based access control: Directory Service Groups from the LDAP provider can be assigned roles directly, so group membership in the external directory determines access level in DSM without requiring per-user assignments.

At the database level, DSM extends authentication controls beyond the platform management layer. MySQL database instances support LDAPS authentication using Active Directory. PostgreSQL and other database instances support host-based authentication (HBA) rule configuration, which determines which clients are permitted to authenticate to a given database instance. SQL Server instances support Windows Authentication through Active Directory integration, enabling Kerberos-based authentication so that clients such as SQL Server Management Studio running on domain-joined machines can authenticate via single sign-on. SQL Server also uses contained database users, where identity information resides within

the database itself rather than at the server level. Administrators can configure SQL Server instances with either a SQL User or Windows Principal as the primary administrator identity, with Windows Principal available for Active Directory-integrated clusters. An internal `dsm_mgmt` management login restricts users from accessing or modifying system-level objects, keeping administrative operations within an isolated context.

Namespace isolation adds a further access boundary. DSM namespaces enforce role-based access control that allows multiple users to work jointly on data services within a namespace while remaining isolated from data services in other namespaces. This supports least-privilege access within multi-tenant deployments.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides a dedicated administrative identity and access management plane through the Avi Controller, supporting multiple authentication methods and fine-grained authorization controls that allow organizations to implement IAM policies across both the management plane and the application delivery layer.

For administrative access, the Avi Controller supports local user accounts, LDAP and LDAPS directory integration, SAML-based federated authentication (including integration with Workspace ONE Access for catalog-based application access), basic authentication, and OAuth/OIDC for API access. Auth Mapping Profiles allow organizations to map external directory groups to specific roles and tenants, so that group membership in an external identity provider directly controls what a user can access within Avi.

Authorization is handled through role-based access control (RBAC) with object-level granularity. Avi's extended granular RBAC uses markers, which are labels assigned to objects, to enable fine-grained authorization based on object ownership and classification. Permission categories cover Operations (including alerts, actions, and traffic capture) and Administration (including controller, tenant, user, role, and system configuration management). This allows restrictions so that a user's permissions apply only to the specific resources matching the markers assigned to their role. RBAC covers object categories including Virtual Services, Application Profiles, SSL/TLS Certificates, Certificate Management Profiles, Cloud definitions, TCP/UDP Profiles, Persistence Profiles, Health Monitors, Analytics Profiles, IP Address Groups, String Groups, SSL/TLS Profiles, PKI Profiles, and Authentication Profiles, with distinct read and write access levels configured per object type.

For multi-tenant deployments, Auth Mapping Profiles support tenant isolation with configurable user group to role mappings, allowing organizations to enforce separation between teams or business units operating within the same Avi Controller.

The Avi License Hub supports role-based access control through an external identity provider, with three predefined roles: Enterprise Admin (full access for all operations, including upgrades and authentication configuration), Auditor (view-only access for tracking activity without making changes), and Support Bundle Collector (restricted to collecting system logs and diagnostics). Management interface access is further controlled through restrictions on allowed ciphers and HMACs for management sessions.

For deployments involving the Avi Kubernetes Operator (AKO), Kubernetes RBAC policies can be applied to AKO Custom Resource Definitions (CRDs) to enforce stricter access control over routing configuration for specific user groups. The Avi Controller also implements RBAC at the Kubernetes and OpenShift cluster level by assigning tenants and roles to user accounts.

At the application layer, Avi can enforce client authentication using OAuth, SAML, JWT token validation, and mutual TLS with client certificates, extending access control to the traffic flowing through virtual services rather than only to the management interface.

Organizations are responsible for defining roles, mapping directory groups to permissions, establishing naming conventions for markers, and maintaining user lifecycle processes. Avi provides the technical mechanisms; the governance and operational processes for identity management must be organized by the teams managing the deployment.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 164.308(a)(4)(ii)(A)

> Implementation specifications: Isolating health care clearinghouse functions (Required). If a health care clearinghouse is part of a larger organization, the clearinghouse must implement policies and procedures that protect the electronic protected health information of the clearinghouse from unauthorized access by the larger organization.

SCF Controls: GOV-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.308(a)(4)(ii)(B)

> Implementation specifications: Access authorization (Addressable). Implement policies and procedures for granting access to electronic protected health information, for example, through access to a workstation, transaction, program, process, or other mechanism.

SCF Controls: IAC-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a layered identity and access management architecture spanning centralized identity services, role-based access control, group-based access policies, identity provider federation, and programmatic access management through APIs.

VCF SSO is the centralized authentication service. VCF SSO issues security tokens that grant authenticated users access to VMware vCenter, NSX Manager, VCF Operations, and other platform components without requiring separate credentials for each service. VCF Operations supports importing users and groups from VCF SSO for consistent identity management across the stack. VMware Identity Manager provides a platform for managing users and groups, managing resources and user authentication, and configuring access policies and resource entitlements. vCenter also supports built-in identity source authentication using local domain credentials. The built-in identity provider can also be configured to use Active Directory as an identity source through LDAP/S, OpenLDAP/S, or Integrated Windows Authentication (IWA), depending on the directory environment.

VCF supports federation with enterprise identity providers. vCenter can be federated to providers such as Microsoft Entra ID, ADFS, and Okta, which enables multifactor authentication and automatic user synchronization with the organization's directory. PingFederate is also supported as a federated identity provider; for these integrations, vCenter uses System for Cross-domain Identity Management (SCIM) to automate the exchange of user and group identity information between the external identity domain and vCenter. VMware Identity Broker allows principals to authenticate to vCenter through an external identity provider. NSX Manager can be configured to authenticate users from identity management providers and can be integrated with Workspace ONE Access for identity management services. The Supervisor component supports registration of OIDC-compliant external identity providers for authentication to VMware Kubernetes Service (VKS) clusters; supported providers include Okta, Workspace ONE Access, and Dex, configured by supplying the Supervisor callback URL to the identity provider.

Role-based access control is enforced across all VCF components. In vCenter, permissions associate a user or group with a role on a specific inventory object, and predefined roles cover common administrative functions. Custom roles can be created with only the minimum required privileges for a given workflow. Managing identity provider configuration in vCenter requires the VcIdentityProviders Manage privilege. VCF Operations supports group-based access control, allowing administrators to configure groups and assign roles that control access to dashboards, reports, policies, alerts, and administration functions, as well as granular role-based controls for platform operations including approvals, audits, certificates, and content libraries.

VCF Automation extends access management through organization-level and project-level controls. The VCF Automation Access Control service supports identity operations for managing groups and users, including editing user names, passwords, and role assignments. The organization portal enforces role-based access control, requiring either Organization Administrator or Organization Auditor roles to manage policy templates. Organization administrators can distribute infrastructure and configure group-level access through the organization management functionality. Project access is governed by predefined roles. Users and groups can be disabled at the organization level to revoke access without deleting accounts. The System Administrator role has the right to manage and view Access Control Lists, and the accessControls API allows administrators to view and manage ACL entries for defined entities.

For Kubernetes workloads within the VCF consumption layer, VKS supports two authentication methods: VCF SSO and OIDC-compliant external identity providers. The OIDC path is implemented through Pinniped and supports providers including Okta, Workspace ONE Access, Dex, GitLab, and Google OAuth. Configuring an external provider requires setting up an OpenID

Connect ID Token with a Groups claim type filter to enable group-based access control tied to the organization's directory. Custom ClusterClass configurations allow clusters to authenticate developers using existing corporate identity systems. VKS supports namespace permission roles: Owner (full control including deletion), Can Edit (provisioning and operating workloads), and Can View (read-only access). These roles map to Kubernetes ClusterRoles through RoleBindings, and RoleBinding objects can reference VCF SSO users and groups directly to integrate SSO identities with Kubernetes role-based access control. A user with the Namespaces.Edit privilege on a user-created Namespace folder can perform CRUD operations on Kubernetes API resources in the Supervisor. Namespace Self-Service permissions control which users can self-provision namespaces through kubectl.

Kubernetes RBAC is the primary authorization mechanism within VKS, using Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings to bind permissions to users, groups, or service accounts. Kubernetes Attribute-Based Access Control (ABAC) is also available, defining access rights through policies that combine user, namespace, resource, and access mode attributes. Authorization webhooks can interpret field and label selectors to enforce fine-grained access control based on resource attributes such as node names and labels.

Service accounts provide namespaced workload identity within VKS clusters. For Windows containers, the Group Managed Service Account (gMSA) Webhook allows containers to run as Active Directory identities. VKS service accounts can be annotated with IAM role ARNs to enable pod identity and role assumption for cloud resource access through OIDC federation, replacing long-lived static credentials with short-lived, least-privileged credentials on demand. IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege.

Several supplementary services within the VKS layer extend the IAM surface. Harbor Registry, available as a standard package on VKS clusters, enforces role-based access control to manage access to container image artifacts. The Secret Store Supervisor Service enforces RBAC for administrators, DevOps engineers, and application tenants managing sensitive data. Argo CD supports both OIDC configuration for external identity providers and local account configuration with global RBAC policies that define role-based access through policy rules and group mappings. The Istio service mesh package includes a pluggable policy layer supporting access controls, rate limits, and quotas at the service-to-service level.

Programmatic access management is available through several APIs. The Identity API authenticates and manages the authorization provider. The Identity Service and Infrastructure as a Service APIs are used to acquire access tokens for REST API authentication. Principal Identity users authenticate using client certificates for service-to-service communications between VCF components.

NSX integrates with LDAP and external identity management services for administrative access to networking configuration. NSX Manager enforces role-based access control with roles such as auditor and network administrator assignable to LDAP users. vDefend, a separate product that extends NSX with security capabilities, offers an Identity Firewall that integrates with Active Directory for identity-based firewall rules.

VMware Private AI Services (PAIS) provides OIDC-based authentication and group-based authorization for AI workloads, the primary IAM mechanisms controlling access to model endpoints, the model runtime, Agent Builder, and Data Indexing and Retrieval capabilities. PAIS authentication is configured with an issuer URL, a client ID (pais-authentication-id), and the openid, groups, and offline_access scopes. The OIDC provider must support the .well-known/openid-configuration discovery endpoint. Authorization restricts access to user accounts that are members of named groups listed in the authorizedGroups setting (such as group-for-pais-access-01 or group-for-pais-access-02). A groups claim is included in the Access Token and a corresponding groups scope is created in the OIDC configuration, while the oidc-groups-claim setting selects which claim name carries group membership when the OIDC provider uses a non-default name. The oidc-extra-audiences setting accepts additional OAuth 2.0 client identifiers that PAIS will accept when validating Access Tokens, supporting integration with downstream clients that present their own audience. Activating PAIS in an organization namespace requires coordination with the OIDC provider administrator and an organization administrator account in VCF Automation.

Identity provider integration for PAIS deployments is configured at the Supervisor level under Workload Management > Supervisors > Configure > Identity Providers. When a PAIS region is created for a Supervisor, an identity provider entry is

automatically created in VMware vCenter for that Supervisor, linking the Supervisor namespace to the configured OIDC source.

The Model Gallery, the curated repository for ML models in PAIS, restricts access to model artifacts and the training data used to tune them through Harbor project access controls. These controls scope which users and service accounts can read, push, or manage sensitive model data, adding an IAM enforcement layer to the model supply chain. A Harbor registry is recommended for PAIS deployments, and OCI-compliant registries from other vendors are also supported.

PAIS Knowledge Bases extend IAM to ingested data sources. Confluence data sources authenticate with a user name and password or a personal access token, while Microsoft SharePoint On-Premises data sources authenticate with a user name and password. Personal access tokens for Knowledge Bases are generated from user account settings and used for programmatic access to linked data sources.

PAIS integrates with Grafana for metrics visualization using the same OIDC provider, extending the IAM model to the observability layer so that operators authenticate through the configured identity provider before accessing PAIS dashboards.

VMware vDefend (Contributes)

VMware vDefend contributes to identity and access management by providing identity-aware network enforcement through Identity Firewall, which integrates with Active Directory to apply firewall policy based on authenticated user identity rather than IP address alone. Identity Firewall supports assigning Active Directory users and groups as source criteria in both distributed firewall rules and gateway firewall rules, applying to tier-0 and tier-1 gateways. This allows organizations to enforce network access policy by user or group membership rather than relying solely on IP-based controls.

Within its management plane, the Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. These roles govern access to security policy management, analytics, incident response, and diagnostic functions across the platform. Network Detection and Response enforces the same five-role RBAC model for triage operations such as viewing detections and campaigns, and for configuration operations including SIEM integration management. For authentication, the Security Services Platform supports Active Directory and OpenLDAP as external identity sources, with one identity source configurable at a time. The License Hub integrates with external identity providers to store and manage user and group information for access delegation.

Centralized IAM for organizational users, including VCF SSO, MFA, and directory lifecycle management, is handled by VCF and falls outside vDefend's scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) incorporates multiple identification and access management mechanisms that support organization-wide IAM controls within the data services layer.

DSM implements role-based access control with two defined roles: the DSM Admin role, which can create, monitor, and manage all data services in the environment, and the DSM User role, which is restricted to managing and monitoring data services within the namespaces to which the user has been granted access. These roles are assigned at user creation time and govern what each user can see and do within the DSM interface. The Permissions view in the DSM dashboard provides administrators with a centralized location for creating, monitoring, and managing all configured users.

DSM supports two identity sources, which can be used independently or together. Local users are created directly within DSM, with credentials validated by matching email address and password. LDAPS users are sourced from a configured LDAP identity provider, allowing organizations to extend their existing directory service into DSM. When LDAPS is configured, administrators can import users from the directory provider and assign them DSM Admin or DSM User roles. DSM also supports group-based access control: Directory Service Groups from the LDAP provider can be assigned roles directly, so group membership in the external directory determines access level in DSM without requiring per-user assignments.

At the database level, DSM extends authentication controls beyond the platform management layer. MySQL database instances support LDAPS authentication using Active Directory. PostgreSQL and other database instances support host-based authentication (HBA) rule configuration, which determines which clients are permitted to authenticate to a given

database instance. SQL Server instances support Windows Authentication through Active Directory integration, enabling Kerberos-based authentication so that clients such as SQL Server Management Studio running on domain-joined machines can authenticate via single sign-on. SQL Server also uses contained database users, where identity information resides within the database itself rather than at the server level. Administrators can configure SQL Server instances with either a SQL User or Windows Principal as the primary administrator identity, with Windows Principal available for Active Directory-integrated clusters. An internal `dsm_mgmt` management login restricts users from accessing or modifying system-level objects, keeping administrative operations within an isolated context.

Namespace isolation adds a further access boundary. DSM namespaces enforce role-based access control that allows multiple users to work jointly on data services within a namespace while remaining isolated from data services in other namespaces. This supports least-privilege access within multi-tenant deployments.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides a dedicated administrative identity and access management plane through the Avi Controller, supporting multiple authentication methods and fine-grained authorization controls that allow organizations to implement IAM policies across both the management plane and the application delivery layer.

For administrative access, the Avi Controller supports local user accounts, LDAP and LDAPS directory integration, SAML-based federated authentication (including integration with Workspace ONE Access for catalog-based application access), basic authentication, and OAuth/OIDC for API access. Auth Mapping Profiles allow organizations to map external directory groups to specific roles and tenants, so that group membership in an external identity provider directly controls what a user can access within Avi.

Authorization is handled through role-based access control (RBAC) with object-level granularity. Avi's extended granular RBAC uses markers, which are labels assigned to objects, to enable fine-grained authorization based on object ownership and classification. Permission categories cover Operations (including alerts, actions, and traffic capture) and Administration (including controller, tenant, user, role, and system configuration management). This allows restrictions so that a user's permissions apply only to the specific resources matching the markers assigned to their role. RBAC covers object categories including Virtual Services, Application Profiles, SSL/TLS Certificates, Certificate Management Profiles, Cloud definitions, TCP/UDP Profiles, Persistence Profiles, Health Monitors, Analytics Profiles, IP Address Groups, String Groups, SSL/TLS Profiles, PKI Profiles, and Authentication Profiles, with distinct read and write access levels configured per object type.

For multi-tenant deployments, Auth Mapping Profiles support tenant isolation with configurable user group to role mappings, allowing organizations to enforce separation between teams or business units operating within the same Avi Controller.

The Avi License Hub supports role-based access control through an external identity provider, with three predefined roles: Enterprise Admin (full access for all operations, including upgrades and authentication configuration), Auditor (view-only access for tracking activity without making changes), and Support Bundle Collector (restricted to collecting system logs and diagnostics). Management interface access is further controlled through restrictions on allowed ciphers and HMACs for management sessions.

For deployments involving the Avi Kubernetes Operator (AKO), Kubernetes RBAC policies can be applied to AKO Custom Resource Definitions (CRDs) to enforce stricter access control over routing configuration for specific user groups. The Avi Controller also implements RBAC at the Kubernetes and OpenShift cluster level by assigning tenants and roles to user accounts.

At the application layer, Avi can enforce client authentication using OAuth, SAML, JWT token validation, and mutual TLS with client certificates, extending access control to the traffic flowing through virtual services rather than only to the management interface.

Organizations are responsible for defining roles, mapping directory groups to permissions, establishing naming conventions for markers, and maintaining user lifecycle processes. Avi provides the technical mechanisms; the governance and operational processes for identity management must be organized by the teams managing the deployment.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 164.308(a)(4)(ii)(C)

> Implementation specifications: Access establishment and modification (Addressable). Implement policies and procedures that, based upon the covered entity's or the business associate's access authorization policies, establish, document, review, and modify a user's right of access to a workstation, transaction, program, or process.

SCF Controls: IAC-08

Aggregate Coverage: Meets

VCF (Meets)

VCF enforces role-based access control across all major platform components, restricting access to technology assets, applications, services, and data based on assigned roles with defined permissions. RBAC is applied consistently throughout the stack, covering compute management, networking, storage, operations management, automation services, and Kubernetes workloads.

VMware vCenter provides fine-grained authorization through a permissions model that associates roles with users or groups on objects in the vCenter inventory hierarchy. Roles are sets of privileges, and vCenter defines three authorization levels: operator (read-only access to configuration, the most restricted level), administrator (read and write access to configuration but cannot manage user accounts, intended for users who alter vCenter configuration or exercise control functions), and super administrator (full control). When a predefined role is modified, the updated privilege set applies immediately to all users assigned that role. New roles are created with three default system-defined privileges (System.Anonymous, System.Read, System.View), and administrators add specific privileges to match the intended access level. vCenter also supports creation of custom roles with granular privilege assignment and permission propagation to vSphere objects in the inventory hierarchy.

NSX implements RBAC by assigning users predefined roles with specific permissions. The platform includes 15 built-in roles: Enterprise Admin, Admin, Network Admin, Network Operator, Security Admin, Security Operator, Cloud Admin, Cloud Operator, Cloud Project Admin, Load Balancer Admin, Load Balancer Operator, VPN Admin, GI Platform Admin, NSX Platform Admin, and Support Bundle Collector. These roles follow the principle of least privilege, with each role carrying only the permissions needed for its functional area. NSX RBAC applies across multiple operational domains including inventory, plan and troubleshoot, and system management functions. NSX also supports project-scoped RBAC, where Network Admin, Network Operator, Security Admin, and Security Operator roles assigned within a project have permissions limited to that project's scope rather than the entire NSX system. This project-scoped model extends to VPCs and subnets within the NSX networking hierarchy. For organizations that need role definitions beyond the built-in set, NSX allows creation of custom roles tailored to specific operational requirements. Only an Enterprise Administrator can assign the role management permission to a custom role. NSX Federation extends RBAC to multi-site deployments, applying the same access control model across federated NSX instances. Principal identities, which are used for service-to-service authentication local to NSX, also support RBAC role assignment, so automated integrations operate under the same access control model as human users.

VCF Operations enforces RBAC through the assignment of service roles to users and groups. Administrators configure role-based permissions through the Roles tab under Infrastructure Operations, where individual permissions can be selected or deselected to define what each role is authorized to do. The System Administrator role includes rights covering approvals, audits, certificates, datastores, edge clusters, integrations, LDAP settings, namespaces, proxy rules, system settings, tokens, and truststore operations. Administrative operations such as password management require authentication with a user assigned the ADMIN role. VCF Operations also defines its own roles within vCenter, with privileges named using a convention that appends the role to the product name (such as VCF Operations ContentAdmin Role and VCF Operations PowerUser Role). The PowerUser role has privileges to perform the actions of the Administrator role except for user management and cluster management. A further restricted PowerUserMinusRemediation role excludes remediation actions in addition to those limitations. A vCenter administrator assigns these roles to users, and VCF Operations maps vCenter users to the appropriate role.

vSAN supports RBAC and permissions management for authentication and authorization of storage operations. The vSAN Security Configuration Guide provides guidance on configuring these role-based controls for storage infrastructure.

VCF Automation governs access through multiple RBAC mechanisms at different scopes. At the organization level, rights bundles assign specific API permissions to roles including Organization Administrator, Organization Auditor, and Organization User. Group membership and role assignment are managed through the Access Control interface, and organization administrators can edit role assignments for groups at any time. At the project level, VCF Automation defines three distinct roles: administrators, members, and viewers, providing tiered access to project resources and operations. VCF Automation also governs blueprints, catalogs, content libraries, and custom entities through its role model. The Assembler Administrator role has read and write access to the entire user interface and API resources, while other roles have progressively narrower permissions.

For Kubernetes workloads running on VMware Kubernetes Service (VKS), VCF enforces RBAC through two complementary control layers. At the vSphere layer, vSphere Namespaces assign three permission roles: Owner (full control including namespace deletion), Can Edit (provisioning and operating workloads), and Can View (read-only access). At the Kubernetes layer, the Kubernetes RBAC authorization framework governs access to all API server requests through four core objects: Roles define permissions scoped to a single namespace, ClusterRoles define permissions applying cluster-wide, and RoleBindings and ClusterRoleBindings associate those roles with authenticated subjects such as users, groups, or ServiceAccounts. Permissions are purely additive with no deny rules, and administrators can restrict access to individual resource instances by name using the resourceNames list in role rules.

VKS clusters integrate with VCF SSO so that Kubernetes RoleBinding objects grant RBAC permissions directly to VCF SSO users and groups. This means the same identity provider that governs VMware vCenter access also governs Kubernetes cluster access, providing a consistent identity model across both the platform and workload layers. Cluster operators use kubectl or the Kubernetes API to assign role permissions to developers and other personas with defined responsibilities.

Kubernetes RBAC also governs ServiceAccounts, which provide discrete identities for pods and automation processes. This separation allows human access and workload access to be governed independently, with each scoped to the minimum permissions required for its function. ServiceAccounts follow the principle of least privilege by receiving only the minimum set of permissions required to function correctly, and RBAC should be applied to Secret objects to enforce least-privilege access to sensitive data stored within namespaces.

The Kubernetes RBAC API includes built-in controls against privilege escalation: the API prevents users from editing roles or role bindings to gain permissions beyond those they already hold, and this enforcement applies at the API level regardless of the authorization mode in use. Role-binding authority can be explicitly delegated by granting a user permission to perform the bind verb on a specific Role or ClusterRole, limiting the roles that identity can delegate to others.

In multi-tenant VKS deployments, RBAC is the primary mechanism for isolating tenants within a shared cluster. Administrators use Role and RoleBinding objects at the namespace level to restrict each tenant's access to its assigned namespaces, and ClusterRole and ClusterRoleBinding objects to control access to cluster-level resources, blocking unprivileged users from crossing tenant boundaries.

Supervisor services deployed on VKS clusters extend RBAC to their own access models. The Secret Store Supervisor Service enforces role-based access control across administrator, DevOps engineer, and application tenant roles, controlling who can manage and retrieve sensitive data. The Argo CD Supervisor Service implements RBAC through a configurable policy field using Casbin syntax, with the spec.rbac.policy setting defining role assignments and permission rules; policy rules (p rules) control account permissions including the ability to grant admin roles to specific local accounts, and group mappings (g rules) assign accounts to role groups.

VMware Private AI Services (PAIS) provides role-based access control scoped to its AI services and AI workload delivery components. The central mechanism is OIDC group-based authorization for PAIS. When activating PAIS in an organization namespace, administrators populate the authorizedGroups setting with one or more OIDC group identifiers so that only users who belong to those groups can access the service. The OIDC configuration supports a configurable groups claim name through the oidc-groups-claim setting, with the groups claim carried in the Access Token and evaluated at access time. PAIS requires an OIDC provider configured as a public client application with Authorization Code and Refresh Token grant types,

and it can be configured with one OIDC provider. Additional OAuth 2.0 client identifiers can be accepted by configuring Extra Audiences through the `oidc-extra-audiences` setting when the OIDC provider issues tokens for multiple audiences.

PAIS extends the same identity model to the Grafana observability platform used for PAIS metrics. Grafana role assignment is configured through the `grafana-oidc-role-mapping` property using an expression such as `contains(groups['*'], 'pais-access-group') && 'Admin' || 'Viewer'`, so OIDC group membership maps automatically to Grafana Admin or Viewer roles. PAIS uses the same OIDC provider for Grafana authentication that it uses for service access.

For machine learning model storage, the Model Gallery uses Harbor project access capabilities to restrict access to the sensitive data used to train and tune models. PAIS integrates with Harbor registries as the model storage backend and requires authentication and certificate-based trust for model retrieval. PAIS is compatible with OCI-compliant registries from other vendors when deployed in a disconnected or air-gapped environment, and the project-scoped access controls apply to the chosen registry.

Access to PAIS catalog items for GPU-accelerated VKS clusters and other AI workloads is governed through project-based permissions in VCF Automation. PAIS custom forms in blueprints can be modified to control user inputs at request time, scoping which configuration choices a requester can make when provisioning AI workloads. Knowledge Base data sources used by PAIS retrieval augmented generation require authenticated access to external repositories, including user name and password authentication for SharePoint On-Premises data sources and access keys with list and read permissions on the target bucket for Amazon S3 compatible stores. PAIS uses a CA trust bundle for secure communication with external services and databases.

These PAIS-specific controls operate at the AI services and workload layer. Access to the underlying compute, storage, and networking infrastructure is governed by platform-level RBAC in VCF, including VCF SSO and VMware vCenter role assignments, and database-level access for vector and operational data is governed by Data Services Manager. PAIS adds service-level and workload-level RBAC for AI-specific assets on top of the VCF platform foundation rather than replacing those platform controls.

VMware vDefend (Contributes)

VMware vDefend (vDefend) enforces role-based access control across its security management interfaces to restrict access to firewall policy administration, threat analysis functions, and monitoring capabilities based on assigned user roles.

The vDefend distributed firewall (DFW) implements RBAC to control who can create or modify firewall rules, limiting policy changes to authorized personnel. Access to DFW monitoring features, including Firewall Insights, requires one of three designated roles: Enterprise Admin, Security Admin, or Security Operator. Rule Analysis operations within the platform are also role-gated across the five defined role types.

Security Services Platform (SSP) implements RBAC with five defined roles governing access to platform operations: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Each role carries differentiated permissions; Full Access grants create, read, update, and delete capabilities, while Read-only access is available for monitoring-oriented roles such as Auditor and Support Bundle Collector. Role assignments can be applied to individual remote users or to remote user groups managed through a directory service, allowing administrators to align vDefend access with existing organizational structures. Multiple roles can be assigned to a single user or group to meet varying operational requirements. SSP's RBAC model also applies to License Hub operations, restricting licensing management actions to authorized roles.

Security Intelligence RBAC in 9.1 uses the same five-role model as SSP (Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector), aligning Security Intelligence access governance with SSP's permission model and providing consistent role boundaries across both the detection and platform layers.

For organizations using VCF Automation for vDefend firewall management, VCF Automation provides a dedicated Firewall category under RBAC rights, controlling access to the management and viewing of DFW rules, Tenant Gateway Firewall policy, VPC Gateway Firewall policy, and VPC Security Profiles. This allows organizations to scope firewall administration

rights independently of other VCF Automation capabilities, supporting separation of duties between network automation and security policy management.

vDefend's RBAC controls complement the broader VCF RBAC model by restricting access to network security policy management independently of compute, storage, or platform configuration access. An administrator with VMware vCenter privileges does not automatically gain the ability to modify firewall rules or security analytics configurations unless explicitly granted the appropriate vDefend roles. This separation of duties between infrastructure administration and security policy management supports distinct team structures for network security management.

VCF Protection and Recovery (Contributes)

Protection and Recovery (PNR) implements role-based access control through purpose-built roles registered in VMware vCenter and through a multi-tenant administrative model for Protection and Recovery for VCF Automation. The SRM Administrator role allows users or user groups to perform all PNR configuration and administration operations. The Protection and Recovery Administrator role can be assigned to user groups to manage permissions. Default roles provide the privileges users require to manage protection groups and perform recoveries, while restricting access to resources belonging to other users.

For automatic protection of virtual machines within a protection group, administrators assign either the SrmAdministrator or SrmProtectionGroupsAdministrator role to the automatic protection user or user group. This scopes the protection actions performed on the user's behalf to the privileges of the assigned role.

Each role is a collection of privileges that defines the actions a user can perform on the protection and recovery site. A user can have at most one role on an object, but roles combine when the user belongs to multiple groups that all have roles on the object. PNR supports propagating roles to child objects in the inventory hierarchy, so administrators can extend privileges from parent objects such as folders to all virtual machines within them.

Protection and Recovery for VCF Automation introduces a multi-tenant role model with Provider Administrator, Organization Administrator, Project Administrator, and Project Advanced User. Each role has specific authorization levels for disaster recovery operations. Provider Administrators select which replication classes each Organization can use, restricting organizational access to specific recovery configurations. Organization Administrators manage the pairing of namespaces and assignment of replication classes within their tenancy.

Underlying directory services, authentication, and enterprise identity governance are provided by VCF SSO and the broader VCF platform. PNR consumes those identities and layers its protection and recovery roles on top of them.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) implements role-based access control natively, with two defined role types that govern access to all data service resources. The DSM Admin role is a super-user role with full access to create, monitor, and manage all data services across the environment. The DSM User role is a restricted role that limits a user to viewing and managing only the data service deployments they own. This separation is enforced at the console level: the views and available actions in the DSM interface differ based on the assigned role, so users with the DSM User role cannot see or act on resources outside their own scope.

Access control is further refined through namespace scoping. DSM User role assignments can be restricted to one or more specific namespaces, limiting access to data services within those assigned namespaces only. Administrators can modify a user's assigned role and namespace access after initial provisioning. DSM namespaces enforce role-based access control that allows multiple users to work on data services within a shared namespace while maintaining appropriate permission boundaries between them.

DSM supports both local user accounts and directory service integration for identity management. Local users are created through the DSM UI, where administrators specify the user's role, email address, and password. For enterprise directory integration, DSM supports LDAPS-based authentication with Directory Service Group mapping, allowing administrators to assign users to either the DSM Admin or DSM User role based on their LDAP group membership. This group-based mapping is configured through the vSphere Client during DSM setup or through the DSM UI after deployment.

Access control extends to storage and database resources as well. DSM IAM policies for S3-compatible storage support granular access control through policy statements that allow specific S3 actions, including PutObject, GetObject, DeleteObject, and ListMultipartUploadParts. At the database level, PostgreSQL instances support the CREATE ROLE command to create database roles for LDAPS users with configurable login capabilities, and administrators can configure Host-Based Authentication (HBA) rules to restrict which clients and authentication methods may connect to a PostgreSQL instance. For SQL Server instances, DSM applies least-privilege access by granting the cluster administrator login restricted read-only privileges and specific ALTER privileges for server management and auditing, rather than full administrative access. Data service policies also support allowlist configuration to restrict users to selecting only from a specific set of approved parameters when provisioning databases.

The DSM Permissions view provides a centralized interface for administrators to create, monitor, and manage configured users. This view supports ongoing governance of who has access to what within the DSM environment, making it straightforward to audit and adjust role assignments as business needs change.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer provides a native, multi-tiered Role-Based Access Control (RBAC) framework that governs all administrative access to the Avi Controller. At the base level, Avi roles assign one of four privilege types to each resource category: Write (full create, read, modify, and delete access), Read (view-only access to configuration, health, and analytics data without modification capability), Assorted (a mixed access level combining permissions across specific operations), and No Access (no access to the resource at all, including the inability to read or list it). Roles are combined with tenants to define the complete authorization settings for each user, scoping what resources a user can interact with and what actions they may take.

Beyond base privilege levels, the Extended Granular RBAC feature refines access using markers, which are key-value label pairs assigned to Avi objects. A role definition specifies that a user may access only objects bearing labels that match the role's marker set. The `allow_unlabelled_access` parameter controls whether a user can view objects that lack matching labels, allowing administrators to restrict visibility to labeled objects only. Label groups can be associated with tenants to enforce label-based access policies across the tenant boundary. Multiple label values can be mapped to a single key, enabling flexible classification schemes. This mechanism enables resource-level scoping across tenants and teams: for example, restricting a group of operators to only the virtual services labeled with their team's identifier, without granting visibility into other teams' objects.

At the finest granularity, Avi implements sub-resource (field-level) RBAC, which scopes which specific fields within a configuration object a given user is authorized to modify. Sub-resource definitions can be combined so that a user can configure multiple fields or features within a single object while remaining restricted from updating others. Label-based permissions for cloud objects extend this field-level control to infrastructure resources managed by the Avi Controller. Virtual service configuration exposes RBAC directly: the RBAC tab in the Virtual Service advanced setup provides label-based access control for health monitors and associated objects, extending role enforcement down to individual service configuration items.

For GSLB deployments, the Avi Controller enforces RBAC through role references such as `Gslb_Group_Enabled` and `Gslb_Health_Monitor` that can be assigned to user accounts with tenant-level scope. These role references apply to follower sites configured with federated JWT profiles, scoping which accounts can modify GSLB configuration.

The Avi Controller applies RBAC within the License Hub, limiting which users can perform specific actions based on their assigned role.

For deployments using the Avi Kubernetes Operator (AKO), the Avi Controller implements RBAC by assigning tenants and roles to user accounts at the Kubernetes or OpenShift cluster level. AKO Custom Resource Definitions (CRDs) can leverage Kubernetes RBAC policies to restrict which user groups can configure routing rules, extending the Controller's authorization model into the Kubernetes control plane.

For deployments on Microsoft Azure, Avi integrates with Azure IAM to control which Azure identities have access to Avi Load Balancer resources hosted in Azure. Administrators can use built-in Azure roles such as Reader (read-only access) or Owner (full access), or define custom roles for finer control over specific resources.

RBAC configuration is managed through the Users section of the Avi Controller UI. Roles are defined per resource type and then assigned to users within a tenant. Extended Granular RBAC markers are attached to individual Avi objects (virtual services, pools, health monitors, and others) and referenced in the role definition. Sub-resource RBAC is configured as part of the Extended Granular RBAC object, combining field-level restrictions as needed.

Control 164.308(a)(5)(i)

> Standard: Security awareness and training. Implement a security awareness and training program for all members of its workforce (including management).

SCF Controls: SAT-01, SAT-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.308(a)(5)(ii)(A)

> Implementation specifications. Implement: Security reminders (Addressable). Periodic security updates.

SCF Controls: SAT-03.6

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.308(a)(5)(ii)(B)

> Implementation specifications. Implement: Protection from malicious software (Addressable). Procedures for guarding against, detecting, and reporting malicious software.

SCF Controls: SAT-03.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.308(a)(5)(ii)(C)

> Implementation specifications. Implement: Log-in monitoring (Addressable). Procedures for monitoring log-in attempts and reporting discrepancies.

SCF Controls: SAT-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.308(a)(5)(ii)(D)

> Implementation specifications. Implement: Password management (Addressable). Procedures for creating, changing, and safeguarding passwords.

SCF Controls: SAT-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.308(a)(6)(i)

> Standard: Security incident procedures. Implement policies and procedures to address security incidents.

SCF Controls: GOV-02, IRO-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support an organization's incident response operations, though it does not govern organization-wide incident response processes or maintain incident response documentation. VCF Operations is the primary platform for detecting, tracking, and investigating infrastructure-level incidents across the VCF environment.

VCF Operations includes a dedicated incident management system that displays all incidents with their current status and key metadata. Each incident record tracks state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation. Operators can edit, share, and delete incidents directly from the incident list interface, and the system maintains an audit trail of who created each incident and when. This structured tracking provides the documentation trail that incident response processes require.

For incident investigation, VCF Operations provides root cause analysis tooling through its Troubleshooting Incident Page. This interface displays information about the affected entity, including traffic and flow data, any past incidents created for the same entity, and root cause metrics. Investigators can flag individual metrics and mark specific metrics as the root cause of an incident. The system also allows drill-down into related entities to view detailed metrics for problem investigation, supporting a methodical approach to identifying the source and scope of an issue. A summary view displays the count of in-progress incidents, entity counts, and top root causes, which supports situational awareness during active incident response and helps teams prioritize efforts across multiple concurrent issues.

For detection, VCF Operations performs event correlation across monitored systems, correlating a subset of published events and delivering them as faults. The platform maps events from target systems into the VCF Operations severity model, with event severity ranked from Info to Immediate. This automated correlation and severity classification helps operations teams identify incidents that require immediate response. Notification rules can be configured to trigger actions based on incident state changes, with configurable fields including incident state, resolution code, on-hold reason, impact, urgency, priority, assignment group, assigned-to person, severity, approval actions, related problems, and change cause. VCF Operations also supports defining fault symptoms and metric event symptoms based on thresholds and conditions reported by monitored systems, which can be combined into alert definitions that surface conditions requiring operator attention.

At the VMware vCenter level, alarms can execute scripts, send SNMP traps, or call APIs when infrastructure conditions match defined thresholds. The SNMP agent included with vCenter sends traps when alarms are triggered, and VCF PowerCLI provides programmatic access to alarm management through cmdlets that support creation of script-based and SNMP alarm actions. These capabilities provide automated event detection and alerting that feed into broader incident response processes.

To integrate with broader organizational incident response workflows, VCF Operations supports a ServiceNow Notifications plug-in that creates incidents directly in a ServiceNow ticketing system. The integration is configurable with fields including caller ID, incident category, sub-category, business service, contact type, and propagation settings for alert updates. This integration enables VCF-detected incidents to flow into an organization's established incident response and ticketing processes.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a physical machine failure. Proactive HA integrates with hardware vendor health monitoring to evacuate workloads before failures occur. vSphere cluster HA configuration supports multiple remediation modes, including quarantine mode, maintenance mode, and mixed mode. These recovery capabilities can be exercised ad hoc or incorporated into existing playbooks and runbooks.

VMware vDefend (a separate product that extends VCF's networking foundation) adds automated threat detection and containment through IDS/IPS and network detection features, including quarantine policies that isolate affected VMs while preserving forensic access.

This control requires organization-wide incident response governance, documented processes, and cross-functional coordination that go beyond what any infrastructure platform provides on its own. VCF delivers incident tracking, investigation tooling, event correlation, automated alerting, ITSM integration, and infrastructure recovery capabilities that form a technical foundation for incident response, but organizations must build their own incident response plans, escalation procedures, communication protocols, and training programs around these capabilities.

VMware vDefend (Contributes)

VMware vDefend contributes to incident response operations by providing integrated threat detection, investigation, correlation, and remediation capabilities within the network security layer of VCF. Security Services Platform defines a Security Operator role specifically for monitoring security systems and responding to security incidents, providing a built-in responsibility model for incident response activities at the network security layer.

Security teams can investigate individual threat events and correlated campaigns through the Security Services Platform interface to assess impact, identify root causes, and take appropriate mitigation actions. The Campaign Blueprint feature visualizes correlated security events and key actors within a campaign, simplifying triage and investigation to reduce mean time to detection. Campaign correlation surfaces multi-stage attack patterns: a drive-by infection event followed by a command-and-control event on the same workload is linked into a single campaign view. Security Intelligence categorizes detected suspicious traffic events by impact type (Critical, High, Medium, and Low) to help prioritize response actions.

Network Detection and Response (NDR) provides security analysts with capabilities to understand security events, triage them, and remediate by creating policies. NDR includes Suspicious Traffic detectors that collect and display suspicious traffic detections as events. Each detection event receives an impact score calculated from Confidence and Severity; informational events with scores from 1 to 24 indicate activity that is not essentially malicious and help teams focus attention on higher-priority events.

Security Services Platform generates Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and flows, helping teams assess the potential scope and lateral spread of an incident. The Rule Analysis feature generates downloadable CSV reports of anomaly analysis results, with separate files for each detected anomaly type. Security Services Platform provides metrics for Malware Prevention Service events, including malware family, non-benign indicators, process inspection events, and process state data, accessible through the API.

For remediation, the Response and Remediation feature in Security Services Platform performs automated policy creation based on user role and permissions. Intelligent Assist supports two remediation strategies, Targeted (surgical, with potentially lower breadth) and Comprehensive (broader scope), allowing teams to select the appropriate approach for each incident. Security Services Platform collects IDS policies, rules, and security profiles created by Intelligent Assist as part of remediation operations. Objects generated during NDR remediation that encounter errors require manual cleanup in Intelligent Assist.

These capabilities support detection, investigation, and remediation phases of an incident response lifecycle at the network security layer. vDefend does not govern organization-wide incident response processes, maintain incident response documentation, or manage incident tracking and status coordination functions. Those organizational and process governance functions fall outside the scope of a network security product.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides data protection incident response capabilities through structured recovery plans, non-disruptive testing, and automated failover orchestration. Recovery plans define documented, repeatable response procedures that specify VM recovery sequences and reprotect operations following a recovery event, with reprotect process states displayed in the recovery plan user interface so operators can observe operation status. Test failover and planned migration operations validate response readiness before an incident, and disaster recovery failover handles unplanned events when the protected site is unavailable.

PNR's event logging and alarm framework detects conditions that may indicate a data protection incident, including site connectivity loss, replication failures, and interrupted reprotect operations. PNR captures audit events that record user actions, including configuration changes and recovery plan executions, with the event name, user identity, and source IP address where the event was initiated. The PlanExecReprotectEnd event is signaled on the recovery site when a reprotect operation completes, supporting closure of the response lifecycle. Protection and Recovery Dashboards in VCF Operations provide consolidated visibility across vCenters, vSAN snapshot and replication sites, VMware Live Recovery Cloud regions, and protection and recovery site pairs to help incident responders see protection status at a glance.

For cyber-incident scenarios, PNR includes Cyber Recovery with a clean room at the recovery site to isolate recovered workloads during ransomware analysis. Cyber Recovery integrates with Carbon Black and CrowdStrike for security and vulnerability analysis; results include risk score details, environmental impact, CrowdScore severity (a CrowdScore of 100 indicates a critical threat level), and recommended remediation actions to support response decisions. When a disaster affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so organization users can return to running their workloads.

Not applicable for this control: VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.308(a)(6)(ii)

> Implementation specification: Response and reporting (Required). Identify and respond to suspected or known security incidents; mitigate, to the extent practicable, harmful effects of security incidents that are known to the covered entity or business associate; and document security incidents and their outcomes.

SCF Controls: IRO-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require

zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 164.308(a)(7)(i)

> Standard: Contingency plan. Establish (and implement as needed) policies and procedures for responding to an emergency or other occurrence (for example, fire, vandalism, system failure, and natural disaster) that damages systems that contain electronic protected health information.

SCF Controls: BCD-01, GOV-02, IRO-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a broad set of infrastructure-level capabilities that support business continuity and disaster recovery planning. While VCF does not itself constitute a Business Continuity Management System, it supplies the technical mechanisms that underpin resilient deployments and contingency operations.

vSAN stretched clusters allow organizations to extend a single vSAN datastore across two geographically separated sites with an independent witness host. When configured with site mirroring, a stretched cluster can tolerate the complete loss of one site while maintaining data availability. vSphere HA, when enabled on a stretched cluster, automatically restarts virtual machines on the surviving site during a site failure. To support this, vSphere HA admission control should be configured to reserve 50% of the cluster's aggregate CPU and memory resources for failover, and site-specific isolation response addresses should be defined so that vSphere HA can validate host isolation even when network connectivity between sites is lost. The admission control setting for host failures the cluster tolerates should also be updated after cluster expansion to reflect the correct host count per availability zone. When stretching a workload domain cluster, the default management vSphere cluster must already be stretched. vSphere HA uses network heartbeats to validate the state of VMware ESX hosts, and can also use heartbeat datastores mounted to more than one host (excluding vSAN datastores) for cluster membership monitoring.

vSphere HA also operates at the individual cluster level independent of stretched clusters. The HA configuration remediation mode can be set to quarantine mode, maintenance mode, or mixed mode to handle host failures in a controlled manner, helping maintain workload availability during hardware events. vSphere Fault Tolerance provides a higher tier of availability for individual virtual machines by maintaining a secondary VM in continuous lockstep with the primary, enabling instantaneous failover with no data loss if the primary host fails.

vSAN Data Protection provides snapshot-based protection through the vSAN Snapshot Service. Protection groups support configurable snapshot scheduling with adjustable intervals and retention policies that define retention duration and time units. This allows organizations to define data protection policies aligned with their recovery point objectives. The Snapshot Service API also supports operations such as restoring deleted virtual machines from snapshots and creating linked clones from snapshots.

vSphere Replication provides asynchronous replication of virtual machines with a configurable Recovery Point Objective (RPO), allowing organizations to replicate workloads to a secondary site and define acceptable data loss windows as part of their contingency planning.

VCF requires all management components, including VCF Operations, VMware vCenter, NSX, and VCF Automation, to be configured with a regular backup schedule and retention policy. VCF Operations configures NSX Manager backups during the initial deployment, with a recommended backup frequency of hourly and 7-day retention. Backup jobs for VCF Operations and all vCenter instances should start within the same 5-minute window to capture a consistent state. The VMware Infrastructure Health adapter within VCF Operations monitors backup job retention for management components, including NSX Manager. Changed Block Tracking (CBT) tracks modified disk sectors on virtual machines to support incremental backups, reducing backup windows and storage requirements for VM-level backup operations. vCenter itself also supports a High Availability configuration with Active and Passive nodes whose configuration files are continuously replicated, providing management-plane resilience independent of the backup schedule.

VMware HCX provides workload mobility capabilities for migrating and replicating VMs between sites. HCX supports multiple migration types through its Mobility Agent service, including vMotion, Cold Migration, Bulk Migration, and Replication Assisted vMotion (RAV), each addressing different scenarios from large-scale parallel migrations to zero-downtime live migrations.

HCX also includes appliance-level backup and restore capabilities for the HCX Manager, including certificate backup and restore, supporting planned migrations and recovery scenarios as part of broader BC/DR operations.

VCF Operations monitors infrastructure health and surfaces alerts when conditions threaten availability, giving operations teams early warning of potential failures. The Platform Health Alerts page provides a centralized view of alerts across data sources and infrastructure nodes. VCF Automation provides alerts through the associated VCF Operations application for capacity, performance, and availability monitoring. VCF Operations also includes infrastructure planning and what-if analysis capabilities that help organizations forecast capacity requirements and plan for contingency scenarios. Committed scenarios reserve capacity by setting aside resources for new, upcoming, or planned workloads, helping stakeholders understand capacity requirements across the environment. Integration with IT Service Management and Configuration Management Database platforms is supported through VCF Automation, enabling organizations to tie their infrastructure management into broader service continuity workflows.

Lifecycle management tools allow administrators to plan updates and schedule maintenance windows to make changes with minimal disruption to services, supporting the operational continuity aspect of business continuity planning.

While VCF provides these technical capabilities, a complete BCMS requires organizational elements that fall outside the platform: documented continuity of operations plans, recovery time and recovery point objectives defined by business stakeholders, regular testing and exercise of recovery procedures, communication plans, and management oversight of the continuity program. VCF supplies the infrastructure resilience and recovery mechanisms that such plans depend on, but the planning, governance, and procedural components must be established and maintained by the organization.

VMware vDefend (Contributes)

VMware vDefend contributes to business continuity by providing security-layer continuity mechanisms that remain active during disaster recovery events and workload migrations. NSX Federation Security maintains security posture across data centers during disaster recovery and workload migration, preserving distributed firewall and gateway firewall policies so that enforcement continues through failover.

The Security Services Platform, which provides the underlying infrastructure for vDefend's threat detection and inspection services, supports vSphere High Availability configurations. When a VMware ESX host becomes unhealthy, vSphere HA migrates the affected Security Services Platform virtual machines to healthy hosts in the cluster, restoring threat detection capacity without manual intervention. VMware recommends enabling vSphere HA for host-level failure recovery and configuring a storage policy with RAID for datastore-level failure tolerance in Security Services Platform deployments.

Security Services Platform can also be deployed on a vSAN stretched cluster configuration, which replicates storage across two physically distinct sites connected by a high-bandwidth or low-latency inter-site link. This configuration requires a minimum of two sites with their own hosts and a witness host to handle potential conflicts arising from network partitions, supporting site-level failure scenarios.

When vSphere HA restarts workload VMs on a new recovery host after a failover, the vDefend distributed firewall automatically reinspects all traffic from those VMs on the receiving host, because the Flow Table contents cannot be moved between hosts during host recovery. Security policy enforcement resumes on the new host without manual reconfiguration.

The broader BCMS framework, including Continuity of Operations Plan and BC/DR playbooks, impact analyses, and organizational governance processes, is outside vDefend's scope and must be established through dedicated business continuity management programs.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides the technical execution layer for contingency planning in virtualized infrastructure. Recovery plans define the sequence, priority, and configuration for failover operations, acting as executable BC/DR playbooks. Protection groups organize virtual machines into logical units aligned with application tiers or business functions, establishing the scope of each contingency plan.

Recovery plans support non-disruptive testing before use in planned migration or disaster recovery, allowing organizations to validate their contingency procedures without affecting production workloads. Recovery plan configuration differs between emergency scenarios at the protected site and planned migration of services from one site to another, with PNR supporting both modes. A forced recovery function is available during disaster recovery plan execution for scenarios requiring immediate failover.

vSphere Replication provides host-based replication with configurable Recovery Point Objectives (RPO), allowing organizations to set per-workload data loss tolerances. vSphere Replication supports up to 200 point-in-time recovery instances per virtual machine using the Latest Instances option, enabling recovery to specific earlier states. This capability is relevant to contingency scenarios involving data corruption or ransomware events. When the source site is accessible at the time of recovery, vSphere Replication can synchronize recent changes from the source site to the target site before completing the operation, reducing data loss.

In 9.1, PNR extends to multi-tenant disaster recovery through integration with VCF Automation. The product implements role-based access control with Organization Administrator, Project Administrator, and Project Advanced User roles, each with defined authorization levels for disaster recovery operations. Role assignments must be configured on both the primary and secondary PNR sites to maintain consistent access control across the DR environment. A multi-region deployment topology places separate management domains in each region to contain disaster impact to one region, while enabling service recovery in an alternate management domain when VCF Automation and VCF Operations are affected. The VCF Operations Orchestrator Plug-In for PNR provides Configuration, Inventory Mappings, Protection Groups, and Storage predefined workflow categories for workflow-driven recovery operations.

Cyber recovery deployments support a standard VCF topology where the workload domain is isolated from the management domain, providing separation between management and user workloads in clean-room recovery scenarios.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer resilience mechanisms at both the control plane and the data plane that organizations can incorporate into business continuity plans for application delivery services.

At the control plane, the Avi Controller is deployed as a cluster with continuous configuration replication across all nodes, providing management-plane redundancy so that a single Controller node failure does not interrupt application delivery operations. Avi supports deployment of the Controller cluster across two availability zones, with vSphere HA recommended to support recovery of any node that fails in the secondary zone. For single-node deployments, enabling vSphere HA on the Controller VM is recommended for node recovery following a host failure. The Avi Controller provides configuration backup and restore capability that supports disaster recovery and configuration migration across Controller instances; organizations should capture and retain Controller backups as part of their continuity documentation.

Availability Zone awareness in Avi allows multiple availability zones to be configured, each defining a subset of vCenter instances, hosts, and datastores that share a fault domain. Configuring availability zones during Service Engine Group setup distributes data-plane capacity across isolated failure domains, supporting continuity designs where application delivery capacity remains available if one fault domain becomes unavailable.

At the data plane, Avi's Elastic High Availability mode provides fast recovery for individual virtual services following Service Engine failure. In vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, giving the application delivery layer its own recovery path distinct from the infrastructure restart cycle. If vSphere HA does not recover the failed Service Engine within a configured timeout period, the Avi Controller resumes recovery independently. Service Engine VMs should be deployed on vSphere clusters configured with both HA and DRS in fully automated mode; when Avi is deployed with VMware Kubernetes Service (VKS) on VCF, DRS and HA are required on every vSphere cluster used with Avi.

For Kubernetes environments, the Avi Multi-Cluster Kubernetes Operator (AMKO) provides federation architecture that supports disaster recovery across Kubernetes clusters. AMKO designates a leader cluster and multiple member clusters, coordinating application delivery failover as part of a multi-cluster DR strategy.

Avi ControlScripts, used in conjunction with the alert framework, can perform automated failover actions such as adding or removing routes based on VIP attachment and detachment events, allowing organizations to define automated remediation workflows that respond to system events without manual administrator intervention.

In 9.1 deployments using VCF Automation, Avi's Central Licensing maintains a global capacity pool that removes the requirement for duplicate licenses in DR scenarios, supporting license continuity across failover sites.

Organizations should document these mechanisms, including the Elastic HA configuration, Controller cluster topology and backup schedule, availability zone placement, and AMKO federation design, in their Business Continuity and Disaster Recovery playbooks. The technical recovery capabilities are built into the product; the planning artifacts, testing procedures, and escalation workflows are organizational responsibilities that extend beyond what Avi provides.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 164.308(a)(7)(ii)(A)

> Implementation specifications: Data backup plan (Required). Establish and implement procedures to create and maintain retrievable exact copies of electronic protected health information.

SCF Controls: BCD-11

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in backup capabilities across its management components, workload layers, and storage subsystems, supporting organizations in meeting their Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).

Management component backups

VCF supports backup of all core management components. VMware vCenter supports both file-based and image-based backup methods, with file-based daily backups configured through the vCenter Management Interface of each vCenter instance. vCenter file-based backup and restore supports FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB as the backup server protocol. vCenter file-based backup optionally encrypts backup files using an encryption password that must be provided during restore; because vCenter backups contain the Key Derivation Key used for vSphere encryption, backup files should be stored on a secured backup server with appropriate access controls. VCF Operations similarly supports file-based and image-based backup methods. NSX Manager uses file-based backup, which VCF Operations configures automatically during the initial bring-up process. File-based backup jobs for VCF Operations and vCenter must be configured separately after deployment.

Scheduled backups should be implemented to prepare for critical failure scenarios, upgrade events, or certificate updates of management components. To capture a consistent state across related components, VCF requires creating a series of coordinated backup jobs that run simultaneously across component nodes. Simultaneous backups of component nodes help ensure that the backed-up state is logically consistent, reducing the need for integrity remediation during a restore. On-demand manual backups can be taken after a successful recovery operation or after a scheduled backup failure. VCF Operations backup is also configured to take a backup on state change, providing an additional layer of protection when configuration changes occur.

The backup file server stores backups from all NSX Manager or Global Manager nodes, and NSX includes a script to automatically delete old backups to manage storage consumption. NSX Global Manager backups should be periodically cleaned up to avoid excessive storage consumption on the backup file server. VCF Operations for Networks can store backups on local storage, retaining up to five backup files, or upload them to SSH or FTP servers. An initial on-demand backup should be performed after configuring VCF Operations to verify that backups complete successfully before relying on scheduled jobs. Sufficient storage capacity must be provisioned to accommodate backup data across all components.

Backup integrity and restore procedures

Backup integrity verification in VCF centers on version compatibility. When restoring a vCenter instance from a file-based backup, administrators must have a valid backup that matches the exact version of the vCenter appliance being restored to. VCF Operations must be available before restoring vCenter, and vCenter must be available before restoring VCF Operations, establishing a defined dependency order for restore operations. These dependencies require careful sequencing during recovery to restore the management plane to a consistent state.

Workload-level data protection

For workload-level data protection, VCF provides several mechanisms. Changed Block Tracking (CBT) tracks modified disk blocks on virtual machines, enabling incremental backups that reduce backup windows and storage requirements. VMware vSphere Storage APIs for Data Protection (VADP) provide a standardized interface for third-party backup solutions to integrate with VCF. vSphere Supervisor supports backup of VM Service VMs through backup partner solutions based on VADP, and if a VADP-based backup solution is deployed on the default management cluster, the solution must be properly started and operational before starting up or shutting down VCF. Quiesced snapshots are appropriate for automated or

periodic backups of VM Service virtual machines, as they capture a consistent state before the backup operation proceeds. VCF Automation supports snapshotting a VM group to create an object that references distinct snapshots for each member VM; restoring a VM group snapshot restores each member of the group.

vSphere Supervisor control plane backup and restore can be performed using vCenter file-based backup and restore from the Workload Management UI. For applications that provide their own backup capabilities, VCF documentation recommends using application-specific backup methods rather than relying on filesystem backup alone.

vSAN data protection and snapshots

vSAN Data Protection allows snapshots to be managed through protection groups with configurable snapshot retention policies and scheduling intervals. The native Snapshot Service is supported by vSAN Express Storage Architecture (ESA) but not by vSAN Original Storage Architecture (OSA). Native snapshots in vSAN ESA are much faster than traditional vSphere snapshots because a base VMDK and its snapshots are contained in one vSAN object rather than being separate objects, allowing more frequent backups and faster recovery. In vSAN OSA, snapshots are separate vSAN objects. The vSAN Distributed File System Snapshot can be used by third-party backup vendors to copy changed files incrementally to a different physical location. The vSAN Snapshot Service API provides programmatic access for operations including creating linked clones from snapshots and restoring deleted virtual machines.

VMware Kubernetes Service backup

VMware Kubernetes Service (VKS) and the Supervisor layer extend VCF's backup capabilities to containerized workloads, cluster state, and persistent volume data. VKS Supervisor backup and restore for cluster node VMs is activated through the vCenter backup feature available in the vCenter Management Interface, integrating Kubernetes cluster state backup with the same management-plane backup infrastructure used for other VCF components.

For workload-level backup of VKS clusters, the platform supports three complementary methods: vSphere Plugin Snapshot (CSI Snapshot), File System Backup (FSB), and the Velero Plugin for vSphere. The vSphere Plugin Snapshot method produces crash-consistent, block-level backups of persistent volumes through the Container Storage Interface (CSI) layer and supports snapshot direct access and network traffic offload; it is faster and less resource-intensive than filesystem backup for complex filesystems with large numbers of small files, making it well-suited for production databases and high-IOPS applications. The File System Backup method operates at the filesystem level, supports NFS volumes and incremental backups where unchanged files are not re-transferred between runs, and offers backup repository features including deduplication, compression, and encryption; it is appropriate for legacy volumes with non-CSI storage. The Velero Plugin for vSphere can back up and restore both stateless and stateful applications running on vSphere Pods in the Supervisor. Platform teams can use both FSB and CSI Volume Snapshots within a single protection strategy to maximize data durability across workload types. VKS cluster backup supports opt-in and opt-out approaches for FSB volume backup, giving operators control over which volumes are included in filesystem-level operations. Third-party backup software can also integrate with VKS clusters using the standard Kubernetes CSI snapshot API: tools create a VolumeSnapshot object from the target PVC, materialize a temporary PVC from the snapshot, and use a Data Mover pod to transfer data to the backup destination. Kubernetes implements Persistent Volume Claim as Snapshot Source Protection, which blocks deletion of in-use API objects while a snapshot is in progress, reducing the risk of partial or inconsistent backup data. Kubernetes also supports provisioning a new PersistentVolumeClaim directly from a VolumeSnapshot by specifying the snapshot as the dataSource, enabling volume-level point-in-time recovery without requiring a full application restore workflow.

VKS cluster management provides a Create backup wizard that allows users to create backups immediately or schedule backups of specified data resources in a cluster. Backup scheduling supports immediate execution, recurring schedule formats with targeted start times, or custom cron expressions; automated backup scheduling can also be configured using the Velero CLI with the `velero schedule create` command, specifying the interval or cron expression for recurring backup operations. For on-demand backups outside a scheduled window, the `velero backup create` command backs up Kubernetes resources and persistent volume data for stateful workloads, with support for per-namespace targeting and volume snapshot inclusion. VKS cluster backups can retain a maximum of 720 backups per backup schedule; when high-frequency schedules are required, the retention period should be reduced to remain within this limit. Backup schedules can be edited, paused, or deleted through

the management interface. File system backups are included in the restore by default, and snapshot data can be moved to a separate backup storage location. Before defining a backup, a target location and credential must be created; if a data protection credential is deleted, scheduled backups relying on that credential will fail on their next execution, creating a detectable gap in backup execution history that administrators should monitor. Creating a backup schedule requires the Organization Administrator or Project Administrator role.

VKS cluster backup and restore operations are managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management > Clusters > Data Protection. The portal provides restore operations on specific backups, and a dedicated cross-cluster restore capability in the Data Protection tab enables restoring backups from a source cluster to a different target cluster. VKS cluster management supports backup and restore of an entire cluster, selected namespaces from the backup, or specific resources identified by a label. The CloneFromSnapshot CRD includes a status.phase field that tracks restore progress through multiple phases, providing operational visibility during restore operations.

For Kubernetes cluster state, etcd is the backing store for all Kubernetes objects, and clusters using etcd should have a backup plan. etcd backup can be performed using the built-in etcdctl snapshot save command by specifying the endpoint, CA certificate, and client credentials, or by taking a volume snapshot of the etcd storage volume when the underlying storage supports it. etcd snapshots can be restored from a previous snapshot file or from the remaining data directory, and cross-patch-version restores are supported. During kubeadm upgrades, automatic backup folders are written to /etc/kubernetes/tmp containing etcd data and manifests as a recovery point.

Backup automation through APIs

VCF exposes backup automation through its APIs, including the RecoveryBackupJobBackupRequest data structure for specifying backup location, protocol, authorization, and database scope, as well as the RecoveryBackupSchedulesUpdateSpec for programmatically managing backup schedules.

Disaster recovery planning

For disaster recovery planning, VCF supports application disaster recovery with data replication to a secondary site. Organizations should plan and test disaster recovery strategies regularly to meet their RTO and RPO targets. VCF Operations provides integration with VMware Live Recovery for periodic test runs to validate that existing recovery plans work with the underlying infrastructure and configured RPO limits. Application disaster recovery may result in some data loss during failover depending on the configured RPO.

VCF directly provides the mechanisms for creating recurring backups, managing retention, and supporting RTO/RPO requirements through multiple backup and snapshot methods. However, organizations must establish backup policies, define RTO/RPO targets, schedule regular restore testing, and maintain backup infrastructure such as external storage and third-party backup solutions to fully satisfy this control.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) provides backup and restore capabilities for the vDefend control plane, covering firewall rules, microsegmentation policies, IDS/IPS configurations, Bare Metal server information, tokens, and all associated security data managed by the platform. These backups protect against data loss from hardware or software malfunctions, data corruption, malware incidents, or unintentional deletion.

SSP supports recurring backup schedules configurable through the Backup Schedule interface, with frequency options ranging from 6 hours to 720 hours (30 days), as well as weekly scheduling by selecting the day and time. Recurring backups can be activated or deactivated by toggling the Recurring setting. Best practice guidance recommends scheduling backups during periods of low platform usage to minimize operational impact. A backup should also be performed before executing scale-out operations on the SSP cluster, to preserve the current configuration state before significant topology changes. Backup data is encrypted with a passphrase and transmitted to an SFTP server. Adequate storage must be verified on the backup server before activating recurring backups, and the platform must be in a healthy state for backup operations to proceed. Backup is also blocked if NSX is not onboarded to SSP.

SSP maintains a Backup History section that displays the status of each backup operation, showing "Completed" when the operation succeeds. When backup or restore operations enter a failed state, pod logs provide detailed error messages, including database query failures and volume attachment errors, to support troubleshooting. Restoration supports deploying the backed-up configuration onto the same SSP instance or a new instance, enabling recovery when the current instance is in a non-recoverable state. Restoration requires that the same NSX instance that was onboarded at the time of backup be used, and that the platform be deployed on the same vSAN datastore and build version as the initial installation. Certificate consistency between backup and restored environments must be maintained to avoid disruptions to NDR Sensor connectivity.

These capabilities address the backup component of this control for vDefend's own configuration and policy data. vDefend does not back up general workload data or application-level information; those responsibilities fall to the broader VCF platform's replication, snapshot, and backup mechanisms, including vSAN Data Protection, Protection and Recovery (PNR), and integration with third-party backup providers. vDefend's contribution is limited to protecting the security policy and configuration data that defines the network security posture of the environment.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides replication, snapshot, and recovery testing capabilities that support recovery point and recovery time objectives for protected workloads.

vSphere Replication delivers host-based continuous replication with RPO configurable from 1 minute to 24 hours, set via a slider during replication configuration. PNR uses the configured RPO to determine the most recent available state to which virtual machines are recovered during disaster recovery. vSAN snapshots and replication is a native, integrated snapshot-based backup solution for VMs running on vSAN datastores, managed through the vSphere Client, and supports RPO as low as 1 minute. Snapshot retention schedules support hourly, daily, weekly, and monthly snapshots with a maximum retention duration of three years. Predefined retention templates are available for quick configuration of RPO and snapshot retention parameters. Array-based replication supports configuring replication schedule, frequency, and RPO through VM storage policies, depending on the storage array's implementation.

PNR replication classes are preconfigured with an RPO that defines the acceptable amount of data loss after a disaster. In deployments using VCF Automation integration, replication classes can be assigned at the organization level.

Cyber Recovery, the cloud-based recovery component within PNR, uses incremental snapshots that transfer only modified or new data to cloud backup. This design enables detection of ransomware encryption by comparing entropy rates between normal snapshots and snapshots containing suspect data. Ransomware recovery plans in Cyber Recovery support predefined retention templates for configuring snapshot RPO and retention parameters.

PNR's own configuration is protected through backup settings that specify a datastore path, enable or disable the backup scheduler, set a retention period, and schedule backup frequency and time. PNR REST APIs can be configured to export and upload configuration data to a datastore on a daily basis. PNR also maintains internal database backups for audit and recovery purposes, covering the replication manager database (srmdb), recovery manager database (vrmsdb), and snapshot service database (snapservice).

Recovery plan testing is the integrity verification mechanism for protected data. During disaster recovery execution, PNR first attempts storage synchronization; if that succeeds, it uses the synchronized storage state to recover virtual machines to their most recent available state per the configured RPO. RPO violation dashboards in VCF Operations report violation counts for incoming and outgoing replications, enabling monitoring of whether replication is meeting defined targets.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides a built-in backup framework for managed PostgreSQL, MySQL, and SQL Server databases, giving administrators and database owners the tools to establish recurring backup schedules aligned with organizational recovery objectives.

Backup configuration is available at database creation and can be modified at any time through the database settings interface. Administrators activate automated backups using the Enable Automated Backups toggle (also exposed as Enable Backups in MySQL flows), specify a backup location pointing to S3-compatible object storage, and define a retention period.

PostgreSQL databases support both full and incremental backups, and SQL Server databases support full and differential backup schedules. SQL Server adds a Log Backup Frequency setting in Advanced Settings with a maximum value of 30 minutes that is directly related to the Recovery Point Objective for that database. Backup schedules are expressed as cron expressions and can be customized per database or applied at the policy level.

Data Service Policies provide centralized backup governance for databases deployed within a namespace. A policy can include named backup jobs specifying backup type and schedule, and the policy backup requirement setting offers three options: Require Automated Backups (databases must have automated backups), Allow Automated Backups (users can choose to activate or deactivate automated backups), and Disallow. Allowed backup locations are defined in the policy via the `allowedBackupLocations` parameter, restricting where backups can be stored. When multiple policies apply, DSM aggregates the backup schedules into a single effective backup policy per database. High Availability clusters require automated backups to be enabled in order to provision databases, helping ensure that recoverable copies exist for replicated topologies.

DSM also supports on-demand backups for primary PostgreSQL databases, independent of the configured automated schedule, which is useful for capturing a point-in-time snapshot before a significant change. Backup storage is managed centrally through the Settings pane Storage Settings tab, which displays Database Backup Storage buckets and allows administrators to add or edit object storage targets. Provider-level control plane backups are stored in a designated Provider Backup Repo bucket configured during Provider VM setup, and recovery of the Provider VM from backup uses the `restore-provider` command with a `pgbackrest.conf` path to restore the appliance to the latest timestamp.

DSM retains automated backups of deleted databases until the configured retention period expires. When a database with configured backups is deleted, the system automatically creates an archive containing all collected backups that remains available in the Archives tab for the remainder of the retention period, allowing recovery of inadvertently deleted databases. Administrators can also manually delete retained backups of deleted databases when they are no longer needed.

Point-in-time recovery is supported from configured backup storage, restoring a backup at a specified date and time to a newly created database VM with a user-specified name and datastore location. The restore function is also accessible through the VCF Automation UI for tenant users. If any incremental backup in a chain is deleted, DSM cannot restore data to points in time that depended on that backup, and a restore from an incremental chain requires the last full backup plus all following incremental backups. Maintaining a balanced schedule of full and incremental backups reduces the risk of a gap in the recovery chain.

DSM provides operational validation of the backup target through the backup storage repository alert, which checks connection and operational status, bucket name, certificate expiration date, credentials, and sufficient available space in the repository. This helps surface configuration drift or storage failures that would otherwise compromise recoverability.

Satisfying this control fully requires that the organization define RTOs and RPOs for each database workload, configure backup policies accordingly, and periodically test restoration to verify that backup data is valid and recovery objectives are achievable. DSM provides the technical backup infrastructure and operational checks on the backup target; RTO and RPO definition and end-to-end backup integrity testing are organizational responsibilities.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) includes a built-in backup and restore capability for the Avi Controller configuration database. The configuration database defines all clouds, virtual services, users, tenants, and related entities. Protecting it is the primary mechanism for recovering the Avi control plane after a Controller failure.

Backup operations can be created on-demand or on a recurring schedule via the Controller web UI, CLI (using the `export` command), or REST API (using the `/api/scheduler/` endpoint). The scheduler supports configurable frequency units, including hourly, daily, and weekly intervals, with the run mode set to periodic. For single-node Controller deployments, enabling periodic external configuration backups is mandatory; the product documentation states that external backups are required to handle recovery from a complete VM or disk failure.

Avi supports multiple backup storage targets. Local backups are stored directly on the Controller with a configurable retention count, configured via the "Enable Local Backups (On Controller)" setting. Remote backups are transferred over Secure Copy

Protocol (SCP) or Secure File Transfer Protocol (SFTP) to an off-Controller server, configured via the "Enable Remote Server Backup" setting. In 9.1, configuration backups can also be stored in Amazon S3 buckets as an additional remote storage target. When deployed as part of VCF, Avi backups are stored by default on the same server used for VCF Operations appliance backups; the recommended best practice is to configure an external SFTP server as the backup destination. VCF Operations can be used to configure the external backup server and storage path for Avi backups. Product guidance also recommends storing backups with clear labeling that includes version and date information.

Before a restore proceeds, Avi performs a set of pre-restore checks to validate the backup image. In 9.1, these checks include verification of backup configuration version compatibility, presence of all file objects from the configuration on the Controller, FIPS mode consistency between the backup and the current Controller environment, Service Engine attachment verification, system configuration validation, and patch verification. All checks must pass before the restore operation is allowed to proceed.

Restore operations can be performed via the CLI (import command with the `keep_uid` option to restore configuration to an empty Controller), the web UI, or the REST API restore endpoint. The API method accepts a configuration file and a passphrase parameter to decrypt an encrypted backup; the passphrase must match the one used when creating the backup. Restore operations generate system reports tracking operation state, start time, end time, duration, and total checks completed. The Controller metrics database can also be exported and imported separately to prevent loss of metrics data during version rollbacks. If all three nodes of a Controller cluster are permanently unavailable, recovery must be performed using a backup and restore procedure.

For multi-site deployments, Avi GSLB (Global Server Load Balancing) supports an Active disaster recovery deployment mode, enabling traffic redirection to a healthy site when a primary site fails. Avi GSLB adaptive replication mode also protects against configuration errors propagating across data centers by preventing faulty configuration objects from being replicated to follower sites.

The Avi backup and restore capability covers the Controller configuration plane. Application data, workload VM images, and the broader RTO/RPO framework depend on organizational process decisions and on the underlying VCF platform for VM-level data protection (see VCF Coverage).

Control 164.308(a)(7)(ii)(B)

> Implementation specifications: Disaster recovery plan (Required). Establish (and implement as needed) procedures to restore any loss of data.

SCF Controls: BCD-12

Aggregate Coverage: Meets

VCF (Contributes)

VCF provides built-in capabilities for secure recovery and reconstitution of infrastructure and workloads to a known state after a disruption, compromise, or failure. These capabilities span compute-level high availability, storage-level data protection, structured backup and restore workflows for management components, and disaster recovery across sites.

At the compute layer, vSphere High Availability (HA) automatically restarts virtual machines on surviving hosts following a physical machine failure, restoring workloads to their prior operational state. vSphere Fault Tolerance provides continuous availability for individual workloads in the event of a hardware failure with no data loss or downtime. Proactive HA supports maintenance mode as a remediation method, allowing the platform to respond to hardware degradation indicators. On TPM-equipped hosts, VMware ESX supports a Secure ESX Configuration recovery key that is required to restore the host configuration following TPM failure, TPM reset, motherboard replacement, or TPM device replacement; administrators can retrieve and store this key using ``esxcli system settings encryption recovery list`` and should keep it in a secure, off-host location.

At the storage layer, vSAN fault domains distribute data according to storage policy so that it remains available even when hardware failures occur. vSAN stretched clusters extend a cluster across two availability zones, providing site-level resiliency against the loss of an entire availability zone. When one site becomes unavailable, the surviving site continues operations, and with local fault protection enabled, the cluster can perform repairs on missing or broken components in the available site. vSAN Data Protection uses native snapshots stored locally on a vSAN Express Storage Architecture (ESA) cluster to support point-in-time recovery from operational failures or ransomware attacks. Changed Block Tracking (CBT) tracks changes on disk sectors, enabling incremental backups through VADP-integrated partner backup solutions.

For large-scale disruptions, Application Disaster Recovery enables failover to a secondary site, with data replication so recovery options exist in the event of catastrophic failure. Disaster recovery can also be implemented for fleet-level components, covering the management plane itself. VCF documentation recommends planning and testing disaster recovery strategies regularly to validate that recovery time objectives (RTO) and recovery point objectives (RPO) can be met.

VCF includes structured backup and restore workflows for its management components. Administrators create a series of backup jobs that capture the state of related components, including VCF Operations, NSX Manager, and VMware vCenter, at a common point in time. VCF Operations backup is configured to take a backup on state change. VMware vCenter supports both file-based and image-based backup methods. The file-based restore procedure is a two-stage operation: stage 1 deploys a new vCenter appliance, and stage 2 transfers data from the backup location to that appliance; the restored appliance operates in non-HA mode, so vCenter High Availability must be reconfigured after recovery completes. Simultaneous backups of VCF Operations fleet management component nodes support restoring the nodes to a logically consistent state, so further integrity remediation is not required after a restore. The platform also recommends backing up the management domain vCenter and VCF Identity Broker appliance following any substantial modifications to the identity source configuration, such as a VCF SSO reset, to preserve a known-good recovery point.

For VMware vCenter specifically, the vCenter Management API provides a unified restore process that handles multiple vCenter components in a single operation. After a file-based or image-based restore, the reconciliation API checks whether vCenter partners in embedded linked mode are available, synchronizes vCenter data and services with the partners, and runs vCenter services. The appliance recovery API exposes a restore client interface for programmatic restore operations, supporting automation of recovery workflows.

VCF Operations supports image-based backup and restore as a recovery process for single node, primary node, replica node, data node, and collector failures. VCF Operations for Networks supports backup and restore of its deployment data to enable

recovery when the existing setup is unrecoverable. VCF Operations HCX provides backup and restore operations through its appliance management interface, and its Mobility Groups support workload migration with state tracking, retry capabilities, and reverse migration from destination back to the original source.

The Consumption layer of VCF, which encompasses VMware Kubernetes Service (VKS), vSphere namespaces, and VCF Services consumption, extends recovery and reconstitution capabilities to containerized workloads and self-service deployments. At the Kubernetes control-plane level, ReplicaSets and Deployment controllers continuously monitor pod health and reschedule workloads to healthy nodes when pods or nodes fail. Liveness probes detect application-level failures and trigger container restarts; readiness probes gate traffic until a workload recovers from transient faults or overloads. These self-healing mechanisms operate without manual intervention for transient failures. Pod Disruption Budgets allow administrators to define minimum availability constraints that the platform respects during voluntary disruptive actions such as node upgrades or certificate rotations, so those operations proceed without taking down an entire service.

VKS clusters support structured backup and restore through VKS Cluster Management and Velero-based mechanisms. VKS Cluster Management backup operations can capture an entire cluster or a subset of data resources, and restore operations allow the operator to specify the scope of resources to recover. Restore operations include file system backups by default; CSI volume snapshots can be optionally selected for restoration. CSI Volume Snapshots deliver crash-consistent backups with support for block mode and file system mode, incremental backups, deduplication, compression, and encryption, and provide a resilient safety net for VKS clusters when primary storage infrastructure fails. CloneFromSnapshot custom resources expose a status.phase field that tracks restore progress through multiple phases, giving operators visibility into the state of ongoing recovery operations. The Velero plugin for vSphere supports backup and restore of vSphere pods, and VADP-based backup partner solutions can perform backup, full restore, and registration of VM Service VMs on a Supervisor.

Deploying workloads across multiple failure zones using the Cluster API defines worker nodes across multiple failure domains with automatic healing rules that reschedule workloads when a zone becomes unavailable. Replicating control plane components across at least three failure zones limits the impact of a single-zone failure on the Kubernetes control plane itself. For VM Service workloads, the IaaS Services Console and Local Consumption Interface provide a Resources tab where users can create snapshots with optional memory capture and guest file system quiescence, and can revert a VM to a prior snapshot to restore it to a known state.

Deployment rollback is available natively in Kubernetes through Deployments with revision history, allowing administrators to return to a previous known-good revision when a newly deployed version fails. The Harness CI/CD Supervisor Service extends this with automated rollback capabilities that can revert to a previous stable state when deployment failures are detected.

Immutable infrastructure patterns supported by Kubernetes, combined with infrastructure-as-code stored in version control, provide a reproducible mechanism for reconstituting a cluster to a known, authorized state. Every change to the declared state is recorded in version control, and the cluster can be rebuilt from that record after a compromise or failure. VKS Cluster Management Policy Insights expose Sync signals that indicate when policy definitions fail to propagate from the management plane to the targeted VKS cluster estate, helping operators detect and remediate policy drift before it affects recovery posture.

Restore operations require that the target infrastructure be in place before a restore can proceed. VCF documentation recommends implementing a consistent backup strategy to safeguard the infrastructure against unforeseen disruptions and to support effective disaster recovery.

VMware vDefend (Contributes)

VMware vDefend contributes to secure recovery and reconstitution through backup and restore capabilities for its own security infrastructure, and through disaster recovery features that maintain security policy continuity across site failover events.

The Security Services Platform provides backup and restore functionality, accessible through the System > Backup and Restore interface, that allows recovery of a platform instance to its previous configuration when the current instance is in a non-recoverable state. The backup scope includes the full system inventory: tokens, Bare Metal servers, and Bare Metal server interfaces are captured as part of inventory backup, and required certificates from the backup server are restored

automatically during the restore process. The platform must be in a healthy state to perform backup operations; backup and restore cannot proceed when the platform is unhealthy. Certificate consistency between backup and restored Security Services Platform environments must be maintained to avoid NDR Sensor disruptions. Backup and restore operations enter a failed state after 30 minutes if internal services are restarted manually or due to failure. Administrators should back up the Security Services Platform before performing scale-out operations, and Bare Metal Service operations (onboarding, offboarding, or upgrading Bare Metal servers) should not be performed while backup or restore is in progress.

The Security Services Platform can be deployed on vSAN stretched configurations, which supports recovery from site failures and reduces recovery time at the infrastructure level.

For disaster recovery scenarios, NSX Federation maintains security posture during workload migration and site failover by propagating Distributed Firewall rules, security groups, and microsegmentation policies across multiple sites. When workloads fail over from a protected site to a recovery site, the vDefend security policies governing east-west traffic at the destination site are already in place. vSphere HA can be configured to handle host-level failures affecting Security Services Platform appliances.

The broader recovery of compute infrastructure, storage, virtual machines, and application workloads to a known state is handled by other VCF components such as Protection and Recovery, vSAN Data Protection, vSphere Replication, and vCenter backup and restore.

VCF Protection and Recovery (Meets)

VCF Protection and Recovery (PNR) provides mechanisms for secure recovery and reconstitution of virtual machine workloads to a known state after a disruption, compromise, or failure.

Recovery is organized through protection groups and recovery plans. Protection groups define which virtual machines are protected, while recovery plans orchestrate the sequence of steps required to recover those workloads at the recovery site. The state of a recovery plan is determined by the states of the protection groups within it, and the plan state governs which operations are permitted at each stage of the DR lifecycle. Recovery plans support two primary modes: planned migration for orderly, scheduled failover, and disaster recovery for unplanned site failures. A single recovery plan can also be configured to serve both disaster recovery and cyber recovery operations, allowing organizations to maintain consistent recovery procedures across different incident types.

Recovery plan testing is a built-in capability. Recovery plans should be tested before use for planned migration or disaster recovery to validate their functionality. This confirms that the recovery process will bring protected virtual machines online at the recovery site and that inventory mappings correctly place workloads on the appropriate networks, storage, and compute resources.

Cyber Recovery extends reconstitution capabilities with an Isolated Recovery Environment (IRE) designed for compromise scenarios such as ransomware incidents. The IRE provides a dedicated, isolated segment of the recovery environment that blocks direct private network connections from production, allowing compromised workloads to be analyzed and validated before being returned to production. Cyber Recovery transitions virtual machines through a controlled sequence of states, including Entering validated, Validated, Staging, and Staged, to prepare them for recovery. This state-based workflow supports data integrity validation prior to production restoration.

Recovery plan compliance checks verify that protection groups are actively replicating, that sufficient point-in-time snapshots are available for each virtual machine in the plan, and that all workflow steps can execute without conflict. Continuous compliance monitoring provides warnings when VM configuration status deviates from expected state.

The Configuration Import/Export Tool enables administrators to export PNR server configuration data, including inventory mappings, placeholder datastores, advanced settings, array manager configurations, and protection group definitions. This capability supports configuration backup and reconstitution of the PNR environment itself after a failure or migration.

PNR integrates with VCF Operations for recovery plan lifecycle visibility. The Recovery Plans Details dashboard shows the current phase of the DR lifecycle, including whether a plan is ready, whether a test is in progress, and whether incomplete recovery or cleanup operations require attention. PNR also supports recovery of VCF Automation and VCF Operations

services: when a disaster event affects the management domain containing these services, PNR enables service recovery in another management domain.

All communications between PNR and VMware vCenter instances use TLS certificates and private keys. The PNR Appliance supports importing server certificates signed by a certificate authority to establish secure communications across both protected and recovery sites.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support the secure recovery and reconstitution of database services to a known state following a disruption, compromise, or failure.

For backup-based recovery, DSM supports point-in-time recovery (PITR), which restores a backup to a newly created database VM. During the restore operation, the administrator can specify the database name, choose the target datastore location, and configure management settings. DSM supports restoring backups from either local or cloud-compatible (S3-compatible) storage, with restoration permitted to any point in time within the configured backup retention period. When restoring a deleted database, DSM's Archives tab allows users to access databases with retained backups and create a new database VM from a selected restore point, including options to restore to the most recent available timestamp or a custom point in time. PITR coverage extends across PostgreSQL, MySQL, and SQL Server database engines. For SQL Server, DSM automatically manages the database recovery model based on backup status, using Full Recovery for databases with automated backups enabled and Simple Recovery otherwise. Cloning a MySQL or PostgreSQL database is functionally equivalent to PITR to the latest available time, giving operators an additional path for rebuilding a known-good database instance. For failed clusters, DSM supports restoration to a different cluster with the option to target either the latest available time or a specific custom restore point.

For active recovery and failover of PostgreSQL databases, DSM provides a multi-site disaster recovery deployment model in which a secondary instance replicates from the primary across sites. When a failover is needed, DSM provides a switchover workflow that reverses the roles of instances, redirecting the secondary to become the new primary and restoring the database service to a fully operational state. DSM also provides a switchover workflow for failback, allowing operators to reverse instance roles again after the primary site is restored. DSM requires trust validation of the new primary database certificate when redirecting secondary instances during disaster recovery switchover, and operators with the DSM user role must manually establish trust between primary and secondary instances by retrieving the Certificate Authority from the primary and adding it to the Provider VM that will host the secondary. For backup-location certificates, DSM supports a Trust On First Use (TOFU) configuration that extracts and trusts certificates for specific backup locations, and at least one backup location must be configured with a trusted root certificate when a data service policy requires or allows automated backups. DSM also preserves the backing virtual machines of removed database nodes in an idle state until an instance is promoted again, maintaining infrastructure capacity for disaster recovery operations.

The resiliency of the DSM Provider Appliance itself is supplied by the underlying VCF platform (see VCF Coverage); DSM relies on vSphere High Availability to restart the appliance on another host in the event of a host failure, and does not add a separate management-plane HA mechanism. If a DSM provider restore fails for any reason, the documented procedure is to re-deploy the appliance and then follow the recovery procedure again rather than re-attempting the restore workflow on the same appliance.

DSM tracks recovery operations through its audit and operations interfaces. Event logs record Provider Restore Success events with timestamps, allowing operators to verify that recovery operations completed. Restore operation progress is visible in the Operations tab and Operations view, and a new entry appears in the Databases view table when a restore completes. To support integrity of recovery artifacts, the DSM Consumption Operator deployment includes Signature Verification of packages.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides application-layer recovery and reconstitution mechanisms at the load balancing and application delivery tier.

The Avi Controller cluster can be deployed across two availability zones, with defined failure scenarios and documented recovery actions for each zone-loss case. Availability zones should be configured based on fault domains associated with shared power supplies, shared networking devices, or other common infrastructure to reduce the risk of virtual service unavailability. When the cluster enters manual recovery state following a failure or compromise, Avi automatically revokes all Service Engine secure channel credentials and causes Service Engines to reboot themselves, halting all application traffic delivery. This returns the data plane to a controlled, known state. Service Engines that subsequently re-establish connectivity to a recovered Controller node reconfigure themselves automatically to connect only to that node.

If all three Controller cluster nodes are permanently unavailable, recovery must be performed using a backup and restore procedure. When a Controller node fails but is not permanently lost, it can be recovered by bringing the existing node back online, which is transparent to existing data traffic, or by rebuilding a new Controller node, which is disruptive to existing connections. Factory reset recovery is irreversible and deletes all Controller configuration, requiring the database to be recreated from the configuration archive. When a Service Engine is compromised or rebooted independently, all configurations including private keys and public certificates are wiped from the Service Engine, providing a clean starting state for reconstitution.

Elastic High Availability (Elastic HA) provides fast recovery for individual virtual services following the failure of a Service Engine, redistributing workloads to surviving Service Engines without requiring a full cluster-level recovery event. In vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, so application services are restored in a defined sequence.

Avi GSLB (Global Server Load Balancing) supports an Active disaster recovery deployment mode, enabling global-level recovery and reconstitution for applications served across multiple sites.

Avi provides configuration backup and restore capabilities for the Controller. A remote backup destination should be specified to protect against non-recoverable Controller cluster failures. The Controller checks and obtains user consent prior to performing a restore operation. After a storage failure requiring a full restore, the Controller is restored from the configuration archive. The restore process follows a defined sequence: cloud discovery, post-restore validation, configuration unblocking, and placement resumption. Post-restore validation verifies the count of restored configuration objects, including clouds and Service Engine groups, confirming that the reconstituted state matches the backup. Restore operations report state information including the operation type, image version, and cluster node name. The Controller logs restore completion events with timestamps, node IP addresses, task status, and success or failure messages for audit trail purposes.

Avi's recovery mechanisms address the application delivery tier. VM-level backup and restore for the Controller and Service Engine VMs, storage-level recovery, and infrastructure reconstitution depend on the underlying VCF platform. See VCF Coverage for those mechanisms.

Control 164.308(a)(7)(ii)(C)

> Implementation specifications: Emergency mode operation plan (Required). Establish (and implement as needed) procedures to enable continuation of critical business processes for protection of the security of electronic protected health information while operating in emergency mode.

SCF Controls: BCD-01, BCD-02.2

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a broad set of infrastructure-level capabilities that support business continuity and disaster recovery planning. While VCF does not itself constitute a Business Continuity Management System, it supplies the technical mechanisms that underpin resilient deployments and contingency operations.

vSAN stretched clusters allow organizations to extend a single vSAN datastore across two geographically separated sites with an independent witness host. When configured with site mirroring, a stretched cluster can tolerate the complete loss of one site while maintaining data availability. vSphere HA, when enabled on a stretched cluster, automatically restarts virtual machines on the surviving site during a site failure. To support this, vSphere HA admission control should be configured to reserve 50% of the cluster's aggregate CPU and memory resources for failover, and site-specific isolation response addresses should be defined so that vSphere HA can validate host isolation even when network connectivity between sites is lost. The admission control setting for host failures the cluster tolerates should also be updated after cluster expansion to reflect the correct host count per availability zone. When stretching a workload domain cluster, the default management vSphere cluster must already be stretched. vSphere HA uses network heartbeats to validate the state of VMware ESX hosts, and can also use heartbeat datastores mounted to more than one host (excluding vSAN datastores) for cluster membership monitoring.

vSphere HA also operates at the individual cluster level independent of stretched clusters. The HA configuration remediation mode can be set to quarantine mode, maintenance mode, or mixed mode to handle host failures in a controlled manner, helping maintain workload availability during hardware events. vSphere Fault Tolerance provides a higher tier of availability for individual virtual machines by maintaining a secondary VM in continuous lockstep with the primary, enabling instantaneous failover with no data loss if the primary host fails.

vSAN Data Protection provides snapshot-based protection through the vSAN Snapshot Service. Protection groups support configurable snapshot scheduling with adjustable intervals and retention policies that define retention duration and time units. This allows organizations to define data protection policies aligned with their recovery point objectives. The Snapshot Service API also supports operations such as restoring deleted virtual machines from snapshots and creating linked clones from snapshots.

vSphere Replication provides asynchronous replication of virtual machines with a configurable Recovery Point Objective (RPO), allowing organizations to replicate workloads to a secondary site and define acceptable data loss windows as part of their contingency planning.

VCF requires all management components, including VCF Operations, VMware vCenter, NSX, and VCF Automation, to be configured with a regular backup schedule and retention policy. VCF Operations configures NSX Manager backups during the initial deployment, with a recommended backup frequency of hourly and 7-day retention. Backup jobs for VCF Operations and all vCenter instances should start within the same 5-minute window to capture a consistent state. The VMware Infrastructure Health adapter within VCF Operations monitors backup job retention for management components, including NSX Manager. Changed Block Tracking (CBT) tracks modified disk sectors on virtual machines to support incremental backups, reducing backup windows and storage requirements for VM-level backup operations. vCenter itself also supports a High Availability configuration with Active and Passive nodes whose configuration files are continuously replicated, providing management-plane resilience independent of the backup schedule.

VMware HCX provides workload mobility capabilities for migrating and replicating VMs between sites. HCX supports multiple migration types through its Mobility Agent service, including vMotion, Cold Migration, Bulk Migration, and Replication Assisted vMotion (RAV), each addressing different scenarios from large-scale parallel migrations to zero-downtime live migrations.

HCX also includes appliance-level backup and restore capabilities for the HCX Manager, including certificate backup and restore, supporting planned migrations and recovery scenarios as part of broader BC/DR operations.

VCF Operations monitors infrastructure health and surfaces alerts when conditions threaten availability, giving operations teams early warning of potential failures. The Platform Health Alerts page provides a centralized view of alerts across data sources and infrastructure nodes. VCF Automation provides alerts through the associated VCF Operations application for capacity, performance, and availability monitoring. VCF Operations also includes infrastructure planning and what-if analysis capabilities that help organizations forecast capacity requirements and plan for contingency scenarios. Committed scenarios reserve capacity by setting aside resources for new, upcoming, or planned workloads, helping stakeholders understand capacity requirements across the environment. Integration with IT Service Management and Configuration Management Database platforms is supported through VCF Automation, enabling organizations to tie their infrastructure management into broader service continuity workflows.

Lifecycle management tools allow administrators to plan updates and schedule maintenance windows to make changes with minimal disruption to services, supporting the operational continuity aspect of business continuity planning.

While VCF provides these technical capabilities, a complete BCMS requires organizational elements that fall outside the platform: documented continuity of operations plans, recovery time and recovery point objectives defined by business stakeholders, regular testing and exercise of recovery procedures, communication plans, and management oversight of the continuity program. VCF supplies the infrastructure resilience and recovery mechanisms that such plans depend on, but the planning, governance, and procedural components must be established and maintained by the organization.

VMware vDefend (Contributes)

VMware vDefend contributes to business continuity by providing security-layer continuity mechanisms that remain active during disaster recovery events and workload migrations. NSX Federation Security maintains security posture across data centers during disaster recovery and workload migration, preserving distributed firewall and gateway firewall policies so that enforcement continues through failover.

The Security Services Platform, which provides the underlying infrastructure for vDefend's threat detection and inspection services, supports vSphere High Availability configurations. When a VMware ESX host becomes unhealthy, vSphere HA migrates the affected Security Services Platform virtual machines to healthy hosts in the cluster, restoring threat detection capacity without manual intervention. VMware recommends enabling vSphere HA for host-level failure recovery and configuring a storage policy with RAID for datastore-level failure tolerance in Security Services Platform deployments.

Security Services Platform can also be deployed on a vSAN stretched cluster configuration, which replicates storage across two physically distinct sites connected by a high-bandwidth or low-latency inter-site link. This configuration requires a minimum of two sites with their own hosts and a witness host to handle potential conflicts arising from network partitions, supporting site-level failure scenarios.

When vSphere HA restarts workload VMs on a new recovery host after a failover, the vDefend distributed firewall automatically reinspects all traffic from those VMs on the receiving host, because the Flow Table contents cannot be moved between hosts during host recovery. Security policy enforcement resumes on the new host without manual reconfiguration.

The broader BCMS framework, including Continuity of Operations Plan and BC/DR playbooks, impact analyses, and organizational governance processes, is outside vDefend's scope and must be established through dedicated business continuity management programs.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides the technical execution layer for contingency planning in virtualized infrastructure. Recovery plans define the sequence, priority, and configuration for failover operations, acting as executable BC/DR playbooks. Protection groups organize virtual machines into logical units aligned with application tiers or business functions, establishing the scope of each contingency plan.

Recovery plans support non-disruptive testing before use in planned migration or disaster recovery, allowing organizations to validate their contingency procedures without affecting production workloads. Recovery plan configuration differs between emergency scenarios at the protected site and planned migration of services from one site to another, with PNR supporting both modes. A forced recovery function is available during disaster recovery plan execution for scenarios requiring immediate failover.

vSphere Replication provides host-based replication with configurable Recovery Point Objectives (RPO), allowing organizations to set per-workload data loss tolerances. vSphere Replication supports up to 200 point-in-time recovery instances per virtual machine using the Latest Instances option, enabling recovery to specific earlier states. This capability is relevant to contingency scenarios involving data corruption or ransomware events. When the source site is accessible at the time of recovery, vSphere Replication can synchronize recent changes from the source site to the target site before completing the operation, reducing data loss.

In 9.1, PNR extends to multi-tenant disaster recovery through integration with VCF Automation. The product implements role-based access control with Organization Administrator, Project Administrator, and Project Advanced User roles, each with defined authorization levels for disaster recovery operations. Role assignments must be configured on both the primary and secondary PNR sites to maintain consistent access control across the DR environment. A multi-region deployment topology places separate management domains in each region to contain disaster impact to one region, while enabling service recovery in an alternate management domain when VCF Automation and VCF Operations are affected. The VCF Operations Orchestrator Plug-In for PNR provides Configuration, Inventory Mappings, Protection Groups, and Storage predefined workflow categories for workflow-driven recovery operations.

Cyber recovery deployments support a standard VCF topology where the workload domain is isolated from the management domain, providing separation between management and user workloads in clean-room recovery scenarios.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer resilience mechanisms at both the control plane and the data plane that organizations can incorporate into business continuity plans for application delivery services.

At the control plane, the Avi Controller is deployed as a cluster with continuous configuration replication across all nodes, providing management-plane redundancy so that a single Controller node failure does not interrupt application delivery operations. Avi supports deployment of the Controller cluster across two availability zones, with vSphere HA recommended to support recovery of any node that fails in the secondary zone. For single-node deployments, enabling vSphere HA on the Controller VM is recommended for node recovery following a host failure. The Avi Controller provides configuration backup and restore capability that supports disaster recovery and configuration migration across Controller instances; organizations should capture and retain Controller backups as part of their continuity documentation.

Availability Zone awareness in Avi allows multiple availability zones to be configured, each defining a subset of vCenter instances, hosts, and datastores that share a fault domain. Configuring availability zones during Service Engine Group setup distributes data-plane capacity across isolated failure domains, supporting continuity designs where application delivery capacity remains available if one fault domain becomes unavailable.

At the data plane, Avi's Elastic High Availability mode provides fast recovery for individual virtual services following Service Engine failure. In vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, giving the application delivery layer its own recovery path distinct from the infrastructure restart cycle. If vSphere HA does not recover the failed Service Engine within a configured timeout period, the Avi Controller resumes recovery independently. Service Engine VMs should be deployed on vSphere clusters configured with both HA and DRS in fully automated mode; when Avi is deployed with VMware Kubernetes Service (VKS) on VCF, DRS and HA are required on every vSphere cluster used with Avi.

For Kubernetes environments, the Avi Multi-Cluster Kubernetes Operator (AMKO) provides federation architecture that supports disaster recovery across Kubernetes clusters. AMKO designates a leader cluster and multiple member clusters, coordinating application delivery failover as part of a multi-cluster DR strategy.

Avi ControlScripts, used in conjunction with the alert framework, can perform automated failover actions such as adding or removing routes based on VIP attachment and detachment events, allowing organizations to define automated remediation workflows that respond to system events without manual administrator intervention.

In 9.1 deployments using VCF Automation, Avi's Central Licensing maintains a global capacity pool that removes the requirement for duplicate licenses in DR scenarios, supporting license continuity across failover sites.

Organizations should document these mechanisms, including the Elastic HA configuration, Controller cluster topology and backup schedule, availability zone placement, and AMKO federation design, in their Business Continuity and Disaster Recovery playbooks. The technical recovery capabilities are built into the product; the planning artifacts, testing procedures, and escalation workflows are organizational responsibilities that extend beyond what Avi provides.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 164.308(a)(7)(ii)(D)

> Implementation specifications: Testing and revision procedures (Addressable). Implement procedures for periodic testing and revision of contingency plans.

SCF Controls: BCD-04, BCD-05

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several infrastructure-level capabilities that support an organization's contingency plan testing and exercise program, though the planning, scheduling, execution, and evaluation of formal contingency tests remains an organizational responsibility.

VCF includes built-in recovery and high-availability mechanisms that organizations can exercise during contingency tests. vSAN stretched clusters can be exercised by simulating site failures through host maintenance mode operations, validating that the surviving availability zone continues storage and compute operations. A vSAN stretched cluster continues to function if a failure or scheduled maintenance occurs at one zone, and with local fault protection enabled, the cluster can perform repairs on missing or broken components in the available site. vSphere HA can be tested by deliberately failing hosts to observe VM restart behavior and confirm that admission control policies reserve sufficient capacity. vSphere HA uses admission control so that a cluster has sufficient resources to support virtual machine recovery when a host fails.

VCF Operations HCX supports workload migrations between sites through Mobility Groups, allowing organizations to exercise mobility procedures and validate that workloads can be moved to alternate processing locations. Migration activity, progress, and history are tracked through the Migration Planning interface, providing visibility into the results of migration exercises.

Management component backup and restore procedures can be tested by performing restore operations for VCF Operations, VMware vCenter, and NSX components. VCF documents the prerequisites and sequencing for file-based restore of these components, allowing organizations to validate their recovery procedures against documented expectations. Changed Block Tracking (CBT) enables incremental backups through VADP-integrated solutions that can be tested independently, and VADP-based backup partner solutions can perform backup, full restore, and registration of VM Service VMs on a Supervisor.

VCF Operations includes a What-If Analysis capability under its capacity planning module that allows administrators to model hypothetical scenarios against current infrastructure. Administrators can create, save, and run scenarios cumulatively to evaluate the demand and supply for capacity on resources and assess potential risk to current capacity. This supports both Traditional and Hyperconverged deployment models. Scenarios can be committed as planning tools for capacity analysis, helping organizations with separate capacity management and operations teams understand current capacity and upcoming capacity requirements. These what-if scenarios can be used as part of contingency testing to model failover capacity needs, validate that sufficient resources exist to absorb relocated workloads, and verify that planned recovery configurations are viable before an actual event occurs.

To support the separation of test and production environments during contingency exercises, VCF Operations allows administrators to configure custom groups with differentiated alert thresholds and capacity calculations. This allows a test environment to operate under different operational policies than production, which is useful when conducting DR drills or failover exercises that temporarily shift workloads between sites or clusters.

VCF also provides built-in pre-check and validation capabilities that verify component connectivity, version compatibility, and component status among other environment readiness checks. These pre-checks run automatically during lifecycle operations such as upgrades and remediation, and they help confirm that the environment is in a known-good state before changes are applied. While these are not contingency plan tests in themselves, they contribute to readiness assessment by confirming that infrastructure components are healthy and correctly configured before and after contingency exercises.

Organizations deploying VCF should establish a formal contingency plan testing program that includes scheduled DR drills, failover exercises, backup restoration validation, and tabletop exercises. VCF's recovery mechanisms, what-if analysis, and

pre-check capabilities can inform and support these activities, but the test plan itself, its schedule, success criteria, scenario design, evaluation criteria, and after-action review process must be defined and managed by the organization.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides non-disruptive testing of disaster recovery plans as a core operational capability. Recovery plans organize protected workloads into sequenced, dependency-aware execution groups, and these plans can be tested without affecting production operations on either the protected or recovery site.

Testing a recovery plan in PNR validates that virtual machines recover correctly to the recovery site and exercises nearly every aspect of a recovery plan to validate disaster recovery readiness. Testing has no lasting effects on either the protected or recovery site, which means exercises can be repeated at any frequency without risk to production workloads. PNR requires that recovery plans be tested before use for planned migration or disaster recovery operations. Recovery plan tests can be canceled at any time; however, a successful cleanup operation must be completed before running a failover or initiating another test.

Recovery plan test execution is tracked through the Test task in Recent Tasks, which monitors overall progress of the test operation. Recovery plans support two types of custom steps: Test Steps that run during recovery plan testing, and Recovery Steps that run during planned migration or disaster recovery operations. The Configure Test Networks step in the recovery plan workflow supports using a separate test network at the recovery site to keep test VMs isolated from production network segments during testing.

Recovery plan testing can be automated through the VCF Operations orchestrator Plug-In for Protection and Recovery. The Initiate Test Recovery Plan workflow starts a test of a selected recovery plan and performs a state check to verify the recovery plan is in ready state before allowing test execution. The Initiate Cleanup Recovery Plan workflow cleans up a test when the recovery plan is in needsCleanup state.

The organizational elements of contingency plan testing, including exercise scheduling, scenario design, evaluation criteria, and after-action reviews, are outside PNR's scope. Recovery plan testing supports two distinct pre-production rehearsal modes: test recovery, which validates failover into an isolated environment without disrupting production, and planned migration, which performs an orderly, validated move of workloads. Tests can be used to verify that recovery time and recovery point objectives are met, and can be run unattended through the VCF Operations Orchestrator plug-in and the REST API for scheduled or scripted execution.

Not applicable for this control: VMware vDefend, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.308(a)(7)(ii)(E)

> Implementation specifications: Applications and data criticality analysis (Addressable). Assess the relative criticality of specific applications and data in support of other contingency plan components.

SCF Controls: AST-01, AST-01.1, BCD-02, TPM-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF contributes to IT Asset Management programs through built-in inventory, discovery, and integration capabilities that provide the technical foundation for asset tracking and governance.

VCF Operations groups discovered objects logically and provides detailed inventory lists across the environment, covering compute, storage, and networking resources. The inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group.

The Service Discovery adapter automatically discovers applications, services, and their associated metrics (CPU, memory) running on managed infrastructure. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be exported in CSV format for use in external asset tracking systems.

For organizations using ServiceNow, VCF provides two integration paths. The Management Pack for ServiceNow in VCF Operations populates the ServiceNow CMDB with discovered resources through the ServiceNow Table API and CMDB Meta API, providing CMDB visibility within VCF Operations. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation provides a structured data source that captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

VCF Automation adds governance through its project model, which controls who can deploy what resources and where those resources are deployed. Projects link users, catalog items, and IaaS resources together. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources.

Tags within VCF Automation express capabilities and constraints that define deployments. Cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

The broader ITAM program responsibilities of establishing asset governance policies, defining ownership lifecycles, and maintaining organizational accountability remain outside VCF's scope.

VMware vDefend (Contributes)

VMware vDefend contributes to identifying and documenting critical technology assets through the Security Services Platform (SSP) and its Security Intelligence feature, which provide asset inventory, classification, and visualization capabilities oriented toward network security segmentation planning.

Security Services Platform maintains a Platform Inventory of infrastructure assets, collecting status information for each asset including identification of assets that are timed out or out of sync. The inventory view provides filtering by Name and Status to locate specific infrastructure assets and identify their operational state. Tags assigned to each infrastructure asset are displayed for verification of tag assignments.

Security Intelligence gathers infrastructure services and servers from CSV files and discovers additional services and servers based on traffic flows analyzed from ESX hosts. During CSV import, Security Intelligence parses and validates the content format and inventory asset data. Security Intelligence also maps discovered unique assets during segmentation analysis, including workloads, groups, IP addresses, distributed virtual port groups (DVPGs), segments, tiers, infrastructure services, and infrastructure servers.

Security Services Platform identifies and publishes application assets, classifying them as either critical or regular applications. This criticality classification supports the identification of mission-critical technology assets within the environment. The inventory hierarchy spans regions, zones, environments, applications, and tiers, with each level displaying the total number of assets within its scope.

Security Intelligence organizes discovered and imported assets into structured Asset Collections: groups, infrastructure assets, environments (such as Production, Non-Prod, DMZ, PCI, and Development), applications, and application tiers. The Environment Asset Collection maps security zones to the operational contexts that support business functions. Application Asset Collections group workloads that provide enterprise functionalities, linking infrastructure resources to the business services they support. The Infrastructure Asset Collection node covers core networking services that enterprise workloads depend on, including LDAP, DNS, NTP, and DHCP. An Unknown Asset Collection surfaces compute entities that are not in the NSX inventory but are present in the data center and communicating to NSX entities, supporting discovery of assets that should be formally inventoried.

Security Intelligence Workload Classification can be set to "Infrastructure Service" to indicate that a compute entity provides infrastructure services such as DNS, DHCP, LDAP, and Syslog. Inferred infrastructure classifications for compute entities can be reviewed, accepted, or modified through the Monitor & Plan > Security Explorer interface.

These capabilities contribute to the control but do not fully satisfy it. vDefend's asset identification is scoped to network security segmentation planning rather than the enterprise-wide technology asset catalog this control requires. Identifying all critical technology assets, applications, services, and data across an organization requires broader inventory and configuration management capabilities within VCF, such as VCF Operations business application views, VMware vCenter inventory exports, and VCF Automation project tagging, which provide the enterprise-wide asset catalog that vDefend's security-focused inventory complements.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) organizes its protection model around identifying which assets are critical enough to warrant disaster recovery protection. Protection groups are an explicit declaration of critical assets, organizing virtual machines into logical units based on their replication and recovery requirements. Placing a workload in a protection group is a deliberate act of classifying it as essential to business operations.

Inventory mappings document how each protected-site asset (resource pools, folders, networks, datastores) corresponds to recovery-site resources, creating a structured record of the infrastructure that supports critical workloads. Site-wide inventory mappings apply defaults across all protected VMs, while per-VM customizations document specific recovery configurations for workloads with unique requirements.

The Protection and Recovery Configuration Import/Export Tool exports a complete record of the DR asset inventory, including site names, inventory mappings, placeholder datastores, advanced settings, array managers with SRA information, protection groups, and recovery plans. This export provides a structured, portable document of which assets are protected and how they are configured for recovery. The export is produced in XML format, enabling automated processing and retention as a configuration record.

PNR generates and exports reports documenting each run of a recovery plan, each test of a recovery plan, and each test cleanup operation. These reports provide an auditable record of which recovery plans executed and which protected workloads were involved.

PNR tracks site metrics including paired sites, pair names, vCenter addresses, site connectivity status, and counts of protection groups, recovery plans, protected virtual machines, and array managers. VCF Operations collects configuration, component health, and usage information from protection and recovery servers and site pairs, providing consolidated visibility into the DR infrastructure as a class of managed assets.

Not applicable for this control: VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.308(a)(8)

> Standard: Evaluation. Perform a periodic technical and nontechnical evaluation, based initially upon the standards implemented under this rule and, subsequently, in response to environmental or operational changes affecting the security of electronic protected health information, that establishes the extent to which a covered entity's or business associate's security policies and procedures meet the requirements of this subpart.

SCF Controls: CPL-03.2, IAO-01.1, IAO-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides configuration-state review and continuous compliance monitoring capabilities that contribute to regular functional reviews of cybersecurity and data protection controls across the infrastructure stack, though the organizational review process, schedule, and corrective action procedures must be established and maintained outside the platform.

VCF Operations includes a compliance management capability that continuously monitors infrastructure against industry-standard security benchmarks and custom policies. Rather than relying solely on periodic manual reviews, VCF Operations flags configuration drift and policy deviations as they occur, giving auditors and administrators ongoing visibility into the compliance posture of technology assets and services running on the platform. When VCF Operations detects non-compliance with a policy, it can generate alerts or notifications, and depending on the severity, administrators can configure automated remediation actions to bring the object back into compliance. Compliance management detects violations, highlights risk areas, and provides actionable remediation recommendations.

VCF Operations calculates a compliance score for each managed object based on the ratio of compliant objects to total objects assessed by a given benchmark, expressed as a percentage. The most critical violated standard determines the overall compliance score for a given object, making it straightforward to identify which assets need attention first. Compliance score cards display the number of non-compliant objects and the total number of objects affected by each hardening guide. Administrators manage all compliance-related tasks from the Security > Compliance page, where they can discover non-compliant objects, review associated violations, and take remedial action.

To support structured reviews against recognized standards, VCF provides pre-built compliance packs available as native packs from the compliance repository. These include packs aligned with ISO security standards and the DISA Security Technical Implementation Guide (STIG), among others. Organizations can apply these packs to evaluate their VCF deployment against established security baselines, identify gaps, and track remediation progress. The vSphere Security Configuration Guide and the vSAN Security Configuration Guide provide additional hardening guidance and address compliance considerations, and are references for what settings and configurations to verify during a functional review. The NSX Security Configuration Guide provides recommendations for securing NSX components such as NSX nodes, NSX Controllers, and NSX Edge nodes.

Beyond the built-in benchmarks, organizations can create custom compliance benchmarks that codify their own cybersecurity and data protection policies. Custom benchmarks are configured through a multi-step process that includes naming, selecting compliance alerts to monitor, and activating policies. VCF Operations supports up to five custom compliance score cards. Custom benchmarks can be exported from one VCF Operations instance and imported to another, providing consistent policy enforcement across multiple deployments.

At the host layer, VCF Operations Configuration Drifts provides a proactive method to monitor configuration changes across vCenter instances and vSphere clusters. vSphere Configuration Profiles must be enabled on clusters to view drift status, and the feature applies to deployments running VCF or later. The Configuration Drift dashboard allows administrators to view and monitor drift statuses, detecting when hosts fall out of their desired-state configurations. vSphere Lifecycle Manager can check the compliance of a cluster or host against the desired state and determine whether additional remediation steps are required.

NSX provides its own compliance status reporting. NSX Manager offers a Compliance Status Report accessible from the Monitoring Dashboards that displays the number of affected resources and compliance status. The report identifies non-

compliant configurations by non-compliance code, description, compliance standard violated, affected resource name or ID, and resource type. Organizations can use the NSX compliance report to configure their NSX environment to adhere to IT policies and industry standards.

The VMware Kubernetes Service (VKS) layer of VCF extends compliance review capabilities to containerized workloads and the Kubernetes control plane. Pod Security Admission (PSA) is the built-in Kubernetes admission controller that evaluates pod specifications against defined security standards at the point of deployment. PSA operates in three modes: enforce blocks non-compliant pods from running, audit records security violations as audit events without blocking deployment, and warn returns warnings to the caller without blocking. Organizations can configure PSA to enforce a baseline standard cluster-wide while operating the restricted standard in audit and warn modes, producing an ongoing stream of compliance findings about workloads that do not meet the stricter profile without disrupting existing workloads. PSA can be configured per namespace using the podSecurityStandard API, allowing different review stringency to be applied to different teams or workload types. Pods' security contexts should be separately reviewed to identify any privileges or capabilities that exceed what the predefined security standards permit for a given use case.

VKS Cluster Management provides out-of-the-box security policy templates that mirror the Kubernetes Pod Security Standards profiles, including baseline and restricted. The baseline template mitigates common privilege escalation risks while maintaining compatibility with standard containerized workloads. Custom security policy templates extend these defaults, allowing organizations to fine-tune individual security context parameters in support of governance requirements specific to their environment.

For Kubernetes RBAC review, the Kubernetes documentation distributed with VKS notes that the default RBAC rights provided in clusters should be reviewed to identify opportunities for security hardening. Auditors reviewing a VKS deployment should examine ClusterRole and ClusterRoleBinding objects for overly broad permissions as well as namespace-scoped Role and RoleBinding objects for each team or namespace. IAM role trust policies should be scoped to specific service accounts and namespaces to support least-privilege enforcement.

STIGs for VKS system components, including Supervisor and VMware Kubernetes Release (VKr) components, are available through Tanzu STIG Hardening and provide a recognized baseline against which deployed VKS environments can be compared during periodic compliance reviews.

Harbor Registry, available as a standard package on VKS clusters, provides vulnerability scanning, content trust, and policy-based replication to help evaluate the security of the container image supply chain. Harbor's role-based access controls and artifact policies can themselves be audited to confirm that only approved images are accessible to workloads. Within CI/CD pipelines integrated through Harness, the Harness Security Testing Orchestration (STO) capability enforces policy based on CVE data and severity thresholds, and Wiz integrates with the pipeline to authenticate to the artifact registry, pull container images, and perform vulnerability scanning before workloads are promoted to production. Wiz can also be deployed as a service on VKS clusters to continuously monitor the cloud environment and deployed workloads for security risks and compliance deviations.

Third-party policy engines such as Kyverno and OPA Gatekeeper can be deployed on VKS clusters to implement policy-as-code compliance review. These tools evaluate cluster resources against defined policies and can generate compliance reports identifying violations across the cluster, extending the platform's built-in review instrumentation.

For auditors evaluating a VCF environment against this control, the key areas to examine are: whether VCF Operations compliance monitoring is enabled and configured with benchmarks that map to the organization's policies; whether compliance packs appropriate to the organization's regulatory environment have been applied; whether the Configuration Drifts feature is active for vSphere clusters; whether PSA is configured in audit and warn modes on VKS namespaces to produce ongoing compliance findings; whether RBAC bindings across VKS clusters have been reviewed against least-privilege expectations; and whether the compliance dashboard and NSX compliance reports are being reviewed on a regular cadence with findings triaged and remediated.

These capabilities verify that infrastructure configurations match desired baselines and that compliance benchmarks are met, but they do not functionally test whether security controls are actively operating as intended. Organizations should

supplement VCF's configuration-state reviews with periodic functional validation such as security assessments or controlled test scenarios. The review schedule, escalation procedures, and corrective action processes are organizational responsibilities that VCF does not enforce on its own.

VMware vDefend (Contributes)

VMware vDefend contributes to the functional review of cybersecurity controls by providing network security-specific compliance assessment, policy analysis, and segmentation scoring capabilities. While the broader review of all technology assets against organizational policies is handled by VCF Operations and its compliance management features, vDefend provides the network security dimension of that review.

Security Services Platform includes a Security Segmentation score and report generation capability that helps compliance officers meet security audit requirements and demonstrate adherence to network security best practices. This scoring mechanism evaluates the current state of microsegmentation policy enforcement across the environment, providing auditors a quantitative measure of alignment between network security controls and policy objectives. The Security Segmentation Score Breakdown report details total environments and pairs, protection rule actions, and highlights environment pairs that lack inter-environment policies, providing specific visibility into coverage gaps in the microsegmentation posture. The Security Policies window within Security Services Platform displays all firewall rules applied for environment pairs, and administrators can change the action of published environment pair protection rules directly from this view.

The metrics service within Security Services Platform collects key performance indicators and operational data points across vDefend components including Distributed Firewall, Gateway Firewall, IDS/IPS, and TLS Inspection, providing the data foundation for ongoing compliance reviews. Viewing the TLS Inspection dashboard requires Security Services Platform to be deployed with the Metrics feature enabled. Security Services Platform Inventory monitoring allows administrators to view the infrastructure hierarchy including regions, zones, and VMs to verify correct definition, supporting periodic reviews of Technology Assets.

Security Services Platform's Security Intelligence capability provides policy recommendation analysis that compares recommended rules, groups, and services against the current environment to identify gaps between desired and actual security policy. Administrators use the Monitor & Plan interface to review, filter, and manage policy recommendations, identifying where current firewall rules diverge from what traffic analysis suggests is appropriate. Recommendations can be filtered by Status and Ready to Publish state, and scoped to selected groups and VMs. Policy Recommendations can be exported in JSON format with resource_type, id, and children elements for infrastructure and domain configuration, allowing compliance teams to analyze recommended rule sets outside the platform.

The Security Overview dashboard in Security Services Platform provides summary-level statistics of file inspections, and the platform provides monitoring of current deployment status and platform-related alarms that highlight errors requiring attention. Security Services Platform support bundles collect diagnostic information from all controller and worker nodes in the deployment for troubleshooting and compliance documentation. Security Services Platform also supports assessment of control effectiveness by enabling comparison of the ratio of detected versus prevented events, providing reviewers a quantifiable measure of security control activity relative to observed threats.

Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. The dedicated Auditor role is designed for personnel performing compliance and security reviews, allowing compliance teams to access review and assessment capabilities without requiring administrative privileges.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides built-in mechanisms that support regular review of database infrastructure assets for adherence to security, compliance, and resilience policies.

The most direct compliance review mechanism in DSM is the Compliance tab, available on each data service policy detail page. This tab displays compliance reports for data service policies and allows administrators to expand policy violations to

identify noncompliant databases, data services, namespaces, and resource configurations. Administrators can use this view to assess which database instances are operating outside defined policy parameters and take corrective action.

Infrastructure policies in DSM create a framework of standards against which deployed database resources are evaluated. Administrators define data service policies that govern resource consumption limits, storage placement, VM class selection, and IP range assignments. These policies apply to PostgreSQL, MySQL, and SQL Server databases and can be enforced across different tenants to maintain a consistent security and compliance posture. The Infrastructure Policies view in the DSM administrator UI lists all policies in the environment and shows which databases are associated with each policy, providing a consolidated view for compliance assessment.

DSM generates infrastructure policy compliance alerts, including `INFRASTRUCTURE_POLICY_CLUSTER_COMPLIANT` and `INVALID_SUPERVISOR_INFRASTRUCTURE_POLICY_STATUS`, to flag when cluster configurations drift from policy requirements. The monitoring framework also raises metrics-based and status-condition-based alerts to identify critical failure conditions across database engines, including engine degradation, non-operational status, and backup failures for PostgreSQL, MySQL, and SQL Server databases. These alerts provide ongoing visibility into the compliance and resilience state of database resources without requiring manual inspection.

For resilience review specifically, DSM requires that High Availability be activated on VMware vCenter clusters as a prerequisite for infrastructure policy compliance. The resiliency of the DSM Provider Appliance itself is provided through vSphere HA. These requirements are surfaced through the policy compliance alerting mechanism, making infrastructure resilience status an integrated part of policy compliance reporting.

Organizations should supplement DSM's built-in compliance reporting with documented review schedules, assigned review responsibilities, and a process for tracking and remediating identified violations. DSM provides technical visibility into policy adherence for database infrastructure, but the organizational governance processes that constitute a complete functional review program remain the responsibility of the operating organization.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) supports organizational reviews of application-layer security, compliance, and resilience through its built-in reporting capabilities.

The Application Security Report generates audit-ready records of WAF findings, statistics, and overall security posture accessible to both technical teams and executive stakeholders. The report is available as a downloadable PDF, making it suitable for sharing findings with auditors and compliance reviewers. Security teams can use this report to assess whether Avi-managed applications are aligned with organizational security policies and to track posture over time.

The WAF Evaluation Report provides structured recommendations for strengthening an application's security posture, giving reviewers a concrete basis for identifying and remediating configuration gaps across virtual services.

In 9.1, Positive Security configuration has been consolidated under Virtual Service > Positive Security Policy, a change from its prior location within the WAF Policy. This mechanism determines which learned application behaviors are promoted to enforced security rules. Periodic review of the Positive Security Policy is part of maintaining the application security posture across Avi-protected services.

User-Defined Metrics extend Avi's reporting capabilities by allowing administrators to define and extract customized telemetry data required for specific enterprise compliance or reporting needs through API calls. This capability supports integration of Avi-specific application metrics into broader compliance dashboards and review workflows.

Avi's contribution to this control is bounded by its role as an application delivery controller. The review program this control requires, encompassing all technology assets and services across the organization, is an organizational governance responsibility that extends beyond the application-layer reporting and validation capabilities Avi provides.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 164.308(b)(1)

> Business associate contracts and other arrangements. A covered entity may permit a business associate to create, receive, maintain, or transmit electronic protected health information on the covered entity's behalf only if the covered entity obtains satisfactory assurances, in accordance with § 164.314(a), that the business associate will appropriately safeguard the information. A covered entity is not required to obtain such satisfactory assurances from a business associate that is a subcontractor.\

SCF Controls: TPM-01, TPM-04, TPM-05, TPM-05.2, TPM-05.4

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.308(b)(2)

> A business associate may permit a business associate that is a subcontractor to create, receive, maintain, or transmit electronic protected health information on its behalf only if the business associate obtains satisfactory assurances, in accordance with § 164.314(a), that the subcontractor will appropriately safeguard the information.\

SCF Controls: TPM-05, TPM-05.2, TPM-05.6

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.308(b)(3)

> Implementation specifications: Written contract or other arrangement (Required). Document the satisfactory assurances required by paragraph (b)(1) or (b)(2) of this section through a written contract or other arrangement with the business associate that meets the applicable requirements of § 164.314(a).

SCF Controls: IAO-03.2, TPM-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.310(a)(1)

> Standard: Facility access controls. Implement policies and procedures to limit physical access to its electronic information systems and the facility or facilities in which they are housed, while ensuring that properly authorized access is allowed.

SCF Controls: GOV-02, PES-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.310(a)(2)(i)

> Implementation specifications: Contingency operations (Addressable). Establish (and implement as needed) procedures that allow facility access in support of restoration of lost data under the disaster recovery plan and emergency mode operations plan in the event of an emergency.

SCF Controls: BCD-09.2, HRS-03, PES-02, PES-02.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.310(a)(2)(ii)

> Implementation specifications: Facility security plan (Addressable). Implement policies and procedures to safeguard the facility and the equipment therein from unauthorized physical access, tampering, and theft.

SCF Controls: GOV-02, PES-01, PES-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.310(a)(2)(iii)

> Implementation specifications: Access control and validation procedures (Addressable). Implement procedures to control and validate a person's access to facilities based on their role or function, including visitor control, and control of access to software programs for testing and revision.

SCF Controls: IAC-01, PES-02, PES-03, PES-06

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a layered identity and access management architecture spanning centralized identity services, role-based access control, group-based access policies, identity provider federation, and programmatic access management through APIs.

VCF SSO is the centralized authentication service. VCF SSO issues security tokens that grant authenticated users access to VMware vCenter, NSX Manager, VCF Operations, and other platform components without requiring separate credentials for each service. VCF Operations supports importing users and groups from VCF SSO for consistent identity management across the stack. VMware Identity Manager provides a platform for managing users and groups, managing resources and user authentication, and configuring access policies and resource entitlements. vCenter also supports built-in identity source authentication using local domain credentials. The built-in identity provider can also be configured to use Active Directory as an identity source through LDAP/S, OpenLDAP/S, or Integrated Windows Authentication (IWA), depending on the directory environment.

VCF supports federation with enterprise identity providers. vCenter can be federated to providers such as Microsoft Entra ID, ADFS, and Okta, which enables multifactor authentication and automatic user synchronization with the organization's directory. PingFederate is also supported as a federated identity provider; for these integrations, vCenter uses System for Cross-domain Identity Management (SCIM) to automate the exchange of user and group identity information between the external identity domain and vCenter. VMware Identity Broker allows principals to authenticate to vCenter through an external identity provider. NSX Manager can be configured to authenticate users from identity management providers and can be integrated with Workspace ONE Access for identity management services. The Supervisor component supports registration of OIDC-compliant external identity providers for authentication to VMware Kubernetes Service (VKS) clusters; supported providers include Okta, Workspace ONE Access, and Dex, configured by supplying the Supervisor callback URL to the identity provider.

Role-based access control is enforced across all VCF components. In vCenter, permissions associate a user or group with a role on a specific inventory object, and predefined roles cover common administrative functions. Custom roles can be created with only the minimum required privileges for a given workflow. Managing identity provider configuration in vCenter requires the VcIdentityProviders Manage privilege. VCF Operations supports group-based access control, allowing administrators to configure groups and assign roles that control access to dashboards, reports, policies, alerts, and administration functions, as well as granular role-based controls for platform operations including approvals, audits, certificates, and content libraries.

VCF Automation extends access management through organization-level and project-level controls. The VCF Automation Access Control service supports identity operations for managing groups and users, including editing user names, passwords, and role assignments. The organization portal enforces role-based access control, requiring either Organization Administrator or Organization Auditor roles to manage policy templates. Organization administrators can distribute infrastructure and configure group-level access through the organization management functionality. Project access is governed by predefined roles. Users and groups can be disabled at the organization level to revoke access without deleting accounts. The System Administrator role has the right to manage and view Access Control Lists, and the accessControls API allows administrators to view and manage ACL entries for defined entities.

For Kubernetes workloads within the VCF consumption layer, VKS supports two authentication methods: VCF SSO and OIDC-compliant external identity providers. The OIDC path is implemented through Pinniped and supports providers including Okta, Workspace ONE Access, Dex, GitLab, and Google OAuth. Configuring an external provider requires setting up an OpenID

Connect ID Token with a Groups claim type filter to enable group-based access control tied to the organization's directory. Custom ClusterClass configurations allow clusters to authenticate developers using existing corporate identity systems. VKS supports namespace permission roles: Owner (full control including deletion), Can Edit (provisioning and operating workloads), and Can View (read-only access). These roles map to Kubernetes ClusterRoles through RoleBindings, and RoleBinding objects can reference VCF SSO users and groups directly to integrate SSO identities with Kubernetes role-based access control. A user with the Namespaces.Edit privilege on a user-created Namespace folder can perform CRUD operations on Kubernetes API resources in the Supervisor. Namespace Self-Service permissions control which users can self-provision namespaces through kubectl.

Kubernetes RBAC is the primary authorization mechanism within VKS, using Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings to bind permissions to users, groups, or service accounts. Kubernetes Attribute-Based Access Control (ABAC) is also available, defining access rights through policies that combine user, namespace, resource, and access mode attributes. Authorization webhooks can interpret field and label selectors to enforce fine-grained access control based on resource attributes such as node names and labels.

Service accounts provide namespaced workload identity within VKS clusters. For Windows containers, the Group Managed Service Account (gMSA) Webhook allows containers to run as Active Directory identities. VKS service accounts can be annotated with IAM role ARNs to enable pod identity and role assumption for cloud resource access through OIDC federation, replacing long-lived static credentials with short-lived, least-privileged credentials on demand. IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege.

Several supplementary services within the VKS layer extend the IAM surface. Harbor Registry, available as a standard package on VKS clusters, enforces role-based access control to manage access to container image artifacts. The Secret Store Supervisor Service enforces RBAC for administrators, DevOps engineers, and application tenants managing sensitive data. Argo CD supports both OIDC configuration for external identity providers and local account configuration with global RBAC policies that define role-based access through policy rules and group mappings. The Istio service mesh package includes a pluggable policy layer supporting access controls, rate limits, and quotas at the service-to-service level.

Programmatic access management is available through several APIs. The Identity API authenticates and manages the authorization provider. The Identity Service and Infrastructure as a Service APIs are used to acquire access tokens for REST API authentication. Principal Identity users authenticate using client certificates for service-to-service communications between VCF components.

NSX integrates with LDAP and external identity management services for administrative access to networking configuration. NSX Manager enforces role-based access control with roles such as auditor and network administrator assignable to LDAP users. vDefend, a separate product that extends NSX with security capabilities, offers an Identity Firewall that integrates with Active Directory for identity-based firewall rules.

VMware Private AI Services (PAIS) provides OIDC-based authentication and group-based authorization for AI workloads, the primary IAM mechanisms controlling access to model endpoints, the model runtime, Agent Builder, and Data Indexing and Retrieval capabilities. PAIS authentication is configured with an issuer URL, a client ID (pais-authentication-id), and the openid, groups, and offline_access scopes. The OIDC provider must support the .well-known/openid-configuration discovery endpoint. Authorization restricts access to user accounts that are members of named groups listed in the authorizedGroups setting (such as group-for-pais-access-01 or group-for-pais-access-02). A groups claim is included in the Access Token and a corresponding groups scope is created in the OIDC configuration, while the oidc-groups-claim setting selects which claim name carries group membership when the OIDC provider uses a non-default name. The oidc-extra-audiences setting accepts additional OAuth 2.0 client identifiers that PAIS will accept when validating Access Tokens, supporting integration with downstream clients that present their own audience. Activating PAIS in an organization namespace requires coordination with the OIDC provider administrator and an organization administrator account in VCF Automation.

Identity provider integration for PAIS deployments is configured at the Supervisor level under Workload Management > Supervisors > Configure > Identity Providers. When a PAIS region is created for a Supervisor, an identity provider entry is

automatically created in VMware vCenter for that Supervisor, linking the Supervisor namespace to the configured OIDC source.

The Model Gallery, the curated repository for ML models in PAIS, restricts access to model artifacts and the training data used to tune them through Harbor project access controls. These controls scope which users and service accounts can read, push, or manage sensitive model data, adding an IAM enforcement layer to the model supply chain. A Harbor registry is recommended for PAIS deployments, and OCI-compliant registries from other vendors are also supported.

PAIS Knowledge Bases extend IAM to ingested data sources. Confluence data sources authenticate with a user name and password or a personal access token, while Microsoft SharePoint On-Premises data sources authenticate with a user name and password. Personal access tokens for Knowledge Bases are generated from user account settings and used for programmatic access to linked data sources.

PAIS integrates with Grafana for metrics visualization using the same OIDC provider, extending the IAM model to the observability layer so that operators authenticate through the configured identity provider before accessing PAIS dashboards.

VMware vDefend (Contributes)

VMware vDefend contributes to identity and access management by providing identity-aware network enforcement through Identity Firewall, which integrates with Active Directory to apply firewall policy based on authenticated user identity rather than IP address alone. Identity Firewall supports assigning Active Directory users and groups as source criteria in both distributed firewall rules and gateway firewall rules, applying to tier-0 and tier-1 gateways. This allows organizations to enforce network access policy by user or group membership rather than relying solely on IP-based controls.

Within its management plane, the Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. These roles govern access to security policy management, analytics, incident response, and diagnostic functions across the platform. Network Detection and Response enforces the same five-role RBAC model for triage operations such as viewing detections and campaigns, and for configuration operations including SIEM integration management. For authentication, the Security Services Platform supports Active Directory and OpenLDAP as external identity sources, with one identity source configurable at a time. The License Hub integrates with external identity providers to store and manage user and group information for access delegation.

Centralized IAM for organizational users, including VCF SSO, MFA, and directory lifecycle management, is handled by VCF and falls outside vDefend's scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) incorporates multiple identification and access management mechanisms that support organization-wide IAM controls within the data services layer.

DSM implements role-based access control with two defined roles: the DSM Admin role, which can create, monitor, and manage all data services in the environment, and the DSM User role, which is restricted to managing and monitoring data services within the namespaces to which the user has been granted access. These roles are assigned at user creation time and govern what each user can see and do within the DSM interface. The Permissions view in the DSM dashboard provides administrators with a centralized location for creating, monitoring, and managing all configured users.

DSM supports two identity sources, which can be used independently or together. Local users are created directly within DSM, with credentials validated by matching email address and password. LDAPS users are sourced from a configured LDAP identity provider, allowing organizations to extend their existing directory service into DSM. When LDAPS is configured, administrators can import users from the directory provider and assign them DSM Admin or DSM User roles. DSM also supports group-based access control: Directory Service Groups from the LDAP provider can be assigned roles directly, so group membership in the external directory determines access level in DSM without requiring per-user assignments.

At the database level, DSM extends authentication controls beyond the platform management layer. MySQL database instances support LDAPS authentication using Active Directory. PostgreSQL and other database instances support host-based authentication (HBA) rule configuration, which determines which clients are permitted to authenticate to a given

database instance. SQL Server instances support Windows Authentication through Active Directory integration, enabling Kerberos-based authentication so that clients such as SQL Server Management Studio running on domain-joined machines can authenticate via single sign-on. SQL Server also uses contained database users, where identity information resides within the database itself rather than at the server level. Administrators can configure SQL Server instances with either a SQL User or Windows Principal as the primary administrator identity, with Windows Principal available for Active Directory-integrated clusters. An internal `dsm_mgmt` management login restricts users from accessing or modifying system-level objects, keeping administrative operations within an isolated context.

Namespace isolation adds a further access boundary. DSM namespaces enforce role-based access control that allows multiple users to work jointly on data services within a namespace while remaining isolated from data services in other namespaces. This supports least-privilege access within multi-tenant deployments.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides a dedicated administrative identity and access management plane through the Avi Controller, supporting multiple authentication methods and fine-grained authorization controls that allow organizations to implement IAM policies across both the management plane and the application delivery layer.

For administrative access, the Avi Controller supports local user accounts, LDAP and LDAPS directory integration, SAML-based federated authentication (including integration with Workspace ONE Access for catalog-based application access), basic authentication, and OAuth/OIDC for API access. Auth Mapping Profiles allow organizations to map external directory groups to specific roles and tenants, so that group membership in an external identity provider directly controls what a user can access within Avi.

Authorization is handled through role-based access control (RBAC) with object-level granularity. Avi's extended granular RBAC uses markers, which are labels assigned to objects, to enable fine-grained authorization based on object ownership and classification. Permission categories cover Operations (including alerts, actions, and traffic capture) and Administration (including controller, tenant, user, role, and system configuration management). This allows restrictions so that a user's permissions apply only to the specific resources matching the markers assigned to their role. RBAC covers object categories including Virtual Services, Application Profiles, SSL/TLS Certificates, Certificate Management Profiles, Cloud definitions, TCP/UDP Profiles, Persistence Profiles, Health Monitors, Analytics Profiles, IP Address Groups, String Groups, SSL/TLS Profiles, PKI Profiles, and Authentication Profiles, with distinct read and write access levels configured per object type.

For multi-tenant deployments, Auth Mapping Profiles support tenant isolation with configurable user group to role mappings, allowing organizations to enforce separation between teams or business units operating within the same Avi Controller.

The Avi License Hub supports role-based access control through an external identity provider, with three predefined roles: Enterprise Admin (full access for all operations, including upgrades and authentication configuration), Auditor (view-only access for tracking activity without making changes), and Support Bundle Collector (restricted to collecting system logs and diagnostics). Management interface access is further controlled through restrictions on allowed ciphers and HMACs for management sessions.

For deployments involving the Avi Kubernetes Operator (AKO), Kubernetes RBAC policies can be applied to AKO Custom Resource Definitions (CRDs) to enforce stricter access control over routing configuration for specific user groups. The Avi Controller also implements RBAC at the Kubernetes and OpenShift cluster level by assigning tenants and roles to user accounts.

At the application layer, Avi can enforce client authentication using OAuth, SAML, JWT token validation, and mutual TLS with client certificates, extending access control to the traffic flowing through virtual services rather than only to the management interface.

Organizations are responsible for defining roles, mapping directory groups to permissions, establishing naming conventions for markers, and maintaining user lifecycle processes. Avi provides the technical mechanisms; the governance and operational processes for identity management must be organized by the teams managing the deployment.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 164.310(a)(2)(iv)

> Implementation specifications: Maintenance records (Addressable). Implement policies and procedures to document repairs and modifications to the physical components of a facility which are related to security (for example, hardware, walls, doors, and locks).

SCF Controls: GOV-02, MNT-01, MNT-02, PES-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.310(b)

> Standard: Workstation use. Implement policies and procedures that specify the proper functions to be performed, the manner in which those functions are to be performed, and the physical attributes of the surroundings of a specific workstation or class of workstation that can access electronic protected health information.

SCF Controls: END-01, GOV-02, HRS-05, HRS-05.1, HRS-05.3, OPS-01.1, OPS-03, PES-03.4, PES-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.310(c)

> Standard: Workstation security. Implement physical safeguards for all workstations that access electronic protected health information, to restrict access to authorized users.

SCF Controls: END-02, PES-03, PES-03.4, PES-04, PES-04.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.310(d)(1)

> Standard: Device and media controls. Implement policies and procedures that govern the receipt and removal of hardware and electronic media that contain electronic protected health information into and out of a facility, and the movement of these items within the facility.

SCF Controls: AST-01, AST-11, DCH-01, DCH-03, DCH-07, DCH-07.1, DCH-13.2, GOV-02, MNT-01, MNT-04.3

Aggregate Coverage: Contributes

VCF (Contributes)

VCF contributes to IT Asset Management programs through built-in inventory, discovery, and integration capabilities that provide the technical foundation for asset tracking and governance.

VCF Operations groups discovered objects logically and provides detailed inventory lists across the environment, covering compute, storage, and networking resources. The inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group.

The Service Discovery adapter automatically discovers applications, services, and their associated metrics (CPU, memory) running on managed infrastructure. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be exported in CSV format for use in external asset tracking systems.

For organizations using ServiceNow, VCF provides two integration paths. The Management Pack for ServiceNow in VCF Operations populates the ServiceNow CMDB with discovered resources through the ServiceNow Table API and CMDB Meta API, providing CMDB visibility within VCF Operations. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation provides a structured data source that captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

VCF Automation adds governance through its project model, which controls who can deploy what resources and where those resources are deployed. Projects link users, catalog items, and IaaS resources together. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources.

Tags within VCF Automation express capabilities and constraints that define deployments. Cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

The broader ITAM program responsibilities of establishing asset governance policies, defining ownership lifecycles, and maintaining organizational accountability remain outside VCF's scope.

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to data protection controls by providing network-level security mechanisms that protect data in transit and restrict unauthorized network access to systems where data is stored or processed.

The vDefend distributed firewall (DFW) enforces microsegmentation policies at the vNIC level, restricting which workloads can communicate with data stores, databases, and application tiers. By segmenting the data center network into isolated security zones, vDefend limits the blast radius of a compromise and restricts lateral movement toward systems that hold sensitive data. Administrators define granular firewall rules based on workload identity, security tags, and application-level attributes, limiting access to data repositories to authorized services. Identity Firewall extends policy enforcement to user identity, allowing administrators to define access controls based on which authenticated user initiated the connection rather than solely the source workload, strengthening data access controls in environments with user-based authorization requirements. Security policies are defined, propagated, and enforced across Bare Metal servers through the Security Services Platform (SSP), extending microsegmentation protections beyond virtualized workloads to physical infrastructure connected to the environment.

The SSP includes Security Intelligence, which identifies risky application protocols that transport data in clear text, including HTTP, Telnet, FTP, TFTP, LDAP, POP3, and IMAP. This visibility allows administrators to detect and remediate unencrypted data flows that could expose sensitive information in transit. Security Intelligence administrators can monitor traffic leakage between environments, establish exceptions, and implement lockdown protection rules to control inter-environment flows. Security Intelligence also enables administrators to generate policy recommendations and deploy them in monitor-before-enforcement mode, allowing observation of traffic patterns before applying restrictive rules. The SSP summary panel displays the number of services that are fully protected, partially protected, or not protected, giving administrators a dashboard view of segmentation coverage gaps across the environment.

IDS/IPS profiles attach to Distributed Firewall and Gateway Firewall rules to inspect east-west and north-south network traffic for signatures and behaviors associated with data theft, command-and-control communication, and exploitation of vulnerabilities in data-handling services. In vDefend, IDS/IPS signature rules support storing TLS/SSL certificates on disk for forensic analysis and threat investigation, providing durable artifacts for post-incident review of potential data exfiltration events.

Malware Prevention profiles attach to DFW and Gateway Firewall rules and can be configured to send files to the cloud for detailed analysis or to process files locally without cloud connectivity, accommodating environments with data-residency or air-gap requirements. Malware Prevention collects file analysis data including file hash submissions and assigns an Analyst UUID to each submission to track its analysis lifecycle. The Malware Prevention dashboard displays trends of malicious, suspicious, and suppressed file events across the data center, and file verdict filtering allows operators to focus on specific verdict categories such as malicious-only views.

Network Detection and Response (NDR) anonymizes sensitive customer information when sharing telemetry data to cloud services, providing a built-in data privacy mechanism for environments that enable cloud-assisted threat detection.

These network security controls complement the data-at-rest encryption, backup, replication, and access management capabilities provided by other VCF components. vDefend does not perform data encryption, classification, backup, or recovery itself, but it protects the network paths and access patterns through which data is stored, replicated, and retrieved.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides replication-based data protection for virtual machine workloads across sites. Protection groups allow administrators to organize virtual machines and datastores under consistent snapshot and replication policies at scale, covering both local recovery via vSAN snapshots and cross-site recovery via vSphere Replication or array-based replication. Protection group membership can be modified after creation, and virtual machines can be automatically enrolled for protection using storage tag selection on designated datastores, reducing manual overhead in maintaining protection coverage across a growing environment.

PNR introduces an immutability mode for protection groups that, when enabled, prevents the data protection group from being modified or deleted. This mechanism allows administrators to safeguard protection configurations against inadvertent or unauthorized changes. PNR Health monitoring provides consolidated visibility into data protection service health, operation issues for local and replication snapshots, storage utilization, and protection group membership changes, giving administrators a current view of protection posture across the environment.

Site Recovery Manager (SRM) integrates with vSphere Replication to provide orchestrated failover with configurable recovery point objectives, giving organizations control over acceptable data loss thresholds for protected workloads. PNR supports additional site topologies, including shared recovery site configurations where protected site resources are mapped to isolated datacenters, networks, folders, and datastores on the recovery site. Inventory mappings allow administrators to define resource configurations once and apply them consistently across protection groups.

vSAN Snapshots and Replication is a native, integrated snapshot-based backup capability for virtual machines running on vSAN datastores, managed through the vSphere Client. It provides VM restore and clone operations from existing snapshots, supporting both rapid recovery from operational failures and ransomware recovery scenarios. Test failover operations allow administrators to validate that recovery configurations are functional before an actual recovery event occurs.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support data protection for managed database instances, covering PostgreSQL, MySQL, and SQL Server databases.

The most direct contribution is DSM's automated backup framework, which administrators can enable on a per-database basis or through data service policies. When configured, DSM performs scheduled full and incremental backups of database content and stores them in S3-compatible object storage at a configurable backup location. Backup retention is configurable (backup-retention-period), and DSM retains backups of deleted databases until the configured retention period expires, supporting recovery from accidental deletion. For point-in-time recovery, DSM restores a backup to a newly created database VM with a user-specified name and datastore location, and can target the most recent timestamp or a specific point in time. DSM archives binary logs in backup storage as part of its backup protection mechanism. Administrators can also initiate manual on-demand backups of primary PostgreSQL databases to safeguard data before high-impact operations or as immediate protection after major changes. For PostgreSQL multi-site deployments, DSM performs a full backup automatically during a promotion event before resuming the regular schedule.

Data service policies give administrators control over backup behavior across all databases governed by a policy. Policies can require that databases have automated backups enabled, allow users to opt in, or disallow automated backups entirely. The allowed-backup-locations setting in the data service policy restricts users to selecting from approved backup locations, reducing the risk of backup misconfiguration. Policies can be enforced across multiple tenants and across different namespaces and namespace labels, supporting consistent data protection posture in multi-tenant deployments. A Compliance tab on data service policies displays compliance reports and allows administrators to expand each policy violation to view the noncompliant database, data service, and namespace, giving administrators visibility into where data protection requirements are not being met. In 9.1, data service policies extend to SQL Server databases in addition to MySQL and PostgreSQL.

DSM implements role-based access control that separates administrative and user-level database access. DSM Admins can create, monitor, and manage all data services in the environment; DSM Users can only manage and monitor the data services they own. This access model limits who can modify backup configurations and policy settings. Infrastructure policies govern which storage resources are available for database VMs, including CPU, memory, storage policies, IP pool, and VM classes, giving administrators control over the storage environment in which data resides.

Control plane recovery requires that a Provider Backup Repo has been configured at installation time. If the Provider VM fails, the restore-provider command restores it to the latest timestamp. In the VCF Automation context, tenants can perform point-in-time restores directly through the VCF Automation UI, broadening restore access to self-service scenarios.

One limitation applies: if an incremental backup in the backup chain is deleted, DSM cannot restore the full data; a successful restore from an incremental chain requires the last full backup and all following incremental backups. Organizations must protect the integrity of the backup chain through access controls on the backup storage.

DSM provides configurable backup, recovery, and policy enforcement mechanisms for managed database instances. The broader data protection program requires organizational decisions about backup schedules, retention periods, backup storage security, and off-site management that DSM does not prescribe on its own.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several application-layer mechanisms that support the implementation of data protection controls within a VCF deployment.

At the transport layer, Avi performs TLS termination with configurable SSL/TLS profiles for connections between clients and virtual services. The SSL/TLS protocol at the Avi proxy secures data in transit by reducing the risk of unauthorized parties reading or modifying information transferred between end users and application workloads. SSL/TLS profiles are configurable through the Avi Controller UI under Templates > Security > SSL/TLS Profile. Management interface access is further restricted through configuration of allowed ciphers and HMACs for management sessions.

Avi integrates with Hardware Security Modules (HSMs), including the Thales Luna (formerly SafeNet Luna) HSM, for cryptographic key storage and management. This allows organizations to store the private keys used in TLS termination and other cryptographic operations within a dedicated hardware key store rather than in software. The Avi Controller also stores sensitive configuration data encrypted in a local database, and backup files can be protected with a passphrase that encrypts the keys included in the backup. Backup and restore operations verify that the FIPS mode of the backup configuration matches the target controller environment.

Avi's Web Application Firewall (WAF) applies both positive and negative security models to inspect and filter HTTP/HTTPS application traffic. WAF policies support ModSecurity rules for application protection and a Positive Security model that learns application behavior to define allowed request patterns. The Application Rules service, available through the Avi Cloud Console, provides WAF rules specifically designed to address known application vulnerabilities including CVE-tracked issues, with automatic updates to keep rules current. WAF configuration is accessible through the Controller UI under Templates > Security > WAF Policy.

Avi DataScript provides a programmable layer for enforcing additional data protection behaviors at the proxy boundary. DataScripts are Lua-based scripted rules that allow inspection and manipulation of client HTTP requests and server HTTP responses, supporting content switching, redirection, header manipulation, and logging. DataScript can be used to enforce cipher suite policies by denying clients connecting with unsupported ciphers. DataScript also supports blocklist-based access control by checking client IP addresses against named IP groups and terminating connections from blocked sources while logging the violation. XML-based DataScript use cases can extract client identifiers from request payloads and compare them against configured string groups to restrict access to authorized clients.

Access to Avi configuration objects is restricted through granular role-based access control (RBAC). Avi supports extended granular RBAC using label-based markers to restrict user permissions to specific resources based on key-value pair matching. The RBAC model differentiates Read and Write access across objects such as SSL/TLS Profiles, PKI Profiles, Authentication Profiles, IP Address Groups, and Health Monitors, allowing organizations to scope access to data protection-relevant configuration to authorized roles only. Roles can also be scoped to tenants through label group associations.

These mechanisms address data protection at the application delivery layer. Broader organizational data protection controls, including data classification policies, data handling procedures, and data-at-rest protection beyond the Avi proxy boundary, require organizational governance and platform-level capabilities that Avi does not provide as an application delivery controller.

Control 164.310(d)(2)(i)

> Implementation specifications: Disposal (Required). Implement policies and procedures to address the final disposition of electronic protected health information, and/or the hardware or electronic media on which it is stored.

SCF Controls: AST-01, AST-09, GOV-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF contributes to IT Asset Management programs through built-in inventory, discovery, and integration capabilities that provide the technical foundation for asset tracking and governance.

VCF Operations groups discovered objects logically and provides detailed inventory lists across the environment, covering compute, storage, and networking resources. The inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group.

The Service Discovery adapter automatically discovers applications, services, and their associated metrics (CPU, memory) running on managed infrastructure. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be exported in CSV format for use in external asset tracking systems.

For organizations using ServiceNow, VCF provides two integration paths. The Management Pack for ServiceNow in VCF Operations populates the ServiceNow CMDB with discovered resources through the ServiceNow Table API and CMDB Meta API, providing CMDB visibility within VCF Operations. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation provides a structured data source that captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

VCF Automation adds governance through its project model, which controls who can deploy what resources and where those resources are deployed. Projects link users, catalog items, and IaaS resources together. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources.

Tags within VCF Automation express capabilities and constraints that define deployments. Cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

The broader ITAM program responsibilities of establishing asset governance policies, defining ownership lifecycles, and maintaining organizational accountability remain outside VCF's scope.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.310(d)(2)(ii)

> Implementation specifications: Media re-use (Required). Implement procedures for removal of electronic protected health information from electronic media before the media are made available for re-use.

SCF Controls: AST-09, DCH-09

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several capabilities that support secure logical disposal and sanitization of virtual resources, though the physical destruction or secure disposal of hardware remains an organizational responsibility outside VCF's scope.

vSAN data-at-rest encryption uses a two-tier key architecture with Key Encryption Keys (KEK) and Data Encryption Keys (DEK), managed through an external Key Management Server (KMS) or vSphere Native Key Provider. When decommissioning encrypted storage, destroying the encryption keys renders the data unrecoverable without requiring a full disk wipe, a technique known as cryptographic erasure. vSAN also provides an "Erase disks before use" option during encryption configuration that wipes existing data from storage devices. For devices being added to or removed from vSAN disk groups, residual data and partition information can be cleaned before the device is reclaimed or released. Administrators can wipe ineligible disks through the vSAN Management API after verifying the partition table and stored data. vSphere provides API methods for cryptographic key lifecycle management, including `removeKey` and `removeKeys` operations that delete encryption keys from host caches. These methods support a `force` parameter for definitive key removal.

VCF Operations includes a Reclamation dashboard and associated settings that help administrators identify virtual resources eligible for cleanup and disposal. The Reclamation Settings interface surfaces powered off VMs, idle VMs, snapshots, and orphaned disks, quantifying the resources that can be reclaimed. The Datastore Capacity Dashboard and ESX Capacity Dashboard both identify three specific reclamation opportunities: powered off VMs, snapshots, and orphaned VMDKs. These dashboards give operations and capacity teams visibility into resources that should be reviewed for secure removal before equipment is repurposed or decommissioned. The Reclamation Report tracks CPUs reclaimed, memory reclaimed, and storage reclaimed across different time periods, providing evidence of resource cleanup activity.

For the actual deletion of virtual resources, VCF Operations provides a `DELETE VM(s)` capability that removes selected powered off VMs, and a `RECLAIM RESOURCES` function that allows immediate execution of resource reclamation processes. VCF Automation extends this with a `Delete` action on Deployments that destroys an entire deployment and deletes all associated resources for reclamation. VCF Automation also supports the creation and deletion of secret reusable properties through its secrets management interface under Administration Secrets, which is relevant when sanitizing credential material before equipment reuse.

VCF Operations can disable virtual disk wiper and disk shrink operations on virtual machines through the `isolation.tools.diskWiper.disable` setting, which blocks data recovery attempts from within guest operating systems.

Core dump handling is another area where VCF provides disposal-relevant guidance. VMware recommends considering disabling core dumps on VMware vCenter systems to protect sensitive information. Unlike virtual machine core dumps, which are encrypted when VM encryption is active, vCenter core dumps are not encrypted by default; vCenter systems support core dump encryption through the `core-dump-encryption` setting, and encrypted core dumps can be decrypted or re-encrypted as needed. Core dumps may contain sensitive information such as host keys, and organizations should follow their security and privacy policies to protect this data. When decommissioning or repurposing hosts, addressing core dumps is an important step for reducing the likelihood of information recovery.

VCF also recommends securely deleting decrypted backup files after restore operations for VCF Operations, vCenter, and NSX components.

Auditors should verify that the organization has defined procedures for securely disposing of or repurposing VCF-managed infrastructure. This includes confirming that virtual resources (VMs, snapshots, orphaned disks, secrets) are deleted through VCF's reclamation and deletion tools before physical equipment is removed from service, and that encryption keys are

destroyed via cryptographic erasure for storage that held sensitive data. Physical chain-of-custody procedures, media sanitization verification, and equipment tracking through the disposal lifecycle are organizational processes outside the scope of VCF.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.310(d)(2)(iii)

> Implementation specifications: Accountability (Addressable). Maintain a record of the movements of hardware and electronic media and any person responsible therefore.

SCF Controls: AST-02, AST-02.1, AST-02.9, AST-03, AST-03.1

Aggregate Coverage: Contributes

VCF (Contributes)

VCF contributes to asset inventory processes by maintaining a detailed, real-time inventory of technology assets across compute, storage, and networking layers.

VMware vCenter maintains the authoritative inventory of all managed objects in the environment. The vSphere inventory organizes objects in a hierarchical structure beginning at the root folder and extending through datacenters, clusters, hosts, virtual machines, networks, and datastores. Each object carries metadata including configuration details, resource allocations, and operational state. Administrators can extend this metadata by defining custom attributes, which store organization-specific fields against any inventory object in vCenter. Custom attribute values are held centrally by vCenter rather than within the individual objects, allowing teams to annotate VMs, hosts, datastores, and other inventory items with organization-defined information such as ownership, classification, or business justification details. This inventory reflects the live state of the environment as objects are created, modified, or removed. Multiple vCenter instances can be linked for centralized inventory management across workload domains.

Programmatic access to the full inventory is available through the vSphere Web Services API. The Property Collector service uses Property Filter Specifications to identify inventory elements either directly or through object property traversal. The `RetrievePropertiesEx` method collects properties from inventory objects, allowing external systems and automation scripts to enumerate assets, gather configuration details, and build reports at whatever level of granularity is needed. The SimpleClient sample application demonstrates how to connect to a vCenter instance and obtain a listing of top-level inventory entities along with their properties and references.

VCF Operations extends inventory visibility by retrieving inventory details from each vCenter, including associated clusters, VMware ESX hosts, datastores, and virtual machines. Discovered objects are grouped logically in detailed inventory lists, and the inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group. ResourceAttribute elements define the metrics that appear in the monitoring interface, each identified by a Metric Key, providing continuous visibility into asset utilization, capacity, and health. The vSphere Compute Inventory Dashboard provides interactive views of clusters, hosts, and virtual machines associated with any selected object.

For application-level visibility, the VCF Operations Service Discovery adapter discovers running applications and services along with their CPU and memory metrics. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be grouped by object type and selected attributes through Application Definition criteria, and the results can be exported in CSV format for use in external asset tracking systems.

VCF Automation adds a consumption-oriented layer to asset tracking. Projects link users, catalog items, and infrastructure resources where deployments are provisioned. The Overview tab displays infrastructure and consumption metrics across the organization. Resources visible in inventory views are scoped by the rights and project roles assigned to each user, providing role-appropriate visibility for audit and review. When catalog items are deployed, they are provisioned against the infrastructure available to the selected project, creating a traceable relationship between the request, the deployment, and the underlying resources. Provider accounts can create and track assets including virtual machines, catalogs, templates, and media. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization

maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources. Tags within VCF Automation express capabilities and constraints that define deployments, and cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

For integration with external asset registries, VCF provides multiple paths. The Management Pack for ServiceNow in VCF Operations discovers and synchronizes asset details including CPU count, CPU speed, CPU type, disk space, RAM, serial number, manufacturer, model ID, OS version, IP address, and vCenter reference through the ServiceNow Table API and CMDB Meta API. These properties are marked as required discovery fields, keeping the external CMDB aligned with the actual virtual infrastructure. VCF Operations for Networks supports adding ServiceNow as a CMDB data source to fetch configuration items and their relationships. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

Software asset tracking is supported through vSphere Lifecycle Manager, where software depots contain both the payloads and metadata for software updates. VCF Lifecycle Management tracks different versions of software components to help maintain compatibility across the infrastructure. The VCF Operations API includes methods to register associated products with their product name, version, and deployment details, contributing to a software-level view of the environment.

The Consumption layer of VCF extends asset inventory to containerized workloads running on VMware Kubernetes Service (VKS) and vSphere Supervisor. The Kubernetes API server maintains a live registry of every object within a cluster or Supervisor namespace, covering pods, deployments, services, ConfigMaps, Secrets, PersistentVolumeClaims, CustomResourceDefinitions, and other resource types. Every resource carries standard metadata including name, namespace, labels, annotations, creation timestamp, and owning references that administrators can query or export at any level of granularity. Labels and annotations allow teams to attach arbitrary metadata to any Kubernetes resource, such as application name, business unit, or data classification, and these fields are queryable via label selectors, supporting filtered inventory exports by category. Supervisor namespaces map to vCenter namespaces, associating Kubernetes workloads with the organizational units defined during provisioning, and resource quotas and limit ranges attached to each namespace record the allocated capacity and support tracking of resource consumption by application or team.

For workloads that consume specialized hardware such as accelerators or dedicated network devices, the Kubernetes Device Plugin framework provides hardware-level asset visibility within VKS clusters. Administrators or device owners use DeviceClasses to define sets of devices available in the cluster, and workloads claim specific hardware resources by creating ResourceClaims that filter for device parameters declared in a DeviceClass. Monitoring agents for device plugin resources discover which devices are in use on each node and collect metadata that associates each device allocation with the specific container consuming it, extending hardware asset tracking to the workload level.

The Harbor Registry Supervisor Service provides an inventory mechanism for container images and artifacts. Harbor organizes images in a Projects structure by team or application and secures them with policies and role-based access control, allowing administrators to track which container images are authorized for use within the environment. Container images deployed through VCF consumption paths should be scanned, signed, and approved according to organizational software supply chain policies before use; digital certificates and validation mechanisms support supply chain assurance of images and artifacts. Where GitOps practices are in use, the Argo CD Supervisor Service extends this inventory capability by recording application synchronization events with timestamps, capturing the resource group, kind, namespace, name, sync status, and health status of each synchronized resource. Git repositories serve as the single source of truth for desired application and infrastructure

state in a GitOps workflow, and infrastructure as code stored in version control creates a durable audit log of every authorized change to that state.

These capabilities give VCF a strong technical foundation for tracking virtual infrastructure assets with accurate, real-time data at multiple levels of granularity. However, the broader requirements of this control, including business justification tracking, organization-defined accountability information, and formal review and audit processes for the full scope of technology assets, applications, services, and data, require organizational policies and processes that operate alongside the platform's inventory capabilities.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) maintains an inventory of network-visible workloads organized into a hierarchical asset collection spanning regions, zones, environments, applications, and application tiers. The Publish Inventory Assets tab in SSP displays infrastructure asset details including asset names, asset types, IP addresses, and total VM counts for assets sourced from imported CSV files, discovered services, or published infrastructure assets, providing accurate, granular records of network-visible assets.

Platform Inventory monitoring supports ongoing inventory accuracy through several mechanisms. Administrators can filter infrastructure assets by Name and Status, identifying assets that are timed out or out of sync. The inventory hierarchy view shows regions, zones, and VMs so administrators can verify correct definition. SSP Inventory displays assigned tags for each infrastructure asset, and environment rows can be expanded to view tag assignments and confirm hierarchy accuracy. The platform also collects and displays VM tags with their respective scopes, supporting classification and tracking. Published applications and their application types are verifiable in the Inventory > Applications interface.

SSP identifies and publishes application assets, classifying them as either critical or regular applications. Application Asset Collections represent groups of workloads delivering enterprise software functions. Security Intelligence within SSP displays application associations for compute entities, indicating the tiers within each application to which a given compute entity belongs. Administering compute entity classifications in Security Intelligence requires appropriate privileges, supporting access control over classification changes. Consistent naming conventions are recommended when preparing inventory data for import, and the Asset Prefix setting enables standardized naming during segmentation planning and monitoring.

In disconnected mode, usage files include an `asset_id` field providing a unique asset identifier, supporting asset tracking in environments without continuous connectivity.

vDefend's inventory scope is limited to network-visible workloads and does not replace enterprise-wide TAASD inventory tools, authorized software catalogs with business justification records, or data asset registries required for full AST-02 compliance.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to asset inventory requirements by providing built-in visibility into the database instances, infrastructure resources, and users it manages. This visibility supports tracking and accountability for the subset of technology assets that DSM governs. Organization-wide TAASD inventory across all asset categories requires organizational processes and additional tooling beyond DSM itself.

DSM tracks the association between deployed databases and the infrastructure policies under which they were provisioned. Administrators can review databases and their configuration details through the Databases tab in the Infrastructure Policies view of the DSM Administrator UI, which displays each policy alongside the databases bound to it. Because infrastructure policies define the compute, storage, and networking resources allocated to databases, including allowed VM classes, this view gives administrators a structured picture of how platform resources are being consumed. The About the DSM UI Views section confirms the Infrastructure Policies view lists all policies available in the environment and the databases associated with each.

DSM administrators can define and configure data service policies for the data services DSM manages, supporting compliance with organizational standards across tenants. Each policy can be tailored to specific requirements and assigned to one or more organizations to enforce consistent configurations. For tenant-facing self-service, the DSM Consumption Operator

creates infrastructure policies as cluster-scoped resources in the consumption cluster and requires an allowedInfrastructurePolicies list that defines which policies a tenant cluster may use, giving administrators a clear inventory of the policies in scope per cluster. Tenant users create and consume databases under a Supervisor namespace through the VCF Automation Cloud Consumption Interface (CCI), and the DSM portal exposes a Consumption Operator endpoint that provides access to deployment artifacts.

For database-level visibility, the Database Health view in the DSM UI collects metric data for each database instance and cross-references alerts with resolution paths. DSM deploys a Telegraf agent on the Provider Appliance and a local Telegraf agent on each workload cluster to gather VM-level metrics such as CPU, memory, and disk usage, plus engine-specific metrics. DSM can forward metrics to an external Metrics target server, supporting integration with external monitoring or inventory aggregation systems.

For auditors, DSM's inventory-relevant information is accessible through the Administrator UI and is available to personnel with the Admin role. The Databases tab, Infrastructure Policies view, Database Health view, and Consumption Operator policy inventory collectively provide the granularity needed to account for DSM-managed database assets and the policies governing them. The documented DSM user roles (vSphere administrator, VCF Automation organization administrator, VCF Automation project user) clarify which personnel have visibility into which inventory views.

DSM provides resource tracking and visibility within its own management scope. DSM does not perform organization-wide asset discovery and does not inventory physical infrastructure, non-database applications, or data assets outside its management domain. A TAASD inventory program spanning all asset categories requires a CMDB or dedicated asset management solution that can aggregate DSM resource data alongside information from other platform components.

VMware Avi Load Balancer (Contributes)

The Avi Load Balancer Controller maintains an internal configuration database that is the authoritative store for all Avi-managed objects within the application delivery layer. The database records configuration information for tenants, virtual services, pools, policies, and accounts, providing structured asset tracking scoped to the load balancing and application delivery functions. This database is the storage layer for all system settings and configurations in Avi Controller, accessible through both the Controller CLI and REST API, giving operators and automation tooling a programmatic way to retrieve and audit configuration details for any Avi-managed object.

For auditors assessing CMDB practices, Avi provides complementary mechanisms. The Controller CLI `configure` command provides access to show subcommands for viewing all configuration objects and system state, including application persistence profiles, application profiles, authentication profiles, backups, cloud configurations, and cluster settings. The Controller REST API endpoint `PUT api/systemconfiguration` enables programmatic retrieval and update of system configuration, allowing external CMDB platforms to pull structured configuration data and maintain up-to-date asset records for all Avi components. Configuration can also be exported and backed up with passphrase encryption of all sensitive fields, producing point-in-time snapshots suitable for import into a third-party CMDB or asset management system.

Avi Load Balancer events provide a record of configuration changes over time and are the foundation of configuration automation within the platform. The Config Events overlay in Service Engine Analytics enables administrators to correlate traffic changes with configuration modifications, such as changes to virtual service security settings, supporting governance requirements by providing a traceable record of configuration state changes within the Avi control plane.

In VCF deployments, Avi adds specific integration capabilities relevant to configuration governance. Organization-Managed Mode allows organization administrators to manage their own Service Engine Group configurations and infrastructure settings within boundaries defined by the VCF Automation Provider Management Portal, which enables provider administrators to specify regions, organizations, and capacity allocations. After upgrading components in a VCF deployment, a drift check against VCF Operations, vCenter, and NSX Manager is required to verify configuration consistency, providing a structured mechanism for detecting configuration drift across the integrated stack.

Organizations deploying Avi in a VCF environment typically integrate Avi configuration data with an enterprise CMDB to achieve unified asset tracking across the full infrastructure stack, with VCF's own inventory mechanisms covering the compute, storage, and networking layers while Avi covers the application delivery layer objects.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 164.310(d)(2)(iv)

> Implementation specifications: Data backup and storage (Addressable). Create a retrievable, exact copy of electronic protected health information, when needed, before movement of equipment.

SCF Controls: BCD-11

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in backup capabilities across its management components, workload layers, and storage subsystems, supporting organizations in meeting their Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).

Management component backups

VCF supports backup of all core management components. VMware vCenter supports both file-based and image-based backup methods, with file-based daily backups configured through the vCenter Management Interface of each vCenter instance. vCenter file-based backup and restore supports FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB as the backup server protocol. vCenter file-based backup optionally encrypts backup files using an encryption password that must be provided during restore; because vCenter backups contain the Key Derivation Key used for vSphere encryption, backup files should be stored on a secured backup server with appropriate access controls. VCF Operations similarly supports file-based and image-based backup methods. NSX Manager uses file-based backup, which VCF Operations configures automatically during the initial bring-up process. File-based backup jobs for VCF Operations and vCenter must be configured separately after deployment.

Scheduled backups should be implemented to prepare for critical failure scenarios, upgrade events, or certificate updates of management components. To capture a consistent state across related components, VCF requires creating a series of coordinated backup jobs that run simultaneously across component nodes. Simultaneous backups of component nodes help ensure that the backed-up state is logically consistent, reducing the need for integrity remediation during a restore. On-demand manual backups can be taken after a successful recovery operation or after a scheduled backup failure. VCF Operations backup is also configured to take a backup on state change, providing an additional layer of protection when configuration changes occur.

The backup file server stores backups from all NSX Manager or Global Manager nodes, and NSX includes a script to automatically delete old backups to manage storage consumption. NSX Global Manager backups should be periodically cleaned up to avoid excessive storage consumption on the backup file server. VCF Operations for Networks can store backups on local storage, retaining up to five backup files, or upload them to SSH or FTP servers. An initial on-demand backup should be performed after configuring VCF Operations to verify that backups complete successfully before relying on scheduled jobs. Sufficient storage capacity must be provisioned to accommodate backup data across all components.

Backup integrity and restore procedures

Backup integrity verification in VCF centers on version compatibility. When restoring a vCenter instance from a file-based backup, administrators must have a valid backup that matches the exact version of the vCenter appliance being restored to. VCF Operations must be available before restoring vCenter, and vCenter must be available before restoring VCF Operations, establishing a defined dependency order for restore operations. These dependencies require careful sequencing during recovery to restore the management plane to a consistent state.

Workload-level data protection

For workload-level data protection, VCF provides several mechanisms. Changed Block Tracking (CBT) tracks modified disk blocks on virtual machines, enabling incremental backups that reduce backup windows and storage requirements. VMware vSphere Storage APIs for Data Protection (VADP) provide a standardized interface for third-party backup solutions to integrate with VCF. vSphere Supervisor supports backup of VM Service VMs through backup partner solutions based on VADP, and if a VADP-based backup solution is deployed on the default management cluster, the solution must be properly started and operational before starting up or shutting down VCF. Quiesced snapshots are appropriate for automated or

periodic backups of VM Service virtual machines, as they capture a consistent state before the backup operation proceeds. VCF Automation supports snapshotting a VM group to create an object that references distinct snapshots for each member VM; restoring a VM group snapshot restores each member of the group.

vSphere Supervisor control plane backup and restore can be performed using vCenter file-based backup and restore from the Workload Management UI. For applications that provide their own backup capabilities, VCF documentation recommends using application-specific backup methods rather than relying on filesystem backup alone.

vSAN data protection and snapshots

vSAN Data Protection allows snapshots to be managed through protection groups with configurable snapshot retention policies and scheduling intervals. The native Snapshot Service is supported by vSAN Express Storage Architecture (ESA) but not by vSAN Original Storage Architecture (OSA). Native snapshots in vSAN ESA are much faster than traditional vSphere snapshots because a base VMDK and its snapshots are contained in one vSAN object rather than being separate objects, allowing more frequent backups and faster recovery. In vSAN OSA, snapshots are separate vSAN objects. The vSAN Distributed File System Snapshot can be used by third-party backup vendors to copy changed files incrementally to a different physical location. The vSAN Snapshot Service API provides programmatic access for operations including creating linked clones from snapshots and restoring deleted virtual machines.

VMware Kubernetes Service backup

VMware Kubernetes Service (VKS) and the Supervisor layer extend VCF's backup capabilities to containerized workloads, cluster state, and persistent volume data. VKS Supervisor backup and restore for cluster node VMs is activated through the vCenter backup feature available in the vCenter Management Interface, integrating Kubernetes cluster state backup with the same management-plane backup infrastructure used for other VCF components.

For workload-level backup of VKS clusters, the platform supports three complementary methods: vSphere Plugin Snapshot (CSI Snapshot), File System Backup (FSB), and the Velero Plugin for vSphere. The vSphere Plugin Snapshot method produces crash-consistent, block-level backups of persistent volumes through the Container Storage Interface (CSI) layer and supports snapshot direct access and network traffic offload; it is faster and less resource-intensive than filesystem backup for complex filesystems with large numbers of small files, making it well-suited for production databases and high-IOPS applications. The File System Backup method operates at the filesystem level, supports NFS volumes and incremental backups where unchanged files are not re-transferred between runs, and offers backup repository features including deduplication, compression, and encryption; it is appropriate for legacy volumes with non-CSI storage. The Velero Plugin for vSphere can back up and restore both stateless and stateful applications running on vSphere Pods in the Supervisor. Platform teams can use both FSB and CSI Volume Snapshots within a single protection strategy to maximize data durability across workload types. VKS cluster backup supports opt-in and opt-out approaches for FSB volume backup, giving operators control over which volumes are included in filesystem-level operations. Third-party backup software can also integrate with VKS clusters using the standard Kubernetes CSI snapshot API: tools create a VolumeSnapshot object from the target PVC, materialize a temporary PVC from the snapshot, and use a Data Mover pod to transfer data to the backup destination. Kubernetes implements Persistent Volume Claim as Snapshot Source Protection, which blocks deletion of in-use API objects while a snapshot is in progress, reducing the risk of partial or inconsistent backup data. Kubernetes also supports provisioning a new PersistentVolumeClaim directly from a VolumeSnapshot by specifying the snapshot as the dataSource, enabling volume-level point-in-time recovery without requiring a full application restore workflow.

VKS cluster management provides a Create backup wizard that allows users to create backups immediately or schedule backups of specified data resources in a cluster. Backup scheduling supports immediate execution, recurring schedule formats with targeted start times, or custom cron expressions; automated backup scheduling can also be configured using the Velero CLI with the `velero schedule create` command, specifying the interval or cron expression for recurring backup operations. For on-demand backups outside a scheduled window, the `velero backup create` command backs up Kubernetes resources and persistent volume data for stateful workloads, with support for per-namespace targeting and volume snapshot inclusion. VKS cluster backups can retain a maximum of 720 backups per backup schedule; when high-frequency schedules are required, the retention period should be reduced to remain within this limit. Backup schedules can be edited, paused, or deleted through

the management interface. File system backups are included in the restore by default, and snapshot data can be moved to a separate backup storage location. Before defining a backup, a target location and credential must be created; if a data protection credential is deleted, scheduled backups relying on that credential will fail on their next execution, creating a detectable gap in backup execution history that administrators should monitor. Creating a backup schedule requires the Organization Administrator or Project Administrator role.

VKS cluster backup and restore operations are managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management > Clusters > Data Protection. The portal provides restore operations on specific backups, and a dedicated cross-cluster restore capability in the Data Protection tab enables restoring backups from a source cluster to a different target cluster. VKS cluster management supports backup and restore of an entire cluster, selected namespaces from the backup, or specific resources identified by a label. The CloneFromSnapshot CRD includes a status.phase field that tracks restore progress through multiple phases, providing operational visibility during restore operations.

For Kubernetes cluster state, etcd is the backing store for all Kubernetes objects, and clusters using etcd should have a backup plan. etcd backup can be performed using the built-in etcdctl snapshot save command by specifying the endpoint, CA certificate, and client credentials, or by taking a volume snapshot of the etcd storage volume when the underlying storage supports it. etcd snapshots can be restored from a previous snapshot file or from the remaining data directory, and cross-patch-version restores are supported. During kubeadm upgrades, automatic backup folders are written to /etc/kubernetes/tmp containing etcd data and manifests as a recovery point.

Backup automation through APIs

VCF exposes backup automation through its APIs, including the RecoveryBackupJobBackupRequest data structure for specifying backup location, protocol, authorization, and database scope, as well as the RecoveryBackupSchedulesUpdateSpec for programmatically managing backup schedules.

Disaster recovery planning

For disaster recovery planning, VCF supports application disaster recovery with data replication to a secondary site. Organizations should plan and test disaster recovery strategies regularly to meet their RTO and RPO targets. VCF Operations provides integration with VMware Live Recovery for periodic test runs to validate that existing recovery plans work with the underlying infrastructure and configured RPO limits. Application disaster recovery may result in some data loss during failover depending on the configured RPO.

VCF directly provides the mechanisms for creating recurring backups, managing retention, and supporting RTO/RPO requirements through multiple backup and snapshot methods. However, organizations must establish backup policies, define RTO/RPO targets, schedule regular restore testing, and maintain backup infrastructure such as external storage and third-party backup solutions to fully satisfy this control.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) provides backup and restore capabilities for the vDefend control plane, covering firewall rules, microsegmentation policies, IDS/IPS configurations, Bare Metal server information, tokens, and all associated security data managed by the platform. These backups protect against data loss from hardware or software malfunctions, data corruption, malware incidents, or unintentional deletion.

SSP supports recurring backup schedules configurable through the Backup Schedule interface, with frequency options ranging from 6 hours to 720 hours (30 days), as well as weekly scheduling by selecting the day and time. Recurring backups can be activated or deactivated by toggling the Recurring setting. Best practice guidance recommends scheduling backups during periods of low platform usage to minimize operational impact. A backup should also be performed before executing scale-out operations on the SSP cluster, to preserve the current configuration state before significant topology changes. Backup data is encrypted with a passphrase and transmitted to an SFTP server. Adequate storage must be verified on the backup server before activating recurring backups, and the platform must be in a healthy state for backup operations to proceed. Backup is also blocked if NSX is not onboarded to SSP.

SSP maintains a Backup History section that displays the status of each backup operation, showing "Completed" when the operation succeeds. When backup or restore operations enter a failed state, pod logs provide detailed error messages, including database query failures and volume attachment errors, to support troubleshooting. Restoration supports deploying the backed-up configuration onto the same SSP instance or a new instance, enabling recovery when the current instance is in a non-recoverable state. Restoration requires that the same NSX instance that was onboarded at the time of backup be used, and that the platform be deployed on the same vSAN datastore and build version as the initial installation. Certificate consistency between backup and restored environments must be maintained to avoid disruptions to NDR Sensor connectivity.

These capabilities address the backup component of this control for vDefend's own configuration and policy data. vDefend does not back up general workload data or application-level information; those responsibilities fall to the broader VCF platform's replication, snapshot, and backup mechanisms, including vSAN Data Protection, Protection and Recovery (PNR), and integration with third-party backup providers. vDefend's contribution is limited to protecting the security policy and configuration data that defines the network security posture of the environment.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides replication, snapshot, and recovery testing capabilities that support recovery point and recovery time objectives for protected workloads.

vSphere Replication delivers host-based continuous replication with RPO configurable from 1 minute to 24 hours, set via a slider during replication configuration. PNR uses the configured RPO to determine the most recent available state to which virtual machines are recovered during disaster recovery. vSAN snapshots and replication is a native, integrated snapshot-based backup solution for VMs running on vSAN datastores, managed through the vSphere Client, and supports RPO as low as 1 minute. Snapshot retention schedules support hourly, daily, weekly, and monthly snapshots with a maximum retention duration of three years. Predefined retention templates are available for quick configuration of RPO and snapshot retention parameters. Array-based replication supports configuring replication schedule, frequency, and RPO through VM storage policies, depending on the storage array's implementation.

PNR replication classes are preconfigured with an RPO that defines the acceptable amount of data loss after a disaster. In deployments using VCF Automation integration, replication classes can be assigned at the organization level.

Cyber Recovery, the cloud-based recovery component within PNR, uses incremental snapshots that transfer only modified or new data to cloud backup. This design enables detection of ransomware encryption by comparing entropy rates between normal snapshots and snapshots containing suspect data. Ransomware recovery plans in Cyber Recovery support predefined retention templates for configuring snapshot RPO and retention parameters.

PNR's own configuration is protected through backup settings that specify a datastore path, enable or disable the backup scheduler, set a retention period, and schedule backup frequency and time. PNR REST APIs can be configured to export and upload configuration data to a datastore on a daily basis. PNR also maintains internal database backups for audit and recovery purposes, covering the replication manager database (srmdb), recovery manager database (vrmsdb), and snapshot service database (snapservice).

Recovery plan testing is the integrity verification mechanism for protected data. During disaster recovery execution, PNR first attempts storage synchronization; if that succeeds, it uses the synchronized storage state to recover virtual machines to their most recent available state per the configured RPO. RPO violation dashboards in VCF Operations report violation counts for incoming and outgoing replications, enabling monitoring of whether replication is meeting defined targets.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides a built-in backup framework for managed PostgreSQL, MySQL, and SQL Server databases, giving administrators and database owners the tools to establish recurring backup schedules aligned with organizational recovery objectives.

Backup configuration is available at database creation and can be modified at any time through the database settings interface. Administrators activate automated backups using the Enable Automated Backups toggle (also exposed as Enable Backups in MySQL flows), specify a backup location pointing to S3-compatible object storage, and define a retention period.

PostgreSQL databases support both full and incremental backups, and SQL Server databases support full and differential backup schedules. SQL Server adds a Log Backup Frequency setting in Advanced Settings with a maximum value of 30 minutes that is directly related to the Recovery Point Objective for that database. Backup schedules are expressed as cron expressions and can be customized per database or applied at the policy level.

Data Service Policies provide centralized backup governance for databases deployed within a namespace. A policy can include named backup jobs specifying backup type and schedule, and the policy backup requirement setting offers three options: Require Automated Backups (databases must have automated backups), Allow Automated Backups (users can choose to activate or deactivate automated backups), and Disallow. Allowed backup locations are defined in the policy via the `allowedBackupLocations` parameter, restricting where backups can be stored. When multiple policies apply, DSM aggregates the backup schedules into a single effective backup policy per database. High Availability clusters require automated backups to be enabled in order to provision databases, helping ensure that recoverable copies exist for replicated topologies.

DSM also supports on-demand backups for primary PostgreSQL databases, independent of the configured automated schedule, which is useful for capturing a point-in-time snapshot before a significant change. Backup storage is managed centrally through the Settings pane Storage Settings tab, which displays Database Backup Storage buckets and allows administrators to add or edit object storage targets. Provider-level control plane backups are stored in a designated Provider Backup Repo bucket configured during Provider VM setup, and recovery of the Provider VM from backup uses the `restore-provider` command with a `pgbackrest.conf` path to restore the appliance to the latest timestamp.

DSM retains automated backups of deleted databases until the configured retention period expires. When a database with configured backups is deleted, the system automatically creates an archive containing all collected backups that remains available in the Archives tab for the remainder of the retention period, allowing recovery of inadvertently deleted databases. Administrators can also manually delete retained backups of deleted databases when they are no longer needed.

Point-in-time recovery is supported from configured backup storage, restoring a backup at a specified date and time to a newly created database VM with a user-specified name and datastore location. The restore function is also accessible through the VCF Automation UI for tenant users. If any incremental backup in a chain is deleted, DSM cannot restore data to points in time that depended on that backup, and a restore from an incremental chain requires the last full backup plus all following incremental backups. Maintaining a balanced schedule of full and incremental backups reduces the risk of a gap in the recovery chain.

DSM provides operational validation of the backup target through the backup storage repository alert, which checks connection and operational status, bucket name, certificate expiration date, credentials, and sufficient available space in the repository. This helps surface configuration drift or storage failures that would otherwise compromise recoverability.

Satisfying this control fully requires that the organization define RTOs and RPOs for each database workload, configure backup policies accordingly, and periodically test restoration to verify that backup data is valid and recovery objectives are achievable. DSM provides the technical backup infrastructure and operational checks on the backup target; RTO and RPO definition and end-to-end backup integrity testing are organizational responsibilities.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) includes a built-in backup and restore capability for the Avi Controller configuration database. The configuration database defines all clouds, virtual services, users, tenants, and related entities. Protecting it is the primary mechanism for recovering the Avi control plane after a Controller failure.

Backup operations can be created on-demand or on a recurring schedule via the Controller web UI, CLI (using the `export` command), or REST API (using the `/api/scheduler/` endpoint). The scheduler supports configurable frequency units, including hourly, daily, and weekly intervals, with the run mode set to periodic. For single-node Controller deployments, enabling periodic external configuration backups is mandatory; the product documentation states that external backups are required to handle recovery from a complete VM or disk failure.

Avi supports multiple backup storage targets. Local backups are stored directly on the Controller with a configurable retention count, configured via the "Enable Local Backups (On Controller)" setting. Remote backups are transferred over Secure Copy

Protocol (SCP) or Secure File Transfer Protocol (SFTP) to an off-Controller server, configured via the "Enable Remote Server Backup" setting. In 9.1, configuration backups can also be stored in Amazon S3 buckets as an additional remote storage target. When deployed as part of VCF, Avi backups are stored by default on the same server used for VCF Operations appliance backups; the recommended best practice is to configure an external SFTP server as the backup destination. VCF Operations can be used to configure the external backup server and storage path for Avi backups. Product guidance also recommends storing backups with clear labeling that includes version and date information.

Before a restore proceeds, Avi performs a set of pre-restore checks to validate the backup image. In 9.1, these checks include verification of backup configuration version compatibility, presence of all file objects from the configuration on the Controller, FIPS mode consistency between the backup and the current Controller environment, Service Engine attachment verification, system configuration validation, and patch verification. All checks must pass before the restore operation is allowed to proceed.

Restore operations can be performed via the CLI (import command with the `keep_uid` option to restore configuration to an empty Controller), the web UI, or the REST API restore endpoint. The API method accepts a configuration file and a passphrase parameter to decrypt an encrypted backup; the passphrase must match the one used when creating the backup. Restore operations generate system reports tracking operation state, start time, end time, duration, and total checks completed. The Controller metrics database can also be exported and imported separately to prevent loss of metrics data during version rollbacks. If all three nodes of a Controller cluster are permanently unavailable, recovery must be performed using a backup and restore procedure.

For multi-site deployments, Avi GSLB (Global Server Load Balancing) supports an Active disaster recovery deployment mode, enabling traffic redirection to a healthy site when a primary site fails. Avi GSLB adaptive replication mode also protects against configuration errors propagating across data centers by preventing faulty configuration objects from being replicated to follower sites.

The Avi backup and restore capability covers the Controller configuration plane. Application data, workload VM images, and the broader RTO/RPO framework depend on organizational process decisions and on the underlying VCF platform for VM-level data protection (see VCF Coverage).

Control 164.312(a)(1)

> Standard: Access control. Implement technical policies and procedures for electronic information systems that maintain electronic protected health information to allow access only to those persons or software programs that have been granted access rights as specified in § 164.308(a)(4).

SCF Controls: GOV-02, HRS-02, HRS-03, IAC-01, IAC-08, IAC-21

Aggregate Coverage: Meets

VCF (Meets)

VCF provides a layered identity and access management architecture spanning centralized identity services, role-based access control, group-based access policies, identity provider federation, and programmatic access management through APIs.

VCF SSO is the centralized authentication service. VCF SSO issues security tokens that grant authenticated users access to VMware vCenter, NSX Manager, VCF Operations, and other platform components without requiring separate credentials for each service. VCF Operations supports importing users and groups from VCF SSO for consistent identity management across the stack. VMware Identity Manager provides a platform for managing users and groups, managing resources and user authentication, and configuring access policies and resource entitlements. vCenter also supports built-in identity source authentication using local domain credentials. The built-in identity provider can also be configured to use Active Directory as an identity source through LDAP/S, OpenLDAP/S, or Integrated Windows Authentication (IWA), depending on the directory environment.

VCF supports federation with enterprise identity providers. vCenter can be federated to providers such as Microsoft Entra ID, ADFS, and Okta, which enables multifactor authentication and automatic user synchronization with the organization's directory. PingFederate is also supported as a federated identity provider; for these integrations, vCenter uses System for Cross-domain Identity Management (SCIM) to automate the exchange of user and group identity information between the external identity domain and vCenter. VMware Identity Broker allows principals to authenticate to vCenter through an external identity provider. NSX Manager can be configured to authenticate users from identity management providers and can be integrated with Workspace ONE Access for identity management services. The Supervisor component supports registration of OIDC-compliant external identity providers for authentication to VMware Kubernetes Service (VKS) clusters; supported providers include Okta, Workspace ONE Access, and Dex, configured by supplying the Supervisor callback URL to the identity provider.

Role-based access control is enforced across all VCF components. In vCenter, permissions associate a user or group with a role on a specific inventory object, and predefined roles cover common administrative functions. Custom roles can be created with only the minimum required privileges for a given workflow. Managing identity provider configuration in vCenter requires the VcIdentityProviders Manage privilege. VCF Operations supports group-based access control, allowing administrators to configure groups and assign roles that control access to dashboards, reports, policies, alerts, and administration functions, as well as granular role-based controls for platform operations including approvals, audits, certificates, and content libraries.

VCF Automation extends access management through organization-level and project-level controls. The VCF Automation Access Control service supports identity operations for managing groups and users, including editing user names, passwords, and role assignments. The organization portal enforces role-based access control, requiring either Organization Administrator or Organization Auditor roles to manage policy templates. Organization administrators can distribute infrastructure and configure group-level access through the organization management functionality. Project access is governed by predefined roles. Users and groups can be disabled at the organization level to revoke access without deleting accounts. The System Administrator role has the right to manage and view Access Control Lists, and the accessControls API allows administrators to view and manage ACL entries for defined entities.

For Kubernetes workloads within the VCF consumption layer, VKS supports two authentication methods: VCF SSO and OIDC-compliant external identity providers. The OIDC path is implemented through Pinniped and supports providers including Okta, Workspace ONE Access, Dex, GitLab, and Google OAuth. Configuring an external provider requires setting up an OpenID

Connect ID Token with a Groups claim type filter to enable group-based access control tied to the organization's directory. Custom ClusterClass configurations allow clusters to authenticate developers using existing corporate identity systems. VKS supports namespace permission roles: Owner (full control including deletion), Can Edit (provisioning and operating workloads), and Can View (read-only access). These roles map to Kubernetes ClusterRoles through RoleBindings, and RoleBinding objects can reference VCF SSO users and groups directly to integrate SSO identities with Kubernetes role-based access control. A user with the Namespaces.Edit privilege on a user-created Namespace folder can perform CRUD operations on Kubernetes API resources in the Supervisor. Namespace Self-Service permissions control which users can self-provision namespaces through kubectl.

Kubernetes RBAC is the primary authorization mechanism within VKS, using Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings to bind permissions to users, groups, or service accounts. Kubernetes Attribute-Based Access Control (ABAC) is also available, defining access rights through policies that combine user, namespace, resource, and access mode attributes. Authorization webhooks can interpret field and label selectors to enforce fine-grained access control based on resource attributes such as node names and labels.

Service accounts provide namespaced workload identity within VKS clusters. For Windows containers, the Group Managed Service Account (gMSA) Webhook allows containers to run as Active Directory identities. VKS service accounts can be annotated with IAM role ARNs to enable pod identity and role assumption for cloud resource access through OIDC federation, replacing long-lived static credentials with short-lived, least-privileged credentials on demand. IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege.

Several supplementary services within the VKS layer extend the IAM surface. Harbor Registry, available as a standard package on VKS clusters, enforces role-based access control to manage access to container image artifacts. The Secret Store Supervisor Service enforces RBAC for administrators, DevOps engineers, and application tenants managing sensitive data. Argo CD supports both OIDC configuration for external identity providers and local account configuration with global RBAC policies that define role-based access through policy rules and group mappings. The Istio service mesh package includes a pluggable policy layer supporting access controls, rate limits, and quotas at the service-to-service level.

Programmatic access management is available through several APIs. The Identity API authenticates and manages the authorization provider. The Identity Service and Infrastructure as a Service APIs are used to acquire access tokens for REST API authentication. Principal Identity users authenticate using client certificates for service-to-service communications between VCF components.

NSX integrates with LDAP and external identity management services for administrative access to networking configuration. NSX Manager enforces role-based access control with roles such as auditor and network administrator assignable to LDAP users. vDefend, a separate product that extends NSX with security capabilities, offers an Identity Firewall that integrates with Active Directory for identity-based firewall rules.

VMware Private AI Services (PAIS) provides OIDC-based authentication and group-based authorization for AI workloads, the primary IAM mechanisms controlling access to model endpoints, the model runtime, Agent Builder, and Data Indexing and Retrieval capabilities. PAIS authentication is configured with an issuer URL, a client ID (pais-authentication-id), and the openid, groups, and offline_access scopes. The OIDC provider must support the .well-known/openid-configuration discovery endpoint. Authorization restricts access to user accounts that are members of named groups listed in the authorizedGroups setting (such as group-for-pais-access-01 or group-for-pais-access-02). A groups claim is included in the Access Token and a corresponding groups scope is created in the OIDC configuration, while the oidc-groups-claim setting selects which claim name carries group membership when the OIDC provider uses a non-default name. The oidc-extra-audiences setting accepts additional OAuth 2.0 client identifiers that PAIS will accept when validating Access Tokens, supporting integration with downstream clients that present their own audience. Activating PAIS in an organization namespace requires coordination with the OIDC provider administrator and an organization administrator account in VCF Automation.

Identity provider integration for PAIS deployments is configured at the Supervisor level under Workload Management > Supervisors > Configure > Identity Providers. When a PAIS region is created for a Supervisor, an identity provider entry is

automatically created in VMware vCenter for that Supervisor, linking the Supervisor namespace to the configured OIDC source.

The Model Gallery, the curated repository for ML models in PAIS, restricts access to model artifacts and the training data used to tune them through Harbor project access controls. These controls scope which users and service accounts can read, push, or manage sensitive model data, adding an IAM enforcement layer to the model supply chain. A Harbor registry is recommended for PAIS deployments, and OCI-compliant registries from other vendors are also supported.

PAIS Knowledge Bases extend IAM to ingested data sources. Confluence data sources authenticate with a user name and password or a personal access token, while Microsoft SharePoint On-Premises data sources authenticate with a user name and password. Personal access tokens for Knowledge Bases are generated from user account settings and used for programmatic access to linked data sources.

PAIS integrates with Grafana for metrics visualization using the same OIDC provider, extending the IAM model to the observability layer so that operators authenticate through the configured identity provider before accessing PAIS dashboards.

VMware vDefend (Contributes)

VMware vDefend contributes to identity and access management by providing identity-aware network enforcement through Identity Firewall, which integrates with Active Directory to apply firewall policy based on authenticated user identity rather than IP address alone. Identity Firewall supports assigning Active Directory users and groups as source criteria in both distributed firewall rules and gateway firewall rules, applying to tier-0 and tier-1 gateways. This allows organizations to enforce network access policy by user or group membership rather than relying solely on IP-based controls.

Within its management plane, the Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. These roles govern access to security policy management, analytics, incident response, and diagnostic functions across the platform. Network Detection and Response enforces the same five-role RBAC model for triage operations such as viewing detections and campaigns, and for configuration operations including SIEM integration management. For authentication, the Security Services Platform supports Active Directory and OpenLDAP as external identity sources, with one identity source configurable at a time. The License Hub integrates with external identity providers to store and manage user and group information for access delegation.

Centralized IAM for organizational users, including VCF SSO, MFA, and directory lifecycle management, is handled by VCF and falls outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) supports least privilege through role-based access control with a defined set of predefined roles and the ability to clone and customize roles for narrower operational scope. The 9.1 release consolidates Site Recovery Manager and vSphere Replication management under a single permissions model where PNR augments vCenter roles and permissions with additional permissions that allow detailed control over PNR-specific tasks and operations. PNR also verifies permissions on the remote vCenter instance as part of its access control validation, so privilege assignments are evaluated at both sites.

By default, PNR restricts login access to vCenter administrators; other users must be explicitly granted access by an administrator through the PNR interface. Users or user groups assigned a PNR role who are not vCenter administrators do not obtain vSphere Replication privileges, because PNR roles do not include the privileges of vSphere Replication roles. A user who is not a vCenter administrator but requires privileges to perform both PNR and vSphere Replication operations should be added to two user groups, one for each role type, to avoid granting vCenter administrator privileges.

vSphere Replication uses role-based access control with predefined roles that can be cloned and customized by adding or removing privileges based on organizational needs. PNR supports role propagation to child objects in the inventory hierarchy, allowing administrators to extend privileges from parent objects such as folders to all virtual machines within them, or to assign permissions at specific inventory levels without propagation when narrower scope is required. When permissions are assigned without propagation, users must have at least Read-only permission on all parent objects in the vCenter inventory.

PNR for VCF Automation access is controlled through role-based permissions assigned to Provider Administrators, Organization Administrators, Project Administrators, and Project Advanced Users, aligning RBAC with VCF Automation tenancy boundaries. Namespace unpair operations require Organization Administrator role authorization. In shared recovery site configurations, PNR restricts users from changing roles or assigning permissions for objects not dedicated to their own use, which helps prevent unauthorized privilege escalation across tenants, and the vCenter administrator manages PNR permissions so that each user has sufficient privileges to configure and use PNR but no user has access to resources belonging to other tenants.

PNR requires separate privilege assignment for testing a recovery plan and running a recovery plan, which helps prevent unintended changes at both sites that would require significant time and effort to reverse. PNR roles that allow users to run commands on PNR Server should be assigned to trusted administrator-level users only, and PNR server access should be limited to administrators to reduce the number of accounts available to an attacker. PNR administrators can assign `SrmAdministrator` or `SrmProtectionGroupsAdministrator` roles to the automatic protection user or user groups for managing automatic protection permissions.

For the 9.1 Clean Room Orchestrator, at least one user must be assigned the Organization Owner role to enable administrative access to all resources in the Organization, with additional roles available for narrower delegation. VCF Operations orchestrator workflows for PNR require administrator credentials to access and execute, which restricts non-administrative users from performing sensitive recovery operations through the orchestration interface.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) incorporates multiple identification and access management mechanisms that support organization-wide IAM controls within the data services layer.

DSM implements role-based access control with two defined roles: the DSM Admin role, which can create, monitor, and manage all data services in the environment, and the DSM User role, which is restricted to managing and monitoring data services within the namespaces to which the user has been granted access. These roles are assigned at user creation time and govern what each user can see and do within the DSM interface. The Permissions view in the DSM dashboard provides administrators with a centralized location for creating, monitoring, and managing all configured users.

DSM supports two identity sources, which can be used independently or together. Local users are created directly within DSM, with credentials validated by matching email address and password. LDAPS users are sourced from a configured LDAP identity provider, allowing organizations to extend their existing directory service into DSM. When LDAPS is configured, administrators can import users from the directory provider and assign them DSM Admin or DSM User roles. DSM also supports group-based access control: Directory Service Groups from the LDAP provider can be assigned roles directly, so group membership in the external directory determines access level in DSM without requiring per-user assignments.

At the database level, DSM extends authentication controls beyond the platform management layer. MySQL database instances support LDAPS authentication using Active Directory. PostgreSQL and other database instances support host-based authentication (HBA) rule configuration, which determines which clients are permitted to authenticate to a given database instance. SQL Server instances support Windows Authentication through Active Directory integration, enabling Kerberos-based authentication so that clients such as SQL Server Management Studio running on domain-joined machines can authenticate via single sign-on. SQL Server also uses contained database users, where identity information resides within the database itself rather than at the server level. Administrators can configure SQL Server instances with either a SQL User or Windows Principal as the primary administrator identity, with Windows Principal available for Active Directory-integrated clusters. An internal `dsm_mgmt` management login restricts users from accessing or modifying system-level objects, keeping administrative operations within an isolated context.

Namespace isolation adds a further access boundary. DSM namespaces enforce role-based access control that allows multiple users to work jointly on data services within a namespace while remaining isolated from data services in other namespaces. This supports least-privilege access within multi-tenant deployments.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer (Avi) provides a dedicated administrative identity and access management plane through the Avi Controller, supporting multiple authentication methods and fine-grained authorization controls that allow organizations to implement IAM policies across both the management plane and the application delivery layer.

For administrative access, the Avi Controller supports local user accounts, LDAP and LDAPS directory integration, SAML-based federated authentication (including integration with Workspace ONE Access for catalog-based application access), basic authentication, and OAuth/OIDC for API access. Auth Mapping Profiles allow organizations to map external directory groups to specific roles and tenants, so that group membership in an external identity provider directly controls what a user can access within Avi.

Authorization is handled through role-based access control (RBAC) with object-level granularity. Avi's extended granular RBAC uses markers, which are labels assigned to objects, to enable fine-grained authorization based on object ownership and classification. Permission categories cover Operations (including alerts, actions, and traffic capture) and Administration (including controller, tenant, user, role, and system configuration management). This allows restrictions so that a user's permissions apply only to the specific resources matching the markers assigned to their role. RBAC covers object categories including Virtual Services, Application Profiles, SSL/TLS Certificates, Certificate Management Profiles, Cloud definitions, TCP/UDP Profiles, Persistence Profiles, Health Monitors, Analytics Profiles, IP Address Groups, String Groups, SSL/TLS Profiles, PKI Profiles, and Authentication Profiles, with distinct read and write access levels configured per object type.

For multi-tenant deployments, Auth Mapping Profiles support tenant isolation with configurable user group to role mappings, allowing organizations to enforce separation between teams or business units operating within the same Avi Controller.

The Avi License Hub supports role-based access control through an external identity provider, with three predefined roles: Enterprise Admin (full access for all operations, including upgrades and authentication configuration), Auditor (view-only access for tracking activity without making changes), and Support Bundle Collector (restricted to collecting system logs and diagnostics). Management interface access is further controlled through restrictions on allowed ciphers and HMACs for management sessions.

For deployments involving the Avi Kubernetes Operator (AKO), Kubernetes RBAC policies can be applied to AKO Custom Resource Definitions (CRDs) to enforce stricter access control over routing configuration for specific user groups. The Avi Controller also implements RBAC at the Kubernetes and OpenShift cluster level by assigning tenants and roles to user accounts.

At the application layer, Avi can enforce client authentication using OAuth, SAML, JWT token validation, and mutual TLS with client certificates, extending access control to the traffic flowing through virtual services rather than only to the management interface.

Organizations are responsible for defining roles, mapping directory groups to permissions, establishing naming conventions for markers, and maintaining user lifecycle processes. Avi provides the technical mechanisms; the governance and operational processes for identity management must be organized by the teams managing the deployment.

Control 164.312(a)(2)(i)

> Implementation specifications: Unique user identification (Required). Assign a unique name and/or number for identifying and tracking user identity.

SCF Controls: IAC-02, IAC-09

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides centralized authentication, authorization, and auditing through VCF SSO, which acts as the identity broker for all VCF management components. All user and service authentication flows through VCF SSO, providing a single point of control for identity management across VMware vCenter, VMware ESX, NSX, VCF Operations, and VCF Automation. VCF SSO is configured via the VCF Operations console and provides a unified authentication source for VCF components.

VCF supports multiple authentication mechanisms for organizational users. VCF SSO issues SAML tokens for authenticated sessions and supports multiple authentication context methods, including PasswordProtectedTransport (password over HTTPS) and holder-of-key tokens that embed security artifacts for delegation scenarios. vCenter supports built-in identity source authentication using local domain credentials and basic authentication through the OAuth 2.0 Password grant type when federated to an external identity provider. VCF SSO also supports the use of SSPI (Security Support Provider Interface) for client authentication.

Identity federation with enterprise identity providers (via SAML or OIDC) enables organizations to extend their existing AAA infrastructure to VCF. Federating vCenter to an enterprise identity provider supports multifactor authentication and automatic registration and termination of users across services. vCenter has documented federation configurations for specific providers including Okta and PingFederate. VCF SSO also supports the System for Cross-domain Identity Management (SCIM) protocol for automating the exchange of user identity information between identity domains and external identity providers.

Organizations using Microsoft Active Directory can use user identities contained in a Windows Server domain controller or Active Directory service across their virtual infrastructure. VCF Automation allows each organization to define its own identity provider that it shares with other applications; users authenticate to the identity provider to obtain a token that they then use to log in to the organization. Every organization in VCF Automation has its own identity source for user import. The Supervisor component supports registration of external OIDC identity providers for authentication using Pinniped, which inspects upstream identity tokens from the external provider to determine user identity and group membership before passing that information to the Kubernetes API server. Supervisor can be configured with any OIDC-compliant provider, including Okta, Workspace ONE Access, and Dex, to authenticate users connecting to VMware Kubernetes Service (VKS) clusters. Custom ClusterClass configurations for VKS clusters can be used to authenticate developers using existing corporate identity systems. The Kubernetes API server also supports integration with organizational authentication infrastructure such as LDAP or Kerberos through authentication plugins, enabling Supervisor to participate in existing centralized identity management. An Identity API is available to programmatically authenticate and manage the authorization provider, supporting automated identity lifecycle management.

Authorization is enforced through role-based access control across all VCF components. vCenter maps authorization levels to groups and roles, providing consistent security controls regardless of operational context. VCF verifies what objects principals have access to as part of its authorization model. NSX has a set of built-in roles including Enterprise Admin, Auditor, Cloud Admin, Cloud Operator, Network Admin, Network Operator, Project Admin, Security Admin, and others. Local guest user accounts in NSX have the Auditor role by default, and only a user with the Enterprise Admin role can create new local guest user accounts. VCF Automation provides Organization Administrator, Organization Auditor (read-only), and Organization Owner roles, along with the ability to create custom roles scoped to an organization. Organization Administrators can view the rights associated with roles and create roles local to their organization. For Kubernetes workloads, vSphere Supervisor supports Namespace Owner, Edit, and View permission roles that allow consumers of vSphere Namespaces to provision VKS clusters and vSphere Pods using kubectl. Kubernetes RBAC evaluates Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings against the username, UID, group membership, and extra fields supplied by authenticator modules to determine whether a request is permitted. Users authenticated through external OIDC providers are referenced in

ClusterRoleBindings using the `oidc:user@example.com` naming convention; users authenticated through VCF SSO use the `sso:<username>@<domain>` convention. The `AuthorizeWithSelectors` feature gate passes field and label selector information to authorization webhooks, supporting more granular per-resource authorization decisions. User impersonation is governed by Kubernetes RBAC: the "impersonate" verb on user, group, and ServiceAccount resources under authentication.k8s.io allows designated administrators to act on behalf of other principals in a traceable manner. Kubernetes also distinguishes human user accounts, whose identities are managed externally by the identity provider, from ServiceAccounts, which are namespace-scoped API objects used by automated workloads and processes; separating their lifecycle management supports differentiated audit strategies for each category. IAM role trust policies for VKS clusters can be scoped to specific service accounts and namespaces to enforce least privilege.

VCF provides role-based visibility into policy enforcements. The Organization Administrator and Organization Auditor roles can view policy enforcements within their organizations. VCF's logging infrastructure captures authentication and authorization events across management components. The Kubernetes API server records API server activity with structured per-event metadata. Audit annotations include `authorization.k8s.io/decision` and `authorization.k8s.io/reason`, which record each authorization decision and its human-readable justification in the audit log, providing per-request traceability of who performed what action and how the authorization decision was reached. An audit event is logged for each impersonation request, enabling tracking of how impersonation is used over time. Audit rules can be configured to alert on specific events, such as concurrent reading of multiple Secrets by a single user. Authentication context, including username and group memberships, can be retrieved and logged using `kubectl auth whoami` for verification purposes. Administrators can use `kubectl auth can-i` with user impersonation to determine what actions other users are permitted to perform.

Service-to-service authentication uses certificate-based Principal Identity users rather than password credentials. Principal identity user certificates must be SHA256-based and use RSA/DSA message algorithm with 2048 bits or above key size. Each VCF component registers with VCF SSO as a solution user. VCF Operations integrates with VCF SSO for centralized user and group authentication and management, and also supports LDAP authentication sources for additional monitoring and management access.

Additional Consumption-layer services extend the AAA model to workload infrastructure. Harbor Registry, available as a standard package on VKS clusters, enforces role-based access control for container image artifacts and artifact security policies. The Secret Store Supervisor Service enforces RBAC across administrators, DevOps engineers, and application tenants for access to secrets and credentials. Argo CD, deployable as a Supervisor Service, supports OIDC authentication with PKCE via the `enablePKCEAuthentication` field and defines access through global RBAC policies using policy rules and group mappings.

While VCF provides the technical mechanisms for authentication, authorization, and audit, centralizing these capabilities requires the organization to deploy and manage an external identity provider (such as Active Directory or an OIDC-compliant provider), define identity governance policies, and establish processes for user lifecycle management including provisioning, periodic access reviews, and de-provisioning. Role assignment procedures and access review processes are organizational responsibilities that fall outside VCF's direct control.

VMware Private AI Services (PAIS) integrates with an external OIDC identity provider to authenticate organizational users accessing AI infrastructure on VCF. The `PAISConfiguration` custom resource is configured with an OIDC authentication block specifying the issuer URL, the client ID (`'pais-authentication-id'`), and the scopes `'openid'`, `'groups'`, and `'offline_access'`. When a region is created for a supervisor in PAIS, an identity provider is automatically created in VMware vCenter for that supervisor, establishing a consistent authentication entry point for AI workloads. Activating PAIS in an organization namespace requires coordination with the OIDC provider administrator, who supplies the issuer URL and client ID.

Authorization for PAIS is enforced through OIDC group-based access control. The `'authorizedGroups'` setting in the `PAISConfiguration` restricts service access to user accounts that belong to designated OIDC groups (for example, `'group-for-pais-access-01'` or `'group-for-pais-access-02'`). The `'oidc-groups-claim'` setting names the claim used to identify group membership in the Access Token, and `'oidc-extra-audiences'` accepts additional OAuth 2.0 client IDs that PAIS will recognize when validating tokens. Grafana, used for PAIS metrics visualization, extends the same model through the `'grafana-oidc-role-`

mapping` configuration: users in a designated PAIS access group are assigned the Admin role automatically, while remaining authenticated users receive the Viewer role.

Harbor Registry imposes its own credential boundaries for AI artifact access. PAIS integrates with Harbor registries as a model storage backend, requiring authentication and certificate-based trust for model retrieval. Processes that push artifacts to Harbor authenticate using the `oras login` command with username and password credentials. Knowledge Base integrations support per-source authentication: Confluence connections accept a user name and password or a personal access token, and SharePoint On-Premises connections use user name and password authentication. These mechanisms restrict access to organizational AI artifacts and reference data to authorized accounts.

VMware vDefend (Contributes)

VMware vDefend contributes to this control through two mechanisms: management plane authentication for its Security Services Platform (SSP) and Identity Firewall (IDFW) for network policy enforcement.

SSP provides two built-in local user accounts configured during deployment: an admin account with the Enterprise Admin role, which has full privileges to deploy, manage, upgrade, and configure authentication and authorization settings, and an audit account with the Auditor role, which provides read-only visibility into system activity and API access for auditing without the ability to make configuration changes. The SSP License Hub implements role-based access control with three defined roles: Enterprise Admin, Auditor, and Support Bundle Collector. Roles can be assigned to individual users or groups defined in an external identity provider, allowing organizations to integrate Active Directory or LDAP group membership into access control for the platform.

SSP supports directory-backed authentication through Active Directory over LDAP and OpenLDAP in addition to local accounts. The platform uses Authelia, an open-source authentication and authorization server, to provide two-factor authentication and single sign-on capabilities for management access, allowing organizations to require multiple authentication factors for access to vDefend's security management functions.

Identity Firewall processes user identity at the source workload to enforce DFW and gateway firewall rules based on Active Directory user and group membership. This allows AD users and groups to be used as source criteria in firewall rules, enabling network access controls based on authenticated user identity rather than IP address. Security administrators are directed to distinguish between two primary administrative personas when managing vDefend access, maintaining security boundaries between different projects and the broader organization.

Centralized AAA for organizational users across the broader VCF environment, including single sign-on and multi-factor authentication for all users, is provided by VMware vCenter and VCF SSO and is outside vDefend's scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) addresses the authentication component of this control through a two-tier identity model. DSM supports both local user accounts and LDAPS-integrated directory service accounts, and administrators can configure one or both identity sources simultaneously. Local users are authenticated by matching their email address and validating their password directly within DSM. LDAPS users are authenticated by matching the email domain name against the registered LDAPS server and validating credentials against the directory service. DSM can be configured to use an LDAP server for both authentication and authorization of platform-level users.

Authentication for the managed databases is handled through database-native mechanisms that DSM exposes and configures. PostgreSQL databases use host-based authentication (HBA), with rules managed through DSM. The HBA configuration applies ordered matching rules where the first entry matching the connection type, client address, requested database, and user name is applied. The default final entry uses SCRAM-SHA-256, providing strong password-based authentication; an optional LDAP entry can also be included. MySQL databases support LDAPS integration using a simple authentication plug-in, with a unique LDAPS user entry per user and support for Active Directory authentication. PostgreSQL and MySQL databases also support LDAPS user accounts linked to organizational directory services, with LDAPS user creation managed through the DSM interface.

DSM adds SQL Server as a supported database engine. SQL Server clusters support two administrator identity types: SQL User credentials and Windows Principal accounts for clusters integrated with Active Directory. DSM's Active Directory integration supports Kerberos-based authentication for domain-joined SQL Server clients, allowing tools such as SQL Server Management Studio running on a Windows machine to authenticate using domain credentials. DSM maps the dbo user, the database object owner, to administrator-controlled identities for SQL Server database access. SQL Server clusters can also use contained database users, where each user authenticates directly against the database rather than a server-level login, keeping identity information self-contained within the database.

Authorization is handled through a role-based model. DSM provides two platform-level roles, DSM Admin and DSM User, which determine the capabilities available to each user within the DSM management interface and API. Custom user roles can be configured for directory service group members, providing scoped monitoring and management access. The Permissions view in DSM supports the creation, monitoring, and management of configured users, giving administrators visibility into who has access. Role assignments also affect behavior in database operations; DSM automatically establishes trust between primary and secondary PostgreSQL instances for Admin-role users, while User-role accounts require manual trust establishment.

DSM produces audit records covering both user-initiated and system-initiated actions. Audit events are generated for actions performed through the DSM UI and API, and each audit log entry includes a Source field identifying the initiating entity: either a user's email address or "System" when the action was initiated by DSM itself. Gateway Audit Logs provide visibility into gateway-level events, and the System Audit Events view is the designated location in the DSM UI for tracking nondatabase-related operations and tasks. For SQL Server clusters, DSM provides configurable server auditing with preset audits for login tracking and log retention; the Login Auditing option can automatically create a simple audit for login events.

In self-service consumption deployments, the DSM Consumption Operator authenticates with the DSM infrastructure using a dedicated authentication secret (dsm-auth-creds), providing a defined authentication path for Kubernetes-native database provisioning.

DSM's authentication, authorization, and audit capabilities are scoped to the DSM platform and its managed databases. Centralized AAA for the broader organizational user population, including account lifecycle management, privileged access governance, and enterprise-wide log aggregation, requires organizational identity governance programs and security tooling outside DSM's scope.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) maintains its own administrative identity plane with mechanisms covering all three AAA elements: authentication, authorization, and audit. User accounts fall into two categories: local users and remote users. Remote users are authenticated through external AAA servers, with support for LDAP, TACACS+, and SAML-based authentication profiles. The product documentation recommends federated authentication as the preferred approach, delegating the authentication process to an organization's central identity provider rather than managing credentials locally within Avi.

For authorization, the Avi Controller evaluates authorization mapping rules on every user login, updating the user record with tenant and role pairs. Auth Mapping Profiles can map multiple user groups to different roles with tenant isolation, supporting both simple single-role assignments and multi-tenant configurations where a single user requires access across multiple administrative boundaries. The admin user is authorized and responsible for the highest-level configuration operations, including user creation and authorization and tenant management. The admin account is maintained as a locally authenticated account even in a system configured for remote authentication, providing a break-glass path for Controller access.

The Avi Controller License Hub provides dedicated role-based accounts for administration and auditing. The Admin account holds the enterprise_admin role with full access to deploy and manage security services, perform upgrades, and configure authentication and authorization. The Audit account holds the auditor role with full access to APIs and services for system auditing. LDAP can be configured as an identity provider for License Hub authentication, and the Admin user can reset the Audit user's password.

Avi also supports OAuth and OpenID Connect (OIDC) for client authentication at the application proxy layer. When configured, the Controller acts as a resource server and retrieves identity information from the OIDC UserInfo endpoint or from ID token claims, enabling per-user identity context to be associated with proxied application traffic. DataScript can check if a user ID is in an approved group list and redirect unauthenticated users to a login page, providing identity-based access control at the virtual service layer.

In the Avi for VCF Organization-Managed Mode, the organization administrator must be authenticated to edit Service Engine Groups and manage their own infrastructure configurations, reinforcing role-based access enforcement at the VCF integration layer.

The control asks whether the organization centrally manages AAA across its environment. Avi provides the mechanisms for its own administrative plane and supports integration with a central identity provider, but the organization must configure that integration, maintain the identity provider, and establish processes for reviewing audit log output.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 164.312(a)(2)(ii)

> Implementation specifications: Emergency access procedure (Required). Establish (and implement as needed) procedures for obtaining necessary electronic protected health information during an emergency.

SCF Controls: IAC-15, IAC-15.2, IAC-15.9

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides account management capabilities for the infrastructure platform's own user, group, system, and service accounts. The broader organizational governance of account management across all enterprise systems is outside VCF's scope.

VCF SSO is the centralized identity service for the platform. Administrators manage individual and group accounts through VMware vCenter, and can integrate external identity sources (Active Directory, LDAP, OIDC) so that account lifecycle management follows existing enterprise directory services. vCenter also supports System for Cross-domain Identity Management (SCIM), enabling automated provisioning and deprovisioning of user and group accounts when synchronized with a supported external identity provider. VCF Automation also supports LDAP, OIDC, and SAML-compliant identity providers for user authentication, allowing consistent identity federation across the stack.

VCF Operations provides a consolidated view of accounts across the VCF stack through its password management dashboard, including account statuses and remediation needs. This centralized visibility helps administrators track account states and identify accounts requiring attention. The password management interface, accessible to users with the Administrator role, supports password rotation and remediation for service account passwords across integrated components. Administrators should plan maintenance windows when rotating passwords for multiple accounts to avoid service interruptions.

At the compute layer, VMware ESX hosts support local account management through the HostLocalAccountManager interface, which allows administrators to create and manage user accounts on individual hosts. In a properly configured VCF environment, access to ESX is brokered through vCenter rather than managed directly on each host. The vSphere Web Services API documentation recommends that user accounts be given the minimal number of privileges required for their roles, consistent with least-privilege principles. For guest virtual machines, vCenter allows administrators to configure VCF SSO user mappings to guest operating system accounts, enabling centralized control over which VCF SSO users can access accounts within guest VMs.

VCF Operations offers account management capabilities including the ability to add, edit, remove, and import user accounts, manage roles, define object-level access for users assigned to specific roles, and manage user group membership. Each user must have a unique account with one or more roles assigned. User accounts can be associated with specific objects in the VCF Operations cluster to control the scope of access. VCF Operations supports importing user accounts from external sources such as LDAP databases or single sign-on servers, allowing organizations to integrate their existing directory services with VCF Operations access control.

VCF Operations for Networks supports local user management with role-based access control, where users are assigned roles during account creation.

NSX Manager supports management of local user accounts through both its user interface and CLI. Through the UI, administrators can configure password expiration, deactivate users, and reset passwords. Through the CLI, the admin user can manage local user account passwords, change user names, and add, delete, or deactivate user accounts. NSX Manager has one active local account out of the box (admin), which cannot be deleted or deactivated, and best practice is to keep all other local user accounts deactivated.

VCF Automation allows system administrators to create other system administrator and user accounts within the provider organization. Service accounts are created by administrators who hold the View Service Accounts and Manage Service

Accounts privileges, providing controlled delegation of service account creation. These service accounts authenticate using API access tokens that rotate after each use. Organization owners can add and manage other users within their scope.

The VCF Consumption layer (VMware Kubernetes Service (VKS) and vSphere namespaces) introduces a structured model for service and application account management governed through the Kubernetes API. Kubernetes ServiceAccount resources are namespace-scoped objects that provide distinct, non-human identities for application pods, in-cluster services, and other entities that need to authenticate to the Kubernetes API server. Service accounts are created automatically when namespaces are provisioned or on demand through API calls, and each is bound to roles through RoleBinding or ClusterRoleBinding resources, enabling RBAC-governed access at either namespace or cluster scope. The Kubernetes documentation advises against granting cluster-wide roles to all service accounts; per-namespace permission management is the recommended practice to maintain proper access control boundaries. Service account tokens should be scoped to minimize their usage to only the application that requires them, and the Kubernetes RBAC model specifies that user account creation must block reuse of deleted usernames so that newly created accounts with identical names do not inherit the permissions of prior accounts. Service account definitions should be included in configuration bundles for complex containerized workloads to support portability of system component identities.

Kubernetes provides lifecycle controls for service account credentials. The LegacyServiceAccountTokenCleanup feature gate enables automatic cleanup of Secret-based service account tokens that have not been used within a specified time period, with a default retention period of one year, supporting governance of stale credentials. Infrastructure credentials, including certificates used by service accounts and cluster components, should be configured with short lifetimes and automated rotation to support ongoing account lifecycle management. Separating ServiceAccount creation from human user onboarding enables distinct audit strategies for each account type, and production VKS clusters should be configured with multiple accounts holding differentiated levels of access to different namespaces rather than relying on a single administrative account. IAM role trust policies for VKS workloads should be scoped to specific service accounts and namespaces to enforce least privilege at the workload level.

For Windows workloads running in VKS clusters, Supervisor supports Group Managed Service Accounts (gMSAs). When Windows node pools are joined to an Active Directory domain, gMSAs provide automatic password management, simplified service principal name (SPN) management, and delegated administration across multiple servers. Access to gMSA credentials is controlled through Active Directory security groups, and the VKS cluster configuration specifies the relevant security group through the gmSAControlSecurityGroupDN setting. Configuring gMSA support for Windows node pools also requires an Active Directory service account with service principal names following Kerberos naming rules, and the VKS Security Group must be granted delegation rights to that account. HostProcess containers running as local user accounts use ephemeral local user accounts that are created and joined to a specified user group at container initialization, eliminating the need to manage passwords for those local accounts.

The Argo CD Supervisor Service supports local account creation through the spec.localAccounts field, allowing named accounts to be defined for GitOps workflows. Argo CD RBAC policy rules and group mappings control account permissions and role assignments, including the ability to grant administrative roles to specific local accounts. Both local accounts and OIDC-authenticated users can be governed through the same RBAC policy framework. Argo CD cluster registration creates a service account with cluster-level privileges to manage the target cluster, so administrators should review and scope those privileges to what is operationally required.

Avi Load Balancer uses a combination of roles and tenants to determine user account authorization, supporting multi-tenant access control for load balancing services.

Role-based access control is available across all VCF components, supporting the principle of least privilege through granular role definitions. User accounts should be given the minimal set of privileges required for their responsibilities.

While VCF provides these technical account management mechanisms across its components, proactive account governance requires organizational policies and procedures that define account lifecycle management, periodic access reviews, temporary and guest account provisioning standards, and account termination processes. These governance activities fall outside the scope of what VCF provides as a platform.

VMware vDefend (Contributes)

Within its own management plane, VMware vDefend (vDefend) Security Services Platform (SSP) maintains two built-in local user accounts: an admin user with the Enterprise Admin role providing full management access, and an audit user with the Auditor role providing access to APIs and services for system auditing. In vDefend, SSP defines five roles at the platform level: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector, enabling separation of duties across administration, auditing, security engineering, security operations, and diagnostic support functions.

SSP enforces password policies for local accounts; passwords must meet defined complexity requirements and can be changed or reset through the Platform and Instance Management interfaces. Remote users and remote user groups are managed through the System > User Management interface, where administrators assign and modify roles. SSP supports directory-managed accounts through external identity providers such as Active Directory over LDAP and OpenLDAP, extending account management to enterprise identity sources; local accounts remain available even when external identity providers are disconnected.

This coverage is limited to vDefend's own management-plane accounts. Organization-wide account management for individual, group, system, service, application, guest, and temporary accounts across all technology assets is outside vDefend's scope and must be addressed through dedicated identity and access management platforms.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides account management mechanisms for the accounts it directly governs: the DSM administrator account, DSM user accounts (local and LDAPS-federated), database owner accounts, and the internal service account DSM uses to authenticate to VMware vCenter.

DSM supports two identity sources for user accounts. Local users are created directly within DSM using an email address as the login username and a password. LDAPS users are federated from a configured directory server, allowing organizations to manage DSM access through their existing identity infrastructure. Administrators can configure one or both identity sources depending on organizational requirements. For LDAP-federated accounts, DSM supports group-based access control by assigning roles to Directory Service Groups, so that group membership in the directory server determines DSM access. This is configured under Administering Data Services Manager > Managing LDAP Users in Data Services Manager.

DSM implements role-based access control with two role types. The DSM Administrator role has full visibility and maintenance capabilities across all data services and is responsible for managing DSM settings including LDAPS and SMTP configuration, database backups, and high availability settings. The DSM Administrator also manages namespaces and permissions for database ownership. The DSM User role allows individuals to provision and manage their own databases and perform database lifecycle operations while having no visibility into other users' data services. DSM User roles support namespace-level access controls that can be configured at the time a user account is created, scoping access to specific Supervisor namespaces. This separation restricts administrative capabilities to designated personnel and scopes each user to the resources they own.

DSM user accounts maintain `failed_login_count`, `last_failed_login_time`, `locked_state_start_time`, and `force_password_change` attributes to enforce account lockout and password management policies. These fields track authentication failures, record when an account entered a locked state, and flag accounts that must change their password at the next login. This is configured under Administering Data Services Manager > Managing LDAP Users in Data Services Manager > Create Directory Service Groups Using the Data Services Manager UI.

The initial DSM administrator account is created during deployment of the DSM Provider Appliance and is mandatory; it cannot be deleted. When access needs to be suspended without disrupting running databases, administrators can reset a local user's password and delegate management of the user's databases to a different user rather than deleting the account.

For database-level accounts, DSM allows database owners to set or change the database administrator password at any time while the database is online. DSM also supports LDAPS user creation for PostgreSQL database authentication and access control, enabling directory-managed credentials for database access rather than locally maintained passwords.

DSM introduces SQL Server as a managed database engine, with specific account management controls for SQL Server instances. DSM deactivates the default sa account and uses a reserved internal account, `dsm_mgmt`, with sysadmin privileges for management operations. The `dsm_mgmt` account restricts users from accessing or modifying system-level objects, keeping administrative operations within an isolated context. DSM uses contained database users for SQL Server database access, so users authenticate directly against the database rather than through a server-level login. For SQL Server clusters in Active Directory environments, DSM requires a service account that is a standard Active Directory user and a member of the Domain Users group. DSM can also be configured with a privileged Active Directory account to automate the management of service principal names (SPNs) and DNS records for SQL Server clusters. The `dbo` user is mapped to administrator-controlled identities for SQL Server database access.

DSM maintains an internal service account for authentication to vCenter. This account is required for DSM to provision and manage infrastructure resources. DSM maintains service account rotation logs that administrators can review to diagnose vCenter authentication failures. Administrators should monitor for alerts indicating that the service account has expired, as an expired service account causes ongoing DSM operations to fail.

DSM's account management capabilities address the technical layer of this control within its scope. Broader account governance (including formal provisioning and deprovisioning procedures, periodic access reviews, approval workflows for account creation and role changes, and lifecycle management for temporary or guest accounts) requires organizational processes that operate outside DSM. Organizations should establish procedures for reviewing DSM account assignments, managing LDAPS group membership to reflect current job roles, and deprovisioning access when personnel change responsibilities.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer maintains its own account management plane on the Avi Controller, distinct from the underlying VCF infrastructure. User accounts are organized into two categories: local users, whose credentials are stored on the Controller, and remote users, who authenticate through an external authentication, authorization, and accounting (AAA) server such as LDAP or Active Directory. The admin account is a special system account used for initial setup that remains locally authenticated even when the system is configured for remote authentication. Local accounts remain available even if external identity providers such as LDAP or OpenLDAP become disconnected, providing a resilient fallback path for administrative access.

Account management operations are gated by role-based access control: configuring or managing user accounts requires write access to the Accounts section, as defined by the role assigned to the managing account. Avi provides predefined roles that can be customized or extended by administrators with appropriate access. Each account can be scoped to specific tenants and assigned different roles within each tenant through Tenant and Role assignment, supporting both centralized administration and delegated management across multi-tenant deployments. When a user has access to multiple tenants, the system places them into a default tenant after login. If no additional tenants have been created, all new user accounts are automatically added to the admin tenant. In the VCF for Avi integration, a Provider or Load Balancer Administrator manages resource assignments to enforce quotas and resource boundaries within organization-managed mode.

User Account Profiles govern account attributes and access controls. All users are attached to the Default-User-Account-Profile by default, which enforces standard lockout thresholds and password policies. Administrators can assign the No-Lockout-User-Account-Profile for accounts that require uninterrupted access, and can create custom `UserAccountProfile` objects to tailor security policies for different user populations. In the VCF for Avi integration, the system manages two specific accounts for password updates: `admin` and `vcfops-admin`, providing a defined account scope for VCF-integrated deployments.

Account lifecycle operations available through the Controller include account creation, deletion, deactivation, and reactivation. Deletion removes an account from the system entirely. Deactivation suspends access without deleting the account record, and reactivation restores access for a previously deactivated account. These operations are available only to users with write access to the Accounts section, scoping account management authority to authorized administrators. The Avi SaaS Controller

supports service account configuration for programmatic and automated access, extending account lifecycle management to service identities within the Avi-managed plane.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 164.312(a)(2)(iii)

> Implementation specifications: Automatic logoff (Addressable). Implement electronic procedures that terminate an electronic session after a predetermined time of inactivity.

SCF Controls: CFG-02, IAC-25

Aggregate Coverage: Meets

VCF (Meets)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the Security.PasswordQualityControlPwquality setting on ESX hosts, including parameters such as minlen=15, maxrepeat=3, maxclassrepeat=4, difok=4, and enforce_for_root. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster

Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. AppArmor and SELinux provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as ConfigMaps and Secrets.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references ConfigMaps containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgml_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs,

and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use `scram-sha-256` as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support `scram-sha-256`, `reject`, and `cert` authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control 164.312(a)(2)(iv)

> Implementation specifications: Encryption and decryption (Addressable). Implement a mechanism to encrypt and decrypt electronic protected health information.

SCF Controls: CRY-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF implements cryptographic protections across its component stack using publicly standardized, validated cryptographic modules and algorithms.

Multiple VCF components rely on cryptographic modules validated through the NIST Cryptographic Module Validation Program (CMVP) to FIPS 140-2 and FIPS 140-3 standards. NSX is configured to use FIPS 140-3 validated cryptographic modules by default, and NSX Manager uses FIPS 140 approved algorithms for authentication to its cryptographic module. Specific NSX validated modules include IKE with Rambus Safezone 2.0 (Certificate #4898), VMware OpenSSL 3.0.9 (Certificate #4861), VMware BouncyCastle 2.0.0 (Certificate #4986), and VMware BoringCrypto 6.0 (Certificate #4694). VCF Automation uses the BouncyCastle FIPS 2.0.0 cryptographic module, which holds FIPS 140-3 Certificate #4743. VCF Operations for Networks uses BC-FJA (Bouncy Castle FIPS Java API) version 2.0.0 with FIPS 140-2 Certificate #37009 as its validated cryptographic module. This consistent use of FIPS-validated modules across the platform means that organizations deploying VCF in regulated environments can rely on cryptographic implementations that have undergone independent validation against well-known public standards. The VMware Kubernetes Service (VKS) consumption layer also supports FIPS mode: VKS ClusterClass configurations include a `fips.enabled` variable that, when set, restricts cryptographic operations on cluster nodes to approved algorithm implementations. FIPS-enabled Kubernetes release images, identified by a `-fips` suffix in the release reference name, are available for organizations that require FIPS-validated cryptography across their containerized workloads.

At the protocol and algorithm level, VCF enforces modern cryptographic standards throughout. Starting in vSphere 9.0, all TLS profiles are FIPS compliant; the COMPATIBLE profile supports modern TLS cipher suites with standardized elliptic curves. Monitoring infrastructure such as Telegraf enforces a modern TLS minimum version for secure communication. The NSX L2 VPN FIPS compliance suite uses AES-GCM encryption with Perfect Forward Secrecy and Diffie-Hellman Group 20. NSX also supports ECDSA (Elliptic Curve Digital Signature Algorithm) encryption for environments with high-assurance cryptographic requirements. VCF Operations for Networks supports several encryption algorithms and ciphers for its data sources. VCF Operations provides a FIPS Security Mode that, when enabled, applies additional algorithm and cipher prerequisites across the management domain. All system management network communications are encrypted by default using standardized cipher suites. At the VKS layer, Kubernetes control plane components expose parameters for restricting permitted TLS configurations: the `kube-apiserver --tls-cipher-suites` parameter, the `kubelet tlsCipherSuites` configuration field, and the equivalent parameter on the `kube-scheduler` each restrict the set of permitted cipher suites, allowing administrators to exclude deprecated or weak algorithms. The `kubelet tlsMinVersion` field and the `--tls-min-version` parameter on the `kube-apiserver` enforce a minimum TLS protocol version floor for inbound connections. The Antrea networking component and vSphere Cloud Provider Interface on VKS clusters also support configurable TLS cipher suites for component-to-component communication. Kubernetes hardening guidance identifies specific preferred cipher suites and calls out cipher suite configuration on the `kube-scheduler` as a required hardening step. VKS clusters support the Istio service mesh package, which provides mutual TLS between workloads within the mesh; the `meshMTLS.minProtocolVersion` setting controls the minimum protocol version for inter-service communication, defaulting to TLS 1.2 with support for configuring TLS 1.3.

Data-in-transit protections using TLS have customizable PKI keypair and certificate options. These range from fully automated within VCF to semi-automated using certificates from enterprise PKI infrastructure or fully custom certificates installed manually. Automated certificate issuance is supported with Microsoft Active Directory Certificate Services. Trust establishment uses standard PKI management with multiple certificate options including Root CA certificates, CSR-based certificates, and direct certificate uploads. VCF Operations provides centralized certificate lifecycle management for all VCF components, enabling automated certificate renewal, monitoring, and replacement across the infrastructure. Organizations should be aware

that if self-signed certificates and private keys are generated using OpenSSL, those certificates and private keys are not FIPS-compatible. Environments operating under FIPS requirements should use certificate authorities and key generation methods that produce FIPS-compliant artifacts. For FIPS environments, certificates should use key sizes of 2048 or 3072 bits; key sizes greater than 3072 bits have not been tested with FIPS. At the VKS layer, the cert-manager package manages the lifecycle of certificates issued to workloads and ingress endpoints. VKS clusters maintain TLS certificates for component-to-component communication across their control and data planes. The Contour ingress package supports minimum TLS version configuration through the `tls.minimum-protocol-version` parameter. Harbor, when deployed as a Supervisor Service, accepts custom TLS certificate configuration through the `tlsCertificate.tls.crt` and `tlsCertificate.tls.key` fields, allowing organizations to supply certificates from their enterprise certificate authority rather than relying on self-signed certificates. The Supervisor secret injection agent automatically configures mutual TLS for communication with the vault-agent-injector service using auto-generated certificates.

Data-at-rest encryption uses vSAN cluster-based encryption or VM Encryption on non-vSAN storage. vSAN encryption uses AES-NI CPU offloading for efficient processing, and VMware ESX hosts encrypt vSAN disk data using the industry standard AES-256 XTS mode. Encryption keys are managed through KMIP 1.1-compatible external Key Management Servers (KMS) or vSphere Native Key Provider (NKP), which is included in all vSphere editions and does not require an external key server. VCF implements a three-element domain of trust comprising the key provider, VMware vCenter, and vSAN hosts. Key Encryption Keys (KEK) wrap Disk Encryption Keys (DEK) for secure key management; ESX hosts use the KEK to encrypt their internal keys and store only the encrypted internal keys on disk, not the KEK itself.

VCF Standard Key Providers have key wrapping capabilities that let organizations store a single wrapping key in their KMS, protecting multiple Key Encryption Keys within the VCF environment. This creates a three-tier key hierarchy: the Data Encryption Key encrypts object data, the Key Encryption Key protects the DEK, and the wrapping key protects the KEK. This approach reduces the number of keys stored in external KMS systems while maintaining cryptographic separation. Key wrapping includes automatic key rotation with configurable intervals from 30 days to 10 years.

With key persistence enabled, ESX hosts can persist encryption keys in the Trusted Platform Module (TPM) across reboots, allowing encryption operations to continue when the key server is unavailable. Each ESX host obtains the encryption keys initially and retains them in its key cache; if the ESX host has a TPM, the encryption keys are persisted in the TPM across reboots. Key persistence can be enabled using the `esxcli system security keypersistence enable` command.

VCF supports guest-level security features including virtual Trusted Platform Module (vTPM) 2.0 for VMs. This enables in-guest encryption capabilities such as Windows BitLocker, Linux disk encryption, and other operating system-native security features. Secure Boot provides UEFI verification to help ensure only signed and trusted code runs during the VM boot process. These features work independently of or in combination with infrastructure-level encryption, allowing organizations to implement defense-in-depth strategies.

vSAN offers Data-in-Transit (DIT) encryption as a cluster-wide setting that encrypts all data and metadata traffic as it transits across hosts. For vSAN Original Storage Architecture (OSA), data-at-rest encryption occurs at the Local Object Manager (LSOM) layer on the target host, making DIT encryption strongly recommended to restrict network-level interception. For vSAN Express Storage Architecture (ESA) in HCI mode, data is encrypted at the VM host before network transmission, making DIT encryption optional based on compliance requirements and risk tolerance. DIT encryption operates without requiring external key management servers and provides independent key rotation from data-at-rest encryption.

Encrypted vSphere vMotion secures confidentiality, integrity, and authenticity of data transferred during VM migrations. For encrypted VMs, vMotion always uses encryption. For unencrypted VMs, encrypted vMotion can be set to Disabled, Opportunistic (default), or Required. Cross-vCenter vMotion is supported when using shared key providers or backup/import of Native Key Provider. VCF uses one-time keys (nonces) for each migration session so that captured traffic cannot be replayed or decrypted after migration completes.

Memory Tiering encryption provides protection for tiered memory without requiring external key management. VCF generates random 256-bit AES-XTS keys at the kernel level during VM power-on, unique to each VM instance or per host depending on configuration.

VM Encryption provides protection across all datastore types including vSAN, iSCSI, NFS, and Fibre Channel. Disk encryption uses XTS-AES-256 keys as the disk encryption key. This encryption occurs before data reaches the storage layer, providing both data-at-rest and data-in-transit protection.

Kubernetes on VKS supports encryption at rest for data stored within the control plane. Operators configure the encryption provider and manage key access for control plane secrets; when relying on a managed key provider, administrators retain responsibility for access controls over the managed key material. The VCF Automation consumption layer includes VCF Encryption Management, which grants organization administrators the ability to use encryption keys from their own key providers for encryption of virtual machines and disks in their VCF environment, extending the platform's cryptographic key management to tenant-level operations.

For storage protocols, VCF provides varying levels of native encryption support. iSCSI includes CHAP for session authentication. Fibre Channel Gen 7 supports end-to-end encryption with secure HBAs. For NFS datastores, version 4.1 supports Kerberos authentication with three security levels: krb5 (authentication only), krb5i (authentication plus integrity checking), and krb5p (authentication plus privacy with full encryption).

ESX stores configuration data in encrypted form on boot devices. When the host has a TPM 2.0 enabled and configured, the configuration encryption key is stored in the TPM. The encryption mode can be configured using the `esxcli system settings encryption set` command with the `--mode=TPM` parameter.

Cryptographic operations are controlled through fine-grained privileges in vCenter. Only users assigned the Cryptographic Operations privileges can perform cryptographic operations. A dedicated No Cryptography Administrator role enables standard VM and infrastructure management while restricting unauthorized encryption changes. This role can be cloned and customized to grant only specific Cryptographic Operations privileges, such as allowing encryption but not decryption, supporting the principle of least privilege for encryption tasks. The `CryptoManager` and `CryptoManagerKmp` managed objects provide programmatic interfaces for handling cryptographic keys and integrating with key management server infrastructure. vSAN encryption key management requires specific permissions including `Cryptographer.ManageEncryptionPolicy`, `Cryptographer.ManageKeyServers`, and `Cryptographer.ManageKeys`.

vSAN includes secure disk wipe capabilities for proper media sanitization when decommissioning storage, supporting the Erase disks before use option during encryption configuration and disk management operations.

Defining the organization's cryptographic policy (algorithm selection, key strength, rotation schedules, KMS architecture, FIPS-mode activation decisions) and the key lifecycle management standards that govern key creation, distribution, storage, archive, and destruction sit with the organization above the platform. VCF supplies the validated cryptographic modules and protocol enforcement; the organizational cryptographic governance program determines how those mechanisms apply across the environment. Security Technical Implementation Guides (STIGs) for Supervisor and VKS releases are available to guide cryptographic hardening of the consumption layer.

VMware Private AI Services (PAIS) provides cryptographic controls across its AI infrastructure components, building on the cryptographic foundation of VCF.

GPU-accelerated VMware Kubernetes Service (VKS) clusters deployed for PAIS workloads use a FIPS-enabled Kubernetes runtime. The VKS cluster topology version applied to both control plane and worker deployments uses a FIPS-enabled VKR build running on Ubuntu 24.04, so AI workloads on PAIS VKS clusters operate within a FIPS-compliant Kubernetes runtime.

PAIS endpoints use TLS for service communication. The `PAISConfiguration` custom resource supports configurable CA bundle references through `spec.clientTls.caBundleRefs` for OIDC provider and Harbor registry authentication. The Supervisor endpoint communication for PAIS uses HTTPS on port 6443 with certificate-based authentication. The PAIS Prometheus metrics endpoint uses self-signed certificate authentication with TLS, where the CA certificate is retrieved from the `pais-ingress-default Secret` in the PAIS namespace and configured in base64-decoded form. Prometheus TLS client authentication and certificate validation are off by default; auditors should verify that client authentication is enabled in production deployments where mutual certificate validation is required.

PAIS requires CA trust bundles to be configured for all external HTTPS connections, including OIDC providers, Harbor registries, content management systems used as data sources in the Data Indexing and Retrieval service (such as Confluence or SharePoint), MCP servers that provide tools to agents, and the pgvector database server used for vector storage. Trust bundle material is obtained from each external system's administrator either as a certificate file or as a ConfigMap stored in the namespace where PAIS is deployed, and PAIS recommends maintaining separate trust bundles per application with periodic updates before certificate expiration. Administrators add trusted certificates through the VCF Automation Provider Management UI under Certificate Management and Trusted Certificates. The issuer certificate of the Harbor registry must also be added to the certificate trust store on Deep Learning VMs that pull models from the registry. When connecting to an MCP server over HTTPS, the MCP server issuer certificate must be added as a CA trust bundle.

The underlying cryptographic algorithms, cipher suites, and platform-level key management are provided by VCF and VKS. Organizations are responsible for selecting and enforcing approved cryptographic standards at the VCF and infrastructure level, while PAIS provides the certificate management and trust chain configuration mechanisms specific to AI service endpoints.

VMware vDefend (Contributes)

VMware vDefend contributes to the implementation of cryptographic protection controls by using known public standards and trusted cryptographic technologies across its component stack for securing inter-component communications and providing cryptographic inspection capabilities for network traffic.

Security Services Platform (SSP), the control-plane component of vDefend, secures communications between vDefend product components using certificates and current TLS protocol versions with approved cipher suites. SSP and the SSP Installer deploy with the most current TLS version by default and also support the prior major TLS version. The TLS versions and cipher suites allowed on SSP Installer and SSP are fixed and cannot be modified, which enforces a consistent cryptographic baseline across deployments.

SSP components, including the SSP Installer and the NDR Sensor for vDefend, implement FIPS 140-2 and FIPS 140-3 cryptographic module standards. SSP uses the VMware BouncyCastle Module (NIST CMVP Certificate #4943) and the VMware OpenSSL FIPS provider Object Module (NIST CMVP Certificate #4861) for its cryptographic operations. SSP actively enforces cryptographic hygiene by rejecting any certificate or TLS configuration that uses deprecated algorithms, short keys, or legacy protocol versions, returning a validation error rather than permitting degraded connections.

Certificate management within SSP provides lifecycle controls including certificate export, certificate signing request (CSR) generation, and CA-signed certificate replacement. SSP monitors and manages several certificate types used to identify client and host machines, establish trust between components, secure communications, and control access levels. Administrators can retrieve and validate LDAP certificates using standard tools to establish secure LDAPS connections for platform authentication. These capabilities allow organizations to integrate vDefend into their broader PKI infrastructure and follow standard certificate lifecycle practices.

vDefend provides TLS Inspection capabilities that allow the firewall to decrypt, inspect, and re-encrypt TLS-protected traffic. Without TLS Inspection, encrypted traffic cannot be examined or enforced against security policies even when other advanced security features are enabled. With TLS Inspection enabled, vDefend gains visibility into encrypted traffic flows, supporting more effective access control and threat detection. TLS Inspection also supports importing or generating trusted and untrusted proxy certificate authorities for external decryption profiles, giving administrators control over the CA chain used in inspection.

TLS Inspection includes a Crypto Enforcement option within decryption action profiles that allows administrators to set minimum and maximum protocol version and cipher suite constraints for both client and server connections. Profiles can be configured in Transparent or Enforce modes; the Enforce mode requires compliance with the configured cryptographic constraints.

vDefend IDS/IPS signature rules extend cryptographic visibility by supporting protocol version matching and certificate Subject field matching, enabling enforcement decisions based on certificate metadata in encrypted traffic. IDS/IPS rules also support storing TLS/SSL certificates to disk for forensic analysis and threat investigation. SSP guidance recommends that

organizations restrict or block protocols that carry data in cleartext and enforce minimum secure protocol versions as part of their network security practices.

vDefend does not itself provide the underlying key management infrastructure (KMS), platform-wide PKI lifecycle management, or the broader VCF platform's cryptographic controls; those responsibilities belong to VCF. However, vDefend's consistent use of approved cryptographic standards for its own operations and its ability to perform cryptographic inspection of network traffic contribute to an organization's overall implementation of cryptographic protection controls.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) implements cryptographic protections for disaster recovery workflows using known public standards and trusted cryptographic technologies.

PNR uses modern TLS by default for all connections to the PNR server. The minimum TLS protocol version is configurable through the `envoy-proxy-config.json` file by editing the `tls_minimum_protocol_version` parameter. When the minimum protocol version is modified, PNR requires that the change be applied consistently across all relevant configuration occurrences in the system. Administrators can verify the TLS version in use on the Site Recovery Manager component using standard OpenSSL tooling.

The PNR Appliance requires an SSL/TLS certificate as the endpoint certificate for all TLS connections to the PNR server. PNR supports custom certificates signed by a certificate authority as an alternative to self-signed certificates. Custom SSL/TLS server endpoint certificates must meet specific requirements, including x509v3 Extended Key Usage indicating TLS Web Server Authentication. The Appliance Management Interface allows administrators to import CA-signed server certificates and custom root CA certificates, and to replace the appliance certificate. PNR uses TLS certificates and private keys to protect network communication and establish authentication with other servers. Certificate verification error messages are logged in security-related log files, and operational log files do not contain sensitive information such as private keys or passwords.

For encrypted virtual machine replication, PNR requires that the recovery and protected sites use a common Key Management Server (KMS) or that the KMS clusters at both sites share common encryption keys. Replication of encrypted virtual machines also requires Secure LWD support to be available on the virtual machine. This supports data-at-rest encryption continuity for virtual machines through the recovery lifecycle.

Defining the organization's cryptographic policy, including KMS architecture decisions, minimum TLS version selection, certificate management standards, and key lifecycle practices, sits with the organization above the DR layer. PNR supplies the cryptographic mechanisms needed for DR-specific traffic and operations; the organizational cryptographic governance program determines how those mechanisms apply across the environment.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) implements cryptographic protections across multiple layers of its architecture, applying standard cryptographic technologies for data in transit, certificate trust management, and credential storage.

Starting with DSM, the platform enforces FIPS 140-3 compliant cryptographic standards and validates certificates during upload, rejecting unsupported algorithms or parameters. Only RSA and ECDSA public key algorithms are accepted for certificates. The Ed25519 elliptic curve signature algorithm is rejected because it does not comply with FIPS 140-3. Custom trusted certificates should use ECDSA P-256 or P-384 algorithms; RSA certificates must meet a minimum key size of 2048 bits per FIPS requirements. DSM's latest certificate validation mode enforces strict cryptographic and KeyUsage validations across all DSM endpoints, including the Provider VM and data service clusters.

For connections to database clusters, DSM requires TLS for all client traffic. PostgreSQL database instances enforce a minimum TLS protocol version through the `ssl_min_protocol_version` setting. MySQL enforces minimum TLS versions on both the main connection interface and the administrative interface; these settings are fixed and cannot be modified by users, which helps maintain a consistent cryptographic baseline across deployments. MySQL also exposes the `group_replication_recovery_tls_version` setting to specify the TLS protocol used during distributed recovery connections. DSM supports SQL Server clusters, which use TLS to encrypt communication between clients and the cluster; the `network.tlsProtocols` custom engine setting defines the allowed TLS versions for client connections, and a minimum TLS

version must be included for the DSM operator to manage the cluster. DSM supports TLS verification during PostgreSQL database migration, covering replication traffic between source and target clusters.

DSM's certificate management capabilities support standard PKI practices. Administrators configure custom TLS certificates for database clusters through the DSM UI or API, providing certificates in PEM format with associated private keys and CA certificates. Supported private key algorithms are RSA and ECDSA with key sizes of 256 and 384 bits. When present, the X509v3 KeyUsage extension on a custom certificate must include the DigitalSignature capability; DSM also accepts certificates that omit the KeyUsage extension entirely, treating absent KeyUsage as permitting all usages in accordance with RFC 5280. To establish secure connections to database clusters and to the DSM Provider VM, clients add the CA to the operating system trust store or the trusted CA list. DSM's API provides a mechanism to retrieve the CA certificate from a custom certificate secret. The Consumption Operator, which enables self-service database provisioning, requires a TLS certificate for its communication with the DSM provider. Certificate management can also be handled through Kubernetes cert-manager, which manages various issuer types and outputs Kubernetes TLS Secrets in the format DSM requires.

DSM supports TLS for connections to external systems. When configuring log forwarding to an SMTP server, DSM supports Auto TLS to establish a secure connection. For private container registries, DSM supports CA certificate validation for untrusted registries.

For local user credential storage, DSM encrypts passwords using PGP symmetric encryption through the PGCrypto library, with dedicated encryption keys stored using the PGCRYPTO_PASSWORD and PGCRYPTO_ALGORITHM keys. MySQL has FIPS mode available on the client side through the `ssl_fips_mode` setting. PostgreSQL databases include the `pgcrypto` extension, which provides cryptographic functions that applications can use directly within the database. The DSM Provider Appliance includes virtual machine encryption, which activates when a Key Management Server is configured in the environment.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides configurable SSL/TLS profiles that control which cipher suites, protocol versions, and key exchange algorithms are permitted for application traffic termination. The SSL/TLS Profile, configured under Templates > Security > SSL/TLS Profile, contains the accepted protocol version list and a prioritized cipher suite list applied to virtual services. Administrators can create custom profiles or select from built-in templates; the documentation notes that the choice of accepted ciphers and protocol versions involves trade-offs between security, client compatibility, and computational expense. SSL profiles in 9.1 include a Post Quantum Cryptography section with support for modern cipher suites. Controller SSL/TLS certificates support elliptic curve (EC) or RSA algorithms, with EC recommended for new deployments.

For environments subject to cryptographic module validation requirements, Avi supports a FIPS mode backed by the OpenSSL FIPS Provider, which has been validated at FIPS 140-3 Security Level 1 and awarded Certificate #4985 by the Cryptographic Module Validation Program (CMVP). When FIPS mode is activated on the Controller cluster, Avi restricts cryptographic operations to FIPS-compliant algorithms only. FIPS 140-3 also requires stricter handling of sensitive security parameters including keys, authentication data, and random number generation. FIPS mode is enabled at the Controller cluster level through the Controller settings. Note that FIPS mode does not support SSL Client Hello events in Avi DataScript, which may affect certain scripted traffic inspection use cases.

Avi Controller allows administrators to restrict specific key exchange algorithms and ciphers for management session access. The Allowed Ciphers field restricts management session ciphers to a specified subset, and the `kex_algorithm_exclude` field under Controller Settings excludes specific key exchange methods for SSH-based administrative access. Internal communications between the Avi Controller and Service Engines also use SSL/TLS, and custom certificates can be selected for this Secure Channel connection via the Access tab certificate field.

For certificate management, Avi integrates with Hardware Security Modules (HSMs), including the Thales Luna (formerly SafeNet Luna) HSM, for cryptographic key storage and management. The Controller is set up as an HSM client and can create keys and certificates directly on the HSM through client libraries, supporting high-availability HSM configurations. Automated certificate lifecycle management is available through Let's Encrypt integration using the ACME protocol. Avi's App Transport

Security feature supports integration with the Venafi Trust Protection Platform for certificate administration across tenants, with the Trust Protection Platform pushing signed certificates and required chain certificates to Avi Load Balancer.

For Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports PKIProfile-based certificate validation and trust management for backend services. The PKIProfile, configured through custom resources, enables secure communication with backend services through certificate-based authentication and encryption. In VCF environments, the Avi PKI Profile defines the list of trusted certificate authorities permitted to sign client certificates and can be used to implement Zero Trust security between servers and clients.

Data-at-rest encryption for Avi Controller and Service Engine VMs is provided by VCF at the platform layer, not by Avi itself. Organizations must configure Avi SSL/TLS profiles, select appropriate cipher suites, and enable FIPS mode where cryptographic module validation requirements apply to activate these controls.

Control 164.312(b)

> Standard: Audit controls. Implement hardware, software, and/or procedural mechanisms that record and examine activity in information systems that contain or use electronic protected health information.

SCF Controls: MON-01, MON-01.16, MON-01.4, MON-01.8, MON-03, MON-03.2, MON-16

Aggregate Coverage: Meets

VCF (Meets)

VCF provides enterprise-wide monitoring through integrated tools that span infrastructure health, performance metrics, compliance assessment, log analysis, and alerting.

VCF Operations continuously monitors the operational state of all VCF components to detect conditions that may affect availability or compliance. It collects metrics across compute, storage, and networking resources, and correlates them over time to identify trends that may lead to potential failures. VCF Health, a component of VCF Operations, continuously monitors the operational state of VCF components to verify they are functioning as expected, giving platform operators a single view of operational status. Platform operators can configure alerts, perform log analysis, run infrastructure diagnostics, and review VCF health from a unified interface.

VCF Operations provides continuous compliance management by monitoring infrastructure against industry-standard benchmarks and custom policies. Administrators can create custom compliance benchmarks that monitor selected alert definitions and policies, tailoring the monitoring posture to organizational requirements. The platform assesses objects based on selected compliance policies and activates alert definitions associated with the current scorecard, providing ongoing visibility into compliance status. Compliance-related alerts are triggered on objects and displayed through a dedicated compliance alert subtype.

The alerting subsystem in VCF Operations supports the full lifecycle of alert management. Administrators can configure and manage alert definitions to monitor infrastructure events and conditions, including performance metrics, log events, and custom conditions configured through the Management Pack Builder. The Platform Health Alerts page provides a centralized view of all alerts related to overall system health, including alerts from data sources and infrastructure nodes. Health alerts are generated for conditions that affect the health of the environment and require immediate attention. Administrators can create policies to govern how alert definitions are evaluated, including which objects to monitor and what thresholds to apply, and can apply consistent practices to optimize alert behavior across monitored objects.

VCF Operations supports flexible grouping and scheduling to align monitoring with operational realities. Custom groups can be configured with automatic membership criteria to support monitoring strategies and achieve a high level of automation. Maintenance schedules can be assigned to objects undergoing planned downtime to keep monitoring data accurate and avoid false alerts when an object is offline for scheduled maintenance.

VCF Log Management provides centralized log collection and analysis. It ingests logs from VMware vCenter, VMware ESX hosts, NSX, vSAN, VCF Automation, VCF Operations, VCF Identity Broker, VCF Operations for Networks, and VCF Operations HCX. VCF Operations and VCF Log Management must be integrated to implement the centralized log collection architecture. The platform provides dashboards and analytics for troubleshooting and security investigation. Log-based alert definitions allow administrators to trigger notifications when specific log patterns appear across monitored systems. Log forwarding to external SIEM or syslog targets is configurable, with support for TLS encryption to protect log data in transit. The vCenter syslog forwarding API supports TCP, UDP, TLS, and RELP protocols. NSX Manager syslog supports TLS and requires port 6514 for encrypted log transmission.

At the vSphere layer, the alarm infrastructure integrates with events and performance counters to provide real-time alerting. The MetricAlarmExpression data object allows administrators to set alarms on specific performance metrics with configurable monitoring intervals and aggregation functions for processing data points. The vSphere Client provides direct visibility into tasks and events for change tracking and troubleshooting. VCF ships with preconfigured vSphere alarms that are active by default and monitor specific components including the Identity Management Service, Message Bus Configuration Service, ESX Agent Manager, VMware Service Control Agent, vSphere HA host status, and host connection and power state. The vCenter

Management Interface provides appliance-level health visibility through an Overall Health badge that reflects one of five states (Good, Warning, Alert, Critical, or Unknown) across all vCenter components, and notifies administrators of available security patches through Critical or Alert badge indicators when automatic patch checks are enabled.

When VCF Automation is integrated with VCF Operations, the Insights dashboard and Alerts tab provide real-time capacity awareness and alert information for VCF Automation objects, giving IT teams visibility into resource usage across both provisioned workloads and the underlying infrastructure. The VCF Automation Monitor tab surfaces deployment health information sourced from VCF Operations, and deployment cards display Last Request Status information that tracks the most recent operation on each deployment (Create, Update, or Delete) and its outcome (Successful, In Progress, or Failed). The Management Pack Builder allows administrators to set up event definitions for integrated systems, monitoring specific conditions or thresholds and configuring alerts for proactive management. Management Packs extend monitoring to network devices, including sensor monitoring for devices such as switches and routers. Adapters can be installed on VCF Operations nodes to extend monitoring to additional systems and data sources beyond the core VCF components.

The VMware Kubernetes Service (VKS) layer of VCF extends enterprise monitoring to container workloads and Kubernetes infrastructure. VKS clusters support MachineHealthCheck objects for both control plane nodes and worker node deployments; administrators manage these through the VCF CLI `vcf cluster machinehealthcheck` command, which supports configuration of unhealthy-condition definitions, maximum unhealthy thresholds (expressed as an absolute number or a percentage), and label selectors to target specific machines. The VCF CLI `vcf cluster machinehealthcheck node get` and `vcf cluster machinehealthcheck control-plane get` commands retrieve node and control plane health status on demand. VKS cluster health conditions, including the Ready and ControlPlaneReady status indicators, reflect the operational state of each cluster and are accessible via `kubectl` and the VCF CLI. The VCF Automation Provider Management UI includes a Services overview interface that exposes VKS cluster management functions and the health status of all cluster elements, giving platform operators a centralized view of the VKS tier. The Kubernetes API server within VKS clusters exposes diagnostic and health check endpoints (`/healthz`, `/livez`, `/readyz`, `/statusz`, and `/metrics`) that external monitoring systems can scrape to track API server availability and readiness; the `kube-apiserver` also emits the `kubernetes_healthchecks_total` counter and `kubernetes_healthcheck` gauge metric, which report structured health check status for components including `etcd` and `autoregister-completion`. Access to these monitoring endpoints is governed by the built-in Kubernetes `system:monitoring` RBAC group, which grants read access to liveness, readiness, and metrics endpoints while restricting broader cluster access. The Kubernetes Watch API allows monitoring tools to track changes to any API object as a live stream, supporting event-driven monitoring without continuous polling. The Node Problem Detector monitors node health and surfaces node-level problems as Kubernetes events and node conditions that external monitoring systems can consume via the event stream.

For workload-level monitoring within VKS clusters, Prometheus Operator is available as a standard package and defines custom resource definitions to deploy and manage Prometheus and Alertmanager StatefulSets, enabling high-availability alerting configurations. The Prometheus Alertmanager custom resource definition configures alert grouping, inhibition, and routing to external notification systems. The Istio service mesh, also available as a standard package on VKS clusters, provides service-level monitoring alongside its traffic management capabilities. The Dynatrace Operator can be deployed on VKS clusters to automate the deployment, scaling, and maintenance of the Dynatrace monitoring stack. Historical analysis, dashboarding, and alerting on cluster-level metrics require a dedicated monitoring solution configured to scrape the VKS metrics endpoints and subscribe to the Kubernetes event stream. The `vcf cluster support-bundler create` command gathers diagnostic information from Supervisor and VKS clusters when troubleshooting is needed.

At the network layer, NSX provides monitored indicators including node uptime status, deployment status, management and controller connections, tunnel status, PNIC status, and uptime duration. NSX time series APIs allow viewing data such as VPN statistics, including metadata about the number of tunnels configured and how many are up or down at a given time.

VCF Operations also supports self-monitoring through the VCF Operations adapter, which collects internal metrics such as activity success counts. This allows administrators to verify that the monitoring platform itself is functioning correctly. The VCF Operations policy engine monitors conditions and generates events to react to changing states in the orchestrator server or connected technologies. The Adapter Instance monitoring interval is configurable, with intervals as granular as five minutes.

VMware Private AI Services (PAIS) includes a built-in observability stack that supplies monitoring data for AI infrastructure and AI workloads. PAIS Controller metrics are exposed at a Prometheus metrics endpoint on the `pais-controller-manager` service, allowing collection by monitoring systems and visualization in observability platforms such as Grafana. Observability is activated by updating the `PAISConfiguration` custom resource with optional sections for Prometheus metrics collection and LLM trace forwarding. The Prometheus runtime can be configured with a specified storage class policy and a configurable metrics retention period, giving administrators control over how long monitoring data is stored. A Prometheus server pod must be in a ready and running state for observability to function.

LLM trace data from PAIS can be forwarded to an OpenTelemetry Collector endpoint over `http/protobuf` or `gRPC`, providing distributed tracing for AI model inference activity. The `observability.llmTraces` configuration governs trace forwarding and works alongside the Prometheus metrics pipeline to produce two signals: metrics for health and performance, and traces for inference-level behavior. PAIS Controller metrics include the Model Endpoint Controller and PAIS Configuration Controller, giving monitoring platforms component-level visibility into PAIS operations.

In 9.1, PAIS adds direct integration with VCF Operations. The `controller-pod-metrics-streaming` setting activates streaming of PAIS controller pod metrics from the Supervisor cluster to VCF Operations, allowing administrators to view PAIS metrics alongside other VCF infrastructure metrics. A Telegraf deployment in the `vmware-system-monitoring` namespace uses a `telegraf-user-config` ConfigMap to manage user-configured monitoring endpoints for PAIS. The VCF Consumption CLI connects to the Supervisor endpoint and enables VI administrators to stream metrics from the PAIS controller pod. DevOps engineers can visualize health and performance metrics for PAIS components running in a VCF Automation namespace using Grafana, and MLOps engineers and application developers can monitor the health, quality, and behavior of AI applications and the models used in agents through the same observability platforms.

PAIS supplies the technical monitoring mechanisms this control requires. Enterprise-wide orchestration of monitoring controls, including alert threshold definition, escalation procedures, and integration with a centralized monitoring or log management platform, remain organizational responsibilities.

VMware vDefend (Contributes)

VMware vDefend (vDefend) supports network security monitoring through multiple integrated capabilities that contribute to enterprise-wide monitoring frameworks.

Security Intelligence, hosted on the Security Services Platform (SSP), provides continuous visibility into network traffic flows across protected workloads. It monitors flows between application pairs, updates the Policy Protection Status for each application to indicate that flows are being monitored, and continuously detects new flows between environment pairs, alerting administrators to unauthorized or unexpected traffic. The Monitor & Plan Overview page presents a consolidated view of pending actions, data collection activity status, network security posture, flow trends, and a summary of suspicious traffic. The Security Intelligence Recommendations monitoring capability checks for changes in the scope of monitored entities every hour when the Monitoring toggle is enabled, allowing administrators to keep policy recommendations current as environments evolve. Segmentation Monitoring provides dedicated views of application and infrastructure flows with configurable time ranges spanning from the last hour to the last month, and displays flows related to detected infrastructure servers in a specified time interval.

The Network Detection and Response (NDR) Sensor checks the status of activated detection features every 15 minutes and updates its configuration accordingly, supporting sustained threat detection coverage. NDR Sensor health status monitoring tracks whether key components, including network traffic capture, file analysis, and data transmission, are operating properly. The NDR Sensor also sends alerts notifying administrators of conditions such as services being down, high CPU, memory, or disk usage, packet drops, or missed heartbeats. NDR provides role-based access control covering triage operations such as viewing detections and campaigns, as well as SIEM configuration management.

The Security Services Platform monitors its own health, with Yellow or Red health status indicators displayed when issues occur in subcomponents. SSP monitoring tracks the status of the flow clustering job that runs every hour and reports suspicious traffic detector execution status after each run, with values such as `SUCCESS`, `NOT_ENOUGH_BASELINE`, and `FAILURE`.

The Security dashboard provides a consolidated view for monitoring and configuring security features across network workloads. In federated deployments, the Global Manager provides centralized event management and monitoring for malicious IP blocking activity across all Local Managers.

vDefend generates Unified Security Logs that VCF Log Management can collect and analyze. These logs cover Distributed Firewall, Gateway Firewall, Identity Firewall, FQDN Analysis, TLS Inspection, Intrusion Detection/Prevention System (IDPS), and URL Filtering activity. Broader log aggregation and SIEM correlation for enterprise-wide monitoring remain the responsibility of the SIEM and logging infrastructure deployed alongside vDefend.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides monitoring capabilities specific to the disaster recovery domain and integrates with the broader VCF monitoring ecosystem through dedicated Protection and Recovery dashboards in VCF Operations. VCF Operations collects configuration, component health, and usage information from protection and recovery servers and site pairs, presenting this through an overview dashboard that displays all site pairs, configurations, health scores, and protection and recoverability status for sites and virtual machines. PNR provides default health alerts for protection groups, recovery plans, cloud file systems, recovery SDDCs, and protected sites through VCF Operations, and the dashboards surface alerts informing administrators about configurations and deployments that require attention. Separate dashboard views cover vSAN Snapshots and Replication monitoring, and an Inventory view provides health status, metrics, alerts, and network topology for all monitored objects.

Within its own domain, PNR provides event logging and configurable alarms for replication and recovery operations. Administrators can create alarms that trigger on specified event conditions, with support for email notifications, SNMP traps, or script execution in response. PNR monitors connections between sites by sending periodic ping requests, logs connection check events, and generates alarms when broken connections are detected. The alarm system generates warning-level alerts for expired snapshot schedules, replication errors such as missing VMs, and connectivity issues with protected and target sites. PNR also monitors resource consumption on the Protection and Recovery Server host and raises alarms when configurable resource thresholds are reached.

PNR includes a health monitoring service that checks each health finding every five minutes and records a timestamp at each check. Health findings are tracked with status history that can be reviewed over configurable time periods, defaulting to a 24-hour window. The Protection and Recovery Appliance supports syslog forwarding to a remote syslog server for log analysis and centralized monitoring, allowing appliance-level events to flow into existing log management infrastructure.

The Clean Room Orchestrator, part of PNR's Cyber Recovery capabilities, supports monitoring of clean room events, tasks, and alarms for recovery operations. Clean Room Orchestrator can forward events to VCF Operations, Microsoft Sentinel, or Splunk Cloud for centralized monitoring, supporting organizations that require DR event data to flow into enterprise SIEM and log management platforms as part of a broader monitoring strategy. The Clean Room Orchestrator integrates with endpoint detection and response tools, including CrowdStrike and Carbon Black sensor appliances, for threat detection within isolated recovery environments.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) contributes to enterprise-wide monitoring controls through a layered set of observability capabilities covering database health, infrastructure compliance, and event-driven alerting.

DSM provides a built-in monitoring framework that tracks database instance health across multiple dimensions. From the Monitoring tab in the DSM UI or the vSphere Client, administrators and authorized users can view real-time and historical metrics for database VMs, including CPU Health, Data Disk Health, System Disk Health, Max Connections, Active Connections, Write Throughput, Read Throughput, Thread Resource Utilization, Slow Queries per Second, InnoDB Buffer Usage, and InnoDB Reads and Writes. The Monitoring page defaults to the last three hours of aggregated metric data, with the time range adjustable through the Time Range Last dropdown. This visibility supports detection of resource contention, performance degradation, and connectivity anomalies at the database layer.

DSM's alert framework provides configurable thresholds for warning and critical conditions on key health indicators. Administrators and users can set separate warning and critical thresholds for CPU Health, Data Disk Health, System Disk Health, and Max Connections parameters. When thresholds are exceeded, DSM generates typed alerts such as Database Engine Health, Custom Config Health, and Backup Storage Health alerts. DSM monitors database replication status and raises an alert when a secondary database is not replicating data from the primary. DSM also raises an alert when metrics are no longer being received from a cluster, supporting detection of monitoring gaps. Alerts can be activated or deactivated per data service through the "Enable Alerts for DB Alert" setting, providing granular control over which databases are subject to active alerting. For each alert, DSM provides mitigation suggestions to help administrators resolve issues without disrupting database services.

In addition to database-level alerts, DSM generates global infrastructure alerts that surface vCenter integration and infrastructure policy issues. These include `INFRASTRUCTURE_POLICY_VC_ALARMS`, raised when vCenter resource alarms are active; `INFRASTRUCTURE_POLICY_CLUSTER_COMPLIANT` and `INVALID_SUPERVISOR_INFRASTRUCTURE_POLICY_STATUS`, which reflect cluster compliance state; `VCENTER_CONNECTIVITY`, raised when vCenter connectivity fails and triggering troubleshooting steps that include verifying connectivity and checking authentication logs; and `LicensingNotUpdated` and `vCenterBinding` API status alerts that surface license and API integration conditions. A Global Alerts page in the DSM UI provides a centralized view of these alerts during and after installation and ongoing operation.

In 9.1, DSM integrates with VCF Operations to extend observability beyond the DSM UI. When configured, VCF Operations automatically discovers and monitors PostgreSQL and MySQL clusters in the Ready state and displays a Data Services View dashboard showing active alerts and inventory items. VCF Operations presents performance data across three levels: cluster-level for overall health, node-level for infrastructure resource use, and database-level for KPIs including Active Connections, Commits, Rollbacks, and Deadlocks. This integration requires configuring the connection between DSM and VCF Operations before use.

DSM also adds SQL Server as a supported database type, with dedicated monitoring through an integrated InfluxDB instance and Telegraf agents deployed across the provider appliance and SQL Server workload clusters. The monitoring framework supports metrics-based and status-condition-based alerts for SQL Server, covering database engine degradation, non-operational status, and automated or transaction log backup failure conditions.

DSM supports event notification to external systems through a webhook integration. Webhooks transmit alert notifications containing the triggered date, triggered time, triggered user email, task status, previous status, and task type. This allows DSM alerts to feed into centralized monitoring or incident management platforms maintained by the organization. DSM generates plug-in registration logs that administrators can review for vCenter connectivity errors, and DSM's troubleshooting guidance directs administrators to review active vCenter infrastructure alarms and resolve underlying issues identified through the alert system.

Enterprise-wide monitoring requires organizational decisions about monitoring architecture, log aggregation platforms, alerting policies, and operational response procedures that lie outside DSM's scope. DSM provides the data and integration points; the organization must determine how those signals are collected, correlated, and acted upon across the broader environment.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer (Avi) contributes to enterprise-wide monitoring through application-delivery-layer mechanisms built into the Avi Controller and Service Engines.

The Avi Controller monitors Service Engine metrics and sends alarms and notifications to administrators when resource utilization data exceeds defined thresholds. Administrators configure custom thresholds on Service Engine groups through the Resource Events tab in the Avi UI. The Alert feature processes system events and metrics against user-defined rules and generates alerts that trigger configured actions, including sending an email, a syslog message, or an SNMP trap. Alert notifications can be forwarded to remote syslog servers for integration with centralized log management and monitoring platforms.

ControlScripts extend this event-response capability: a ControlScript can alter Avi configuration or communicate to external systems, including through webhook integrations with external monitoring tools, in response to defined system events. This supports dynamic responses including resource scaling or automated notifications based on health scores from monitoring data.

The Avi Controller and Service Engines track health score changes and SSL certificate expiration events. Avi integrates with external monitoring tools such as Prometheus for metrics collection and analysis. User-Defined Metrics allow administrators to define and extract customized telemetry data for specific compliance or reporting needs through the API. Real-time metrics are available via API but deactivate by default after 30 minutes to conserve resources and must be reactivated when sustained real-time visibility is required.

At the data plane, Avi health monitors track the status of backend servers and Service Engines continuously. Service Engine health monitoring records detailed server operational status, including health monitor name, type, last transition timestamps, rise count, fall count, total checks, and total failed checks. Each health monitor can be assigned its own threshold and timeout period for server health validation. Monitors support HTTP, HTTPS, TCP, and UDP health-check protocols with configurable success and failure thresholds, send intervals, and receive timeouts.

In Kubernetes environments managed by the Avi Kubernetes Operator (AKO), the HealthMonitor custom resource definition (CRD) allows users to define custom health monitoring configurations for backend services with fine-grained control over health check parameters. The Avi Multi-Cluster Kubernetes Operator (AMKO) GlobalDeploymentPolicy supports health monitor references for consistent monitoring across multi-cluster deployments. Within VCF Automation, a HealthMonitor custom resource can create monitors for tracking backend pool member status using TCP, PING, and HTTP check types.

Control 164.312(c)(1)

> Standard: Integrity. Implement policies and procedures to protect electronic protected health information from improper alteration or destruction.

SCF Controls: DCH-01, DCH-01.2, GOV-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides multiple layers of data protection controls spanning encryption, storage resilience, backup and recovery, disaster recovery, centralized monitoring, and access management.

For data at rest, vSAN encryption protects data on storage devices so that if a device is physically removed from the cluster, the data remains unreadable. At the virtual machine level, VM encryption protects NVRAM, swap (VSWP), and snapshot (VMSN) files, providing per-VM granularity independent of the underlying storage encryption. For data in transit, vSAN data-in-transit encryption protects data as it moves between hosts and file service inter-host connections within a vSAN cluster, with forward secrecy enforced. TLS protects data in transit between other VCF components. Both vSAN and VM encryption integrate with external Key Management Server (KMS) infrastructure for key lifecycle management, requiring a trust relationship established through certificate and key file exchange. VCF components use FIPS-validated cryptographic modules: NSX cryptographic modules are validated to FIPS 140-3 standards, vSphere uses FIPS-validated cryptographic modules matching the FIPS 140-2 standard, and VCF Automation runs in FIPS-compliant mode by default using FIPS 140-3 validated modules.

vSAN implements erasure coding through RAID-5 storage policies, which split data into blocks with parity information to protect against component failures. vSAN includes failure indication and data rebuild mechanisms that detect storage failures and automatically reconstruct unavailable data. Virtual machines on vSAN datastores can be assigned storage policies that define specific data protection and performance characteristics, giving administrators granular control over how data is protected at the workload level.

VCF supports backup methods for its management components at multiple levels. VMware vCenter file-based daily backups are configured through the vCenter Management Interface for each vCenter instance. vCenter file-based backup supports optional password-based encryption of backup files, and backup files are stored off-appliance on servers accessible via FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB. When vSphere Native Key Provider is configured, vCenter backups contain the Key Derivation Key and must be stored in a secure, access-controlled location. VCF Operations backups support both file-based and image-based methods. NSX Manager backup is configured automatically during the bring-up process. For vSphere Supervisor environments, control plane backup and restore can be performed from the Workload Management UI, and Supervisor control plane backup can also be included as an option in vCenter file-based backup schedules. vSAN Data Protection uses native snapshots stored locally on vSAN Express Storage Architecture (ESA) clusters to help recover virtual machines from operational failure or ransomware attacks.

For Kubernetes workloads, VMware Kubernetes Service (VKS) provides dedicated data protection capabilities built into the VCF platform. VKS cluster node VMs are backed up through Supervisor state backup using the vCenter backup feature available in the vCenter Management Interface, so Supervisor state is covered by the same vCenter backup workflow used for the management plane. When data protection is activated for a VKS cluster, VKS cluster management installs the data protection extension, selected plugins, and Velero on the cluster; activation requires an Organization Administrator or Project Administrator role. Backup and restore operations are managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management > Clusters > Data Protection. Two backup methods are available: vSphere Plugin Snapshot performs block-level backup writing directly to object storage and is faster for workloads with large numbers of small files, while File System Backup operates at the file system level and supports incremental backups. The vSphere Plugin Snapshot method performs full backups on each run since it does not support changed block tracking, so organizations that require incremental backups should use the File System Backup method. Both methods support stateless and stateful workloads. Backup scope is configurable to the entire cluster, selected namespaces, or specific resources identified by label, and VKS cluster backups include file system backups in the restore by default. Velero 1.17 supports scheduled backups,

allowing organizations to configure automated backup cadences. Backup repositories support deduplication, compression, and encryption of backup data. The Velero Plugin for vSphere backs up and restores both stateless and stateful applications running on vSphere Pods in the Supervisor. VKS Backup and Restore Hooks enable execution of pre- and post-operation scripts for granular control over the data protection lifecycle, supporting application consistency and custom automation during recovery. Cross-cluster restore is available through the Restore from another cluster option in the Data Protection tab of the VCF Automation Tenant Portal. Data protection account credentials are scoped to users with Organization Administrator or Project Administrator roles, restricting who can configure backup target locations; VCF Automation enables platform teams to create target locations pointing to self-provisioned storage environments, supporting both cloud-hosted accounts and on-premises endpoints. VCF Automation also supports snapshotting VM groups, where each member VM receives a distinct snapshot, and restoring a VM group snapshot restores each member of the group.

Kubernetes cluster state is stored in etcd, and two backup methods are available for the etcd datastore: the built-in snapshot method and volume snapshot. The `etcdctl snapshot save` command creates a backup by specifying the endpoint, CA certificate, client certificate, and client key, providing authenticated access to the backup operation. Snapshots can be restored from a snapshot file or from a remaining data directory. During `kubeadm` upgrades, backup folders for etcd state and cluster manifests are written automatically to `/etc/kubernetes/tmp` with timestamped names, providing a recovery point in case of upgrade failure. Storage policy-based data management is available through Kubernetes StorageClass objects that reference vSphere storage policies via Storage Policy Based Management (SPBM); those policies may include encryption settings, allowing organizations to apply consistent encryption-at-rest requirements to persistent volumes through standard Kubernetes StorageClass configuration. CSI-based data protection for VKS requires a validated configuration between VKS and the underlying storage infrastructure.

VKS clusters on the Supervisor also support the Kubernetes VolumeSnapshot API, which provides `VolumeSnapshotContent` and `VolumeSnapshot` resources as a native point-in-time snapshot mechanism for persistent volumes. Volume snapshots can be provisioned dynamically from a `PersistentVolumeClaim` using a `VolumeSnapshotClass` that specifies storage provider parameters and the deletion policy for snapshot content. Restoring from a snapshot is performed by creating a new `PersistentVolumeClaim` with the target `VolumeSnapshot` as its `dataSource`, referenced via the `snapshot.storage.k8s.io` API group. Kubernetes `PersistentVolumes` have a configurable reclaim policy; setting the policy to `Retain` preserves volume data in a `Released` state after the associated `PersistentVolumeClaim` is deleted, allowing administrators to recover or migrate the data before the underlying storage is reclaimed.

Kubernetes Secrets provide a mechanism for storing sensitive configuration data separately from application code, reducing the risk of accidental exposure in container workloads. Applications consuming Secrets from environment variables or mounted volumes should avoid logging secret values in the clear or transmitting them to untrusted parties. Using short-lived Secrets helps limit the impact of accidental or intentional exposure. Kubernetes and applications can take additional precautions with Secrets, such as avoiding writing sensitive data to non-volatile storage.

vSphere APIs for Data Protection provide an integration point for third-party backup software to perform nondisruptive full, differential, and incremental image backups using VMFS snapshot capabilities, without requiring virtual machines to be powered off or placing backup processing overhead on VMware ESX hosts. For virtual machines running supported Microsoft Windows operating systems, these APIs integrate with Microsoft Volume Shadow Copy Services (VSS) to maintain application consistency during backup operations.

VMware Live Site Recovery extends data protection with orchestrated disaster recovery across sites. Replication can be configured with recovery point objectives as low as 60 seconds, with options for network compression, multiple point-in-time recovery, and automatic replication of new disks. vSphere Replication provides configurable RPO settings for VM-level replication to local or remote datastores. Application-level high availability and disaster recovery mechanisms combine real-time availability with sitewide disaster recovery, with data replication to secondary sites providing recovery options in case of catastrophic failure.

VCF Operations Data and Site Resiliency Monitoring provides centralized visibility into data protection metrics across private clouds, enabling administrators to track the status of data protection controls from a single view. This monitoring layer helps organizations verify that their data protection configurations remain in place and functioning as expected.

For Kubernetes workloads on VKS clusters, volume health status is reported through `volumehealth.storage.kubernetes.io/messages` annotations on `PersistentVolumeClaims`, giving administrators granular visibility into whether individual persistent volumes are accessible.

Management of data protection settings is restricted through role-based access controls. VCF Operations uses privilege-based access controls that restrict visibility based on user roles, limiting which accounts can view sensitive operational data. For VKS clusters, managing data protection requires assignment of an Organization Administrator or Project Administrator role. VCF documentation includes storage security best practices covering securing access to storage devices, implementing storage encryption, and protecting virtual machine data as part of an overall data protection posture.

Selecting which of these data protection mechanisms apply to specific datasets, defining protection policies and recovery objectives, and configuring the relevant features to match those decisions remain organizational responsibilities. VCF supplies the technical mechanisms; organizations define what to protect, to what recovery point, and with which retention and access controls.

VMware Private AI Services (PAIS) contributes to data protection by applying access controls, authenticated connectivity, and credential management to AI workloads, model repositories, knowledge bases, and associated data assets that the platform handles.

The Model Gallery uses Harbor project access capabilities to restrict access to the sensitive data used to train and tune models. PAIS integrates with Harbor registries as a model storage backend, requiring authentication and certificate-based trust for model retrieval. PAIS is also compatible with OCI-compliant registries from other vendors, so organizations using an alternate backend can apply equivalent registry-level access controls.

Access to PAIS itself is gated by OIDC group-based authorization. Only user accounts that are members of the groups specified in the `authorizedGroups` configuration can access the service, and the OIDC group claim name is configurable to match the identity provider in use. PAIS uses a CA trust bundle for secure communication with external services and databases, and supports CA trust bundle management for secure connections with external registries and content management systems by uploading or referencing certificate files. VCF Automation Provider Management requires trusted certificate import for vCenter validation before integration with PAIS, restricting integration paths to validated endpoints.

For retrieval-augmented generation, PAIS Knowledge Bases link to external data sources through stored credentials, scoping indexed-data retrieval to defined service identities, and Data Indexing and Retrieval handles automatic collection and indexing of updates from those linked sources over time. Personal access tokens generated from user account settings provide programmatic access to Knowledge Bases and data sources. SharePoint data sources for PAIS Knowledge Bases require user name and password authentication, with support limited to SharePoint On-Premises deployments.

PAIS observability also flows through authenticated paths: the Grafana integration uses OIDC provider authentication for metrics visualization, and LLM traces can be sent to an OpenTelemetry Collector for monitoring.

PAIS DSM database resource allocation is controlled through an infrastructure policy that defines the quality and quantity of resources the database can consume from vSphere clusters, with associated storage policies and VM classes. A default storage policy can be selected to define storage placement for the database in PAIS, and storage policy and VM class selections should be chosen to suit RAG workloads when the database supports RAG use cases.

Organizations connecting external data sources or registries to PAIS should examine the capabilities and parameters of those integrations and approve only those suitable for use, since unreviewed connectors can affect what data models access or expose.

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to data protection controls by providing network-level security mechanisms that protect data in transit and restrict unauthorized network access to systems where data is stored or processed.

The vDefend distributed firewall (DFW) enforces microsegmentation policies at the vNIC level, restricting which workloads can communicate with data stores, databases, and application tiers. By segmenting the data center network into isolated security

zones, vDefend limits the blast radius of a compromise and restricts lateral movement toward systems that hold sensitive data. Administrators define granular firewall rules based on workload identity, security tags, and application-level attributes, limiting access to data repositories to authorized services. Identity Firewall extends policy enforcement to user identity, allowing administrators to define access controls based on which authenticated user initiated the connection rather than solely the source workload, strengthening data access controls in environments with user-based authorization requirements. Security policies are defined, propagated, and enforced across Bare Metal servers through the Security Services Platform (SSP), extending microsegmentation protections beyond virtualized workloads to physical infrastructure connected to the environment.

The SSP includes Security Intelligence, which identifies risky application protocols that transport data in clear text, including HTTP, Telnet, FTP, TFTP, LDAP, POP3, and IMAP. This visibility allows administrators to detect and remediate unencrypted data flows that could expose sensitive information in transit. Security Intelligence administrators can monitor traffic leakage between environments, establish exceptions, and implement lockdown protection rules to control inter-environment flows. Security Intelligence also enables administrators to generate policy recommendations and deploy them in monitor-before-enforcement mode, allowing observation of traffic patterns before applying restrictive rules. The SSP summary panel displays the number of services that are fully protected, partially protected, or not protected, giving administrators a dashboard view of segmentation coverage gaps across the environment.

IDS/IPS profiles attach to Distributed Firewall and Gateway Firewall rules to inspect east-west and north-south network traffic for signatures and behaviors associated with data theft, command-and-control communication, and exploitation of vulnerabilities in data-handling services. In vDefend, IDS/IPS signature rules support storing TLS/SSL certificates on disk for forensic analysis and threat investigation, providing durable artifacts for post-incident review of potential data exfiltration events.

Malware Prevention profiles attach to DFW and Gateway Firewall rules and can be configured to send files to the cloud for detailed analysis or to process files locally without cloud connectivity, accommodating environments with data-residency or air-gap requirements. Malware Prevention collects file analysis data including file hash submissions and assigns an Analyst UUID to each submission to track its analysis lifecycle. The Malware Prevention dashboard displays trends of malicious, suspicious, and suppressed file events across the data center, and file verdict filtering allows operators to focus on specific verdict categories such as malicious-only views.

Network Detection and Response (NDR) anonymizes sensitive customer information when sharing telemetry data to cloud services, providing a built-in data privacy mechanism for environments that enable cloud-assisted threat detection.

These network security controls complement the data-at-rest encryption, backup, replication, and access management capabilities provided by other VCF components. vDefend does not perform data encryption, classification, backup, or recovery itself, but it protects the network paths and access patterns through which data is stored, replicated, and retrieved.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides replication-based data protection for virtual machine workloads across sites. Protection groups allow administrators to organize virtual machines and datastores under consistent snapshot and replication policies at scale, covering both local recovery via vSAN snapshots and cross-site recovery via vSphere Replication or array-based replication. Protection group membership can be modified after creation, and virtual machines can be automatically enrolled for protection using storage tag selection on designated datastores, reducing manual overhead in maintaining protection coverage across a growing environment.

PNR introduces an immutability mode for protection groups that, when enabled, prevents the data protection group from being modified or deleted. This mechanism allows administrators to safeguard protection configurations against inadvertent or unauthorized changes. PNR Health monitoring provides consolidated visibility into data protection service health, operation issues for local and replication snapshots, storage utilization, and protection group membership changes, giving administrators a current view of protection posture across the environment.

Site Recovery Manager (SRM) integrates with vSphere Replication to provide orchestrated failover with configurable recovery point objectives, giving organizations control over acceptable data loss thresholds for protected workloads. PNR supports

additional site topologies, including shared recovery site configurations where protected site resources are mapped to isolated datacenters, networks, folders, and datastores on the recovery site. Inventory mappings allow administrators to define resource configurations once and apply them consistently across protection groups.

vSAN Snapshots and Replication is a native, integrated snapshot-based backup capability for virtual machines running on vSAN datastores, managed through the vSphere Client. It provides VM restore and clone operations from existing snapshots, supporting both rapid recovery from operational failures and ransomware recovery scenarios. Test failover operations allow administrators to validate that recovery configurations are functional before an actual recovery event occurs.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support data protection for managed database instances, covering PostgreSQL, MySQL, and SQL Server databases.

The most direct contribution is DSM's automated backup framework, which administrators can enable on a per-database basis or through data service policies. When configured, DSM performs scheduled full and incremental backups of database content and stores them in S3-compatible object storage at a configurable backup location. Backup retention is configurable (backup-retention-period), and DSM retains backups of deleted databases until the configured retention period expires, supporting recovery from accidental deletion. For point-in-time recovery, DSM restores a backup to a newly created database VM with a user-specified name and datastore location, and can target the most recent timestamp or a specific point in time. DSM archives binary logs in backup storage as part of its backup protection mechanism. Administrators can also initiate manual on-demand backups of primary PostgreSQL databases to safeguard data before high-impact operations or as immediate protection after major changes. For PostgreSQL multi-site deployments, DSM performs a full backup automatically during a promotion event before resuming the regular schedule.

Data service policies give administrators control over backup behavior across all databases governed by a policy. Policies can require that databases have automated backups enabled, allow users to opt in, or disallow automated backups entirely. The allowed-backup-locations setting in the data service policy restricts users to selecting from approved backup locations, reducing the risk of backup misconfiguration. Policies can be enforced across multiple tenants and across different namespaces and namespace labels, supporting consistent data protection posture in multi-tenant deployments. A Compliance tab on data service policies displays compliance reports and allows administrators to expand each policy violation to view the noncompliant database, data service, and namespace, giving administrators visibility into where data protection requirements are not being met. In 9.1, data service policies extend to SQL Server databases in addition to MySQL and PostgreSQL.

DSM implements role-based access control that separates administrative and user-level database access. DSM Admins can create, monitor, and manage all data services in the environment; DSM Users can only manage and monitor the data services they own. This access model limits who can modify backup configurations and policy settings. Infrastructure policies govern which storage resources are available for database VMs, including CPU, memory, storage policies, IP pool, and VM classes, giving administrators control over the storage environment in which data resides.

Control plane recovery requires that a Provider Backup Repo has been configured at installation time. If the Provider VM fails, the restore-provider command restores it to the latest timestamp. In the VCF Automation context, tenants can perform point-in-time restores directly through the VCF Automation UI, broadening restore access to self-service scenarios.

One limitation applies: if an incremental backup in the backup chain is deleted, DSM cannot restore the full data; a successful restore from an incremental chain requires the last full backup and all following incremental backups. Organizations must protect the integrity of the backup chain through access controls on the backup storage.

DSM provides configurable backup, recovery, and policy enforcement mechanisms for managed database instances. The broader data protection program requires organizational decisions about backup schedules, retention periods, backup storage security, and off-site management that DSM does not prescribe on its own.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several application-layer mechanisms that support the implementation of data protection controls within a VCF deployment.

At the transport layer, Avi performs TLS termination with configurable SSL/TLS profiles for connections between clients and virtual services. The SSL/TLS protocol at the Avi proxy secures data in transit by reducing the risk of unauthorized parties reading or modifying information transferred between end users and application workloads. SSL/TLS profiles are configurable through the Avi Controller UI under Templates > Security > SSL/TLS Profile. Management interface access is further restricted through configuration of allowed ciphers and HMACs for management sessions.

Avi integrates with Hardware Security Modules (HSMs), including the Thales Luna (formerly SafeNet Luna) HSM, for cryptographic key storage and management. This allows organizations to store the private keys used in TLS termination and other cryptographic operations within a dedicated hardware key store rather than in software. The Avi Controller also stores sensitive configuration data encrypted in a local database, and backup files can be protected with a passphrase that encrypts the keys included in the backup. Backup and restore operations verify that the FIPS mode of the backup configuration matches the target controller environment.

Avi's Web Application Firewall (WAF) applies both positive and negative security models to inspect and filter HTTP/HTTPS application traffic. WAF policies support ModSecurity rules for application protection and a Positive Security model that learns application behavior to define allowed request patterns. The Application Rules service, available through the Avi Cloud Console, provides WAF rules specifically designed to address known application vulnerabilities including CVE-tracked issues, with automatic updates to keep rules current. WAF configuration is accessible through the Controller UI under Templates > Security > WAF Policy.

Avi DataScript provides a programmable layer for enforcing additional data protection behaviors at the proxy boundary. DataScripts are Lua-based scripted rules that allow inspection and manipulation of client HTTP requests and server HTTP responses, supporting content switching, redirection, header manipulation, and logging. DataScript can be used to enforce cipher suite policies by denying clients connecting with unsupported ciphers. DataScript also supports blocklist-based access control by checking client IP addresses against named IP groups and terminating connections from blocked sources while logging the violation. XML-based DataScript use cases can extract client identifiers from request payloads and compare them against configured string groups to restrict access to authorized clients.

Access to Avi configuration objects is restricted through granular role-based access control (RBAC). Avi supports extended granular RBAC using label-based markers to restrict user permissions to specific resources based on key-value pair matching. The RBAC model differentiates Read and Write access across objects such as SSL/TLS Profiles, PKI Profiles, Authentication Profiles, IP Address Groups, and Health Monitors, allowing organizations to scope access to data protection-relevant configuration to authorized roles only. Roles can also be scoped to tenants through label group associations.

These mechanisms address data protection at the application delivery layer. Broader organizational data protection controls, including data classification policies, data handling procedures, and data-at-rest protection beyond the Avi proxy boundary, require organizational governance and platform-level capabilities that Avi does not provide as an application delivery controller.

Control 164.312(c)(2)

> Implementation specification: Mechanism to authenticate electronic protected health information (Addressable). Implement electronic mechanisms to corroborate that electronic protected health information has not been altered or destroyed in an unauthorized manner.

SCF Controls: CFG-08, CFG-08.1, MON-01.15, MON-01.7, MON-16

Aggregate Coverage: Meets

VCF (Meets)

VCF provides several capabilities that contribute to anomalous behavior detection and user activity monitoring, though it does not include a dedicated User & Entity Behavior Analytics (UEBA) or User Activity Monitoring (UAM) solution.

VCF Operations includes anomaly detection capabilities that use both dynamic and static thresholds to identify when metrics deviate from normal operating behavior. Dynamic thresholding is enabled by default and uses historical data analysis to establish baselines for each monitored object. The Smart Early Warning feature analyzes the number of applicable metrics that violate the dynamic threshold determining normal operating behavior, triggering alerts when the number of anomalies on an object exceeds a trending threshold. When an anomalous entity is detected, VCF Operations generates an outlier violation alert (vmwAnalyticsOutlierEvent, OID 37002), notifying administrators of unexpected behavior. A Critical threshold violation alert is also generated when anomalous entities are detected.

The Anomalies widget displays detected anomalies for a resource over the past six hours at configurable time intervals, with color-coded criticality indicators. The Anomaly Breakdown widget shows likely root causes for symptoms on a selected resource, helping operators triage issues. The Troubleshooting Workbench includes an Anomalous Metrics card that surfaces metrics exhibiting drastic changes within a selected scope and time window, ranked by degree of change with the most recent anomaly given the highest weighting. Administrators can also examine outlier VMs detected by VCF Operations to identify unexpected behavior and take corrective actions. VCF Operations supports outbound SNMP trap notifications, enabling alert delivery to external SNMP management systems with up to four configurable trap destinations.

For user activity monitoring, VCF Operations provides a User Activity Audit report that offers traceability of user actions including logging in, operations on clusters and nodes, changes to system passwords, certificate activation, and logging out. Each audit event has a detailed view containing information that supports analysis of events in the virtual infrastructure for suspicious user actions or system issues. Event auditing across the VCF platform provides visibility into platform interaction changes and surfaces suspicious access events and policy violations. Administrators should continuously monitor user security aspects to detect security risks early and respond to potential threats. VCF SSO maintains a dedicated audit log that captures user management events, including account creation, modification, deletion, and activation or deactivation, as well as changes to account credentials and profile information. The vSphere Client's Advanced Export feature allows administrators to export tasks performed by a specific user during a specified time range, providing targeted audit data for investigating suspicious activity.

Audit logging extends across VCF components. NSX Manager generates audit log messages that record user operations with fields for UserName, ModuleName, Operation, and Operation status, along with detailed resource change information and timestamps. NSX Manager audit logs also record failed login attempts with username and timestamp information, enabling tracking of access patterns across the environment. VCF Operations for Networks captures audit logs of administrative actions, including CRUD operations and login/logout events.

VCF Operations supports forwarding user activity audit logs to an external syslog server, enabling integration with dedicated SIEM or UEBA platforms for broader correlation and behavioral analysis. VCF Log Management includes content packs that offer pre-built dashboards, alerts, and queries for VCF components. These content packs support security monitoring use cases such as tracking failed login attempts and privilege escalations.

VCF's built-in anomaly detection is primarily oriented toward infrastructure metrics and operational health rather than user behavior profiling. A dedicated UEBA or UAM solution consuming VCF's audit data would be needed to establish user behavior baselines, detect credential compromise through behavioral deviation, and provide the full scope of analytics this

control requires. For organizations requiring deeper behavioral analysis, VMware vDefend extends VCF's monitoring foundation with IDS/IPS, network traffic inspection, and threat intelligence integration.

VMware vDefend (Contributes)

VMware vDefend contributes to restricting access to sensitive data workloads at the network layer through microsegmentation and firewall policy. The Distributed Firewall enforces both inter-application and intra-application tier access controls, restricting which workloads and users can communicate with sensitive systems such as DNS, DHCP, NTP, and LDAP infrastructure servers to reduce exposure to unauthorized access and data exfiltration. The Distributed Firewall supports consistent enforcement of Layer 2 through Layer 7 access policies, including FQDN filtering to restrict access to sensitive network destinations by domain name.

Privileged labels provide a tamper-proof mechanism for anchoring Distributed Firewall rules to immutable labels that restrict virtual machines from being removed from their assigned security groups, supporting stable enforcement of access policies on sensitive workloads. The Identity Firewall can be enabled to enforce access controls based on user identity, supplementing workload-based segmentation with user-aware policies that follow identity across the environment.

The vDefend gateway firewall supports isolation between organizational projects by denying all inter-project communication except for essential infrastructure protocols such as DHCP, DNS, NTP, and ICMP, restricting lateral access to sensitive systems. URL filtering applies access control policies to both encrypted and non-encrypted web traffic, allowing administrators to restrict web-based access to sensitive resources.

Security Services Platform (SSP) extends enforcement to bare metal servers, with security policies defined, propagated, and enforced consistently across both virtualized and physical infrastructure. Security Intelligence within SSP generates granular application-level rules that allow only authorized traffic between environments and recommends restricting risky application protocols that carry data in clear text. Segmentation Monitoring identifies servers and services not fully protected by security rules, allowing administrators to prioritize coverage of sensitive assets. Initial policy recommendations can be deployed in a monitoring mode that allows traffic while administrators verify that rules do not disrupt legitimate operations before full enforcement.

Data-level access controls such as encryption, data loss prevention, and database access management are outside vDefend's scope and must be addressed by complementary data protection tools.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides role-based access control mechanisms that restrict who can configure and manage disaster recovery operations for virtual machines, including those containing sensitive or regulated data.

PNR defines a tiered set of predefined roles for access management. The Provider Administrator role holds system-level access for overall PNR administration. Organization Administrators manage access and resources within their organization's scope. Project Administrators and Project Advanced Users hold narrower permissions scoped to project-level operations. These roles govern both the appliance-based management interface and VCF Automation-integrated deployments.

In VCF Automation-integrated environments, the RBAC model extends to control over replication configuration options: Provider Administrators select which replication classes each Organization can use, restricting which recovery configurations are available to each tenant organization. Organization Administrators manage the pairing of namespaces and the assignment of replication classes to their Organizations.

In shared recovery site configurations, PNR isolates customer resources by mapping protected-site resources, networks, folders, and datastores to separate datacenters, networks, folders, and placeholder datastores on the recovery site. RBAC in these configurations also restricts users from renaming, moving, or deleting data centers or hosts, limiting the scope of what any individual user can modify within shared recovery infrastructure.

PNR is designed to record operational information into log files without capturing sensitive information such as private keys or passwords, limiting inadvertent exposure of credentials in administrative log output.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to this control through role-based access control, configurable infrastructure policies, data service policies, and database-engine-level access restrictions that limit who can access database resources and under what conditions.

DSM implements role-based access control at the service level. Administrators can create, monitor, and manage all data services in the environment, while users are restricted to managing and monitoring only the data services assigned to them. DSM User roles also carry namespace-level access controls that restrict permissions to specific namespaces, confining each user's actions to the namespaces they are authorized for. This separation is configured during DSM deployment through directory service group assignments in the vSphere Client, and it provides the foundation for restricting access to databases that hold sensitive or regulated data.

DSM infrastructure policies create configurable guardrails around the compute and storage resources that database instances can consume. They filter available storage options to only those compatible with the specified compute resources, and users must hold appropriate DSM permissions before they can configure infrastructure policies. The Infrastructure Policies view in the DSM administrative dashboard provides visibility into available policies, including CPU, memory, storage policies, IP pool, VM classes, and associated resources. Cloud Administrators can enforce namespace-specific restrictions to allow or disallow the use of infrastructure policies and backup locations in individual namespaces, providing an additional layer of access scoping.

Data service policies define which infrastructure policies, placements, and versions are permitted for a given data service. DataServicePolicy custom resources used by the Consumption Operator require the allowedInfrastructurePolicies field to be populated, scoping database provisioning to administrator-approved resource boundaries. The allowed placements, versions, and infrastructure policies available in a given namespace result from the intersection of all matching data service policies for that namespace. In multi-tenant deployments, administrators can assign data service policies and object stores to specific tenants, maintaining isolation between tenant workloads. DSM adds SQL Server data service policies, which can be enforced across tenants and tailored to specific organizational requirements before assignment.

All database connections in DSM require TLS. Clients connecting to PostgreSQL, MySQL, and SQL Server clusters must have the appropriate certificate authority in their trust store, restricting connectivity to clients that have been configured with the correct trust material.

DSM adds database-engine-level access restrictions for SQL Server. The cluster administrator login is granted restricted read-only privileges and specific ALTER privileges for server management and auditing rather than full administrative access. An internal management login (dsm_mgmt) restricts user access to system-level objects, keeping administrative operations within a controlled, isolated context. For PostgreSQL, DSM supports the pgcrypto extension, which provides cryptographic functions that enable column-level data protection within the database engine.

DSM provides a Compliance tab on data service policy detail pages. This view displays compliance reports and allows administrators to expand each policy violation to identify the noncompliant database, data service, and namespace, supporting targeted remediation.

Achieving full compliance with this control requires organizational decisions about which data is considered sensitive or regulated, mapping that classification to the database instances and tenants where such data resides, and configuring DSM roles, policies, and tenant assignments accordingly. DSM provides the technical mechanisms to enforce those access restrictions once the data classification and access decisions have been made by the organization.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides application-layer anomaly detection mechanisms that contribute to meeting this control. The Anomalies Overlay feature, available in Virtual Service Analytics, Service Engine Analytics, and Pool Analytics, flags statistical deviations in traffic metrics as anomaly events when a specific metric deviates from the historical norm by more than four sigma during the anomaly period. Monitored metrics include CPU utilization, bandwidth, disk I/O, server response time, and connection rates. Each anomaly event is identified by entity name, entity type (Virtual Machine, Virtual Service, or Service Engine), and metric value, with a timestamp indicating when the deviation occurred. Anomaly detection operates against a moving-average baseline calculated from recent historical traffic. The Pool Anomalies Overlay also displays

prediction interval upper and lower bounds alongside the anomalous value. Administrators can adjust detection granularity by changing the statistics time interval, and can configure alert filter sensitivity to tune the threshold for new alert generation. Note that anomaly recording is disabled when the statistics interval is set to Real Time; a non-real-time statistics interval is required for anomaly capture to function.

The Bot Management module adds a behavioral detection layer focused on credential stuffing and web attack patterns at the application proxy boundary. Bot Management detects malicious bots responsible for online fraud and credential stuffing attacks. The IP Reputation service extends detection by maintaining a database of categorized IP addresses and identifying anomalous traffic patterns, including DoS and DDoS activity and anomalous SYN floods.

For authentication-related anomalous behavior, Avi provides the `AUDIT_COMPLIANCE_EVENT` mechanism to log authentication failures for audit purposes, persisting them via the alerts infrastructure. The Web Application Firewall (WAF) App Log Analytics component captures events whenever a WAF application rule is triggered, recording the type of attack detected. Service Engines generate `DOS_ATTACK` alert events that include attack type, source IP addresses, virtual service UUID and name, and a report timestamp, supporting audit and forensic analysis of detected attacks. Avi also supports DataScripts for custom identification of suspicious traffic and execution of appropriate mitigation actions, enabling organizations to define custom behavioral detection logic beyond the built-in statistical baselines.

Avi monitors over 500 real-time metrics to support DDoS detection and attack visibility. Alerts from any of these mechanisms can be forwarded proactively to email, syslog, SNMP, or custom APIs, enabling integration with a central SIEM or security operations platform. Avi integrates with Splunk via the Avi Load Balancer Splunk Add-on, generating events that serve as an audit trail for user logins, configuration changes, and runtime state changes.

These capabilities operate at the application delivery and load balancing layer. An organization requires a dedicated UEBA or UAM platform to fulfill the full scope of this control, including identity-level behavioral baselines, user session correlation, and cross-system entity analytics that extend beyond application traffic visible to Avi.

Control 164.312(d)

> Standard: Person or entity authentication. Implement procedures to verify that a person or entity seeking access to electronic protected health information is the one claimed.

SCF Controls: HRS-01, HRS-04, IAC-28, IAC-28.2, IAC-28.3, TPM-01

Aggregate Coverage: Contributes

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides configurable identity evidence validation mechanisms at the application proxy boundary, supporting certificate-based validation, federated identity through SAML, and token-based validation through OAuth, OpenID Connect (OIDC), and JSON Web Tokens (JWT).

For certificate-based identity evidence, Avi's Client SSL Certificate Validation feature requires a PKI Profile when the Validation Type is set to Request or Required. The PKI Profile defines the trusted certificate authorities and validation parameters, allowing organizations to specify which certificate-based identity evidence is acceptable. The Avi Service Engine performs server certificate verification including CA certificate validation, CRL checking, certificate chain validation, hostname matching, and validity period checking, enforcing these checks at the proxy boundary. DataScript provides access to the `avi.ssl.check_client_cert_validity()` function with a configurable fingerprint-type parameter supporting Full, Filtered, and Normalized JA3 modes for programmatic certificate validity checking against application-specific requirements. Certificates require a trusted chain of authority to be considered valid by clients.

For federated identity scenarios, Avi acts as a SAML Service Provider, accepting and verifying SAML assertions from a trusted organizational Identity Provider (IdP). After successful user credential validation at the IdP level, the IdP's SSO service returns an XHTML document containing a SAML Response with authentication statements and user attribute assertions. Avi validates that the Entity ID matches between the IdP and the Service Provider configuration as part of the assertion verification process. SAML 2.0 metadata provides an interoperable format for bootstrapping the trust process between the Service Provider and Identity Provider. The Avi Controller's SAML Authentication Profile supports IdP metadata configuration via direct metadata upload or metadata URL. The SAML integration supports external identity providers including PingFederate, where administrators can configure standard identity mapping or custom user attribute mappings to align with organizational identity schemas. Federated authentication is recommended to centralize the authentication process by delegating to the organizational Identity Provider rather than managing authentication locally within Avi.

For token-based identity, Avi supports OAuth 2.0, OIDC, and JWT flows, enabling organizations to require access token presentation for application access. Avi can extract user identity information from the OIDC UserInfo endpoint by accepting the access token, or from claims in the ID token. JWT validation includes verification of token claims: the not-before time (nbf), issued-at time (iat), and unique token identifier (jti), allowing organizations to enforce token freshness and uniqueness requirements at the application boundary.

For Kubernetes workloads, the Avi Kubernetes Operator (AKO) extends these identity validation capabilities through SSORule Custom Resource Definitions (CRDs), which support OAuth/OIDC configuration for virtual services. When configured with `SAML_AUTHN_REQ_ACS_TYPE_URL`, the single sign-on URL endpoint is sent in the `AssertionConsumerServiceURL` attribute of the authentication request to the Identity Provider. AKO also monitors certificate files and Kubernetes secret updates, logging certificate and secret update events for operational visibility.

DataScript provides additional programmatic access control, enabling checks against approved user ID lists and redirecting unauthenticated users to a login page based on identity.

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.312(e)(1)

> Standard: Transmission security. Implement technical security measures to guard against unauthorized access to electronic protected health information that is being transmitted over an electronic communications network.

SCF Controls: CFG-02, CRY-03, NET-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the Security.PasswordQualityControlPwquality setting on ESX hosts, including parameters such as minlen=15, maxrepeat=3, maxclassrepeat=4, difok=4, and enforce_for_root. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster

Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. AppArmor and SELinux provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as ConfigMaps and Secrets.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references ConfigMaps containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgml_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs,

and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use `scram-sha-256` as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support `scram-sha-256`, `reject`, and `cert` authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control 164.312(e)(2)(i)

> Implementation specifications: Integrity controls (Addressable). Implement security measures to ensure that electronically transmitted electronic protected health information is not improperly modified without detection until disposed of.

SCF Controls: CFG-02, CRY-04, NET-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the Security.PasswordQualityControlPwquality setting on ESX hosts, including parameters such as minlen=15, maxrepeat=3, maxclassrepeat=4, difok=4, and enforce_for_root. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster

Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. AppArmor and SELinux provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as ConfigMaps and Secrets.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references ConfigMaps containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgml_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs,

and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use `scram-sha-256` as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support `scram-sha-256`, `reject`, and `cert` authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control 164.312(e)(2)(ii)

> Implementation specifications: Encryption (Addressable). Implement a mechanism to encrypt electronic protected health information whenever deemed appropriate.

SCF Controls: CFG-02, CRY-01, OPS-03

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the Security.PasswordQualityControlPwquality setting on ESX hosts, including parameters such as minlen=15, maxrepeat=3, maxclassrepeat=4, difok=4, and enforce_for_root. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster

Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. AppArmor and SELinux provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as ConfigMaps and Secrets.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references ConfigMaps containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgml_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs,

and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use `scram-sha-256` as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support `scram-sha-256`, `reject`, and `cert` authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control 164.314(a)(1)

> Standard: Business associate contracts or other arrangements. The contract or other arrangement required by § 164.308(b)(3) must meet the requirements of paragraph (a)(2)(i), (a)(2)(ii), or (a)(2)(iii) of this section, as applicable.

SCF Controls: CPL-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.314(a)(2)(i)(B)

> Implementation specifications (Required) Report to the covered entity any security incident of which it becomes aware, including breaches of unsecured protected health information as required by § 164.410.

SCF Controls: TPM-05.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.314(a)(2)(i)(C)

> Report to the covered entity any security incident of which it becomes aware, including breaches of unsecured protected health information as required by § 164.410.

SCF Controls: TPM-05.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.314(a)(2)(ii)

> Other arrangements. The covered entity is in compliance with paragraph (a)(1) of this section if it has another arrangement in place that meets the requirements of § 164.504(e)(3).

SCF Controls: CPL-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.314(a)(2)(iii)

> Business associate contracts with subcontractors. The requirements of paragraphs (a)(2)(i) and (a)(2)(ii) of this section apply to the contract or other arrangement between a business associate and a subcontractor required by § 164.308(b)(4) in the same manner as such requirements apply to contracts or other arrangements between a covered entity and business associate.

SCF Controls: TPM-05, TPM-05.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.314(b)(1)

> Standard: Requirements for group health plans. Except when the only electronic protected health information disclosed to a plan sponsor is disclosed pursuant to § 164.504(f)(1)(ii) or (iii), or as authorized under § 164.508, a group health plan must ensure that its plan documents provide that the plan sponsor will reasonably and appropriately safeguard electronic protected health information created, received, maintained, or transmitted to or by the plan sponsor on behalf of the group health plan.

SCF Controls: TPM-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.314(b)(2)(i)

> Implementation specifications (Required). The plan documents of the group health plan must be amended to incorporate provisions to require the plan sponsor to- Implement administrative, physical, and technical safeguards that reasonably and appropriately protect the confidentiality, integrity, and availability of the electronic protected health information that it creates, receives, maintains, or transmits on behalf of the group health plan;

SCF Controls: TPM-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.314(b)(2)(ii)

> Implementation specifications (Required). The plan documents of the group health plan must be amended to incorporate provisions to require the plan sponsor to- Ensure that the adequate separation required by § 164.504(f)(2)(iii) is supported by reasonable and appropriate security measures;

SCF Controls: TPM-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.314(b)(2)(iii)

> Implementation specifications (Required). The plan documents of the group health plan must be amended to incorporate provisions to require the plan sponsor to- Ensure that any agent to whom it provides this information agrees to implement reasonable and appropriate security measures to protect the information; and

SCF Controls: TPM-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.314(b)(2)(iv)

> Implementation specifications (Required). The plan documents of the group health plan must be amended to incorporate provisions to require the plan sponsor to- Report to the group health plan any security incident of which it becomes aware.

SCF Controls: TPM-05.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.316(a)

> Standard: Policies and procedures. Implement reasonable and appropriate policies and procedures to comply with the standards, implementation specifications, or other requirements of this subpart, taking into account those factors specified in § 164.306(b)(2)(i), (ii), (iii), and (iv). This standard is not to be construed to permit or excuse an action that violates any other standard, implementation specification, or other requirements of this subpart. A covered entity or business associate may change its policies and procedures at any time, provided that the changes are documented and are implemented in accordance with this subpart.

SCF Controls: GOV-01, GOV-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.316(b)(1)(i)

> Standard: Documentation. Maintain the policies and procedures implemented to comply with this subpart in written (which may be electronic) form; and

SCF Controls: GOV-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.316(b)(1)(ii)

> Standard: Documentation. If an action, activity or assessment is required by this subpart to be documented, maintain a written (which may be electronic) record of the action, activity, or assessment.

SCF Controls: CPL-03, GOV-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.316(b)(2)(i)

> Implementation specifications: Time limit (Required). Retain the documentation required by paragraph (b)(1) of this section for 6 years from the date of its creation or the date when it last was in effect, whichever is later.

SCF Controls: DCH-18

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides configurable data retention controls within VCF Operations that allow administrators to align operational data retention periods with organizational requirements. These controls do not address the full scope of media and data retention governance, but they give administrators granular tuning over how long different categories of platform-generated data are kept.

VCF Operations exposes data retention settings through Administration > Global Settings > Data Retention. Administrators can configure retention periods independently for several data categories. Metrics data supports a retention window between 1 month and 13 months. Entities and configuration data can be retained for a minimum of 1 month and a maximum of 3 months. Organization reports support a maximum data retention period of 1,440 days. At the normal retention tier, VCF Operations retains data at 5-minute granularity for 6 months, then rolls up the seventh month into 1-hour aggregations. A real-time retention tier provides 5-minute granularity, a standard tier retains data for 1 month, and a long-term tier retains data for 13 months. Different data retention policies can be configured and controlled for each category according to organizational requirements. Log data is governed separately through VCF Log Management, where administrators define log partitions that each carry their own retention period in days, with logs removed from disk automatically once a partition's period elapses and the option to archive partitions to external NFS or S3 storage for longer-term preservation.

VCF Operations for Networks provides additional granular retention controls. The default data retention period is 1 month in the advanced license edition. Flow data retention is fixed at a 1-month window within the platform. For organizations that need to retain flow data beyond one month, the Streaming Databus provides a mechanism to export flows to an external subscriber via HTTPS/HTTP for extended retention. Miscellaneous data retention can be configured with up to 100 GB of additional disk space.

VCF Operations also provides backup capabilities that support regulatory and operational retention needs. Administrators can take regular backups of both custom and out-of-the-box content. When reducing an entity metrics retention period in VCF Operations for Networks, the recommendation is to back up log files first to prevent data loss, which supports the principle of preserving data before modifying retention windows.

The Consumption layer of VCF, comprising VMware Kubernetes Service (VKS), vSphere Supervisor, and vSphere namespaces, adds Kubernetes-native persistent storage lifecycle controls relevant to data retention for containerized workloads. Persistent volumes in Supervisor namespaces store application data outside the lifecycle of individual pods and workloads, so data remains available when workloads restart or scale. The central mechanism governing retention behavior is the PersistentVolume reclaim policy, which controls what happens to the underlying storage and its data when the associated PersistentVolumeClaim is deleted. The Retain policy preserves the volume and its data in a Released state for manual administrator reclamation, leaving the data intact for inspection, archival, or transfer before final disposal. The Delete policy causes the storage asset to be removed when the claim is released. Retain is the default for manually provisioned PersistentVolumes. StorageClass definitions carry a ReclaimPolicy field that sets the default behavior for all dynamically provisioned volumes within a given storage class, allowing cluster administrators to enforce organization-wide retention defaults at the storage class level rather than per-volume. For StatefulSet workloads, Kubernetes provides a persistentVolumeClaimRetentionPolicy setting with a whenDeleted field that controls whether PVCs and their backing volumes are retained or deleted when the StatefulSet is removed; scaling a StatefulSet down does not delete the associated volumes by default. Organizations subject to retention obligations should configure StorageClasses with the Retain policy so that workload termination does not destroy data that must be kept for a defined period.

Storage Policy Based Management (SPBM) provides a unified control plane across VKS storage, enabling storage policies to be associated with persistent volumes that capture the storage characteristics required by a given workload or retention regime. VKS clusters surface a storage compliance status per volume: a Compliant status indicates that the datastore backing the volume satisfies the requirements of the associated policy; an Out of Date status indicates the policy has been updated but the new requirements have not yet been communicated to the datastore, requiring the policy to be reapplied to bring the volume back into compliance. This policy-driven model allows administrators to codify storage requirements and verify adherence continuously.

For Harbor Registry deployments on VKS clusters, administrators should note that configuring a StorageClass or PersistentVolume with a Delete reclaim policy results in all Harbor data being deleted when the Harbor package is removed. Image artifact retention requirements should drive reclaim policy selection for Harbor-backing storage. Platform teams should also manage data protection storage locations in VCF Automation to align with company-specific data residency and infrastructure standards.

These retention controls apply to the operational, monitoring, and configuration data that VCF Operations collects and manages, and to the persistent volume lifecycle for containerized workloads on VKS. They do not extend to application data stored within virtual machines outside the Kubernetes layer, user-generated content on datastores not managed by Kubernetes, or media outside the VCF platform. Organizations must establish broader data retention policies, classification schemes, and lifecycle management processes that address all media and data types subject to statutory, regulatory, and contractual obligations. VCF's retention settings are one component of a larger retention program that requires organizational governance, legal review of applicable obligations, and potentially additional tools for archival and disposition of data beyond what VCF Operations and VKS storage lifecycle controls manage.

VMware vDefend (Contributes)

VMware vDefend provides configurable data retention capabilities for the security telemetry and flow data it collects, contributing to an organization's ability to retain security-relevant data in accordance with statutory, regulatory, and contractual obligations.

Security Services Platform, which underpins Network Detection and Response (NDR) and related analytics services, offers control over flow data retention. Flow data is retained for 30 days by default via the flow-data-retention setting. If storage capacity is insufficient to handle flow volume from workloads, some flow metadata may be lost, flow ingestion may be paused, or data retention may be reduced dynamically to stay within available storage. Administrators can monitor retention health through the `ssp_flow_storage.avg_flow_storage_ratio` metric, which reports the ratio of current retention days to predicted full days for flow storage, and through the `ssp_analytics_storage.avg_predicted_tabl_retention_days` metric, which tracks predicted retention for the correlated flow visualization table (default 30 days). Security Services Platform persistent storage collects data even when the License Hub is offline, providing resilience against brief service interruptions that might otherwise affect data continuity.

Network Detection and Response retains detection events and campaign data for 12 months, providing a fixed retention window for threat detection artifacts.

For organizations using cloud-connected vDefend features, Security Services Platform maintains defined retention periods for data collected under active service subscriptions: IDS events and other network events, VM identifiers, rules and policies, conversation history, and security profiles are retained for one year during an active subscription, and for 90 days following subscription expiration.

Administrators should note that when the Malware Prevention Service feature is deleted, all previously gathered data analytics are permanently removed. Organizations with compliance-driven retention requirements should account for this before decommissioning that service.

These retention controls allow organizations to align vDefend's security data storage with their compliance requirements. The broader scope of media and data retention across the full infrastructure stack, including operational data, log archives, backup snapshots, and storage-level data protection, is handled by other VCF components such as VCF Operations, VCF Log Management, and vSAN Data Protection.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable retention mechanisms that allow administrators to align disaster recovery and cyber recovery data with retention obligations. PNR snapshot schedules define a retention policy that determines how long each snapshot is retained, with hourly, daily, weekly, and monthly cadences and a maximum retention duration of three years. Administrators can also select predefined retention templates that combine recovery point objective (RPO) and snapshot retention parameters for quick configuration of protection groups.

For vSphere Replication, the retention policy determines the expiration of point-in-time copies, and storage consumption drops after all point-in-time copies referring to the original disk are expired. Administrators configure the number of retention slots and the spacing between recovery points, so older instances expire automatically once the configured limit is exceeded.

Cyber Recovery snapshot schedules in PNR follow the same retention model, defining a retention policy that controls how long each snapshot is retained. Administrators should account for storage capacity when configuring longer retention schedules, since extended retention periods increase storage consumption on the underlying datastores.

These retention controls allow organizations to align disaster recovery and cyber recovery data retention with applicable statutory, regulatory, and contractual obligations. PNR provides the technical mechanisms; determining the specific retention durations that satisfy each obligation is an organizational policy decision.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides configurable backup retention controls that support an organization's data retention requirements for its managed databases. These controls do not define retention obligations, which come from the organization's legal and compliance functions, but they provide the technical means to implement those obligations for PostgreSQL, MySQL, SQL Server, and MinIO data.

Retention periods are configured through Data Service Policies in the DSM administration interface. Each policy supports a backup-retention-period setting that defines the duration for which backups are kept. When multiple policies apply to a namespace, DSM aggregates the retention constraints by selecting the more restrictive minimum and maximum retention day values, producing a resultant retention window that reflects all applicable policies. Data service policies can also be tailored to specific requirements and enforced across different tenants, giving administrators a consistent mechanism for applying retention standards in multi-tenant deployments.

For deleted databases, DSM retains automated backups according to the configured retention period and exposes an Archives tab in the administration interface where administrators can access and adjust the retention period of retained backups. This allows organizations to maintain access to backup data even after a database instance has been removed, supporting retention obligations that outlast the operational lifetime of a specific database. When a database is deleted, automated backups continue to be retained until the retention policy is met.

DSM also supports point-in-time restore within the backup retention period, enabling recovery to any point within the retained window. On-demand backups behave differently from automated backups: they are permanent and do not expire automatically. On-demand backups remain in the backup storage location until an administrator manually deletes them, which means they can consume storage quota indefinitely and require separate tracking for retention compliance.

Data service policies also define backup storage locations (S3-compatible targets) alongside retention duration. If a data service policy that is in use is deleted, the data services associated with that policy become non-compliant, alerting administrators to a configuration gap.

Meeting this control fully requires the organization to determine the applicable retention periods, communicate those requirements to DSM administrators, and configure policies accordingly. DSM does not automatically derive retention obligations from regulatory or contractual sources. Its retention controls also cover only the database data it manages and do not address retention of all media and data types that may fall within an organization's broader retention obligations.

Not applicable for this control: VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 164.316(b)(2)(ii)

> Implementation specifications: Availability (Required). Make documentation available to those persons responsible for implementing the procedures to which the documentation pertains.

SCF Controls: OPS-01.1, OPS-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.316(b)(2)(iii)

> Implementation specifications: Updates (Required). Review documentation periodically, and update as needed, in response to environmental or operational changes affecting the security of the electronic protected health information.

SCF Controls: CPL-02, GOV-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

